信息安全实验手册

——主机与网络安全

宁波大学

金光、倪翠霞、江先亮

2011 年 3 月

目录

网络信息安全教学实验平台操作指导.....1
一．系统简介.....1
二．入门指导.....1
实验一 DES 算法.....8
一、实验目标.....8
二、实验工具.....8
三、实验准备.....8
四、实验原理.....8
1.DES算法简介.....8
2.DES算法过程.....9
五、实验步骤.....11
六、问题思考.....17
实验二 AES算法.....19
一、实验目的.....19
二、实验环境.....19
三、实验工具.....19
四、实验原理.....19
1.AES算法关键简介.....19
2.AES的分组过程.....20
3.状态矩阵.....20
4.AddRoundKey变换.....20
5.10 轮循环.....21
6.密钥膨胀.....23
7.解密过程.....24
8.InvShiftRows变换.....25
9.InvSubBytes变换.....25
10.InvMixColumns变换.....26
11.AddRoundKey变换.....26
五、实验步骤.....26
六、问题思考.....32
实验三 IDEA算法.....33
一、实验目的.....33
二、实验环境.....33
三、实验工具.....33
四、实验原理.....33
1.IDEA算法简介.....33
2.IDEA算法加密过程.....34
五、实验步骤.....37
六、问题思考.....42
实验四 RSA算法.....43
一、实验目的.....43
二、实验环境.....43

三、实验工具.....43
四、实验原理.....43
1.非对称密钥加密简介.....43
2.RSA算法概述.....45
3.RSA算法加密/解密.....45
五、实验步骤.....46
六、问题思考.....50
实验五 MD5 算法.....51
一、实验目的.....51
二、实验环境.....51
三、实验工具.....51
四、实验原理.....51
1.哈希函数简介.....51
2.哈希函数特点.....52
3.针对哈希函数的攻击.....52
4.MD5 哈希函数.....52
五、实验步骤.....56
六、问题思考.....60
实验六 SHA1 算法.....61
一、实验目的.....61
二、实验环境.....61
三、实验工具.....61
四、实验原理.....61
1.SHA1 与MD5 差异.....61
2.SHA1 算法流程.....62
3.SHA1 的分组过程.....62
4.SHA1 的 4 轮运算.....63
五、实验步骤.....64
六、问题思考.....69
实验七 文件传输应用.....70
一、实验目的.....70
二、实验环境.....70
三、实验工具.....70
四、实验原理.....70
1.数字签名.....70
2.安全通信要求.....71
五、实验步骤.....71
六、问题思考.....77
实验八 PGP应用.....78
一、实验目的.....78
二、实验环境.....78
三、实验工具.....78
四、实验原理.....78
1.PGP概述.....78

2.PGP加密机制 79
五、实验步骤 80
六、问题思考 84
实验九 Windows口令破解 85
一、实验目的 85
二、实验环境 85
三、实验工具 85
四、实验原理 85
1.口令破解方法 85
2.口令破解方式 85
五、实验步骤 86
六、问题思考 89
实验十 IIS服务器 90
一、实验目的 90
二、实验环境 90
三、实验工具 90
四、实验原理 90
五、实验步骤 92
1.创建网站 92
2.创建和访问主页 93
3.创建FTP站点 93
实验十三 日志审计 96
一、实验目的 96
二、实验环境 96
三、实验工具 96
四、实验原理 96
1.Windows日志系统 96
2.IIS日志系统 98
五、实验步骤 100
六、问题思考 105
实验十二 防范SQL注入 106
一、实验目的 106
二、实验环境 106
三、实验工具 106
四、实验原理 106
1.防范SQL注入 106
2.合法性校验 107
3.预编译SQL查询 108
五、实验步骤 109
1.客户端进行合法性校验 109
2.服务器进行合法性校验 111
3.预处理执行SQL查询 111
实验十三 IPSec安全协议 112
一、实验目的 112

二、实验环境.....112
三、实验工具.....112
四、实验原理.....112
1.VPN和IPSec概述.....112
2.IPSec服务.....113
3.安全关联.....113
4.传输模式和隧道模式.....114
5.IPSec工作原理.....114
五、实验步骤.....116
1.IPsec虚拟专用网络的设置.....116
2.IPsec虚拟专用网络的检测.....121
3.协议分析ESP.....121
4.协议分析AH.....122
实验十四 信息搜集.....124
一、实验目的.....124
二、实验环境.....124
三、实验工具.....124
四、实验原理.....124
1.信息搜集步骤.....124
2.ping命令概述.....124
3.nmap概述.....125
五、实验步骤.....125
六、问题思考.....127
实验十五 综合扫描与安全评估.....128
一、实验目的.....128
二、实验环境.....128
三、实验工具.....128
四、实验原理.....128
1.漏洞扫描概述.....128
2.漏洞扫描方法.....128
3.弱口令.....129
4.Microsoft-ds漏洞.....129
五、实验步骤.....129
1.开放服务扫描.....129
2.漏洞检测脚本扫描.....133
实验十六 洪泛攻击.....135
一、实验目的.....135
二、实验环境.....135
三、实验工具.....135
四、实验原理.....135
1.SYN Flood攻击.....135
2.ICMP Flood攻击.....136
五、实验步骤.....136
1.捕获洪水数据.....136

2.洪水攻击.....138
3.ICMP洪水攻击.....139
实验十七 ARP欺骗.....142
一、实验目的.....142
二、实验环境.....142
三、实验工具.....142
四、实验原理.....142
五、实验步骤.....143
1.正常通信.....143
2.ARP攻击.....145
3.单向欺骗.....147
3.ARP监听.....148
六、问题思考.....148
实验十八 shell后门.....149
一、实验目的.....149
二、实验环境.....149
三、实验工具.....149
四、实验原理.....149
1.后门的定义.....149
2.不同类型的后门通道.....150
3.后门的安装.....150
五、实验步骤.....151
1.系统自带远程控制工具(3389 远程控制).....151
2.远程控制工具(JlcssShell).....152
六、问题思考.....153
实验十九 Windows2003 防火墙实践.....154
一、实验目的.....154
二、实验环境.....154
三、实验工具.....154
四、实验原理.....154
1.防火墙.....154
2.防火墙功能.....154
3.NAT.....155
4.Windows 2003 防火墙.....157
五、实验步骤.....158
1.防火墙日志设置.....158
2.防火墙基础操作.....158
3.防火墙例外操作.....160
4.NAT操作.....160
实验二十 Windows2003 用户权限管理.....164
一、实验目的.....164
二、实验环境.....164
三、实验原理.....164
1.什么是权限.....164

2.安全标识符.....164
3.权限的四项基本原则.....165
4.磁盘配额.....165
四、实验步骤.....166
1.SID查看.....166
2.权限的四项基本原则演示.....166
3.NTFS分区上分配磁盘配额.....168
实验二十一 Windows2003 审核策略设置.....170
一、实验目的.....170
二、系统环境.....170
三、实验工具.....170
四、实验原理.....170
1.审核策略.....170
2.文件审核.....171
五、实验步骤.....172
1.设置并验证“审核对象访问”策略.....172
2.文件事件审计.....173
实验二十二 Windows2003 注册表安全设置.....174
一、实验目的.....174
二、实验环境.....174
三、实验原理.....174
1.注册表概述.....174
2.注册表的作用.....175
3.注册表的特点.....175
4.注册表主键说明.....176
四、实验步骤.....176
1.注册表安全设置.....176

网络信息安全教学实验平台操作指导

一．系统简介

中软吉大“网络信息安全教学实验系统 v3.2”（简称 ExpNIS）是针对高校信息安全及相关专业所开发的教学实验系统。该系统能够为高校建立完善的信息安全教学实验体系，涉及社会工程学，密码学及应用，主机安全，网络攻防，病毒攻防，容灾备份，无线安全和生物特征八个方面。ExpNIS 采用“进阶式”教学方式，强调学生的设计，创新及实践能力，着重培养信息安全专业的高级人才。此外，ExpNIS 配有强大的实验教学管理系统，全方位打造专业的网络信息安全实验室。

中软吉大与国家反计算机入侵和防病毒研究中心合作，依托 ExpNIS 联合推出“信息网络安全专业人员认证”（简称 INSPC）培训体系。该系统由硬件，软件和教学实验系统组成，如图 1 所示。

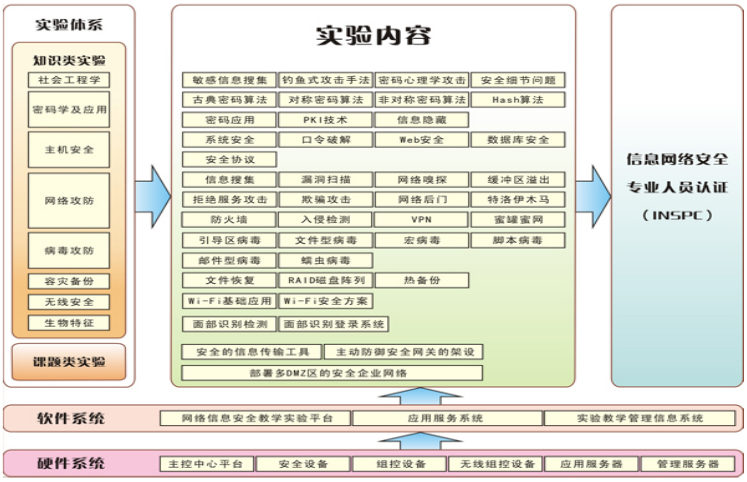


图 1 实验平台结构图

二．入门指导

在对实验平台整体结构有了初步的了解之后，接下来就开始进入实验平台。为了便于实验和考虑方便性和安全的特点，所有的实验都在虚拟环境中完成，偶尔需要用到真是主机进行相关的测试。实验时，只需要启动虚拟机，并启动或恢复(用快照保存的)其中的系统(Linux 或 Windows)即可进行实验，实验过程中所需的平台和软件可以在启动或恢复的系统中获得，随后的每个实践实验中，将会具体说明需要的系统和所需的软件。

为更快的进入实验，接下来将对如何进入实验平台进行详细的说明。

1.插入加密狗

加密狗是外形酷似 U 盘，它为执行中的软件提供加密信息。本实验平台的加密狗插入到主机的 USB 口，可以在开机前或开机后插入，但必须是在启动实验平台前。

2.启动，选择需要的系统

开机后，会进入启动系统选择界面，选择其中的“net&security”系统。系统不需要密码。

3.启动虚拟机平台

进入系统后，点击桌面的“VMware Workstation”图标，如图 2 所示，启动虚拟机。



图 2　VMware 图标

启动虚拟机之后，会出现如图 3 所示的界面。

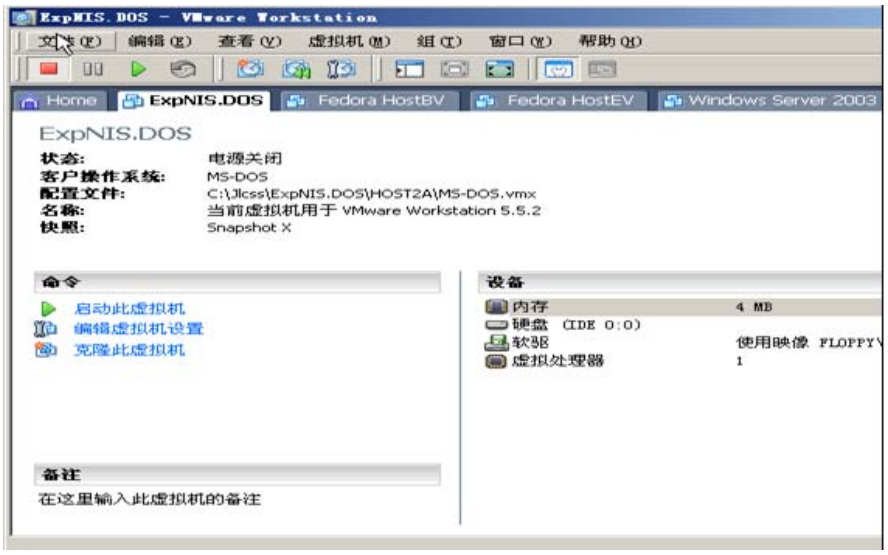


图 3 虚拟机启动后界面

4.启动虚拟机中的系统

在有些虚拟软件里面我们创建了 ExpNIS.Windows 系统，在这种情况下只需点击图 3 中左下边的“启动此虚拟机”按钮即可。如果不存在对应的虚拟机系统，即在上图的虚拟机栏目中看不到 ExpNIS.Windows 项，如图 4 所示。此时，需要创建此系统，本手册实验的虚拟系统可以在图 5 所示的位置找到，即“C:/Jlcss/ExpNIS.Windows/HOST1C/ExpNIS.Windows”，然后点击打开其中的 ExpNIS.Windows.vmx。



图 4 不存在 ExpNIS.Windows 的虚拟机系统列表

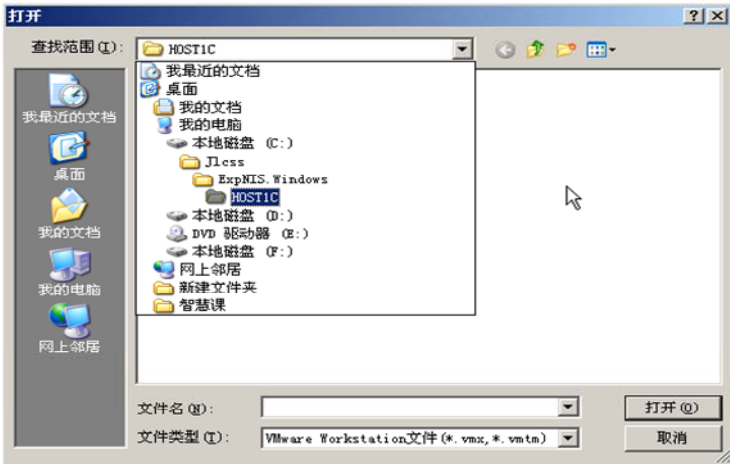


图 5 虚拟机系统路径

打开之后，可以看见如图 6 所示的虚拟机系统列表，其中已经存在了 ExpNIS.Windows 项。



图 6 打开 ExpNIS.Windows 后的虚拟机系统列表

在选中 ExpNIS.Windows 项后，紧接着点击“启动此虚拟机”按钮，此时会出现如图 7 所示的界面，点击“确定”即可开始启动 ExpNIS.Windows 虚拟机系统。



图 7 启动 ExpNIS.Windows

在虚拟机系统的启动过程中，需要输入密码，此时的密码为：jlcssadmin。启动完成后，就可以在虚拟机系统中进行相应的实验。

5.启动虚拟机系统中的实验平台

进入虚拟系统后，点击桌面上的“网络信息安全教学实验平台”图标，如图 8 所示，进入实验平台。图 9 所示为实验平台启动完成后的界面。



图 8 实验平台图标



图 9 进入实验平台

在实验平台的左边有“全部实验”和“详细实验”两部分，如图 9 所示。而在这两部分内容中又包含了“知识类实验”和“课程类实验”两部分，如图 10 和 11 所示。



图 10 全部实验

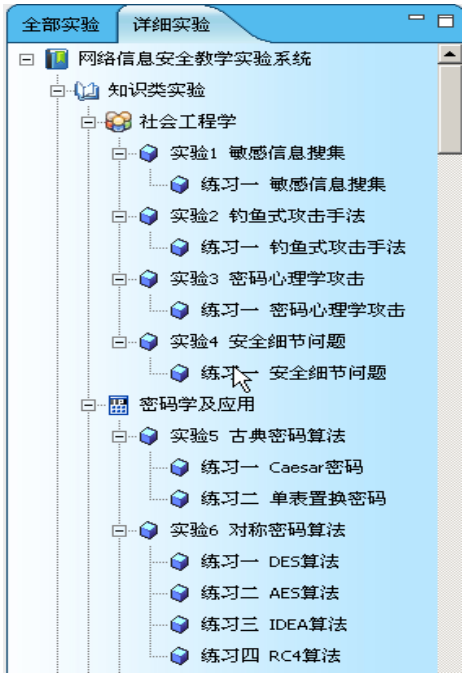


图 11 详细实验

点击“全部实验”或“详细实验”中的对称密码算法(此处可以选择其他列表项)，可以在右边看到关于对称密码算法的实验信息，如图 12 所示。

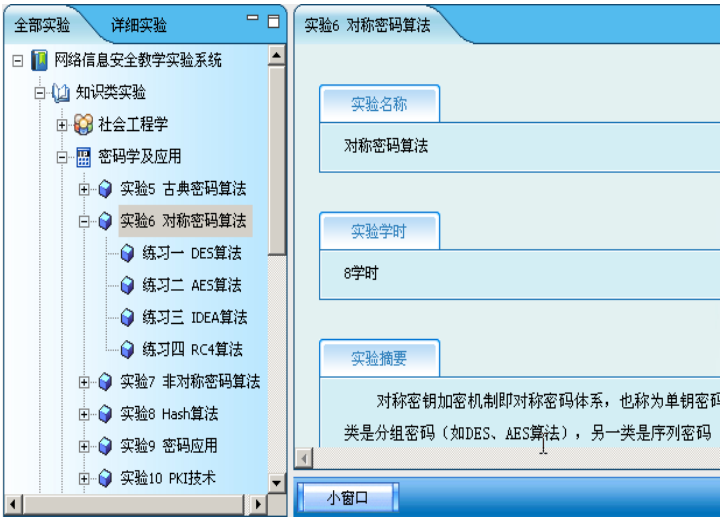


图 12 对称加密算法实验

接下来，以 DES 加密算法为例，阐述如何进行实验操作和最终完成实验。打开 DES 算法的标签后，可以看到如图 13 所示的信息。

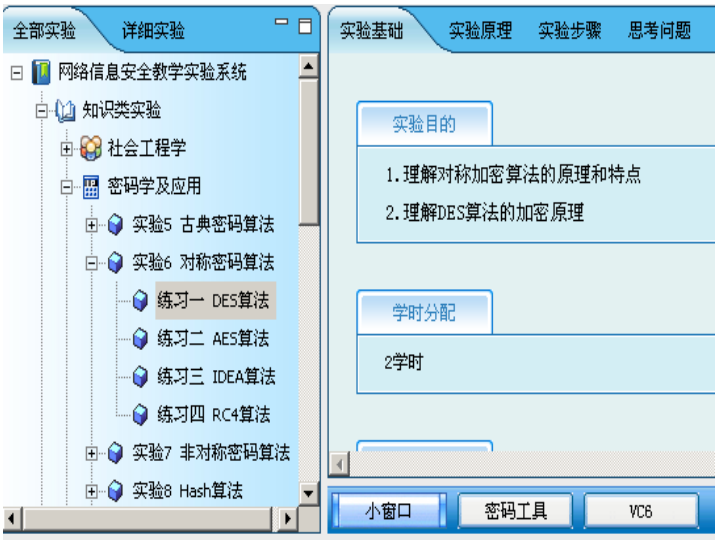


图 13 DES 算法实验信息

在打开的 DES 算法实验界面中，可以看到其有“实验基础”、“实验原理”、“实验步骤”和“思考问题”四个选项，选择每一个选项，可以看到“实验基础”是对具体实验目的和要求等的简单介绍，“实验原理”是对该实验所涉及的原理性知识进行简单的介绍，“实验步骤”是对具体如何进行实验操作的详细说明，“思考问题”是在完成了实验后，对此实验最核心和最基本问题的思考。在完成实验后，应将实验结果以详细的报告形式写出来。

此外，在图 13 的右下方还可以看到有“小窗口”“密码工具”和“VC6”三个选项，点点击相应的选项，可以打开不同的窗口。如图 14 所示为点击“小窗口”选项时的效果，图 15 所示为点击“VC6”选项的结果。

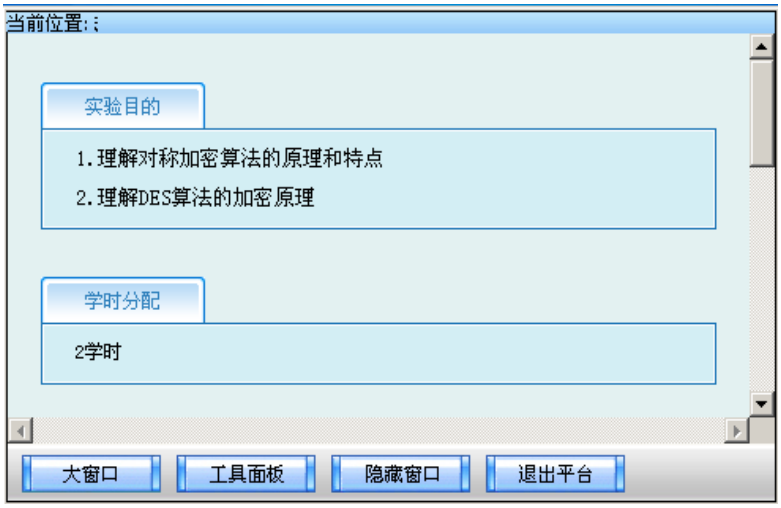


图 14 小窗口显示



图 15 点击“VC6”的结果

图 15 的左边列出常见的密码算法实验，再次以以 DES 算法为例，点击进去，会出现如图 16 的界面。



图 16 操作界面

在上图右边的对话框中，有“演示”和“加密/解密”（不同的实验，选项的个数和内容不一样）两个选项，其中，“演示”选项给了详细的算法执行过程的演示，“加密/解密”选项允许输入实验参数，验证实验结果，同时提供了一个具有重置功能的按钮，允许重设参数。在这里不具体对它们进行详细的介绍，在进行相关实验时再做介绍。

到目前为止，对于此实验平台我们进行了相应的介绍，相信大家对此平台也有一定的了解，接下来的将以具体的实验实践为主。

实验一 DES 算法

一、实验目标

理解 DES 算法的加密过程

二、实验工具

Microsoft Visual++ 6.0

三、实验准备

了解中软吉大网络信息安全教学实验平台的使用方法，学习 Microsoft Visual++ 6.0 程序设计和调试运行。

四、实验原理

1.DES 算法简介

DES 是 Data Encryption Standard(数据加密标准)的缩写，最初由 IBM 公司研制，并于 1977 年被美国国家标准局公布。在信息保密的舞台上，DES 扮演了十分重要的角色，得到了广泛的应用。

DES 是分组加密算法的一种，分组长度为 64bits。作为对称算法(共享密钥加密算法)，其加密和解密使用同一个密钥，密钥长度为 56bits(其中每个 8 位包含一位的奇偶校验位)，密钥可为任意的 56 位数，可随时改变。

DES 的入口参数有 3 个：Key、Data 和 Mode。Key 为 8 个字节共 64bits，是输入的加密密钥；Data 为 8 个字节共 64bits，为需要加密或解密的数据；Mode 为工作模式，标示了是进行加密还是解密操作。

对于上面的 Mode 选择，不同的选择有不同的工作模式。若 Mode 为加密，则用 Key 对 Data 进行加密，生成 Data 的 64 位密文作为输出结果；若 Mode 为解密，则用 Key 对 Data 密文解密，还原为 Data 的 64 位明文作为输出结果。

在采用 DES 算法时，通信双方在进行数据交换前需要协商一个用于加密传输数据的共享密钥(Key)。发送方发送数据时，首先用 Key 对数据进行加密，然后将密文通过公共通信信道传输到接收方。加密的数据到达接收方后，接收方用同样的 Key 对密文进行解密，重

现了明文数据。这样便保证了数据在公共通信网中传输的安全性和可靠性。通过定期更新 Key，能更进一步提高数据的保密性。DES 有 16 轮，意味着要在明文分组上 16 次实施相似的组合技术。

2.DES 算法过程

DES 算法把 64 位明文分组输入变为 64 位密文输出，使用 56 位密钥。通过一个初始置换，将 64 位明文分组分成左半部分和右半部分，各 32 位。然后进行 16 轮相同的运算，这些运算称为函数 f，在运算过程中数据和密钥相结合。经过 16 轮运算后，左、右部分一起经过一个初始置换的逆置换，即完成了加密过程。其算法框架如图 1.1 所示。

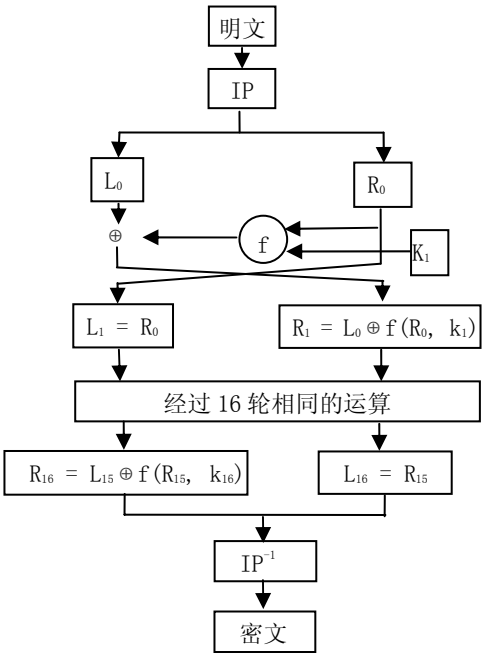


图 1.1 DES 的算法框架

(1)初始置换

其功能是把输入的 64 位数据块按位重新组合，并把输出分为 L0、R0 两部分，每部分各长 32 位，其置换规则如表 1.1 所示。

表 1.1　初始置换表

58，	50，	42，	34，	26，	18，	10，	2，	60，	52，	44，	36，	28，	20，	12，	4
62，	54，	46，	38，	30，	22，	14，	6，	64，	56，	48，	40，	32，	24，	16，	8
57，	49，	41，	33，	25，	17，	09，	1，	59，	51，	43，	35，	27，	19，	11，	3
61，	53，	45，	37，	29，	21，	13，	5，	63，	55，	47，	39，	31，	23，	15，	7

即将输入的第 58 位换到第 1 位，第 50 位换到第 2 位，…，依次类推，最后 1 位是原来的第 7 位。L0，R0 则是换位输出后的两部分，L0 是输出的左 32 位，R0 是右 32 位。例如，设置换前的输入值为 D1D2D3…D64，则经过初始置换后的结果为：L0=D58D50…D8；R0=D57D49…7。

(2)逆置换

经过 16 次迭代运算后，得到 L16 和 R16，将此作为输入进行逆置换，即得到密文输出。逆置换正好是初始置换的逆运算。例如，第 1 位经过初始置换后，处于第 40 位，而通过逆置换，又将第 40 位换回到第 1 位，其逆置换的规则如表 1.2 所示。

表 1.2　逆置换表

40，8，48，16，56，24，64，32，39，7，47，15，55，23，63，31
38，6，46，14，54，22，62，30，37，5，45，13，53，21，61，29
36，4，44，12，52，20，60，28，35，3，43，11，51，19，59，27
34，2，42，10，50，18，58，26，33，1，41，9，49，17，57，25

函数 f(R_i, K_i)的算法描述如图 1.2 所示。

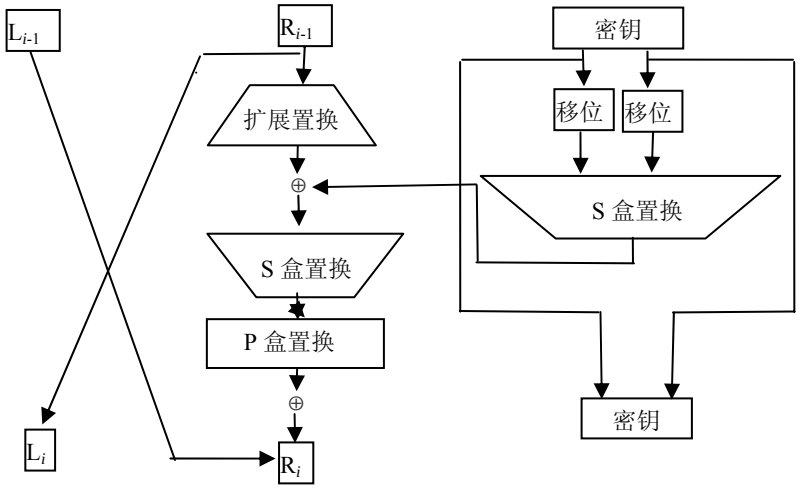


图 1.2 函数 f(R_i,K_i)的算法描述

在图 1.2 中，“扩展置换”是将 32 位扩展成 48 位，“P 盒置换”是 32 位到 32 位的换位，其换位规则如表 1.3、表 1.4 所示。

表 1.3　扩展置换表

32，1，2，3，4，5，4，5，6，7，8，9
8，9，10，11，12，13，12，13，14，15，16，17
16，17，18，19，20，21，20，21，22，23，24，25
24，25，26，27，28，29，28，29，30，31，32，1

表 1.4　P 盒置换表

16，7，20，21，29，12，28，17，1，15，23，26，5，18，31，10
2，8，24，14，32，27，3，9，19，13，30，6，22，11，4，25

在(R_i, K_i)算法描述图中，S1，S2，…，S8 为选择函数，其功能是把 6 位数据变为 4 位数据。下面以选择函数 S1 为例说明其功能。其功能表如表 1.5 所示。

表 1.5　选择函数 S1 的功能

14，4，13，1，2，15，11，8，3，10，6，12，5，9，0，7
0，15，7，4，14，2，13，1，10，6，12，11，9，5，3，8
4，1，14，8，13，6，2，11，15，12，9，7，3，10，5，0
15，12，8，2，4，9，1，7，5，11，3，14，10，0，6，13

通过表 1.5 可以看到，在 S1 中共有 4 行数据，分别命名为 0，1，2，3 行，每行有 16 列，分别命名为 0，1，2，3，…，14，15 列。

现设输入为：D=D1D2D3D4D5D6

令：列=D2D3D4D5，行=D1D6

然后在 S1 表中查得对应的数，以 4 位二进制表示，此即为选择函数 S1 的输出。

(3)子密钥 Ki(48bits)的生成

由于不考虑每个字节的第 8 位，DES 的密钥从 64 位变为 48 位，如表 1.6 所示，首先 56 位密钥被分成两个部分，每部分 28 位，然后根据轮数，两部分分别循环左移 1 或 2 位。

表 1.6　密钥置换

57，	49，	41，	33，	25，	17，	9，	1，
58，	50，	42，	34，	26，	18		
10，	2，	59，	51，	43，	35，	27，	19，
11，	3，	60，	52，	44，	36		
63，	55，	47，	39，	31，	23，	15，	7，
62，	54，	46，	38，	30，	22		
14，	6，	61，	53，	45，	37，	29，	21，
13，	5，	28，	20，	12，	4		

移位的位数如下：

迭代顺序	1	2	3	4	5	6	7	8	9	10	11	12	13	14	15	16
左移位数	1	1	2	2	2	2	2	2	1	2	2	2	2	2	2	1

五、实验步骤

DES 算法实验可以在吉大的网络信息安全教学实验平台里完成。另外，在手册附件中包含了 DES 算法的源码，可以在 VC++6.0 环境下编译执行。接下来将以实验平台中 DES 算法为主，解析实验过程。

1.按照入门指导进入实验平台，如图 1.3 所示：



图 1.3 进入实验平台

2.选则“网络信息安全教学实验系统”——>知识类实验——>密码学及应用——>实验 6——>练习一 DES 算法，如图 1.4 所示。

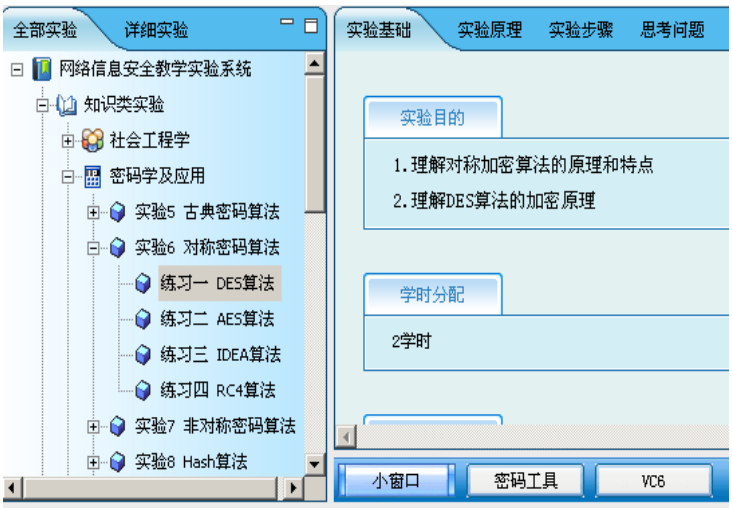


图 1.4 选择实验

3.认真阅读“实验基础”和“实验原理里面的相关内容”，特别是“实验原理”的内容，体会并掌握该实验原理。

4.看完相关内容后，点击实验步骤选项，然后点击“密码工具”，如图 1.5 所示，按照步骤进行实验。



图 1.5 密码学工具

5.点击左边的 DES 算法，然后点击“加密/解密”，如图 1.6 所示。

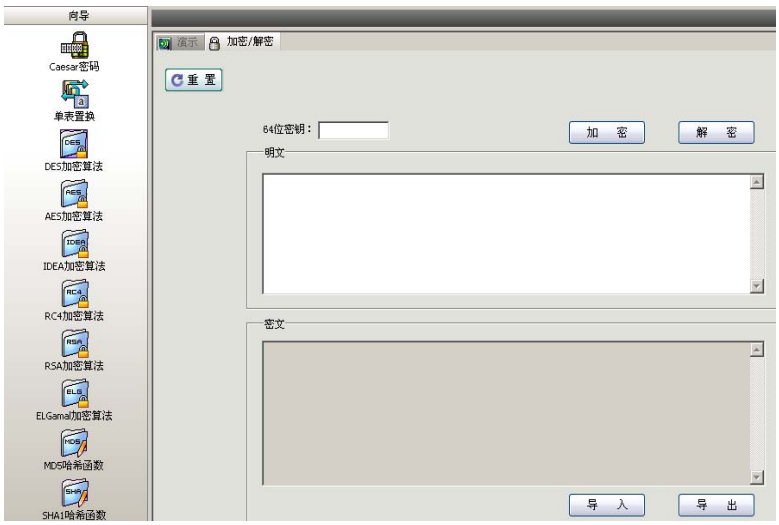


图 1.6 DES 加密/界面实验界面

6.在明文窗口中输入明文，如图 1.7 所示的输入：xinxianquan；在 64 位密钥窗口中输入加密的密钥，如图 1.7 所示的输入：123456。单击“加密”按钮，会在图 1.7 所示的密文窗口中生成加密后的信息。

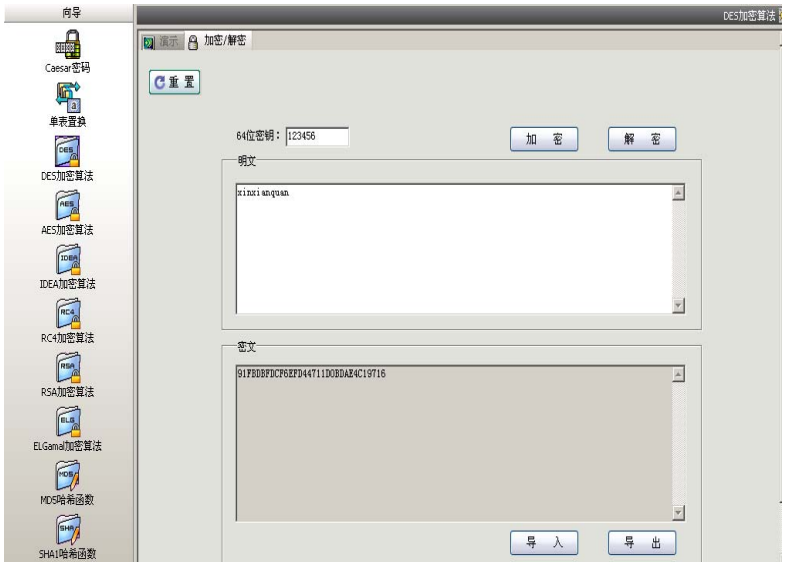


图 1.7 加密过程

7.点击“导出”按钮，将密文保存在 DES（D：\Work\Encryption\DES\）文件夹中，如图 1.8 所示。

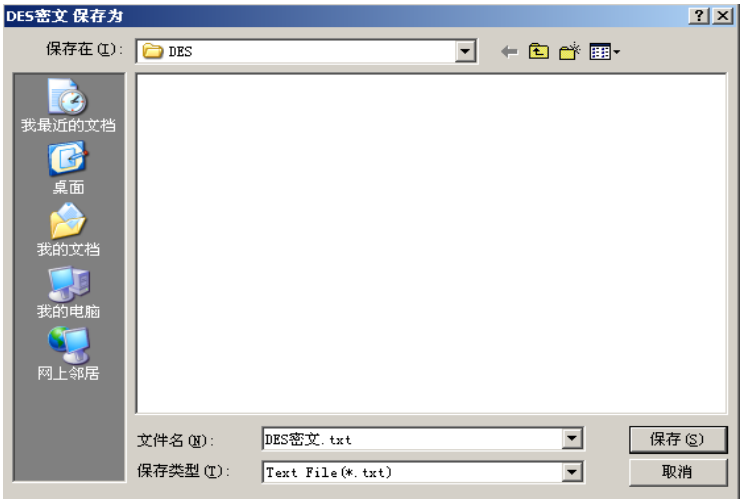


图 1.8 导出密文

8.单击“重置”按钮，清空我们所填写的内容。紧接着单击“导入”按钮，如图 1.9 所示，导入前面保存的密文，然后输入与前面加密过程相同的密钥，如图 1.10 所示。

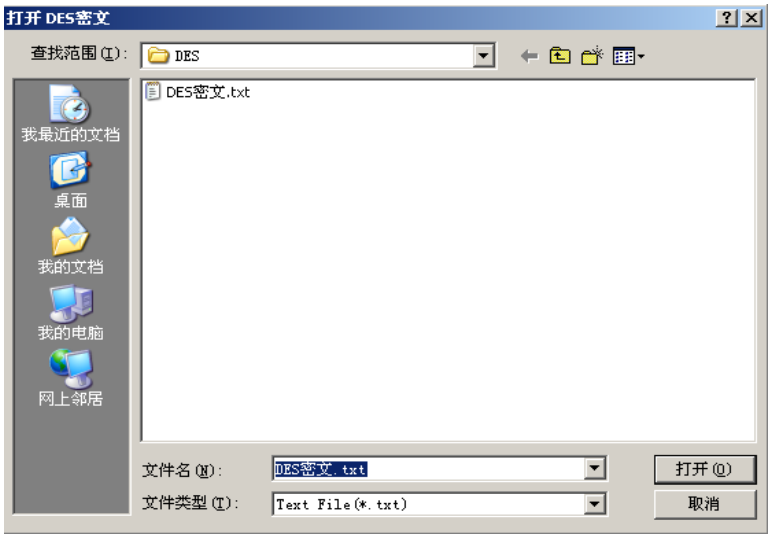


图 1.9 导入密文

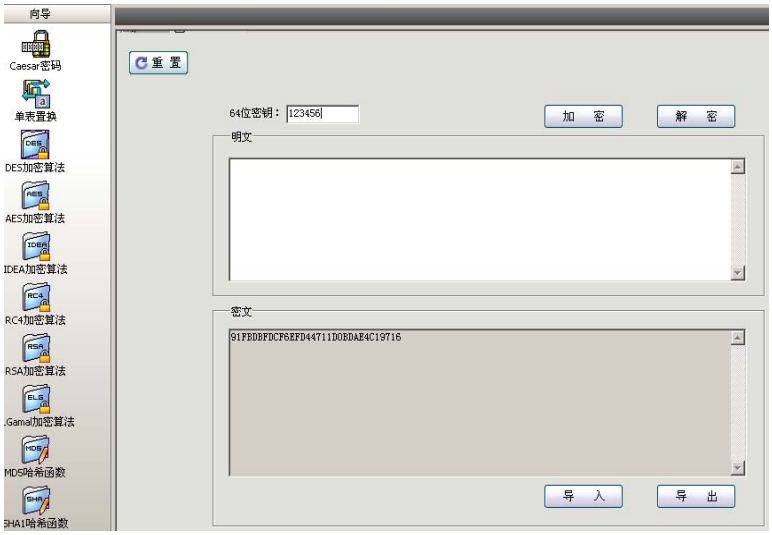


图 1.10 输入密钥

9.点击“解密”按钮，就可得到解密后的明文，如图 1.11 所示，可以看出与之前加密的明文一样。

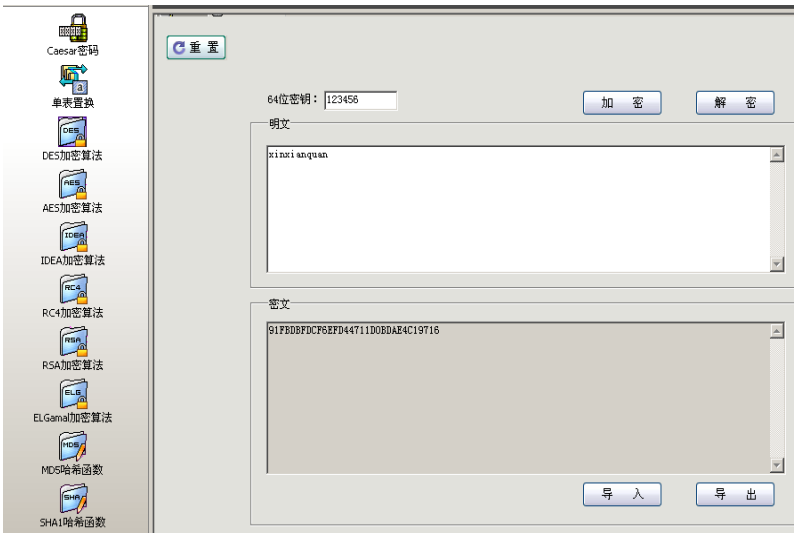


图 1.11 解密后的明文

10.以上是实验室的操作过程，要想深入理解 DES 算法，可以观察 DES 算法的演示。单击“演示”选项，会得到如图 1.12 所示的界面。

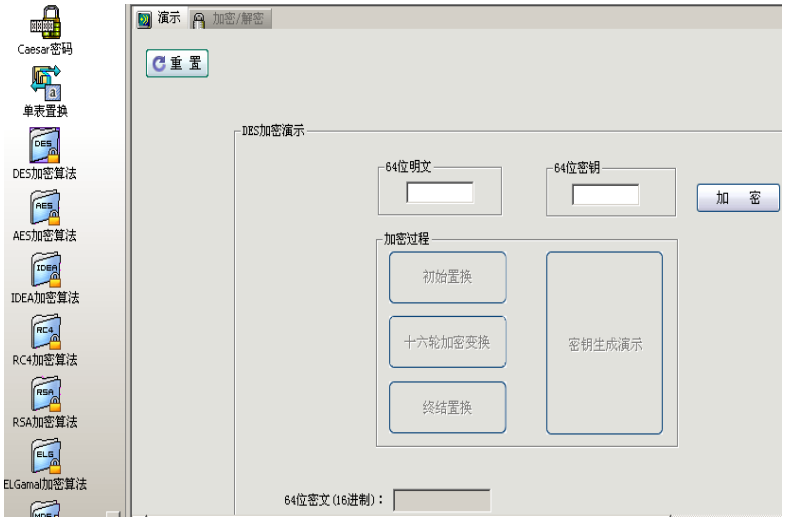


图 1.12 演示界面

11.在明文和密钥窗口中分别输入 xinxianquan（系统要求的是 8 个字符，多余的字符将不会显示）和 123456，点击“加密”，如图 1.13 所示。

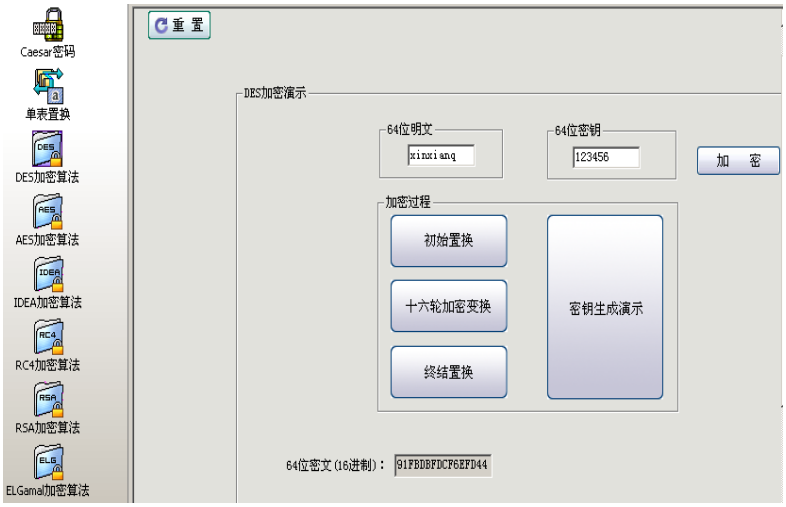


图 1.13 输入明文和密钥并加密

12.然后点击“初始置换”按钮，观察初始置换，如图 1.14 所示，64 位明文经过初始置换形成了新的 64 位置换输出。



图 1.14 初始置换

13.点击“返回”，紧接着点击“十六轮加密运算”，可以看到明文的每一轮变换的过程，如图 1.15 所示。

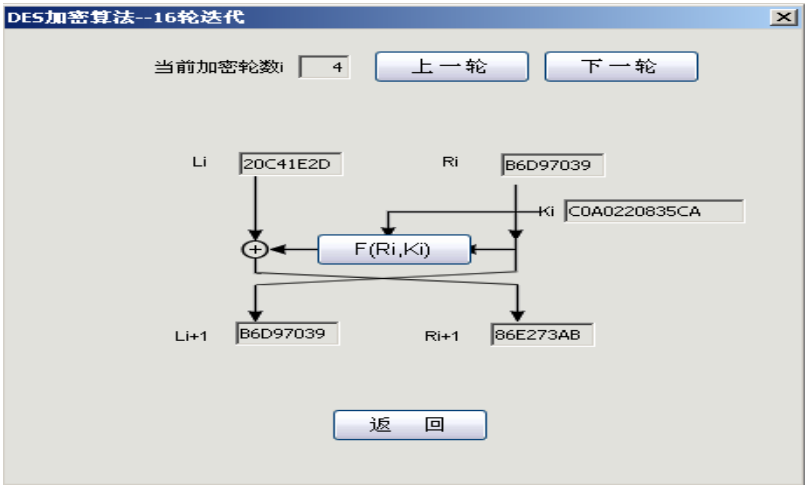


图 1.15 16 轮迭代

14.点击“返回”，紧接着点击“密钥生成演示”，观察密钥的生成过程，如图 1.16 所示。

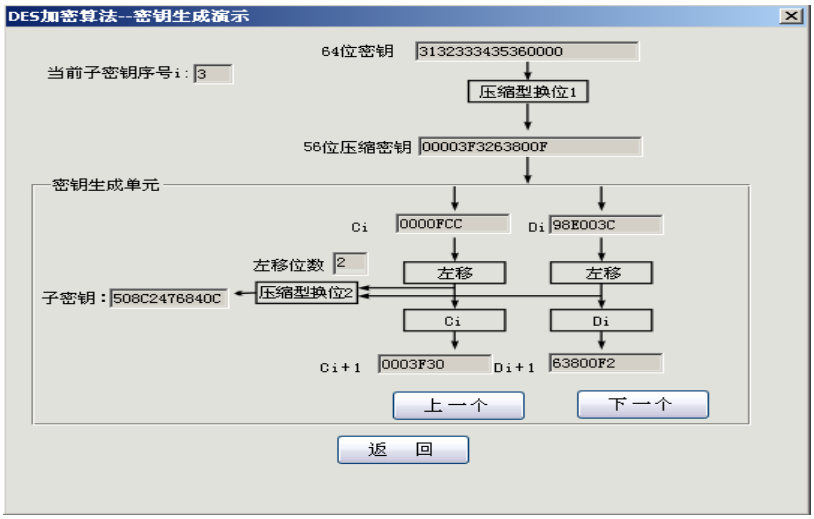


图 1.16 密钥生成演示

15.点击“返回”，紧接着点击“终结置换”，查看最后的置换输出，如图 1.17 所示。

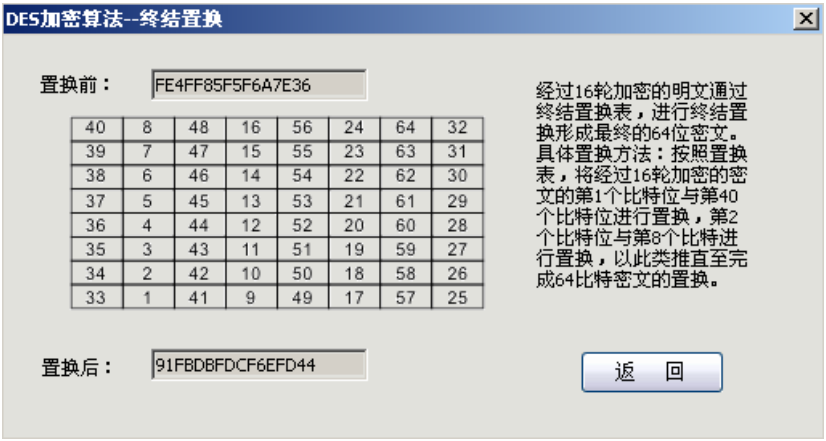


图 1.17 终结置换

在这个平台里面，只能看到算法的原理和实验过程测试，为此，与手册一起还提供了 DES 算法实验的 C++实验，供大家在 VC++6.0 环境下调试和运行。

六、问题思考

1.根据实验原理的讲解，回答下列问题：

(1)DES 每一个明文分组的长度是多少位？这个明文分组加密后的密文是多少位？

(2)在 DES 算法的各种置换中，哪个置换为 DES 提供了最好的安全性？

2.DES 的 S 盒在设计时就能够防止某些类型的攻击，当 1991 年 Biham 和 Shamir 发现的差分攻击的方法时，美国国家安全局就已承认某些未公布的 S 盒设计原则正是为了使得差分密码分析变得不可行。也就是说，差分密码分析在 DES 最初被研发时就已为 IBM 的研发者所知，但是这种方法却被保密了将近 20 年，直到 Biham 和 Shamir 又独立地发现了这种

攻击。目前，DES 加密方法已经被认为是不安全的了，请同学查阅相关资料，列出两种 DES 的分析方法。

3.对运行的结果进行思考，为什么会有这样的结果?

实验二 AES 算法

一、实验目的

理解 AES 算法的加密/解密原理

二、实验环境

Windows Xp 系统，交换网络结构

三、实验工具

Microsoft Visual C++6.0，密码工具

四、实验原理

1.AES 算法关键简介

对于任意长度的明文，AES 首先对其进行分组，每组的长度为 128 位。分组之后将分别对每个 128 位的明文分组进行加密。

对于每个 128 位长度的明文分组的加密过程如下：

(1)将 128 位 AES 明文分组放入状态矩阵中。

(2)AddRoundKey 变换。对状态矩阵进行 AddRoundKey 变换，与膨胀后的密钥进行异或操作(密钥膨胀将在实验原理中详细讨论)。

(3)10 轮循环。AES 对状态矩阵进行了 10 轮类似的子加密过程。前 9 轮子加密过程中，每一轮子加密过程包括 4 种不同的变换，而最后一轮只有 3 种变换，前 9 轮的子加密步骤如下：

●SubBytes 变换：SubBytes 变换是一个对状态矩阵非线性的变换；

●ShiftRows 变换：ShiftRows 变换对状态矩阵的行进行循环移位；

●MixColumns 变换：MixColumns 变换对状态矩阵的列进行变换；

●AddRoundKey 变换:AddRoundKey 变换对状态矩阵和膨胀后的密钥进行异或操作。

最后一轮的子加密步骤如下：

●SubBytes 变换：SubBytes 变换是一个对状态矩阵非线性的变换；

●ShiftRows 变换：ShiftRows 变换对状态矩阵的行进行循环移位；

●AddRoundKey 变换:AddRoundKey 变换对状态矩阵和膨胀后的密钥进行异或操作；

(4)经过 10 轮循环的状态矩阵中的内容就是加密后的密文。

AES 的加密算法的伪代码如下。

```
Nb = 4                          // 状态矩阵的列数
Nr = 10                         // 加密的轮数
Cipher(byte in[4*Nb], byte out[4*Nb], word w[Nb*(Nr+1)])
begin
    byte state[4, Nb]
    state = in
    AddRoundKey(state, w[0, Nb-1])
    for round = 1 step 1 to Nr-1
        SubBytes(state)
        ShiftRows(state)
        MixColumns(state)
        AddRoundKey(state, w[round*Nb, (round+1)*Nb-1])
    end for
    SubBytes(state)
    ShiftRows(state)
    AddRoundKey(state, w[Nr*Nb, (Nr+1)*Nb-1])
    out = state
end
```

在 AES 算法中，AddRoundKey 变换需要使用膨胀后的密钥，原始的 128 位密钥经过膨胀会产生 44 个字（每个字为 32 位）的膨胀后的密钥，这 44 个字的膨胀后的密钥供 11 次 AddRoundKey 变换使用，一次 AddRoundKey 使用 4 个字（128 位）的膨胀后的密钥。

2.AES 的分组过程

对于任意长度的明文，AES 首先对其进行分组，分组的方法与 DES 相同，即对长度不足的明文分组后面补充 0 即可，只是每一组的长度为 128 位。

AES 的密钥长度有 128 比特，192 比特和 256 比特三种标准，其他长度的密钥并没有列入到 AES 联邦标准中，在下面的介绍中，我们将以 128 位密钥为例。

3.状态矩阵

状态矩阵是一个 4 行、4 列的字节矩阵，所谓字节矩阵就是指矩阵中的每个元素都是一个 1 字节长度的数据。我们将状态矩阵记为 State，State 中的元素记为 Sij，表示状态矩阵中第 i 行第 j 列的元素。128 比特的明文分组按字节分成 16 块，第一块记为“块 0”，第二块记为“块 1”，依此类推，最后一块记为“块 15”，然后将这 16 块明文数据放入到状态矩阵中，将这 16 块明文数据放入到状态矩阵中的方法如图 2.1 所示。

表 2.1 将明文块放入状态矩阵中

块 0	块 4	块 8	块 12
块 1	块 5	块 9	块 13
块 2	块 6	块 10	块 14
块 3	块 7	块 11	块 15

4.AddRoundKey 变换

状态矩阵生成以后，首先要进行 AddRoundKey 变换，AddRoundKey 变换将状态矩阵与膨胀后的密钥进行按位异或运算，如下所示。

$$[S'_{0,c}, S'_{1,c}, S'_{2,c}, S'_{3,c}] = [S_{0,c}, S_{1,c}, S_{2,c}, S_{3,c}] \oplus [W_{round * Nb+c}] \quad \text{for } 0 \leqslant c < Nb$$

其中，c 表示列数，数组 W 为膨胀后的密钥，round 为加密轮数，Nb 为状态矩阵的列数。它的过程如图 2.1 所示。

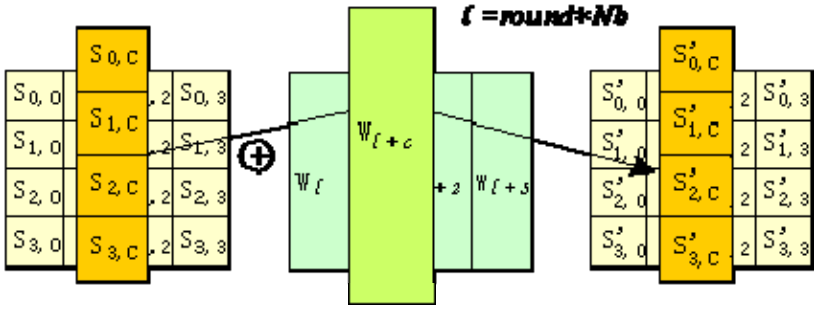


图 2.1 AES 算法 AddRoundKey 变换

5.10 轮循环

经过 AddRoundKey 的状态矩阵要继续进行 10 轮类似的子加密过程。前 9 轮子加密过程中，每一轮要经过 4 种不同的变换，即 SubBytes 变换、ShiftRows 变换、MixColumns 变换和 AddRoundKey 变换，而最后一轮只有 3 种变换，即 SubBytes 变换、ShiftRows 变换和 AddRoundKey 变换。AddRoundKey 变换已经讨论过，下面分别讨论余下的三种变换。

(1)SubBytes 变换

SubBytes 是一个独立作用于状态字节的非线性变换，它由以下两个步骤组成：

1)在 GF（28）域，求乘法的逆运算，即对于 α∈GF（28）求 β∈GF（28），使 αβ=βα=1mod（x8 + x4 + x3 + x + 1）。

2)在 GF（28）域做变换，变换使用矩阵乘法，如下所示：

$$\begin{pmatrix} y_0 \\ y_1 \\ y_2 \\ y_3 \\ y_4 \\ y_5 \\ y_6 \\ y_7 \end{pmatrix} = \begin{bmatrix} 1 & 1 & 1 & 1 & 1 & 0 & 0 & 0 \\ 0 & 1 & 1 & 1 & 1 & 1 & 0 & 0 \\ 0 & 0 & 1 & 1 & 1 & 1 & 1 & 0 \\ 0 & 0 & 0 & 1 & 1 & 1 & 1 & 1 \\ 1 & 0 & 0 & 0 & 1 & 1 & 1 & 1 \\ 1 & 1 & 0 & 0 & 0 & 1 & 1 & 1 \\ 1 & 1 & 1 & 0 & 0 & 0 & 1 & 1 \\ 1 & 1 & 1 & 1 & 0 & 0 & 0 & 1 \end{bmatrix} \begin{pmatrix} x_0 \\ x_1 \\ x_2 \\ x_3 \\ x_4 \\ x_5 \\ x_6 \\ x_7 \end{pmatrix} \oplus \begin{pmatrix} 0 \\ 1 \\ 1 \\ 0 \\ 0 \\ 0 \\ 1 \\ 1 \end{pmatrix}$$

由于所有的运算都在 GF（28）域上进行，所以最后的结果都在 GF(28)上。若 g∈GF(28)是 GF(28)的本原元素，则对于 α∈GF(28)，α≠0，则存在 β∈GF(28)，使得：

β = gαmod（x8 + x4 + x3 + x + 1）

由于 g255 = 1mod（x8 + x4 + x3 + x + 1）

所以 g255-α = β-1mod（x8 + x4 + x3 + x + 1）

根据 SubBytes 变换算法，可以得出 SubBytes 的置换表，如表 2.2 所示，这个表也叫做 AES 的 S 盒。该表的使用方法如下：状态矩阵中每个元素都要经过该表替换，每个元素为 8 比特，前 4 比特决定了行号，后 4 比特决定了列号，例如求 SubBytes(0C)查表的 0 行 C 列得 FE。

表 2.2 AES 的 SubBytes 置换表

	0	1	2	3	4	5	6	7	8	9	A	B	C	D	E	F
0	63	7C	77	7B	F2	6B	6F	C5	30	01	67	2B	FE	D7	AB	76
1	CA	82	C9	7D	FA	59	47	F0	AD	D4	A2	AF	9C	A4	72	C0
2	B7	FD	93	26	36	3F	F7	CC	34	A5	E5	F1	71	D8	31	15
3	04	C7	23	C3	18	96	05	9A	07	12	80	E2	EB	27	B2	75
4	09	83	2C	1A	1B	6E	5A	A0	52	3B	D6	B3	29	E3	2F	84
5	53	D1	00	ED	20	FC	B1	5B	6A	CB	B3	39	4A	4C	58	CF
6	D0	EF	AA	FB	43	4D	33	85	45	F9	02	7F	50	3C	9F	A8
7	51	A3	40	8F	92	9D	38	F5	BC	B6	DA	21	10	FF	F3	D2
8	CD	0C	13	EC	5F	97	44	17	C4	A7	7E	3D	64	5D	19	73
9	60	81	4F	DC	22	2A	90	88	46	EE	B8	14	DE	5E	0B	DB
A	E0	32	3A	0A	49	06	24	5C	C2	D3	AC	62	91	95	E4	79
B	E7	C8	37	6D	8D	D5	4E	A9	6C	56	F4	EA	65	7A	AE	08
C	BA	78	25	2E	1C	A6	B4	C6	E8	DD	74	1F	4B	BD	8B	8A
D	70	3E	B5	66	48	03	F6	0E	61	35	57	B9	86	C1	1D	9E
E	E1	F8	98	11	69	D9	8E	94	9B	1E	87	E9	CE	55	28	DF
F	8C	A1	89	0D	BF	E6	42	68	41	99	2D	0F	B0	54	BB	16

它的变换过程如图 2.2 所示。

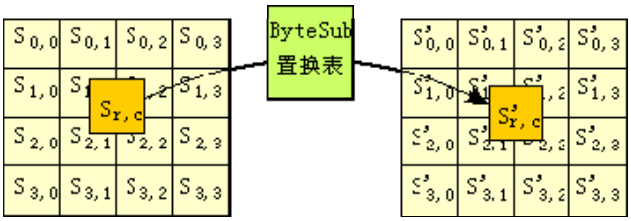


图 2.2 SubBytes 变换

AES 加密过程需要用到一些数学基础，其中包括 GF(2)域上的多项式、GF（28）域上的多项式的计算和矩阵乘法运算等，有兴趣的同学请参考相关的数学书籍。

(2)ShiftRows 变换

ShiftRows 变换比较简单，状态矩阵的第 1 行不发生改变，第 2 行循环左移 1 字节，第 3 行循环左移 2 字节，第 4 行循环左移 3 字节。ShiftRows 变换的过程如图 2.3 所示。

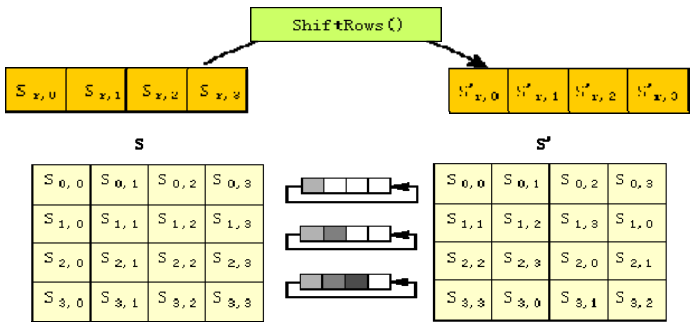


图 2.3 AES 的 ShiftRows 变换

(3)MixColumns 变换

在 MixColumns 变换中，状态矩阵的列看作是域 GF(28)的多项式，模(x4＋1)乘以 c(x)的结果：

c(x)＝(03)x3＋(01)x2+(01)x+(02)

这里(03)为十六进制表示，依此类推。c(x)与 x4＋1 互质，故存在逆：

d(x)=(0B)x3＋(0D)x2＋(0G)x＋(0E)使 c(x)•d(x) = (D1)mod(x4＋1)。

设$b(x)=c(x)\otimes a(x)$有：

$$\begin{pmatrix} b_0 \\ b_1 \\ b_2 \\ b_3 \end{pmatrix} = \begin{bmatrix} 01 & 03 & 01 & 01 \\ 01 & 02 & 03 & 01 \\ 01 & 01 & 02 & 03 \\ 03 & 01 & 01 & 02 \end{bmatrix} \begin{pmatrix} a_0 \\ a_1 \\ a_2 \\ a_3 \end{pmatrix}$$

它的过程如图 2.4 所示。

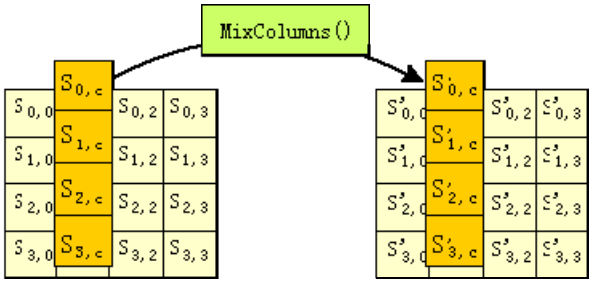


图 2.4 AES 算法 MixColumns 变换

6.密钥膨胀

在 AES 算法中，AddRoundKey 变换需要使用膨胀后的密钥，膨胀后的密钥记为子密钥，原始的 128 位密钥经过膨胀会产生 44 个字（每个字为 32 位）的子密钥，这 44 个字的子密钥供 11 次 AddRoundKey 变换使用，一次 AddRoundKey 使用 4 个字（128 位）的膨胀后的密钥。

密钥膨胀算法是以字为基础的（一个字由 4 个字节组成，即 32 比特）。128 比特的原始密钥经过膨胀后将产生 44 个字的子密钥，我们将这 44 个密钥保存在一个字数组中，记为 W[44]。128 比特的原始密钥分成 16 份，存放在一个字节的数组：Key[0]，Key[1]……Key[15]中。

在密钥膨胀算法中，Rcon 是一个 10 个字的数组，在数组中保存着算法定义的常数，分别为：

Rcon[0] = 0x01000000

Rcon[1] = 0x02000000

Rcon[2] = 0x04000000

Rcon[3] = 0x08000000

Rcon[4] = 0x10000000

Rcon[5] = 0x20000000

Rcon[6] = 0x40000000

Rcon[7] = 0x80000000

Rcon[8] = 0x1b000000

Rcon[9] = 0x36000000

另外，在密钥膨胀中包括其他两个操作 RotWord 和 SubWord，下面对这两个操作做说明：

RotWord(B0,B1,B2,B3)对 4 个字节 B0,B1,B2,B3 进行循环移位，即

RotWord(B0,B1,B2,B3) = (B1,B2,B3,B0)

SubWord(B0,B1,B2,B3)对 4 个字节 B0,B1,B2,B3 使用 AES 的 S 盒，即

SubWord(B0,B1,B2,B3) = (B’0,B’1,B’2,B’3)

其中，B’i = SubBytes（Bi），i = 0,1,2,3。

密钥膨胀的算法如下：

```
Nk = 4                  // 密钥长度，以字为单位（32 比特）
Nr = 10                 // 加密的轮数
Nb = 4                  // 状态矩阵的列数
KeyExpansion(byte key[4*Nk], work w[Nb*(Nr+1)], Nk)
begin
    word temp
    i = 0
    while(i < Nk)
        w[i] = word(key[4*i], key[4*i+1], key[4*i+2], key[4*i+3])
        i=i+1
    end while
    i = Nk
    while(i < Nb * (Nr+1))
        temp = w[i-1]
        if(i mode Nk = 0)
            temp = SubWord(RotWord(temp)) xor Rcon[i/Nk]
        else if(Nk > 6 and i mod Nk = 4)
            temp = SubWord(temp)
        end if
        w[i] = w[i-Nk] xor temp
        i = i + 1
    end while
end
```

7.解密过程

AES 的加密和解密过程并不相同，首先密文按 128 位分组，分组方法和加密时的分组方法相同，然后进行轮变换。

AES 的解密过程可以看成是加密过程的逆过程，它也由 10 轮循环组成，每一轮循环包括四个变换分别为 InvShiftRows 变换、InvSubBytes 变换、InvMixColumns 变换和 AddRoundKey 变换；

这个过程可以描述为如下代码片段所示：

```
Nk = 4                  // 状态矩阵的列数
Nr = 10                 // 加密的轮数

InvCipher(byte in[4*Nb], byte out[4*Nb], word w[Nb*(Nr+1)])
begin
    byte state[4,Nb]
    state = in
    AddRoundKey(state, w[Nr*Nb, (Nr+1)*Nb-1])
    for round = Nr-1 step -1 downto 1
        InvShiftRows(state)
        InvSubBytes(state)
        AddRoundKey(state, w[round*Nb, (round+1)*Nb-1])
        InvMixColumns(state)
    end for

    InvShiftRows(state)
    InvSubBytes(state)
    AddRoundKey(state, w[0, Nb-1])

    out = state
end
```

8.InvShiftRows 变换

InvShiftRows 变换是 ShiftRows 变换的逆过程，十分简单，指定 InvShiftRows 的变换如下。

Sr,(c+shift(r,Nb))modNb = Sr,c for 0 < r < 4 and 0 ≤ c < Nb

图 2.5 演示了这个过程。

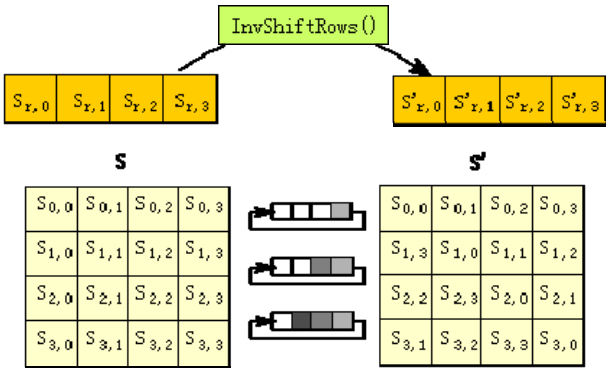


图 2.5 AES 算法 InvShiftRows 变换

9.InvSubBytes 变换

InvSubBytes 变换是 SubBytes 变换的逆变换，利用 AES 的 S 盒的逆作字节置换，表 2.3 为 InvSubBytes 变换的置换表。

表 2.3 InvSubBytes 置换表

	0	1	2	3	4	5	6	7	8	9	A	B	C	D	E	F
0	52	09	6A	D5	30	36	A5	38	BF	40	A3	9E	81	F3	D7	FB
1	7C	E3	39	82	9B	2F	FF	87	34	8E	43	44	C4	DE	E9	CB
2	54	7B	94	32	A6	C2	23	3D	EE	4C	95	0B	42	FA	C3	4E
3	08	2E	A1	66	28	D9	24	B2	76	5B	A2	49	6D	8B	D1	25
4	72	F8	F6	64	86	68	98	16	D4	A4	5C	CC	5D	65	B6	92
5	6C	70	48	50	FD	ED	B9	DA	5E	15	46	57	A7	8D	9D	84
6	90	D8	AB	00	8C	BC	D3	0A	F7	E4	58	05	B8	B3	45	06
7	D0	2C	1E	8F	CA	3F	0F	02	C1	AF	BD	03	01	13	8A	6B
8	3A	91	11	41	4F	67	DC	EA	97	F2	CF	CE	F0	B4	E6	73
9	96	AC	74	22	E7	AD	35	85	E2	F9	37	E8	1C	75	DF	6E
A	47	F1	1A	71	1D	29	C5	89	6F	B7	62	0E	AA	18	BE	1B
B	FC	56	3E	4B	C6	D2	79	20	9A	DB	C0	FE	78	CD	5A	F4
C	1F	DD	A8	33	88	07	C7	31	B1	12	10	59	27	80	EC	5F
D	60	51	7F	A9	19	B5	4A	0D	2D	E5	7A	9F	93	C9	9C	EF
E	A0	E0	3B	4D	AE	2A	F5	B0	C8	EB	BB	3C	83	53	99	61
F	17	2B	04	7E	BA	77	D6	26	E1	69	14	63	55	21	0C	7D

10.InvMixColumns 变换

InvMixColumns 变换与 MixColumns 变换类似，每列乘以 d(x)

d(x) = (OB)x3 + (0D)x2 + (0G)x + (0E)

下列等式成立：

((03)x3 + (01)x2 + (01)x + (02))⊙d(x) = (01)

上面的内容可以描述为以下的矩阵乘法：

$$s'(x) = a^{-1}(x) \otimes s(x):$$

$$\begin{bmatrix} s'_{0,c} \\ s'_{1,c} \\ s'_{2,c} \\ s'_{3,c} \end{bmatrix} = \begin{bmatrix} 0e & 0b & 0d & 09 \\ 09 & 0e & 0b & 0d \\ 0d & 09 & 0e & 0b \\ 0b & 0d & 09 & 0e \end{bmatrix} \begin{bmatrix} s_{0,c} \\ s_{1,c} \\ s_{2,c} \\ s_{3,c} \end{bmatrix} \text{ for } 0 \le c < Nb.$$

11.AddRoundKey 变换

AES 解密过程的 AddRoundKey 变换与加密过程中的 AddRoundKey 变换一样，都是按位与子密钥做异或操作。解密过程的密钥膨胀算法也与加密的密钥膨胀算法相同。最后状态矩阵中的数据就是明文。

五、实验步骤

1.按照实验指导篇进入教学实验平台，如图 2.6 所示。



图 2.6 进入实验平台

2.选择“网络信息安全教学实验系统”——>“知识类实验”——>“密码学及应用”——>实验 6 对称密码算法——>“练习二 AES 算法”，如图 2.7 所示。

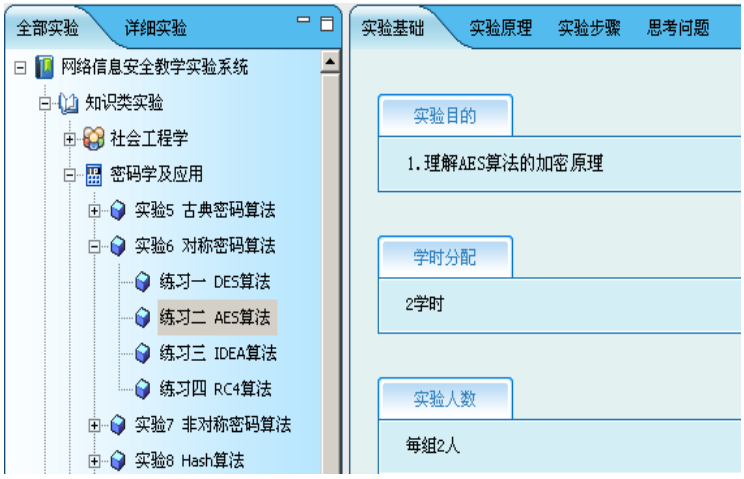


图 2.7 选择算法

3.仔细阅读“实验基础”和“实验原理”，特别是实验原理需要重点掌握。

4.在掌握原理的基础上，紧接着可以开始如下实验。

(1)点击“实验步骤”——>“密码工具”——>“AES 加密算法”——>“加密/解密”，如图 2.8 所示。

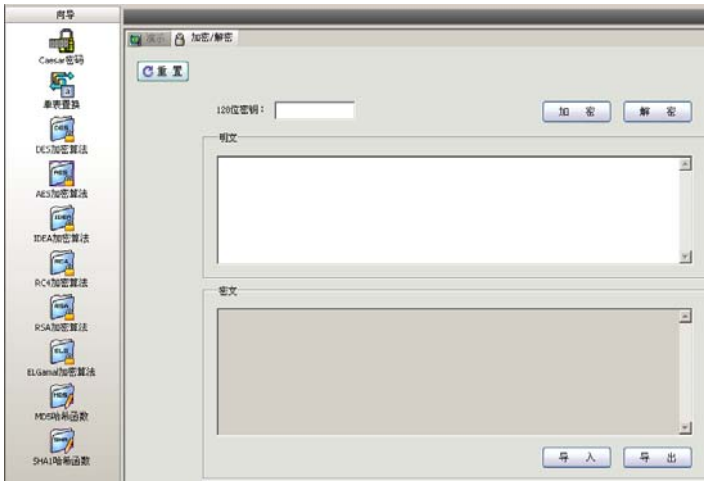


图 2.8 加密/解密

(2)在明文输入窗口输入明文，如 xinxianquan，在密钥窗口输入密钥(128 位)，要记住这个密钥以用于解密，例如，密钥 k=123456。单击“加密”按钮，会出现加密后的密文，如图 2.9 所示。

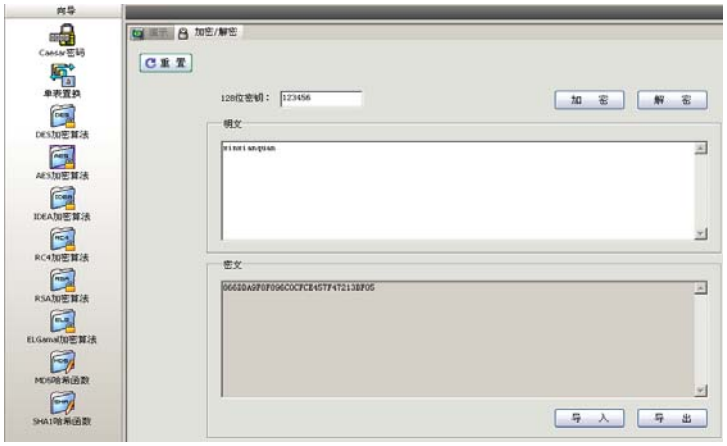


图 2.9 加密后的密文

(3)将密文导出到 AES 文件夹（D:\Work\Encryption\AES\）中，单击“导出”按钮，按图 2.10 所示路径保存密文。



图 2.10 导出密文

(4)解密文件，单击“导入”按钮，导入密文，并在密钥窗口输入密钥 k=123456，如图 2.11 所示，单击“解密”按钮，我们会得到明文，如图 2.12 所示。

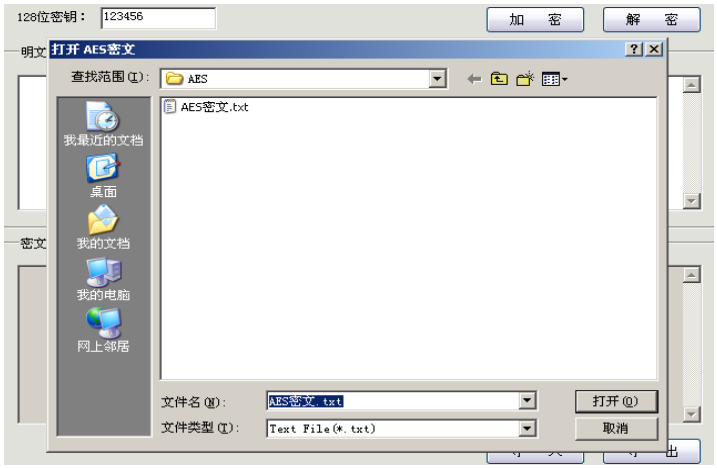


图 2.11 导入密文

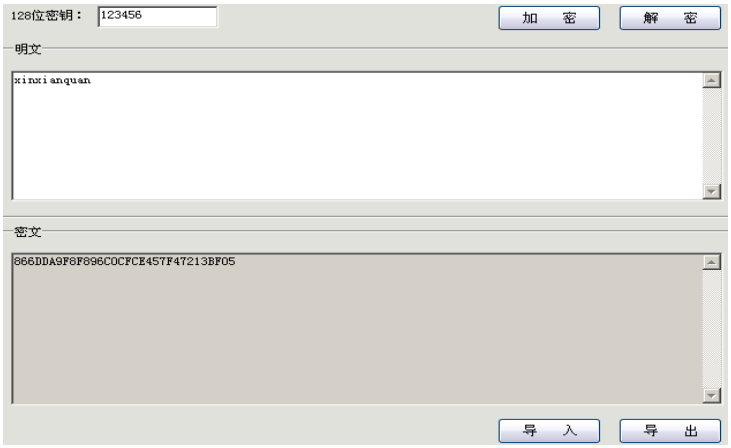


图 2.12 解密后的明文

(5)将破解后的明文与之前的明文比较，看它们是否一样。

为更加深入的理解 AES 算法，实验平台中给出了 AES 算法各个部分的执行过程和结果，接下来给予简单的演示。

1.单击“AES 算法”——>“演示”，如图 2.13 所示为演示的界面。

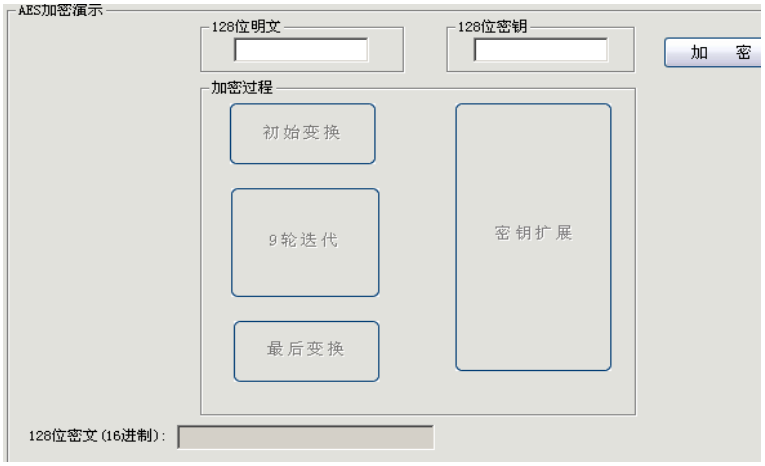


图 2.13 演示界面

2.在明文窗口输入明文，如：xinxianquan，在密钥窗口输入密钥，如 123456。点击“加密”，如图 2.14 所示，可得到加密后的密文。

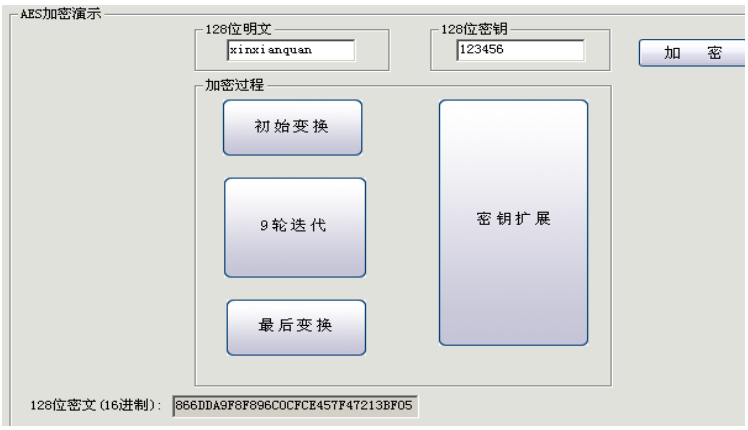


图 2.14 加密文件

3.单击“初始变换”，如图 2.15 所示。

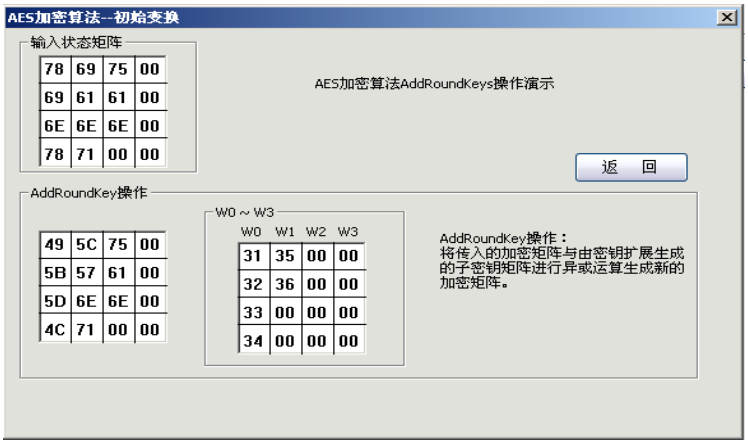


图 2.15 初始变换

4.单击“9 轮迭代”，仔细分析每次迭代后矩阵里面的数字变化，如图 2.16 所示。



图 2.16　9 轮迭代

5.单击“密钥扩展”，查看实验过程中用到的所有密钥，如图 2.17 所示。

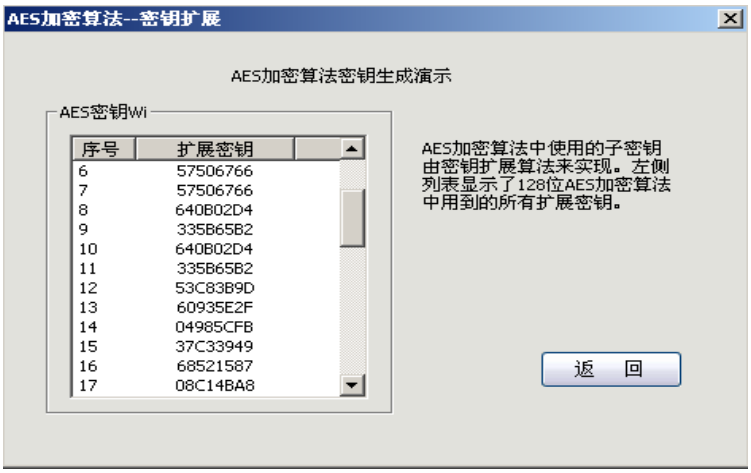


图 2.17 密钥扩展

6.单击“最后变换”，分析算法的最后演示过程，如图 2.18 所示：



图 2.18 最后变换

除了上述的实验之外，本手册还提供了可在 VC++6.0 下编译运行的源代码。

六、问题思考

1.在 AES 加密的 10 轮循环中，前 9 轮与第 10 轮有什么不同？

2.“AES 算法和 DES 算法一样，都是对比特进行操作从而完成加密的”，你认为这句话对吗？

实验三 IDEA 算法

一、实验目的

理解 IDEA 算法的加密原理

二、实验环境

Windows，换网络结构

三、实验工具

VC++6.0，密码工具

四、实验原理

1.IDEA 算法简介

IDEA（International Data Encryption Alogrithm）是由瑞士苏黎士联邦工业大学的 XueJiaLai 和 James L.Massey 于 1991 年提出的。IDEA 使用 128 比特密钥，整个算法和 DES 相似，也是将明文划分成一个个 64 比特长的数据分组，然后经过几次迭代和一次变换，得出 64 比特的密文。

IDEA 是将两个 16 比特的值映射为一个 16 比特的值，这些操作是：

●半加运算，即“异或”运算，用符号“⊕”表示。所谓的半加运算，就是在进行二进制运算时只加，不进位。

●模 2^{16} 的加法运算（即 mod 65536），用“+”表示。

●模 $2^{16}+1$ 乘运算用符号“⊙”表示。

实际上，⊙是将两个输入的数进行乘法运算，然后再对此结果按模 $2^{16}+1$ 运算得出的结果。对于这样的运算应该注意的是，参与运算的任何一个二进制数据 n 位，如果全是 0，则用 n+1 位数据表示，且最高位为 1，其余全为 0。

为了理解以上三种操作，我们用 2 位的数来表示以上的三种关系，如表 3-1 所示。

表 3.1 IDEA 三种操作的关系

X		Y		X⊞Y		X⊙Y		X⊕Y	
十进制	二进制	十进制	二进制	十进制	二进制	十进制	二进制	十进制	二进制
0	00	0	00	0	00	1	01	0	00
0	00	1	01	1	01	0	00	1	01
0	00	2	10	2	10	3	11	2	10
0	00	3	11	3	11	2	10	3	11
1	01	0	00	1	01	0	00	1	01
1	01	1	01	2	10	1	01	0	00
1	01	2	10	3	11	2	10	3	11
1	01	3	11	0	00	3	11	2	10
2	10	0	00	2	10	3	11	2	10
2	10	1	01	3	11	2	10	3	11
2	10	2	10	0	00	0	00	0	00
2	10	3	11	1	01	1	01	1	01
3	11	0	00	3	11	2	10	3	11
3	11	1	01	0	00	3	11	2	10
3	11	2	10	1	01	1	01	1	01
3	11	3	11	2	10	0	00	0	00

2.IDEA 算法加密过程

(1)IDEA 迭代过程

IDEA 加密算法采用 8 次迭代，如图 3.1 所示。

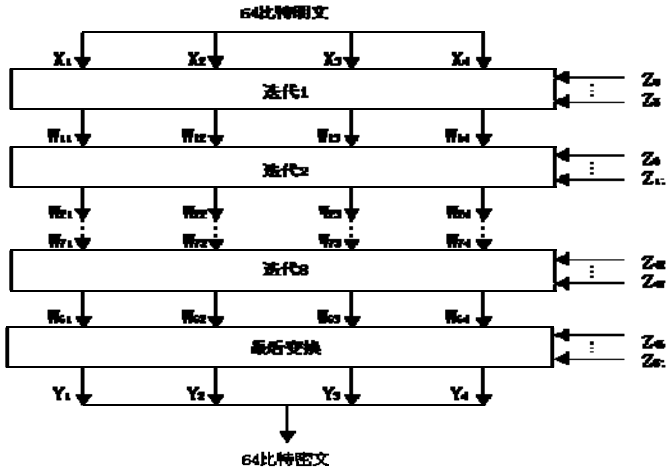


图 3.1 8 次迭代

64 比特的密钥生成的数据被分成 8 个子块，每个子块 16 比特。每一次迭代过程如图 3.2 所示。

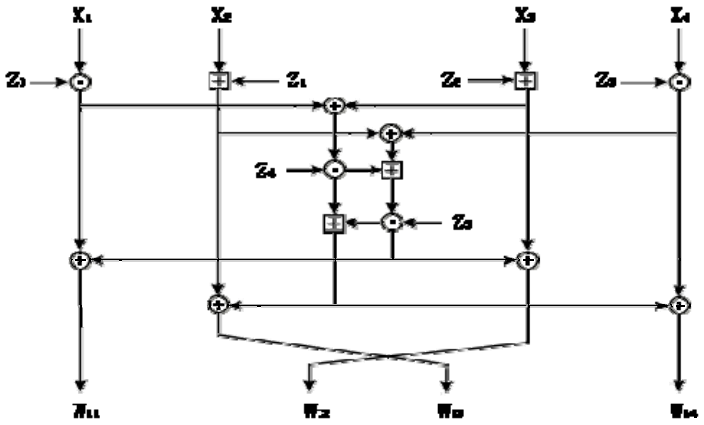


图 3.2 单次迭代

「说明」图中⊕表示异或运算；表示模 2^{16} 的加法运算；⊙表示模 $2^{16}+1$ 的乘法运算。

X1，X2，X3 和 X4 作为第一次迭代的输入，每轮的迭代步骤如下：迭代都是 4 个子块以及 16 比特子密钥间的异或运算，模 2^{16} 做加法运算和模（$2^{16}+1$）的乘法运算。

1)X1 和第一个子密钥块做乘法运算。

2)X2 和第二个子密钥块做加法运算。

3)X3 和第三个子密钥块做加法运算。

4)X4 和第四个子密钥块做乘法运算。

5)(1)和(3)的结果做异或运算。

6)(2)和(4)的结果做异或运算。

7)(5)的结果和第五个子密钥块做乘法运算。

8)(6)和(7)的结果做加法运算。

9)(8)的结果与第六个子密钥块做乘法运算。

10)(7)和(9)的结果做加法运算。

11)(1)和(9)的结果做异或运算。

12)(3)和(9)的结果做异或运算。

13)(2)和(10)的结果做异或运算。

14)(4)和(10)的结果做异或运算。

每轮完成以上的 14 次运算，共进行 8 轮，然后进行最后的输出变换，如图 3.3 所示。经过 8 轮迭代运算后，W81，W82，W83，W84 分别与 Z48，Z49，Z50，Z51 运算得到 Y1，Y2，Y3 和 Y4。其方法如下：

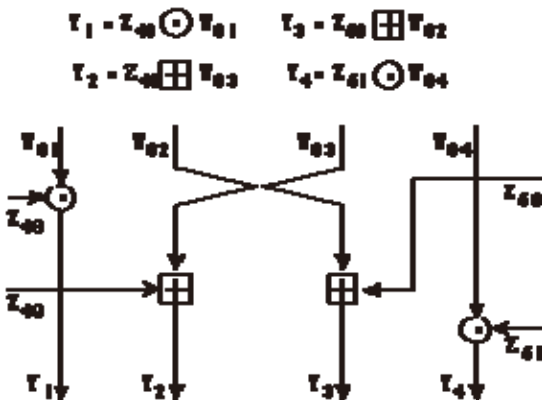


图 3.3 8 轮迭代变换后的输出变换

(2)IDEA 密钥生成过程

在图 3-3 中可以看出，在加密过程中共有 52 个子密钥块参与运算，每个块长 16 比特。这 52 个密钥块是由 128 比特密钥产生的，我们将这 52 个密钥块记为 Z0，Z1……，Z51。最初的 8 个子密钥 Z0，Z1，……，Z7 是直接来自用户输入，Z0 是用户输入密钥的前 16 比特；Z1 是用户输入密钥的第二个 16 比特，Z7 是用户输入密钥的最后 16 比特。这样从 Z0 到 Z7 的密钥共计长度为 128 比特。

IDEA 每一轮迭代使用 6 个子密钥，每个子密钥有 16 位，这意味着在一轮迭代中，密钥中只有 96 位被使用。最初的 6 个连续的子密钥（Z0 到 Z5）直接用于第一轮迭代，然后 128 位的密钥要循环左移 25 位，之后再取密钥的前 96 位作为下一轮的 6 个子密钥。以此类推，直到 8 轮迭代全部完成。

(3)IDEA 解密算法与其加密的关系

IDEA 的解密处理和其加密处理基本相同，只是解密处理输入的是密文，选择的密钥不大相同，但也有一定的联系。它与加密密钥的关系如下。

解密过程的第 i 轮前四个密钥是与加密过程中的第（10-i）轮的相同，最后置换作为第 9 轮。解密过程的第 1 和第 4 轮是对应加密处理过程第 1 轮和第 4 轮的模（216+1）乘运算，解密过程中的第 2 轮和第 3 轮对应与加密过程中的第 3 轮和第 2 轮的模 216 的加运算。

在前 8 轮运算中，解密的第 i 轮的最后两个子密钥块等于加密过程中的第 9-i 轮的最后两个子密钥块。每一轮的加密和解密的子密钥关系如表 3.2 所示。

表 3.2 加密和解密的子密钥关系

加解密轮次	每轮的加密密钥	原始密钥对应的位
第一轮	$Z_0Z_1Z_2Z_3Z_4Z_5$	$Z_{48}^{-1}-Z_{49}-Z_{50}Z_{51}^{-1}Z_{46}Z_{47}$
第二轮	$Z_6Z_7Z_8Z_9Z_{10}Z_{11}$	$Z_{42}^{-1}-Z_{44}-Z_{43}Z_{45}^{-1}Z_{40}Z_{41}$
第三轮	$Z_{12}Z_{13}Z_{14}Z_{15}Z_{16}Z_{17}$	$Z_{36}^{-1}-Z_{38}-Z_{37}Z_{39}^{-1}Z_{34}Z_{35}$
第四轮	$Z_{28}Z_{19}Z_{20}Z_{21}Z_{22}Z_{23}$	$Z_{30}^{-1}-Z_{32}-Z_{31}Z_{33}^{-1}Z_{28}Z_{29}$
第五轮	$Z_{34}Z_{25}Z_{26}Z_{27}Z_{28}Z_{29}$	$Z_{24}^{-1}-Z_{26}-Z_{25}Z_{27}^{-1}Z_{22}Z_{23}$
第六轮	$Z_{30}Z_{31}Z_{32}Z_{33}Z_{34}Z_{35}$	$Z_{18}^{-1}Z_{20}-Z_{19}Z_{21}^{-1}Z_{18}Z_{17}$
第七轮	$Z_{46}Z_{37}Z_{38}Z_{39}Z_{40}Z_{41}$	$Z_{12}^{-1}Z_{14}-Z_{13}Z_{15}^{-1}Z_{10}Z_{11}$
第八轮	$Z_{42}Z_{43}Z_{44}Z_{45}Z_{46}Z_{47}$	$Z_6^{-1}-Z_8-Z_7Z_9^{-1}Z_4Z_5$
最后的置换	$Z_{48}Z_{49}Z_{50}Z_{51}$	$Z_0^{-1}-Z_1-Z_2Z_3^{-1}$

以上 Zj 与 Zj-1 及-Zj 与 Zj 的关系为：

●Zj⊙Zj-1 = 1

●-ZjZj = 0

五、实验步骤

1.按照实验指导篇进入教学实验平台，如图 3.4 所示。



图 3.4 进入实验平台

2.选择“网络信息安全教学实验系统”——>“知识类实验”——>“密码学及应用”——>实验 6 对称密码算法——>“练习三 IDEA 算法”，如图 3.5 所示。

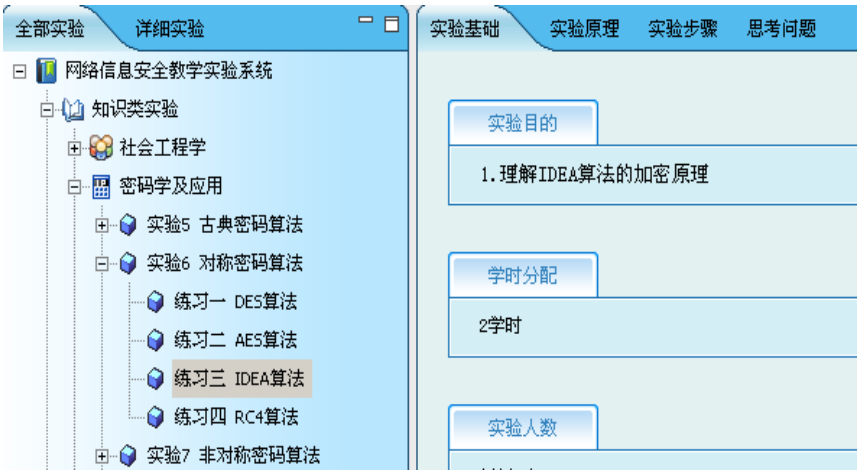


图 3.5 选择算法

3.认真仔细的阅读“实验基础”和“实验原理”，特别是实验原理是我们重点应该掌握的内容。

4.开始实验

(1)点击“实验步骤”——>“密码工具”——>“IDEA 加密算法”——>“加密/解密”，如图 3.6 所示。



图 3.6 加密/解密

(2)在明文输入窗口输入明文，如 xinxianquan，在密钥窗口输入密钥 k，要记住这个密钥以用于解密，例如密钥 k=123456。单击“加密”按钮，会出现加密后的密文，如图 3.7 所示。

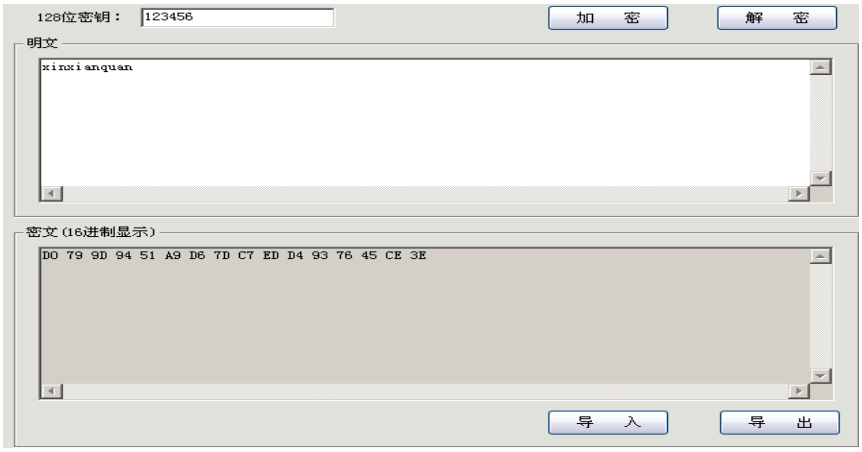


图 3.7 加密后的密文

(3)将密文导出到 IDEA 文件夹（D:\Work\Encryption\IDEA\）中，单击“导出”按钮，按此路径保存密文，如图 3.8 所示。

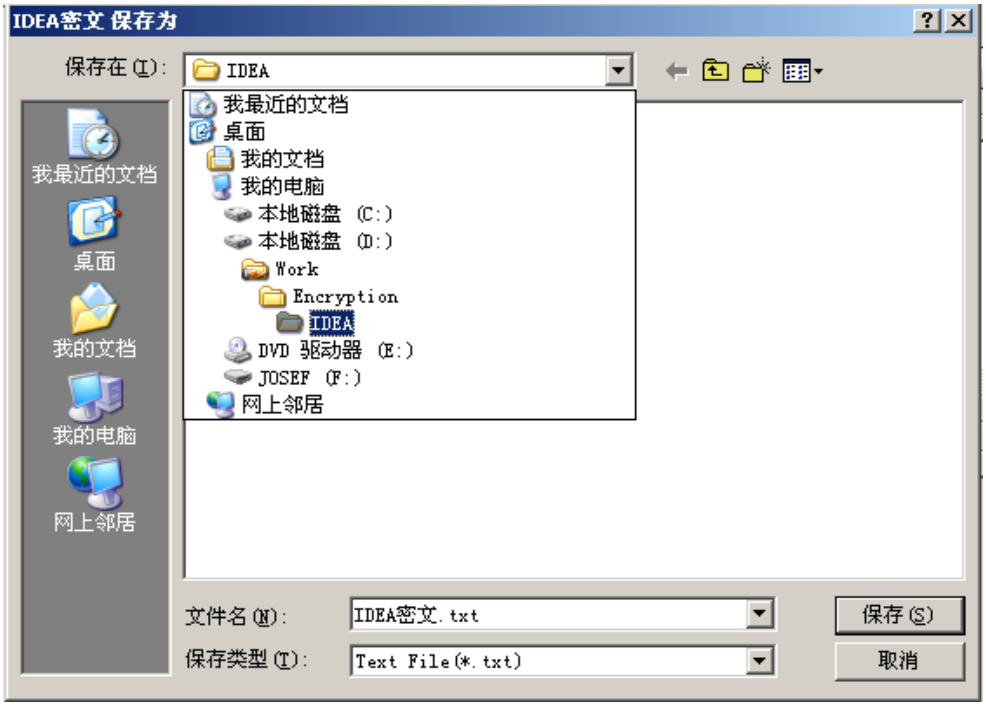


图 3.8 导出文件

(4)解密文件，单击“导入”按钮，输入密钥 k=123456,如图 3.9 所示。单击“解密”按钮，就可得到明文，如图 3.10 所示。

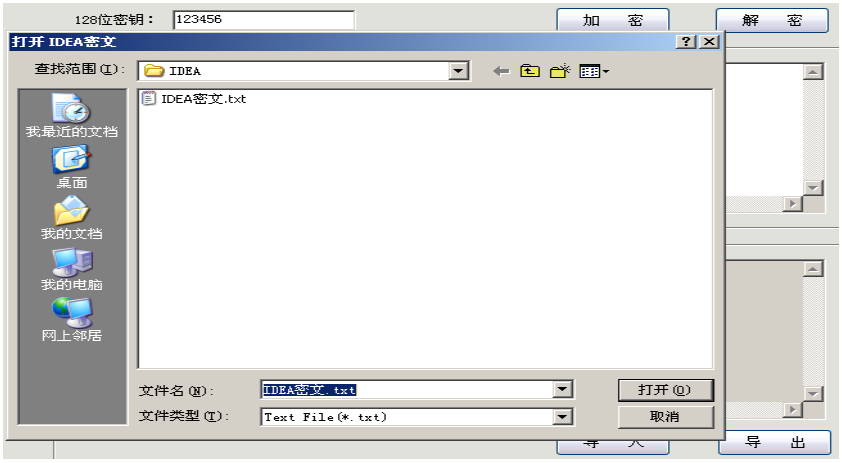


图 3.9 导入文件

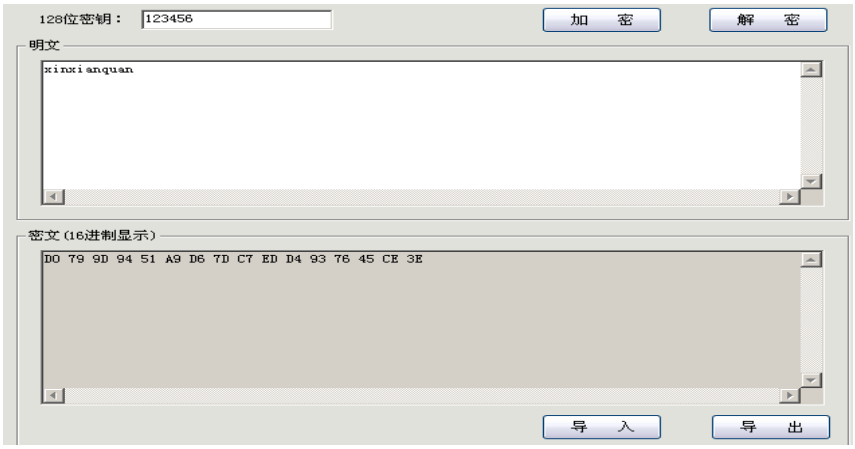


图 3.10 解密后的明文

(5)将破解后的明文与之前的明文比较，看它们是否一样。

为更深入的理解 IDEA 算法，实验平台中海提供了算法执行过程的详细演示，接下来对其进行阐述。

(1)单击“IDEA 算法”——>“演示”，如图 3.11 所示。



图 3.11 加密演示界面

(2)在明文窗口输入明文，如：xinxianquan，在密钥窗口输入密钥，如 123456，点击“加密”，如图 3.12 所示：我们会得到加密后的密文。

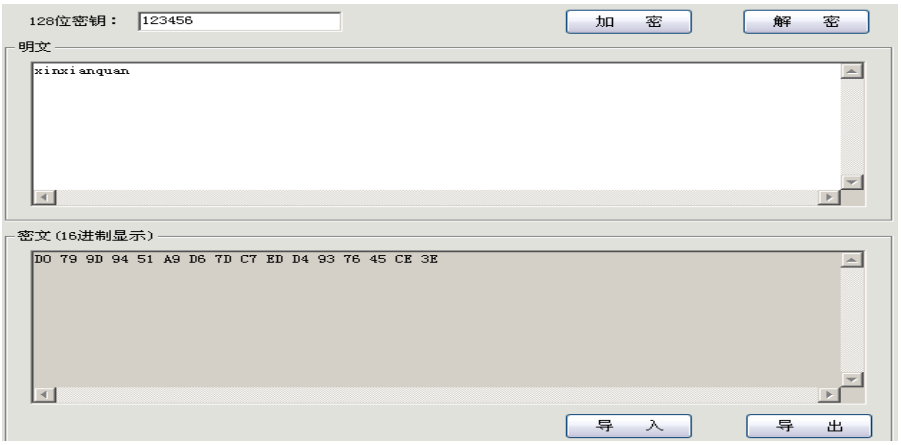


图 3.12 加密后的密文

(3)单击“8 轮迭代”，如图 3.13 所示。

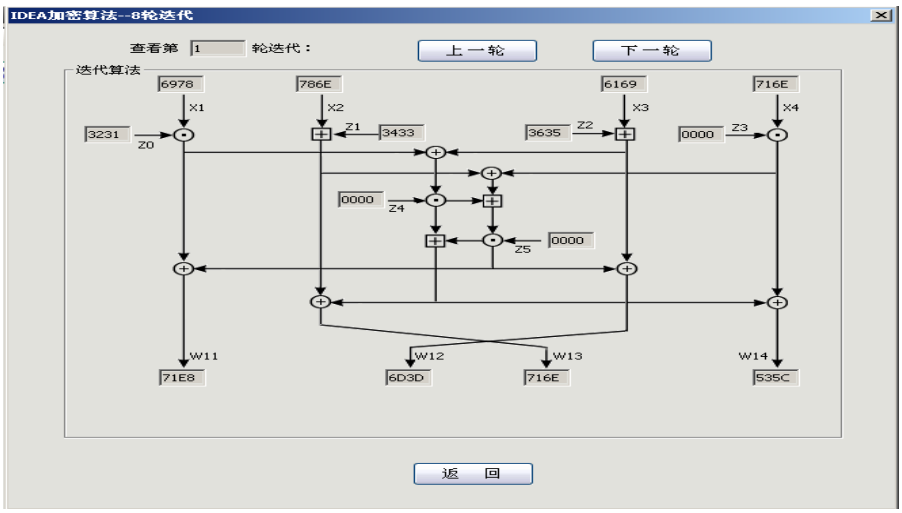


图 3.13 8 轮迭代

(4)单击“52 个子密钥”，查看全部密钥，如图 3.14 所示。

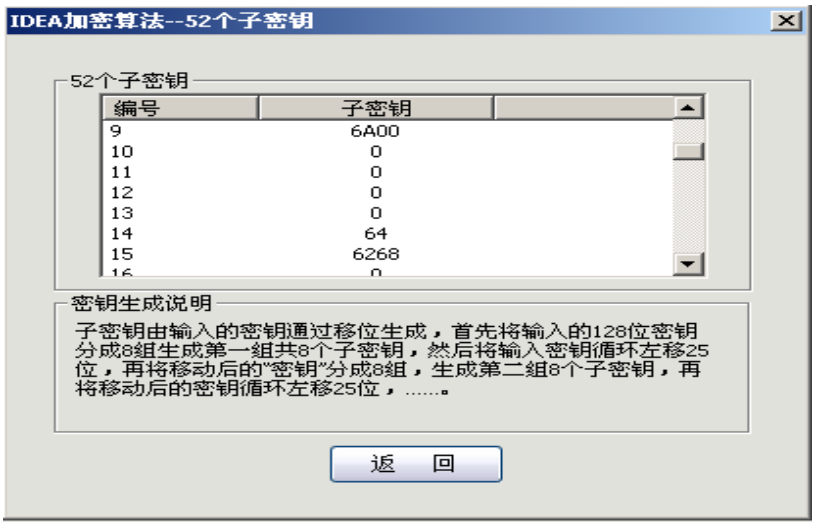


图 3.14 52 个子密钥

(5)单击“最后交换”，查看变换结果，如图 3.15 所示。

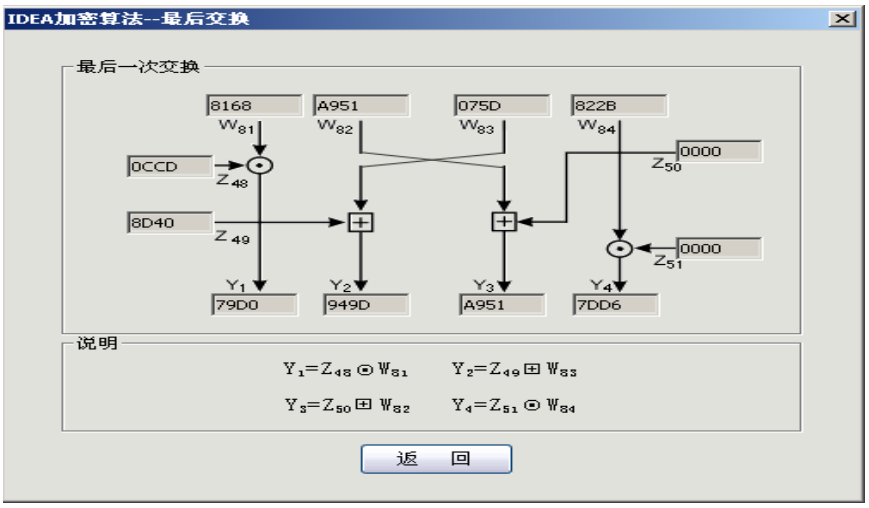


图 3.15 最后变换

此外，与本手册一起还给出了能够用 VC++6.0 调试运行的 IDEA 算法的 C++实现。

六、问题思考

1.IDEA 加密算法的加密、解密子密钥的生成过程。

实验四 RSA 算法

一、实验目的

1.了解非对称加密算法机制
2.理解 RSA 算法的加密原理

二、实验环境

Windows，交换网络结构

三、实验工具

VC++6.0，密码工具

四、实验原理

1.非对称密钥加密简介

前面讲述了对称密钥加密体制。使用对称密钥加密体制进行保密通信时，任意不同的两个用户之间都应该使用互不相同的密钥。这样，如果一个网络中有 n 个用户，他们之间彼此都可能进行秘密通信，这时网络中将需要 n(n-1)/2 个密钥(其中，每个用户都需要保存 n-1 个密钥)，这样巨大的密钥量给密钥分配和管理带来了极大的困难。另外，随着计算机网络，特别是因特网的发展，网络上互不相识的用户可能需要进行保密的会话(例如，如果用户在进行电子商务活动时，需要保密的连接，这时的客户对象可能根本不是固定的对象)。最后，对称密钥加密机制难以解决签名验证问题。

非对称密钥加密也称为公开密钥加密，或者叫做公钥加密算法。使用公开密钥密码的每一个用户都分别拥有两个密钥：加密密钥和解密密钥，它们两者并不相同，并且由加密密钥得到解密密钥在理论上是不可行的。每一个用户的加密密钥都是公开的。因此，加密密钥也称为公开密钥。所有用户的公开密钥都将记录在作用类似于电话号码薄的密钥本上，而它可以被所有用户访问，这样每一个用户都可以得到其他所有用户的公开密钥。同时，每一个用户的解密密钥将由用户保存并严格保密。因此，解密密钥也称为私有密钥。

非对称密码算法解决了对称密码体制中密钥管理的难题，并提供了对信息发送人的身份进行验证的手段，是现代密码学最重要的发明。公钥加密算法一般是将对密钥的求解转化为

对数学上的困难问题的求解，例如 RSA 算法的安全性是建立在“大数分解和素性检测”这个数论难题的基础上，已知两个大素数 a、b，求出 a*b 是容易计算的，而已知 a*b，想知道其是哪两个大素数的乘积目前还没有好的计算方法，另外也有一些非对称加密算法(如 ELGamal 算法)的安全性是基于求“离散对数”这个数学难题上的。

在公钥密码系统中每个实体都有自己的公钥和相应的私钥。公钥密码系统的加密变换和解密变换分别用 E 和 D 表示。任何实体 B 要向实体 A 发送信息 m 的步骤如下：实体 B 首先获得实体 A 的真实公钥的拷贝(eA)，实体 B 使用 eA 计算密文 c=E(m)并发送给实体 A，实体 A 使用自己的私钥 dA，计算 m=D(c)解密密文，恢复出明文 m。这里公钥不需要保密，但要保证它的真实性，即 eA 确实是实体 A 掌握的私钥 dA 所对应的公钥。提供真实的公钥比安全地分配密钥实现起来要容易得多。这也是公钥密码系统的主要优点之一。

公钥密码系统的主要目的是提供保密性，它不能提供数据源认证(data origin authentication)和数据完整性(data integrity)。数据源认证是指：指定的数据是在以前的某个时间确实是由真正的源创建的。数据完整性是指：真正的源创建该数据后经过传输后存储没有发生改变。数据源认证和数据完整性要由其他技术来提供（如消息认证码技术、数字签名技术等）。

从本质上来看，公钥密码比对称密钥密码加密的速度要慢，粗略的说，公钥加密算法 RSA 硬件实现比分组加密算法 DES 硬件实现的速度慢 1500 倍，而软件实现的速度要慢 100 倍。

公钥解密也可以提供认证保证(如：在实体认证协议、带认证的密钥建立协议等)。公钥加密中必须有颁发让发送消息的人得到想要发送到的那个人的公钥的真实拷贝，否则就会受到伪装攻击。在实践中有很多方法分发真实的公钥，如：使用可信的公共文件，使用在线可信服务器，使用离线服务器和认证。

公钥加密的优点：

●大型网络中的每个用户需要的密钥数量少。

●对管理公钥的可信第三方的信任程度要求不高而且是离线的。

●只有私钥是保密的，而公钥只要保证它的真实性。

缺点：

●多数公钥加密比对称密钥加密的速度要慢几个数量级。

●公钥加密方案的密钥长度比对称加密的密钥要长。

●公钥加密方案没有被证明是安全的。

公钥密码的概念本身就被公认为是密码学上的一块里程碑。二十多年来的研究表明，公钥密码成功地解决了计算机网络安全中的密钥管理，身份认证和数字签名等问题，已经成为信息安全技术中的重大核心技术。

2.RSA 算法概述

RSA加密算法于1977年由美国麻省理工学院的Ronal Rivest，Adi Shamir和Len Adleman三位年轻教授提出，并以三人的姓氏的首字母命名为 RSA。这三位科学家荣获 2002 年度图灵奖，以表彰他们在算法方面的突出贡献。该算法利用了数论领域的一个事实，那就是虽然把两个大质数相乘生成一个合数是件十分容易的事情，但要把一个合数分解为两个质数的乘积却十分困难。合数分解问题目前仍然是数学领域尚未解决的一大难题，至今没有任何高效的分解方法。它无须收发双方同时参与加密过程，既可以用于保密也可以用于签名，因而非常适合于电子邮件系统的加密，互连网和信用卡安全系统。

3.RSA 算法加密/解密

在 RSA 算法中，每个实体有自己的公钥（e，n）及私钥(d，n)，其中 n = p*q，p，q 是两个大素数，e*d = 1 modϕ(n)，显然 e 应该满足 gcd(e,ϕ(n))＝1。实体 B 加密消息 m，将密文在公开信道上传送给实体 A。实体 A 接到密文后对其解密。具体算法如下。

(1)公钥的生成算法

RSA 的公钥生成算法十分简单，可以分为四步：

1)选择两个素数，p 和 q；

2)计算 n = p×q 和 z = (p-1)×(q-1)；

3)选择一个与 z 互质的数 d；

4)找出一个 e，使得 e×d = 1 mod z。

公开密钥是由（e，n）构成，私有密钥由（d，n）构成。

(2)加密算法

实体 B 的操作如下：

1)得到实体 A 的真实公钥（e，n）；

2)把消息表示成整数 m，0＜m≤n－1；

3)使用平方－乘积算法，计算 C = Ek(m) = me mod n；

4)将密文 C 发送给实体 A。

(3)解密算法

实体 A 接收到密文 C，使用自己的私钥 d 计算 m = Dk（C） = Cd mod n，m∈Zn。

在此选择 p = 3，q = 11，得到 n = 33，z = (p-1)×(q-1) = 2×10 = 20。由于 7 和 20 互质，故设 d = 7。对于所选的 d = 7，解方程 7×e = 1 mod 20，可以得到 e = 3。

对于明文 SUZANNE，RSA 的加密和解密过程如表 4.1 所示。

表 4.1 加密/解密过程

加密				解密			
明文（m）		m^e	密文（C）	密文（C）	C^d	明文（m）	
符号	值	m^3	$m^3(mod33)$	$m^3(mod33)$	C^7	值	符号
S	19	6859	28	28	13492928512	19	S
U	21	9261	21	21	1801088541	21	U
Z	26	17576	20	20	1280000000	26	Z
A	1	1	1	1	1	1	A
N	14	2744	5	5	78125	14	N
N	14	2744	5	5	78125	14	N
E	5	125	26	26	8031810176	5	E

五、实验步骤

(1)按照实验指导篇进入教学实验平台，如图 4.1 所示。



图 4.1 进入实验平台

(2)选择“网络信息安全教学实验系统”——>“知识类实验”——>“密码学及应用”——>“实验 7 非对称密码算法”——>“练习一 RSA 算法”，如图 4.2 所示。

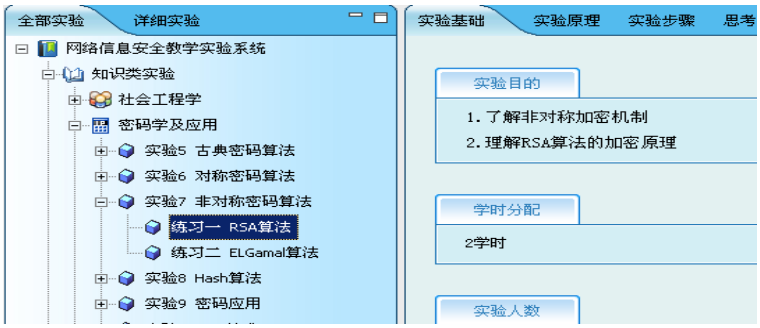


图 4.2 选择算法

(3)认真仔细的阅读“实验基础”和“实验原理”，特别是实验原理是我们重点应该掌握的内容。

(4)开始实验操作

1)点击“实验步骤”——>“密码工具”——>“RSA 加密算法”——>“加密/解密”——>“公钥”，如图 4.3 所示。

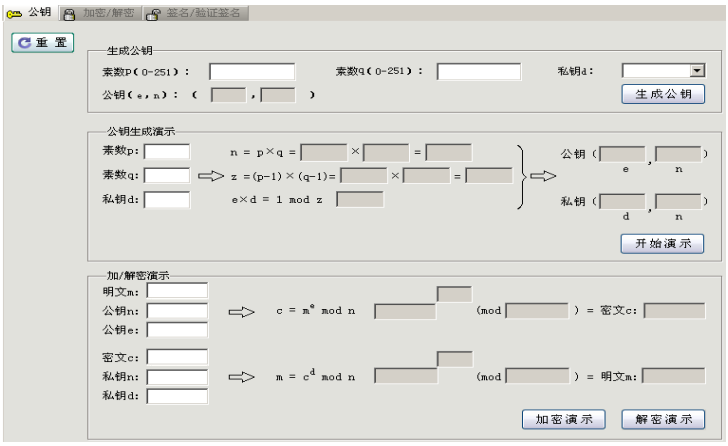


图 4.3 生成公钥及加密/解密演示初始界面

①在生成公钥窗口输入素数 p 和素数 q，这里要求 p 和 q 不能相等(因为很容易开平方求出 p 与 q 的值)，并且 p 与 q 的乘积也不能小于 127(因为小于 127 不能包括所有的 ASCII 码，导致加密失败)。你选用的素数 p 与 q 分别是：p=__；q=__。这里我们令 p=53,q=97。

②单击“私钥 d”下拉按钮，选择私钥 d，并记录这个私钥用于解密，d=__。这里令 d=1009。

③单击“生成公钥”按钮生成公钥，记录下公钥 e=__, n=__。

④在生成公钥演示区中输入素数 p=__和素数 q=__，还有私钥 d=__。单击“开始演示”按钮查看结果。

⑤在加/解密演示区中输入明文 m=__，公钥 n=__(m<n)，公钥 e=__。单击“加密演示”按钮，查看 RSA 加密过程，然后记录得到的密文 c=__。

⑥在密文 c 编辑框输入刚刚得到的密文，分别输入私钥 n=__，私钥 d=__，点击“解密演示”按钮，查看 RSA 解密过程，然后记录得到的明文 m=__。整个过程的数据如图 4.4 所示。

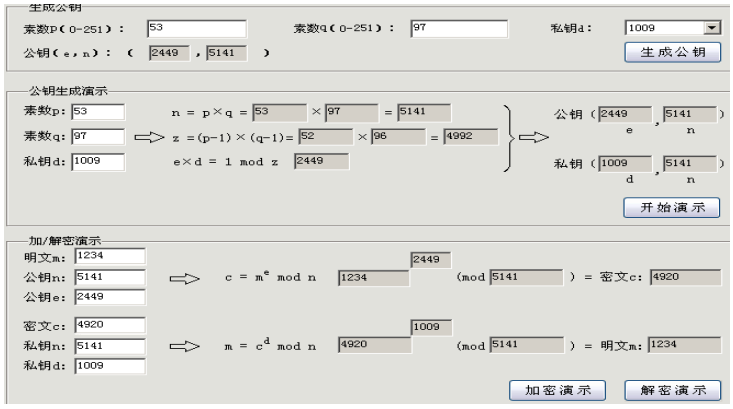


图 4.4 加密/解密演示

比较解密后的明文与原来的明文是否一致。

为了更加深入的理解 RSA 的加密/解密原理，接下来将在实验平台中演示整个过程，帮助读者理解。

(1)单击“加密/解密”，进入数据测试界面，如图 4.5 所示。

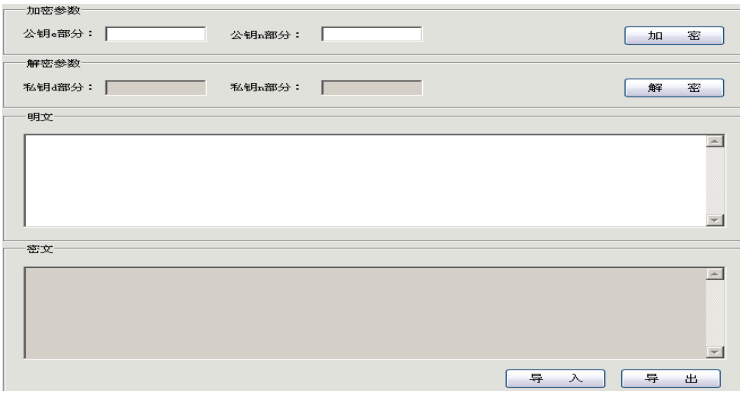


图 4.5 加密/解密初始界面

(2)在“公钥 e 部分”和“公钥 n 部分”输入同组主机的公钥，在明文输入区输入明文：如 123，单击“加密”按钮对明文进行加密，得到如图 4.6 所示的密文。

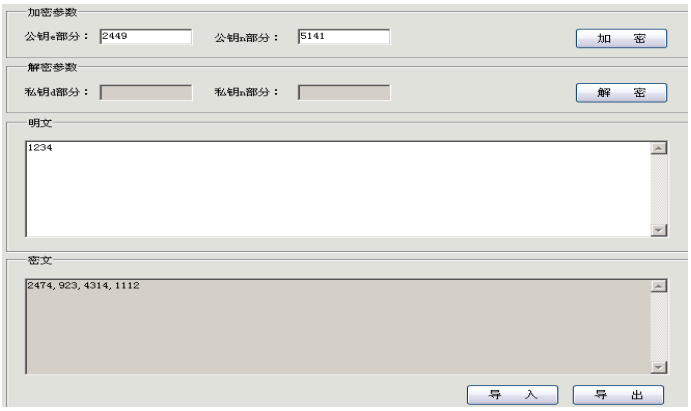


图 4.6 加密数据

(3)单击“导出”按钮将密文导出到 RSA 共享文件夹（D:\Work\Encryption\RSA\）中，如图 4.7 所示。

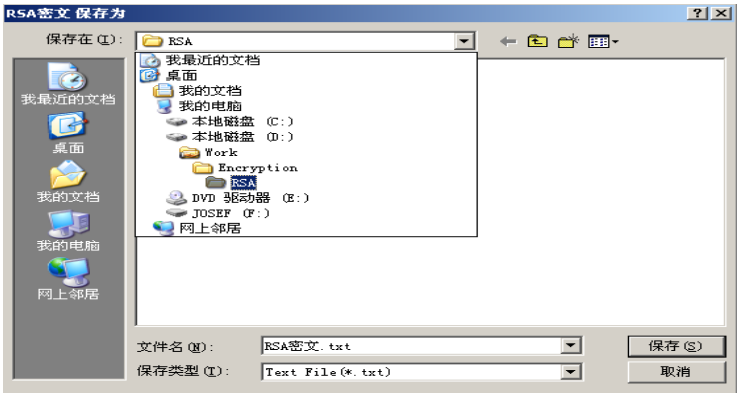


图 4.7 保存密文

(4)单击“重置”——>“导入”按钮，导入刚刚的密文，如图 4.8 所示。



图 4.8 导入密文

(5)点击“解密”按钮，切换到解密模式，在“私钥 d 部分”和“私钥 n 部分”输入自己的私钥，再次点击“解密”按钮进行 RSA 解密，如图 4.9 所示。

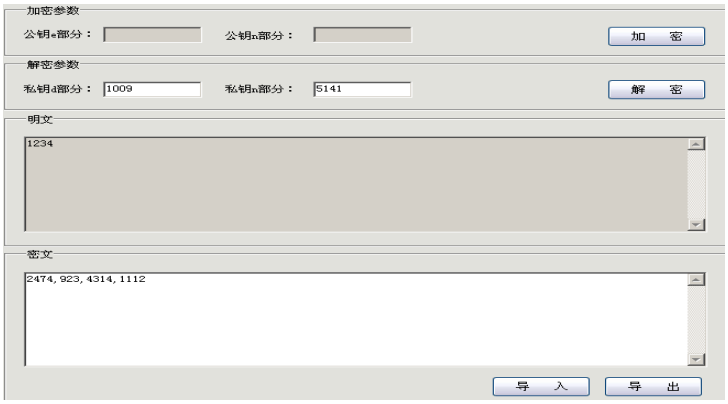


图 4.9 对密文进行解密

(6)将破解后的明文与之前的明文比较，看它们是否一样。

除此之外，实验手册一起还提供了 RSA 算法的 C++实现，可以在 VC++6.0 环境中调试运行。

六、问题思考

1.简述 RSA 的公钥生成算法？

2.“无法证明 RSA 算法是安全的”，你认为这句话对吗？

实验五 MD5 算法

一、实验目的

1.理解 Hash 函数的计算原理和特点
2.理解 MD5 算法的加密原理

二、实验环境

Windows，交换网络结构

三、实验工具

VC++6.0，密码工具

四、实验原理

1.哈希函数简介

信息安全的核心技术是应用密码技术。密码技术的应用远不止局限于提供机密性服务，密码技术也提供数据完整性服务。密码学上的散列函数(Hash Functions)就是能提供数据完整性保障的一个重要工具。Hash 函数常用来构造数据的短“指纹”，消息的发送者使用所有的消息产生一个短“指纹”，并将该短“指纹”与消息一起传输给接收者。即使数据存储在不安全的地方，接收者重新计算数据的指纹，并验证指纹是否改变，就能够检测数据的完整性。这是因为一旦数据在中途被破坏或改变，短指纹就不再正确。

散列函数是一个函数，它以一个变长的报文作为输入，并产生一个定长的散列码，有时也称为报文摘要，作为函数的输出。散列函数最主要的作用是用于鉴别，鉴别在网络安全中起到举足轻重的地位。鉴别的目的有以下两个：第一，验证信息的发送者不是冒充的，同时发信息者也不能抵赖，此为信源识别；第二，验证信息完整性，在传递或存储过程中未被篡改，重放或延迟等。

2.哈希函数特点

密码学哈希函数（cryptography hash function，简称为哈希函数）在现代密码学中起着重要的作用，主要用于数据完整性认证和消息认证。哈希函数的基本思想是对数据进行运算得到一个摘要，运算过程满足：

●压缩性：任意长度的数据，算出的摘要长度都固定。

●容易计算：从原数据容易计算出摘要。

●抗修改性：对原数据进行任何改动，哪怕只修改 1 个字节，所得到的摘要都有很大区别。

●弱抗碰撞：已知原数据和其摘要，想找到一个具有相同摘要的数据（即伪造数据），在计算上是困难的。

●强抗碰撞：想找到两个不同的数据，使它们具有相同的摘要，在计算上是困难的。

3.针对哈希函数的攻击

对散列函数的攻击方法主要有两种：

●穷举攻击：它可以用于对任何类型的散列函数的攻击，最典型的方式就是所谓的“生日攻击”。采用生日攻击的攻击者将产生许多明文消息，然后计算这些明文消息的摘要，进行比较。

●利用散列函数的代数结构：攻击其函数的弱性质。通常的有中间相遇攻击、修正分组攻击和差分分析攻击等。

4.MD5 哈希函数

1990 年 R.L.Rivest 提出哈希函数 MD4。MD4 不是建立在其他密码系统和假设之上，而是一种直接构造法，所以计算速度快，特别适合 32 位计算机软件实现，对于长的信息签名很实用。MD5 是 MD4 的改进版，它比 MD4 更复杂，但是设计思想相似并且也产生了 128 位摘要。

(1)MD5 哈希算法流程

对于任意长度的明文，MD5 首先对其进行分组，使得每一组的长度为 512 位，然后对这些明文分组反复重复处理。

对于每个明文分组的摘要生成过程如下：

1)将 512 位的明文分组划分为 16 个子明文分组，每个子明文分组为 32 位。

2)申请 4 个 32 位的链接变量，记为 A、B、C、D。

3)子明文分组与链接变量进行第 1 轮运算。

4)子明文分组与链接变量进行第 2 轮运算。

5)子明文分组与链接变量进行第 3 轮运算。

6)子明文分组与链接变量进行第 4 轮运算。

7)链接变量与初始链接变量进行求和运算。

8)链接变量作为下一个明文分组的输入重复进行以上操作。

9)最后，4 个链接变量里面的数据就是 MD5 摘要。

(2)MD5 分组过程

对于任意长度的明文，MD5 可以产生 128 位的摘要。任意长度的明文首先需要添加位数，使明文总长度为 448（mod512）位。在明文后添加位的方法是第一个添加位是 l，其余都是 0。然后将真正明文的长度（没有添加位以前的明文长度）以 64 位表示，附加于前面已添加过位的明文后，此时的明文长度正好是 512 位的倍数。当明文长度大于 2 的 64 次方时，仅仅使用低 64 位比特填充，附加到最后一个分组的末尾。

经过添加处理的明文，其长度正好为 512 位的整数倍，然后按 512 位的长度进行分组(block)，可以划分成 L 份明文分组，我们用 Y0，Y1，……，YL-1 表示这些明文分组。对于每一个明文分组，都要重复反复的处理，如图 5.1 所示。

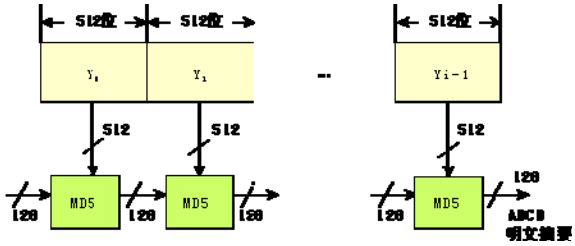


图 5.1 MD5 的分组处理方法

(3)MD5 子明文分组和链接变量

对于 512 位的明文分组，MD5 将其再分成 16 份子明文分组（sub-block），每份子明文分组为 32 位，我们使用 M[k]（k= 0, 1,……15）来表示这 16 份子明文分组。这里的概念要弄清楚，一个添加位后的明文可以划分为 L 份明文分组，而一个明文分组又可以划分为 16 份子明文分组。

MD5 有 4 轮非常相似的运算，每一轮包括 16 个类似的步骤，每一个步骤的数据处理都是针对 4 个 32 位记录单元中的数据进行的。这 4 个链接变量的初始值以 16 进位制表示如下(低字节优先)A：0x01234567，B：0x89ABCDEF，C：0xFEDCBA98，D：0x76543210，这时 A、B、C、D 四个链接变量的值为：A=0x67452301，B=0xEFCDAB89，C=0x98BADCFE，D=0x10325476。链接变量用于存放中间散列函数值，经过 4 轮运算（共 64 个步骤）之后，链接变量 A，B，C，D 中的 128 位即为中间散列函数值。中间散列函数值作为下一个明文

分组的输入继续使用，当所有的明文分组都处理完毕后，链接变量 A，B，C，D 中的 128 位数据就是摘要。

(4)MD5 第 1 轮运算

MD5 有 4 轮非常相似的运算，每一轮包括 16 个类似的步骤，当第 1 轮运算中的第 1 步骤开始处理时，A、B、C、D 四个链接变量中的值先赋值到另外 4 个记录单元 A′，B′，C′，D′中。这 4 个值将保留，用于在第 4 轮的最后一个步骤完成之后与 A，B，C，D 进行求和操作。

第 1 轮的操作程序为 FF(a,b,c,d,M[k],S,T[i])

它表示的逻辑为：a←b+((a+F(b,c,d)+M[k]+T[i])<<<S)

其中，a、b、c、d 为 32 位的变量，M[k]表示相应的子明文分组，对于 4 轮共 64 步的 MD5 算法中 T[i]是 64 个不同的固定的数值，S 为循环左移的位数，F（x，y，z）是第一轮的逻辑函数，最后将结果存放在链接变量 A 中，固定值 T[i]，循环左移位数和逻辑函数将在以后讨论。

第 1 轮 16 步的固定值 T[i]的取值如表 5.1 所示。

表 5.1 MD5 第 1 轮固定数 T

T[1]=D76AA478	T[5]=F57C0FAF	T[9]=698098D8	T[13]=6B901122
T[2]=E8C7B756	T[6]=4787C62A	T[10]=8B44F7AF	T[14]=FD987193
T[3]=242070DB	T[7]=A8304613	T[11]=FFFF5BB1	T[15]=A679438E
T[4]=C1BDCEEE	T[8]=FD469501	T[12]=895CD7BE	T[16]=49B40821

MD5 规定，第一轮 16 步的操作程序如表 5.2 所示。

表 5.2 MD5 第 1 轮 16 步运算

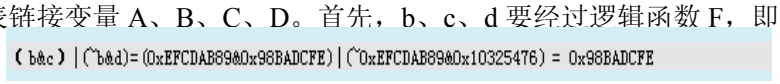
步骤数	运算
1	FF(A,B,C,D,M[0],7,0xD76AA478)
2	FF(D,A,B,C,M[1],12,0xE8C7B756)
3	FF(C,D,A,B,M[2],17,0x242070DB)
4	FF(B,C,D,A,M[3],22,0xC1BDCEEE)
5	FF(A,B,C,D,M[4],7,0xF57C0FAF)
6	FF(D,A,B,C,M[5],12,0x4787C62A)
7	FF(C,D,A,B,M[6],17,0xA8304613)
8	FF(B,C,D,A,M[7],22,0xFD469501)
9	FF(A,B,C,D,M[8],7,0x698098D8)
10	FF(D,A,B,C,M[9],12,0x8B44F7AF)
11	FF(C,D,A,B,M[10],17,0xFFFF5BB1)
12	FF(B,C,D,A,M[11],22,0x895CD7BE)
13	FF(A,B,C,D,M[12],7,0x6B901122)
14	FF(D,A,B,C,M[13],12,0xFD987193)
15	FF(C,D,A,B,M[14],17,0xA6794383)
16	FF(B,C,D,A,M[15],22,0x49B40821)

MD5 算法中，第一轮的逻辑函数为 F(x，y，z)= (x & y)|(~x & z)，MD5 的算法比较复杂，每一轮包括 16 步类似的运算，下面以第 1 轮的第 1 步为例来展示每一步的运算。

例如，子明文分组 M[0] = 0x4368696E，第 1 轮的操作程序为 FF(a,b,c,d,M[k],S,T[i])，它表示的逻辑为：

a←b+((a+F(b,c,d)+M[k]+T[i])<<<S)

第一轮的逻辑函数 F（x，y，z）= (x & y)|(~x & z)，第 1 轮第 1 步的运算为：FF(A,B,C,D,M[0],7,0xD76AA478)，注意到这里的 0xD76AA478 就是 T[1]的值，变量 a、b、c、d 分别代表链接变量 A、B、C、D。首先，b、c、d 要经过逻辑函数 F，即：



运算得到的值要与 A、M[0]和 T[1]相加 0x67452301+0x98BADCFE+0x6E696843+0xD76AA478=0x45D40CBA，0x45D40CBA 要循环左移 7 位，得到结果：0xEA065D22。0xEA065D22 与 b 相加得：0xEA065D22 + 0xEFCDAB89 = 0xD9D408AB，最后，将这个结果赋值给 a，第 1 步的计算就完成了，只有链接变量 A 发生了改变，这时链接标量的值为：

A = 0xD9D408AB

B = 0x89ABCDEF

C = 0xFEDCBA98

D = 0x76543210

经过 16 个步骤之后，MD5 的第一轮运算就完成了，链接变量 A、B、C、D 将携带第 1 轮运算后的数值进入第二轮运算。

(5)MD5 后 3 轮运算

MD5 第 2 轮、第 3 轮和第 4 轮算运与第一轮运算相似，这里给出相应的操作程序、固定数 T、每一步运算和逻辑函数。

第 2 轮的逻辑函数为：G(x, y, z) = (x & z)|(y & ~z)。

第 3 轮的逻辑函数为：H(x, y, z) = x ⊕ y ⊕ z。

第 4 轮的逻辑函数为：I(x, y, z) = y ⊕ (x & ~z)。

第 2 轮的操作程序为：GG(A,B,C,D,M[k],S,T[i])。

它表示的逻辑为：a←b+((a+G(B,C,D)+M[k]+T[i])<<<S)。

第 3 轮的操作程序为：HH(A,B,C,D,M[k],S,T[i])。

它表示的逻辑为：a←b+((a+H(B,C,D)+M[k]+T[i])<<<S)。

第 4 轮的操作程序为：II(A,B,C,D,M[k],S,T[i])。

它表示的逻辑为：a←b+((a+I(B,C,D)+M[k]+T[i])<<<S)。

后 3 轮的每个步骤的运算如表 5.3 所示。

表 5.3　MD5 后 3 轮 16 步运算

第二轮	
1	GG(A,B,C,D,M[1],5,0xF61E2562)
2	GG(D,A,B,C,M[6],9,0xC040B340)
3	GG(C,D,A,B,M[11],14,0x265E5A51)
4	GG(B,C,D,A,M[0],20,0xE9B6C7AA)
5	GG(A,B,C,D,M[5],5,0xD62F105D)
6	GG(D,A,B,C,M[10],9,0x02441453)
7	GG(C,D,A,B,M[15],14,0xD8A1E681)
8	GG(B,C,D,A,M[4],20,0xE7D3FBC8)
9	GG(A,B,C,D,M[9],5,0x21E1CDE6)
10	GG(D,A,B,C,M[14],9,0xC33707D6)
11	GG(C,D,A,B,M[3],14,0xF4D50D87)
12	GG(B,C,D,A,M[8],20,0x455A14ED)
13	GG(A,B,C,D,M[13],5,0xA9E3E905)
14	GG(D,A,B,C,M[2],9,0xFCEFA3F8)
15	GG(C,D,A,B,M[7],14,0x676F02D9)
16	GG(B,C,D,A,M[12],20,0x8D2A4C8A)

第三轮	
1	HH(A,B,C,D,M[5],4,0xFFFA3942)
2	HH(D,A,B,C,M[8],11,0x8771F681)
3	HH(C,D,A,B,M[11],16,0x6D9D6122)
4	HH(B,C,D,A,M[14],23,0xFDE5380C)
5	HH(A,B,C,D,M[1],4,0xA4BEEA44)
6	HH(D,A,B,C,M[4],11,0x4BDECFA9)
7	HH(C,D,A,B,M[7],16,0xF6BB4B60)
8	HH(B,C,D,A,M[10],23,0xBEBFBC70)
9	HH(A,B,C,D,M[13],4,0x289B7EC6)
10	HH(D,A,B,C,M[0],11,0xEAA127FA)
11	HH(C,D,A,B,M[3],16,0xD4EF3085)
12	HH(B,C,D,A,M[6],23,0x04881D05)
13	HH(A,B,C,D,M[9],4,0xD9D4D039)
14	HH(D,A,B,C,M[12],11,0xE6DB99E5)
15	HH(C,D,A,B,M[15],16,0x1FA27CF8)
16	HH(B,C,D,A,M[2],23,0xC4AC5665)

第四轮	
1	II(A,B,C,D,M[0],6,0xF4292244)
2	II(D,A,B,C,M[7],10,0x411AFF97)
3	II(C,D,A,B,M[14],15,0xAB9423A7)
4	II(B,C,D,A,M[5],21,0xFC93A039)
5	II(A,B,C,D,M[12],6,0x655B59C3)
6	II(D,A,B,C,M[3],10,0x8F0CCC92)
7	II(C,D,A,B,M[10],15,0xFFEFF47D)
8	II(B,C,D,A,M[1],21,0x85845DD1)
9	II(A,B,C,D,M[8],6,0x6FA87E4F)
10	II(D,A,B,C,M[15],10,0xFE2CE6E0)
11	II(C,D,A,B,M[6],15,0xA3014314)
12	II(B,C,D,A,M[13],21,0x4E0811A1)
13	II(A,B,C,D,M[4],6,0xF7537E82)
14	II(D,A,B,C,M[11],10,0xBD3AF235)
15	II(C,D,A,B,M[2],15,0x2AD7D2BB)
16	II(B,C,D,A,M[9],21,0xEB86D391)

后 3 轮的固定数 T[i]的值如表 5.4 所示。

表 5.4　后 3 轮的固定数 T[i]

T[17]=F61E2562	T[33]=FFFA3942	T[49]=F4292244
T[18]=C040B340	T[34]=8771F681	T[50]=432AFF97
T[19]=265E5A51	T[35]=699D6122	T[51]=AB9423A7
T[20]=E9B6C7AA	T[36]=FDE5380C	T[52]=FC93A039
T[21]=D62F105D	T[37]=A4BEEA44	T[53]=655B59C3
T[22]=02441453	T[38]=4BDECFA9	T[54]=8F0CCC92
T[23]=D8A1E681	T[39]=F6BB4B60	T[55]=FFEFF47D
T[24]=E7D3FBC8	T[40]=BEBFBC70	T[56]=85845DD1
T[25]=21E1CDE6	T[41]=289B7EC6	T[57]=6FA87E4F
T[26]=C33707D6	T[42]=EAA127FA	T[58]=FE2CE6E0
T[27]=F4D50D87	T[43]=D4EF3085	T[59]=A3014314
T[28]=455A14ED	T[44]=04881D05	T[60]=4E0811A1
T[29]=A9E3E905	T[45]=D9D4D039	T[61]=F7537E82
T[30]=FCEFA3F8	T[46]=E6DB99E5	T[62]=BD3AF235
T[31]=676F02D9	T[47]=1FA27CF8	T[63]=2AD7D2BB
T[32]=8D2A4C8A	T[48]=C4AC5665	T[64]=EB86D391

(6)求和运算

第四轮最后一步骤的 A，B，C，D 输出，将分别与 A′，B′，C′，D′记录单元中数值进行求和操作。其结果将成为处理下一个 512 位明文分组时记录单元 A，B，C，D 的初始值。当完成了最后一个明文分组运算时，A，B，C，D 中的数值就是最后的散列函数值。

五、实验步骤

1.按照实验指导篇进入教学实验平台，如图 5.2 所示。



图 5.2 进入实验平台

2.选择“网络信息安全教学实验系统”——>“知识类实验”——>“密码学及应用”——>实验 8　Hash 算法——>“练习一 MD5 算法”，如图 5.3 所示。

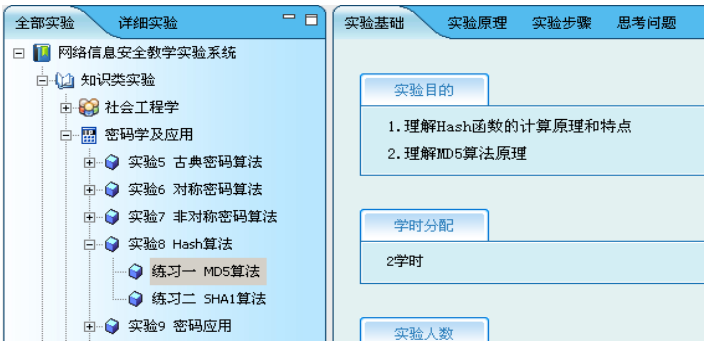


图 5.3 选择算法

3.认真仔细的阅读“实验基础”和“实验原理”，特别是实验原理是我们重点应该掌握的内容。

4.开始实验

(1)点击“实验步骤”——>“密码工具”——>“MD5 哈希函数”——>“生成摘要”，如图 5.4 所示。



图 5.4 生成摘要初试界面

(2)在明文框中编辑文本内容，如 xinxianquan, 单击“生成摘要”按钮，生成文本摘要,如图 5.5 所示。

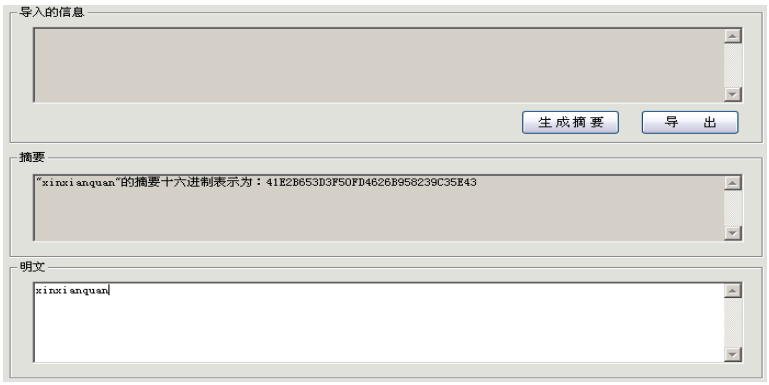


图 5.5 生成摘要

(3)单击“导出”按钮，将摘要导出到 MD5 共享文件夹（D:\Work\Encryption\MD5\）中，如图 5.6 所示。

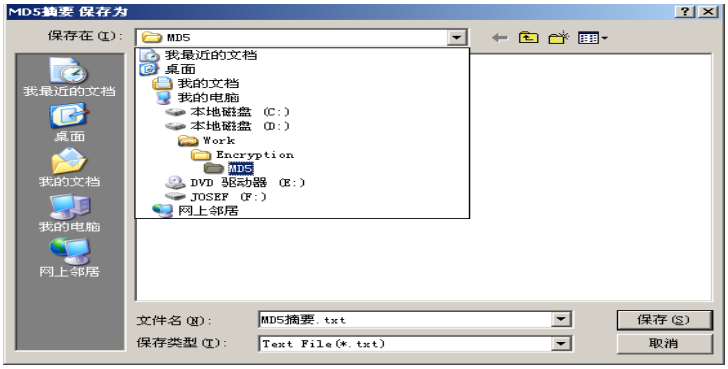


图 5.6 保存摘要

(4)单击“重置”——>“导入”，清空内容，导入摘要，如图 5.7 所示。

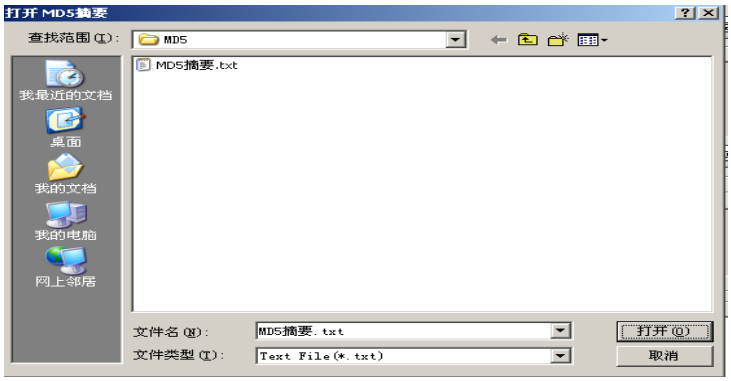


图 5.7 导入摘要

(5)在明文区输入之前的文本：xinxianquan，单击“生成摘要，”如图 5.8 所示，将新生成的摘要与导入的摘要进行比较，验证相同文本会产生相同的摘要。



图 5.8 摘要验证

(6)对文本内容做很小的改动，如改为：xinxian,再次生成摘要，与导入的摘要进行对比，验证 MD5 算法的抗修改性,如图 5.9 所示。

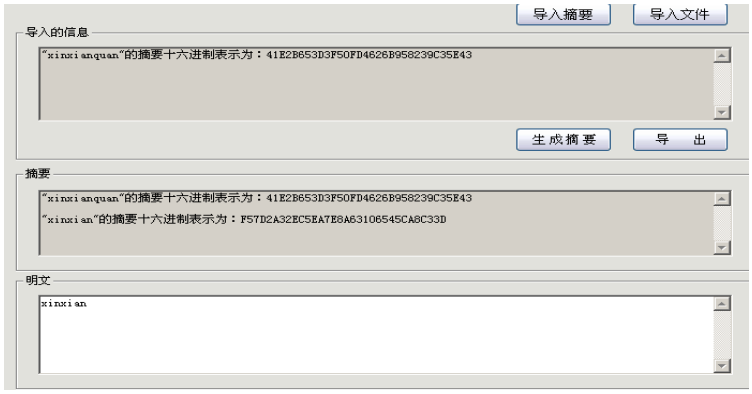


图 5.9 验证算法的抗修改性

为更好的理解 MD5 算法的原理和实现过程，实验平台给出了算法执行过程的每一步细节，接下来将详细给出。

(1)单击“演示”，如图 5.10 所示。

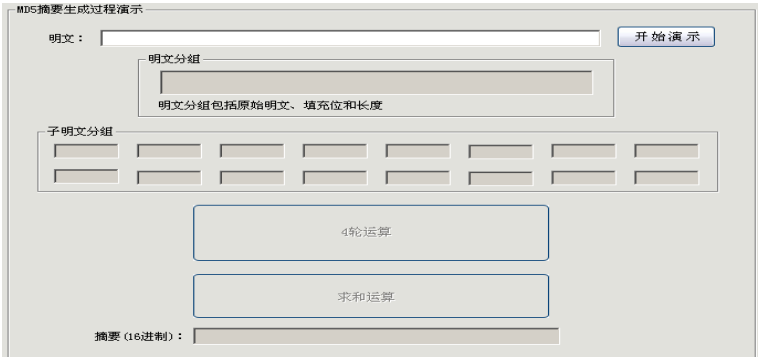


图 5.10 算法演示初始界面

(2)在明文输入区输入文本（文本不能超过 48 个字符）,单击“开始演示”，查看各模块数据及算法流程，如图 5.11 所示。

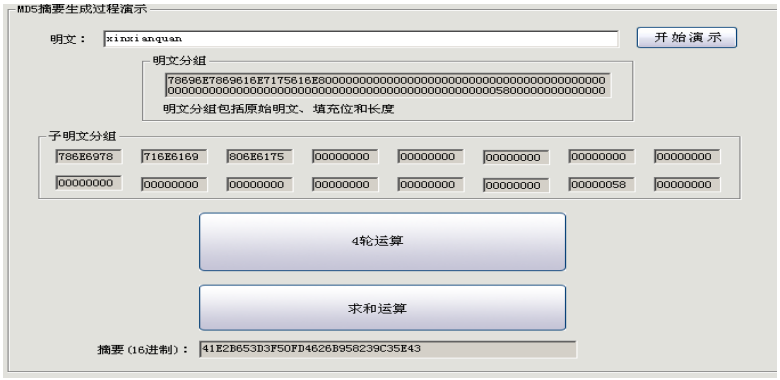


图 5.11 演示执行示意图

1)单击“4 轮运算”， 如图 5-12 所示。

初始链接变量为：A：67452301

B：EFCDAB89

C：98BADCFE

D：10325476



图 5.12　4 轮运算

2)单击“下一轮”及“下一步”，观察变量的变化及逻辑函数的变化，如图 5.13 所示。

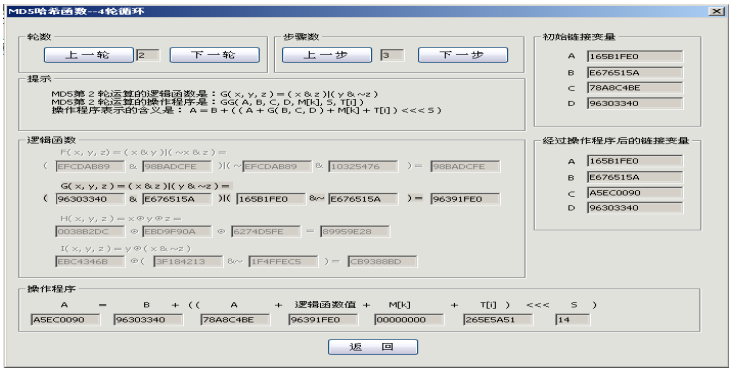


图 5.13　详细步骤

3)单击“求和运算”，如图 5.14 所示，查看最后的结果。



图 5.14　最后结果

除了上述的实验外，本手册还提供了 MD5 算法的 C++实现，可以在 VC++6.0 环境下调试运行。

六、问题思考

1．MD5 生成摘要的长度是多少位。

实验六 SHA1 算法

一、实验目的

1.理解 SHA1 函数的特点
2.理解 SHA1 算法的原理

二、实验环境

Windows，交换网络结构

三、实验工具

VC++6.0，密码学工具

四、实验原理

1.SHA1 与 MD5 差异

SHA1 对任意长度明文的预处理和 MD5 的过程是一样的，即预处理完后的明文长度是 512 位的整数倍，但是有一点不同，那就是 SHA1 的原始报文长度不能超过 2 的 64 次方，然后 SHA1 生成 160 位的报文摘要。SHA1 算法简单而且紧凑，容易在计算机上实现。

表 6.1 比较了 MD5 及 SHA1 的差异之处。

表 6.1 MD5 与 SHA1 的比较

差异处	MD5	SHA1
摘要长度	128位	160位
运算步骤数	64	80
基本逻辑函数数目	4	4
常数数目	64	4

●安全性：SHA1 所产生的摘要比 MD5 长 32 位。若两种散列函数在结构上没有任何问题的话，SHA1 比 MD5 更安全。

●速度：两种方法都是主要考虑以 32 位处理器为基础的系统结构。但 SHA1 的运算步骤比 MD5 多了 16 步，而且 SHA1 记录单元的长度比 MD5 多了 32 位。因此若是以硬件来实现 SHA1，其速度大约比 MD5 慢了 25%。

●简易性：两种方法都是相当的简单，在实现上不需要很复杂的程序或是大量存储空间。然而总体上来讲，SHA1 对每一步骤的操作描述比 MD5 简单。

2.SHA1 算法流程

对于任意长度的明文，SHA1 首先对其进行分组，使得每一组的长度为 512 位，然后对这些明文分组反复重复处理。

对于每个明文分组的摘要生成过程如下：

(1)将 512 位的明文分组划分为 16 个子明文分组，每个子明文分组为 32 位。

(2)申请 5 个 32 位的链接变量，记为 A、B、C、D、E。

(3)16 份子明文分组扩展为 80 份。

(4)80 份子明文分组进行 4 轮运算。

(5)链接变量与初始链接变量进行求和运算。

(6)链接变量作为下一个明文分组的输入重复进行以上操作。

(7)最后，5 个链接变量里面的数据就是 SHA1 摘要。

3.SHA1 的分组过程

对于任意长度的明文，SHA1 的明文分组过程与 MD5 相类似，首先需要对明文添加位数，使明文总长度为 448(mod512)位。在明文后添加位的方法是第一个添加位是 1，其余都是 0。然后将真正明文的长度(没有添加位以前的明文长度)以 64 位表示，附加于前面已添加过位的明文后，此时的明文长度正好是 512 位的倍数。与 MD5 不同的是 SHA1 的原始报文长度不能超过 2 的 64 次方，另外 SHA1 的明文长度从低位开始填充。

经过添加位数处理的明文，其长度正好为 512 位的整数倍，然后按 512 位的长度进行分组(block)，可以划分成 L 份明文分组，我们用 Y0，Y1，……YL-1 表示这些明文分组。对于每一个明文分组，都要重复反复的处理，这些与 MD5 是相同的。

对于 512 位的明文分组，SHA1 将其再分成 16 份子明文分组(sub-block)，每份子明文分组为 32 位，我们使用 M[k](k= 0, 1,……15)来表示这 16 份子明文分组。之后还要将这 16 份子明文分组扩充到 80 份子明文分组，我们记为 W[k](k= 0, 1,……79)，扩充的方法如下。

$$W_t = M_t$$

当 $0 \leqslant t \leqslant 15, W_t = (W_{t-3} \oplus W_{t-8} \oplus W_{t-14} \oplus W_{t-16}) <<< 1$, 当 $16 \leqslant t \leqslant 79$。

SHA1 有 4 轮运算，每一轮包括 20 个步骤（一共 80 步），最后产生 160 位摘要，这 160 位摘要存放在 5 个 32 位的链接变量中，分别标记为 A、B、C、D、E。这 5 个链接变量的初始值以 16 进制位表示如下。

A=0x67452301

B=0xEFCDAB89

C=0x98BADCFE

D=0x10325476

E=0xC3D2E1F0

4.SHA1 的 4 轮运算

SHA1 有 4 轮运算，每一轮包括 20 个步骤，一共 80 步，当第 1 轮运算中的第 1 步骤开始处理时，A、B、C、D、E 五个链接变量中的值先赋值到另外 5 个记录单元 A′，B′，C′，D′，E′中。这 5 个值将保留，用于在第 4 轮的最后一个步骤完成之后与链接变量 A，B，C，D，E 进行求和操作。

SHA1 的 4 轮运算，共 80 个步骤使用同一个操作程序，如下：

A,B,C,D,E←[(A<<<5)+ft(B,D,C)+E+Wt+Kt],A,(B<<<30),C,D

其中 ft(B,D,C)为逻辑函数，Wt 为子明文分组 W[t]，Kt 为固定常数。这个操作程序的意义为：

●将[(A<<<5)+ft(B,D,C)+E+Wt+Kt]的结果赋值给链接变量 A；

●将链接变量 A 初始值赋值给链接变量 B；

●将链接变量 B 初始值循环左移 30 位赋值给链接变量 C；

●将链接变量 C 初始值赋值给链接变量 D；

●将链接变量 D 初始值赋值给链接变量 E。

SHA1 规定 4 轮运算的逻辑函数如表 6.2 所示。

表 6.2　SHA1 的逻辑函数

轮	步骤	函数定义	轮	步骤	函数定义
1	0≤t≤19	$f_t(B,C,D)=(B\cdot C)\vee(\neg B\cdot D)$	3	40≤t≤59	$f_t(B,C,D)=(B\cdot C)\vee(B\cdot D)\vee(C\cdot D)$
2	20≤t≤39	$f_t(B,C,D)=B\oplus C\oplus D$	4	60≤t≤79	$f_t(B,C,D)=B\oplus C\oplus D$

在操作程序中需要使用固定常数 K_i（i= 0，1，2，……79），K_i 的取值如表 6.3 所示。

表 6.3　SHA1 的常数 K 取值表

轮	步骤	函数定义	轮	步骤	函数定义
1	0≤t≤19	K_t=5A827999	3	40≤t≤59	K_t=8F188CDC
2	20≤t≤39	K_t=6ED9EBA1	4	60≤t≤79	K_t=CA62C1D6

同样举一个例子来说明 SHA1 哈希算法中的每一步是怎样进行的，比起 MD5 算法，SHA1 相对简单，假设 W[1]=0x12345678，此时链接变量的值分别为 A=0x67452301、B=0xEFCDAB89、C=0x98BADCFE、D=0x10325476、E=0xC3D2E1F0，那么第 1 轮第 1 步的运算过程如下。

(1)将链接变量 A 循环左移 5 位，得到的结果为：0xE8A4602C。

(2)将 B，C，D 经过相应的逻辑函数：

```
(B&C)|(~B&D)=(0xEFCDAB89&0x98BADCFE)|(~0xEFCDAB89&0x10325476)=0x98BADCFE
```

(3)将第(1)步，第(2)步的结果与 E，W[1]，和 K[1]相加得：

```
0xE8A4602C+0x98BADCFE+0xC3D2E1F0+0x12345678+0x5A827999=0xB1E8EF2B
```

(4)将 B 循环左移 30 位得：(B<<<30)=0x7BF36AE2。

(5)将第 3 步结果赋值给 A，A（这里是指 A 的原始值）赋值给 B，步骤 4 的结果赋值给 C，C 的原始值赋值给 D，D 的原始值赋值给 E。

(6)最后得到第 1 轮第 1 步的结果：

A = 0xB1E8EF2B

B = 0x67452301

C = 0x7BF36AE2

D = 0x98BADCFE

E = 0x10325476

按照这种方法，将 80 个步骤进行完毕。

第四轮最后一个步骤的 A，B，C，D，E 输出，将分别与记录单元 A′，B′，C′，D′，E′中的数值求和运算。其结果将作为输入成为下一个 512 位明文分组的链接变量 A，B，C，D，E，当最后一个明文分组计算完成以后，A，B，C，D，E 中的数据就是最后散列函数值。

五、实验步骤

1.按照实验指导篇进入教学实验平台，如图 6.1 所示：



图 6-1 进入实验平台

2.选择“网络信息安全教学实验系统”——>“知识类实验”——>“密码学及应用”——>实验 8　Hash 算法——>“练习二　SHA1 算法”，如图 6.2 所示。

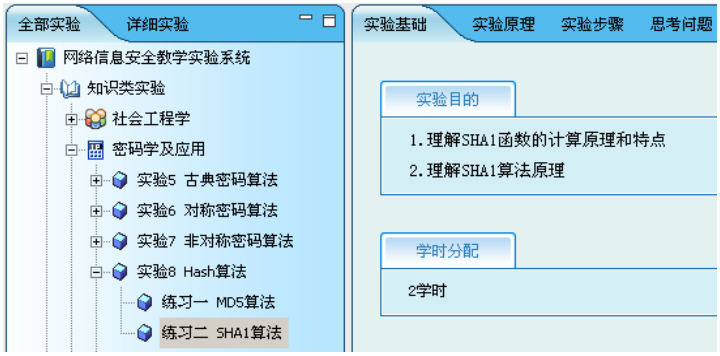


图 6.2 选择算法

3.认真仔细的阅读“实验基础”和“实验原理”，特别是实验原理是我们重点应该掌握的内容。

4.开始实验

(1)点击“实验步骤”——>“密码工具”——>“SHA1 哈希函数”——>“生成摘要”，如图 6.3 所示。

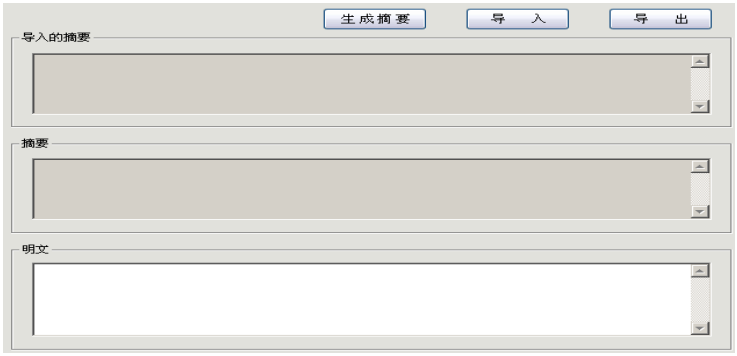


图 6.3 生成摘要初试界面

(2)在明文框中编辑文本内容：xinxianquan，单击“生成摘要”按钮，如图 6.4 所示。



图 6.4 生成摘要

(3)单击“导出”按钮，将摘要导出到 SHA1 共享文件夹（D:\Work\Encryption\SHA1\）中，如图 6.5 所示。

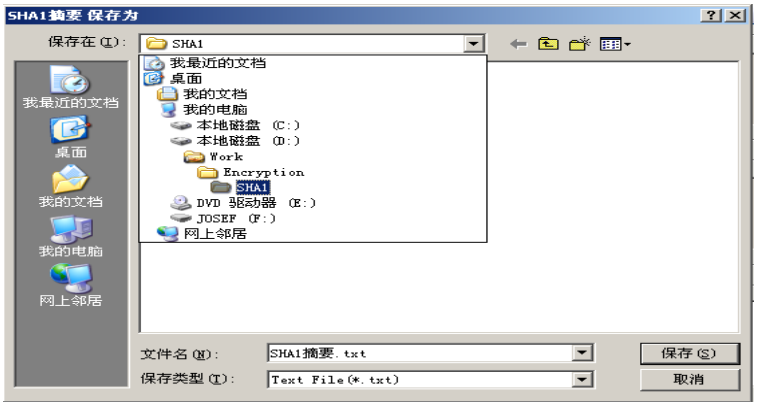


图 6.5 保存摘要

(4)单击“导入”按钮，从 SHA1 共享文件夹中将摘要导入，如图 6.6 所示。



图 6.6 导入摘要

(5)在文本框中输入明文区编辑过的文本内容，单击“生成摘要”按钮，将新生成的摘要与导入的摘要进行比较，验证相同文本会产生相同的摘要，如图 6.7 所示。

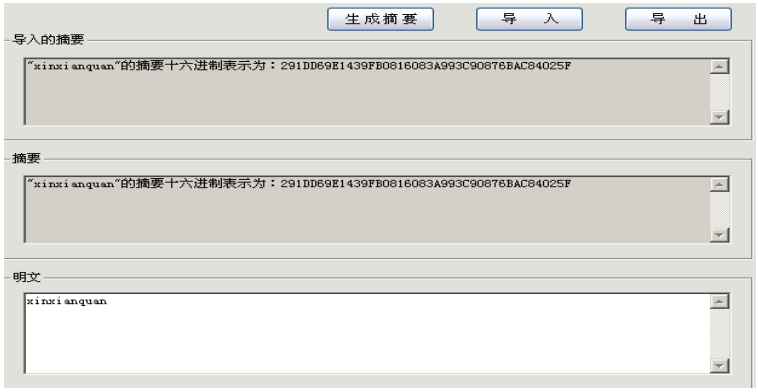


图 6.7 验证摘要

(6)对文本内容做很小的改动，如改为 xinxian,再次生成摘要，与导入的摘要进行对比，验证 SHA1 算法的抗修改性,如图 6.8 所示。



图 6.8 验证算法的抗修改性

为更加深入的理解 SHA1 算法，实验平台中给出了 SHA1 算法的执行过程演示，接下来将对其进行阐述。

(1)单击“演示”，如图 6.9 所示。



图 6.9 算法演示初始界面

(2)在明文输入区输入文本(文本不能超过 48 个字符)，如 xinxianquan，单击“开始演示”，查看各模块数据及算法流程，如图 6.10 所示。



图 6.10 摘要生成

(3)单击”80 个自明文组的扩充”，如图 6.11 所示，观察扩充之后的明文分组。

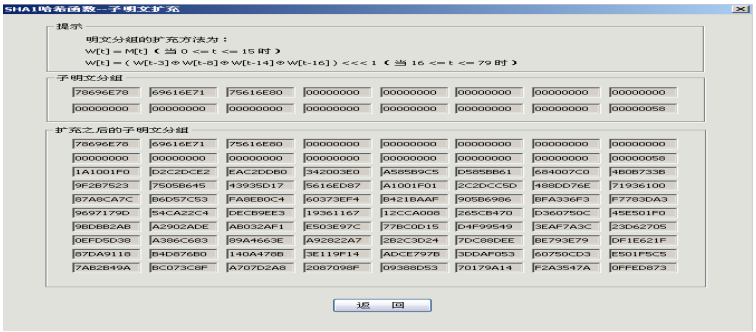


图 6.11 扩充之后的明文分组

(4)单击“80 步运算”，如图 6-12 所示。

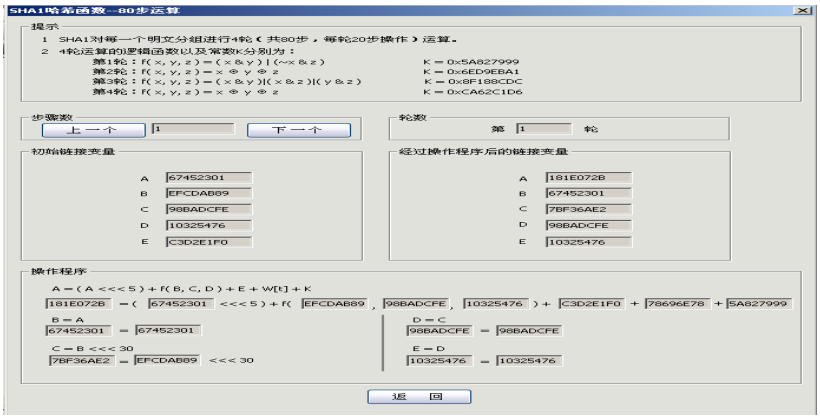
初始链接变量为：A：67452301

B：EFCDAB89

C：98BADCFE

D：10325476

E：C3D2E1F0



如图 6.12　80 步运算

(5)单击“下一轮”及“下一步”，观察变量的变化操作程序数的变化，如图 6.13 所示。

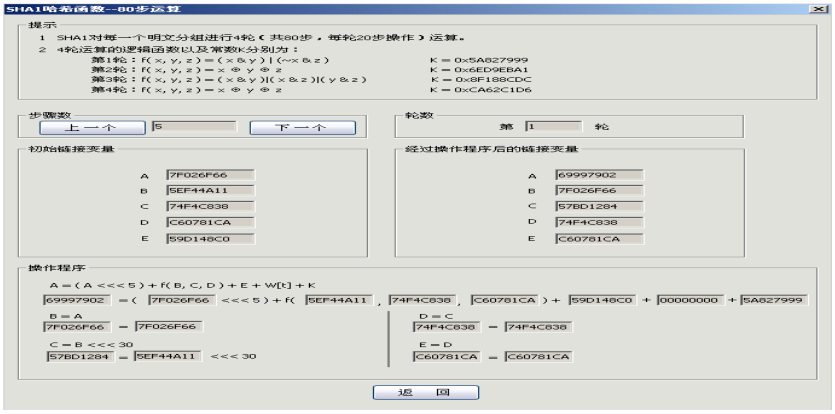


图 6.13 详细步骤

(6)“求和运算”，如图 6.14 所示，观察最后链接变量和变量结果。



图 6.14 求和运算

六、问题思考

1．Hash 函数密码技术有哪些应用？

2．试着自己构造一个 Hash 函数算法。

实验七 文件传输应用

一、实验目的

1.掌握安全通信中常用的加密算法
2.掌握数字签名过程
3.掌握安全文件传输基本步骤

二、实验环境

Windows，交换网络结构

三、实验工具

VC++6.0，密码工具

四、实验原理

1.数字签名

传统的签名在商业和生活中广泛使用，它主要作为身份的证明手段。在现代的网络活动中，人们希望把签名制度引入到网络商业和网络通信的领域，用以实现身份的证明。密码学的发展，为数字签名这项技术的实现提供了基础，PKI(公钥基础设施)体系也正是利用数字签名技术来保证信息传输过程中的数据完整性以及提供对信息发送者身份的认证和不可抵赖性。图 7.1 所示为数字签名过程。

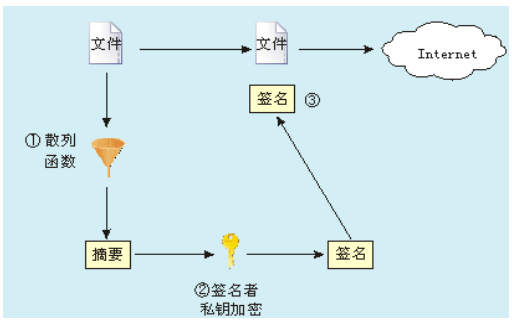


图 7.1　数字签名过程

数字签名的验证过程如图 7.2 所示。

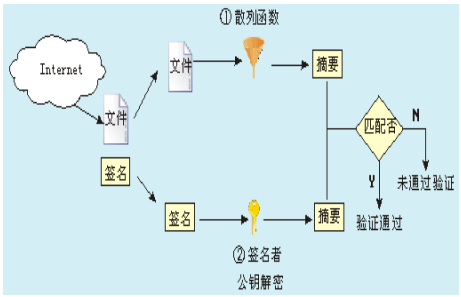


图 7.2 数字签名验证过程

2.安全通信要求

我们假设一下要进行网络通信的两个终端（A 和 B）所处的环境：

●终端 A 和终端 B 相距很远，彼此间很难见面（但可以通过 Internet 通信）。

●终端 A 有很重要的信息必须要发送给终端 B。

●这个过程中，终端 A 不能使用除计算机网络之外其他的通信方式，比如电话，传真等。

安全通信的要求：

●保密要求：终端 A 的信息（明文）要加密通信给终端 B。

●认证要求：终端 B 能认证发送人的身份是终端 A，而不是其他人。

●数据完整性要求：终端 B 能认证收到的密文没有被篡改。

●不可否认要求：终端 A 事后不能否认曾经把信息传递给终端 B。

以上这些要求也是真实世界中安全通信的基本要求，只能较好的提供安全性，但是不能达到绝对的安全通信（有关更高级的安全通信方法请参考公钥基础设施 PKI 的相关知识）。

五、实验步骤

1.选则对称加密算法为 DES，非对称加密算法为 RSA，哈希函数为 MD5 算法。

2.假定自己充当 A 和 B 两个角色，假设 A 拥有 B 的公钥和自己的私钥，B 拥有 A 的公钥和自己的私钥匙。

3.A 和 B 生成自己的公钥匙：

(1)按照操作指导进入平台，如图 7.3 所示。



图 7.3 进入实验平台

(2)选择“网络信息安全教学实验系统”——>“知识类实验”——>“密码学及应用”——>实验 7 非对称密码算法——>“练习一 RSA 算法”——>“密码工具”——>“RSA 算法”——>“公钥”，如图 7.4 所示。

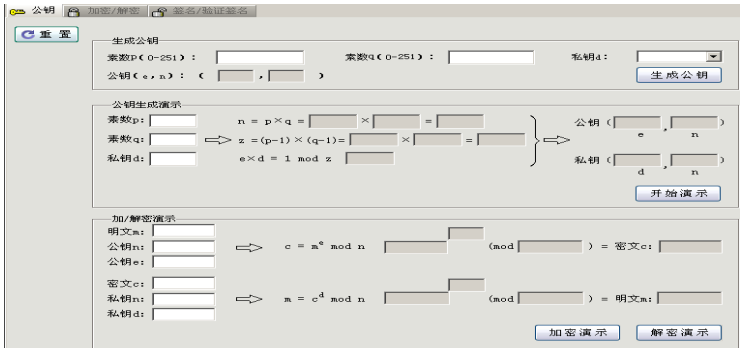


图 7.4 生成公钥初始界面

(3)选择 P 和 Q，生成 A 的公钥，如图 7.5 所示。

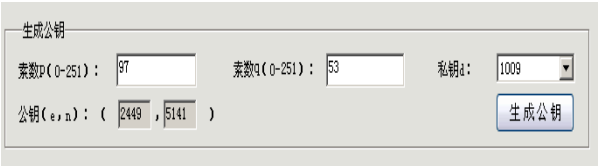


图 7.5A 生成公钥

(4)A 记住自己的私钥和公钥对。

(5)B 用同样的方法生成自己公钥和私钥，如图 7.6 所示。

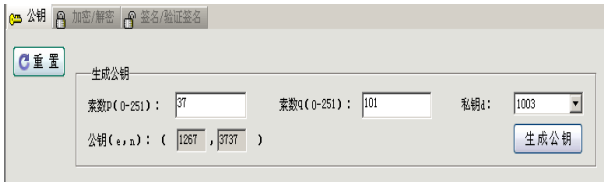


图 7.6 B 生成公钥

4.A 生成自己要和 B 交流的明文，假设明文内容为：1111，并放在桌面的 xinxi.txt 文本里面，如图 7.7、7.8 所示。



图 7.7 创建文本

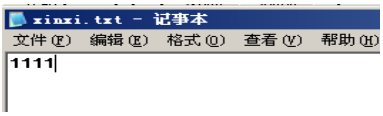


图 7.8 文本内容

5.A 约定自己对称加密算法的密钥为：123

6.A 首先用对称加密算法 DES 对明文加密，并得到密文，如图 7.9 所示。

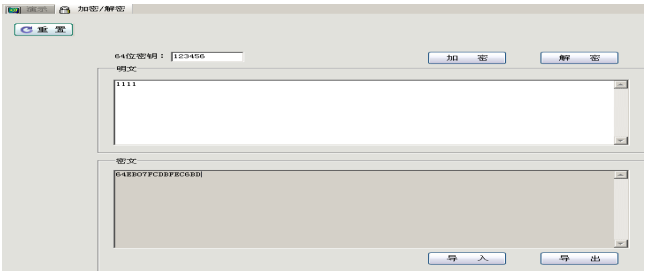


图 7.9 生成密文

7.导出密文，并保存在桌面的密文.txt 文件中，如图 7.10 所示。

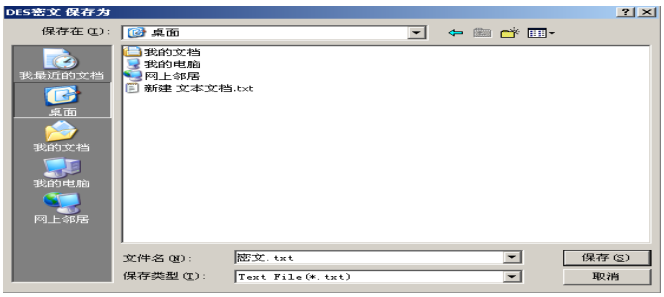


图 7.10 保存密文

8.选择非对称加密算法 RSA，用 B 的公钥对对称加密算法的密钥加密，如图 7.11 所示。

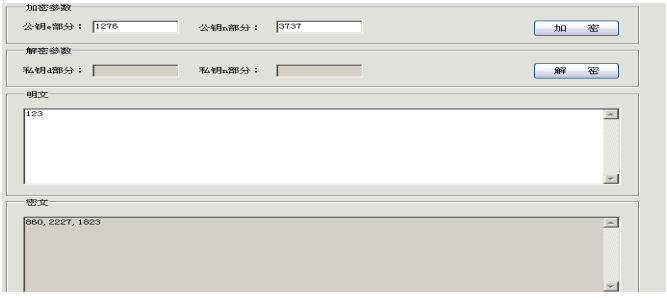


图 7.11 公钥加密

9.将加密后的密钥密文保存在桌面的密钥.txt 文件中，如图 7.12 所示。

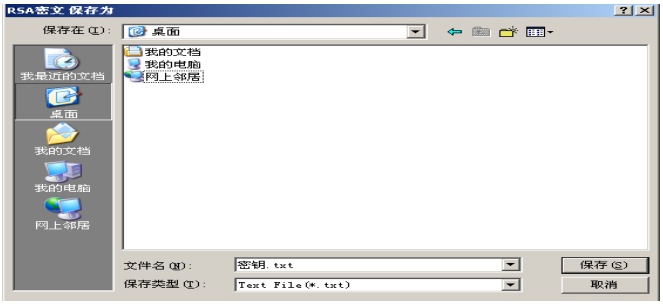


图 7.12 保存密文

10.A 选择 MD5 算法计算明文的摘要并保存摘要信息，如图 7.13，7.14 所示。

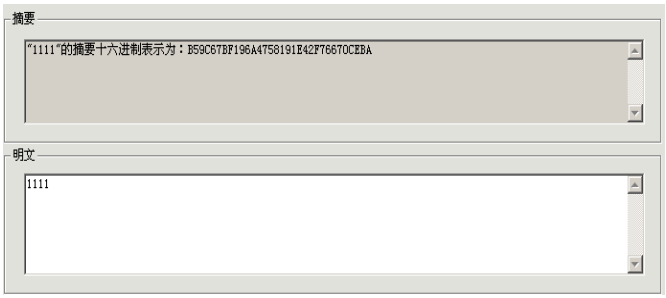


图 7.13 摘要信息

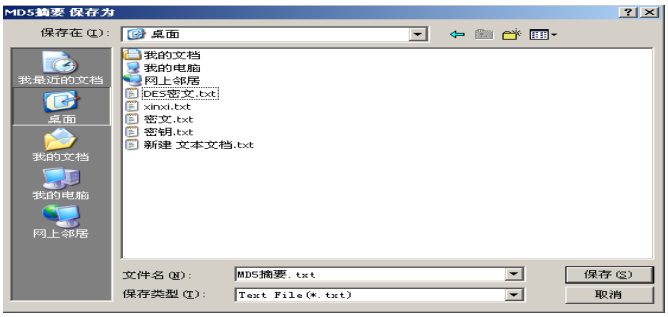


图 7.14 保存摘要

11. A 用自己的私钥对摘要进行加密，形成数字签名，如图 7.15 所示。

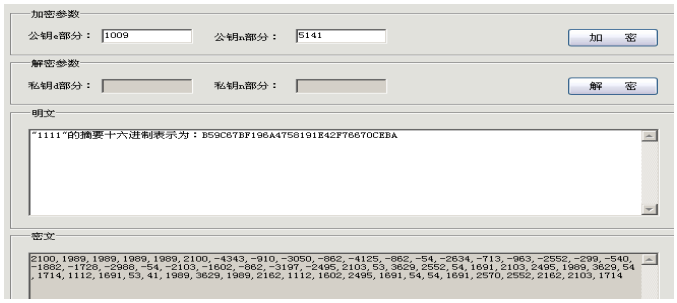


图 7.15 形成数字签名

12.导出签名，如图 7.16 所示。

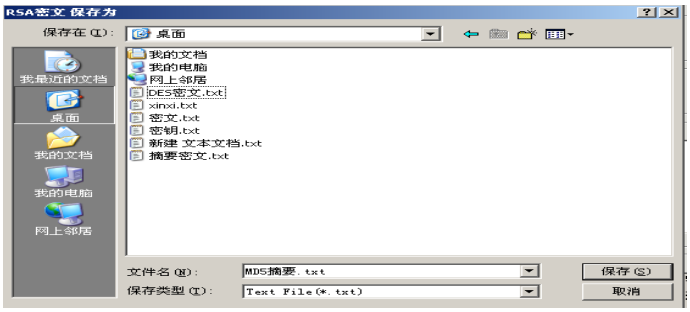


图 7.16 导出摘要

13.A 把信息的密文，加密后的密钥和加密后的摘要打包发送给 B，假设 B 已经收到了。

14.B 收到包后，解压，首先用自己的私钥解密加密后的密钥，得到密钥，首先导入密文，如图 7.17 所示。

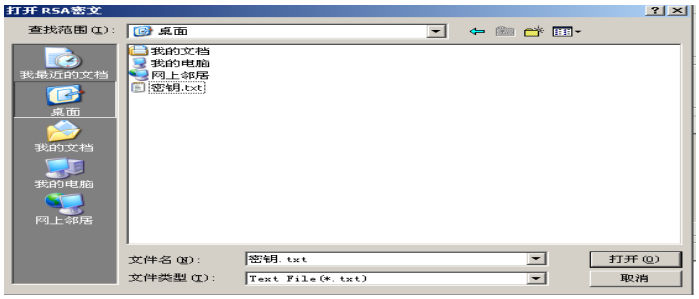


图 7.17 导入密文

15.点击“解密”，得到密钥，如图 7.18 所示。

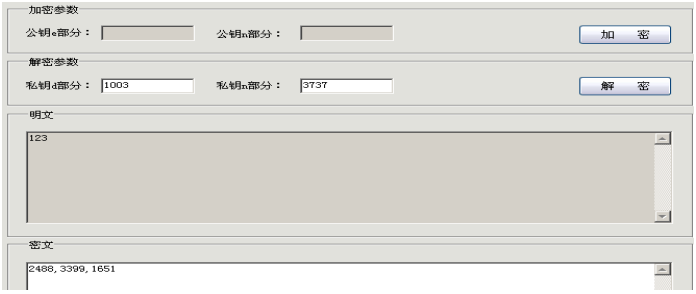


图 7.18 解密密钥

16.B 得到密钥后，就对原文解密。首先导入密文，如图 7.19 所示，输入得到的密钥，点击“解密”，得到明文，如图 7.20 所示。

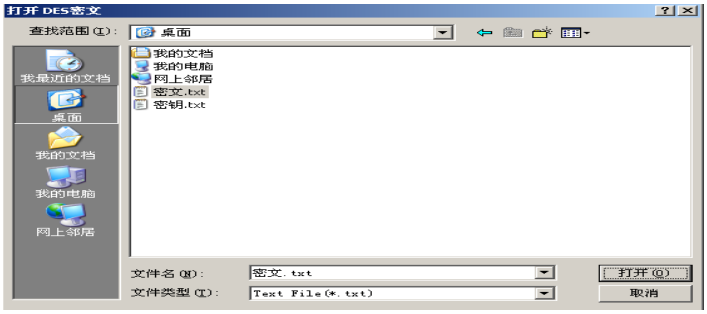


图 7.19 导入密文

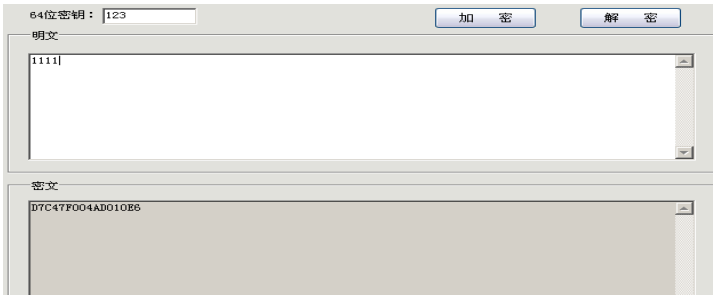


图 7.20 解密明文

17. B 验证原文是否被修改。

(1)B 用 A 的公钥匙对数字签名进行解密，写入密文，如图 7.21 所示。

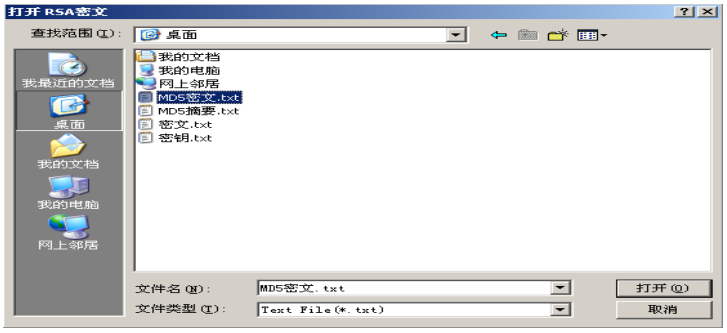


图 7.21 导入 MD5 密文

(2)在解密区写入 A 的公钥，点击“解密”，如图 7.22 所示。

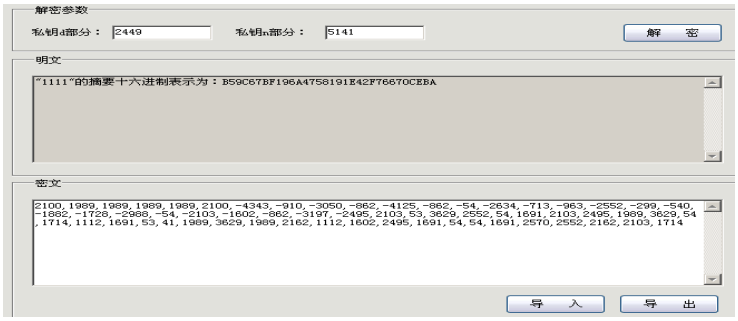


图 7.22 解密密文

(3)B 选用 MD5 算法将明文变成摘要，如图 7.23 所示。

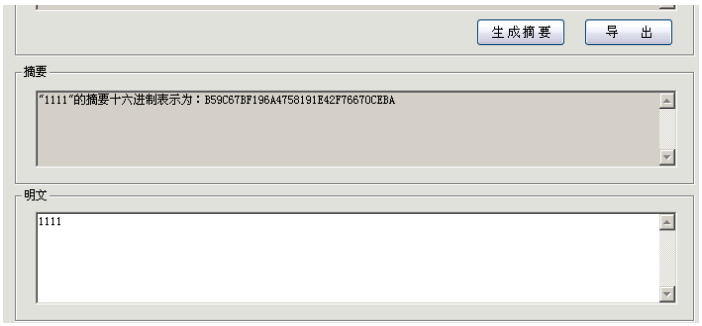


图 7.23 明文摘要

(4)比较两个摘要是否相等，如果相等则说明信息没被修改，如果不等则证明信息被修改了。

六、问题思考

1.你所设计的实验步骤，哪些步骤实现了信息传输的保密性、完整性和不可否认性。

2.在实验设计中为什么不直接应用非对称加密算法直接对明文进行加密传输，而是使用对称加密算法完成对明文的加密工作。

实验八 PGP 应用

一、实验目的

1.学会利用 PGP 工具实现安全通信
2.理解安全通信实现过程

二、实验环境

Windows，交换网络结构

三、实验工具

VC++6.0，密码工具

四、实验原理

1.PGP 概述

在现代社会里，电子邮件和网络上的文件传输已经成为生活的一部分。邮件的安全问题也就突出了，大家都知道在互联网上传输的数据是不加密的。如果用户不保护自己的信息，第三者就会轻易获得用户的隐私。还有一个问题就是信息认证，如何让收信人确信邮件没有被第三者篡改，就需要使用数字签名技术。

RSA 公钥体系的特点使它非常适合用来满足上述两个要求：保密性(privacy)和认证性(authentication)。PGP(Pretty Good Privacy)，是一个基于 RSA 公钥加密体系的邮件加密软件，它提供了非对称加密和数字签名。其创始人是美国的 Phil Zimmermann，他把 RSA 公钥体系的方便和传统加密体系的高速结合起来，并且在数字签名和密钥认证管理机制上有巧妙的设计，因此 PGP 成为目前非常流行的公钥加密软件包。

PGP 有以下主要功能：

●使用 PGP 对邮件加密，以防止非法阅读；

●能给加密的邮件追加上数字签名，从而使收信人进一步确信邮件的发送者，而事先不需要任何保密的渠道用来传递密钥；

●可以实现只签名而不加密，适用于发表公开声明时证实声明人身份，也可防止声明人抵赖，这一点在商业领域有很大的应用前景；

●能够加密文件，包括图形文件、声音文件以及其它各类文件；

●利用 PGP 代替 Unicode 生成 RADIX64（就是 MIME 的 BASE 64 格式）的编码文件。

2.PGP 加密机制

假设甲要寄信给乙，他们互相知道对方的公钥。甲就用乙的公钥加密邮件寄出，乙收到后就可以用自己的私钥解密出甲的原文。由于别人不知道乙的私钥，所以即使是甲本人也无法解密那封信，这就解决了信件保密的问题。另一方面，由于每个人都知道乙的公钥，他们都可以给乙发信，那么乙怎么确定来信是不是甲的，这就是数字签名的必要性，用数字签名来确认发信的身份。

PGP 的数字签名是利用一个叫“邮件文摘”的功能，“邮件文摘”（message digest），简单地讲就是对一封邮件用某种算法算出一个最能体现这封邮件特征的数来(一旦邮件有任何改变这个数都会发生变化)，这个数加上用户的名字（实际上在用户的密钥里）和日期等等，就可以作为一个签名了，确切地说 PGP 是用一个 128 位的二进制数做为“邮件文摘”的，用来产生它的算法就是 MD5。

PGP 给邮件加密和签名的过程是这样的：首先甲用自己的私钥将上述的 128 位值加密，附加在邮件后，再用乙的公钥将整个邮件加密（要注意这里的次序，如果先加密再签名的话，别人可以将签名去掉后签上自己的签名，从而篡改了签名）。这样这份密文被乙收到以后，乙用自己的私钥将邮件解密，得到甲的原文和签名，乙的 PGP 也从原文计算出一个 128 位的特征值来和用甲的公钥解密签名所得到的数进行比较，如果符合就说明这份邮件确实是甲寄来的。这样两个安全性要求都得到了满足。

PGP 还可以只签名而不加密，这适用于公开发表声明时，声明人为了证实自己的身份，可以用自己的私钥签名，这样就可以让收件人能确认发信人的身份，也可以防止发信人抵赖自己的声明。这一点在商业领域有很大的应用前途，它可以防止发信人抵赖和信件被途中篡改。

为什么说 PGP 用的是 RSA 和传统加密的杂合算法呢？因为 RSA 算法计算量很大而且在速度上也不适合加密大量数据，所以 PGP 实际上用来加密的不是 RSA 本身，而是采用了一种叫 IDEA 的传统加密算法。

IDEA 是一个有专利的算法，它的加（解）密速度比 RSA 快得多，所以实际上 PGP 是以一个随机生成的密钥（每次加密不一样），用 IDEA 算法对明文加密，然后用 RSA 算法对该密钥加密。这样收件人同样是用 RSA 解出这个随机密钥，再用 IDEA 解密邮件本身。这样的链式加密就做到了既有 RSA 体系的保密性，又有 IDEA 算法的快捷性。

PGP 加密前会对文件进行预压缩处理，PGP 内核使用 PKZIP 算法来压缩加密前的明文。一方面对文件而言，压缩后加密产生的密文可能比明文更短，这就节省了网络传输的时间。另一方面，明文经过压缩，实际上相当于经过一次变换，信息更加杂乱无章，对明文攻击的

抵御能力更强。PGP 中使用的 PKZIP 算法是经过原作者同意的。PKZIP 算法是一个公认的压缩率和压缩速度都相当好的压缩算法。在 PGP 中使用的是 PKZIP2.0 版本兼容的算法。

五、实验步骤

1.按照实验指导篇进入教学实验平台，如图 8.1 所示。



图 8.1　进入实验平台

2.选择“网络信息安全教学实验系统”——>“知识类实验”——>“密码学及应用”——>实验 9 密码应用——>“练习二 PGP 应用”，如图 8.2 所示。

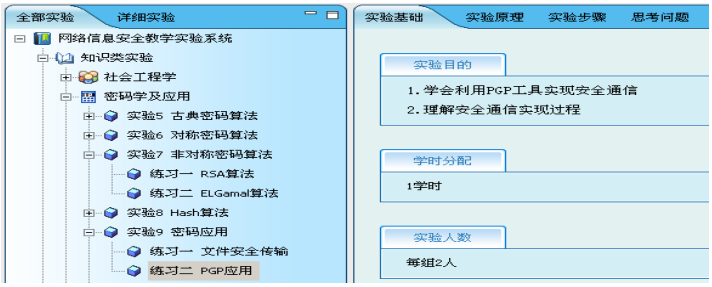


图 8.2 选择实验

3.认真仔细的阅读“实验基础”和“实验原理”，特别是实验原理是我们重点应该掌握的内容。

4.单击“GnuPG”，进入工作目录，如图 8.3 所示。

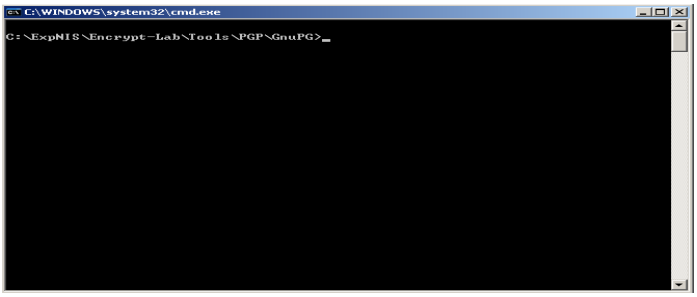


图 8.3 进入工作目录

5.键入命令：gpg --gen-key，开始生成公私钥对。如图 8.4 所示。

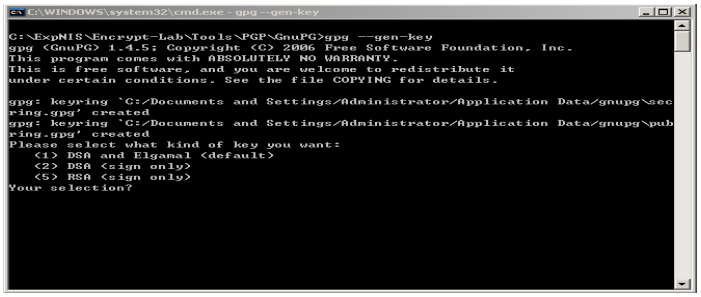


图 8.4 询问列表

6.选择密钥种类，密钥大小，有效期，最后选择 y, 如图 8.5 所示。

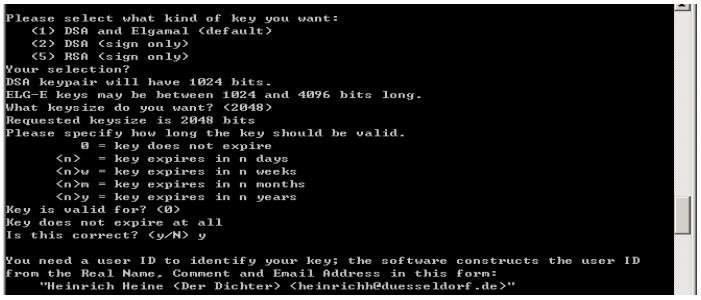


图 8.5 参数选择

7.生成用户标识，如图 8.6 所示。



图 8.6 生成用户 ID

8.键入“O”确定以上信息后，gpg 需要一个密码来保护即将生成的用户私钥，为了方便记忆，此处选择密码与用户名相同，即在密码文本输入：user5E，在确认处也输入 user5E，如图 8.8 所示。

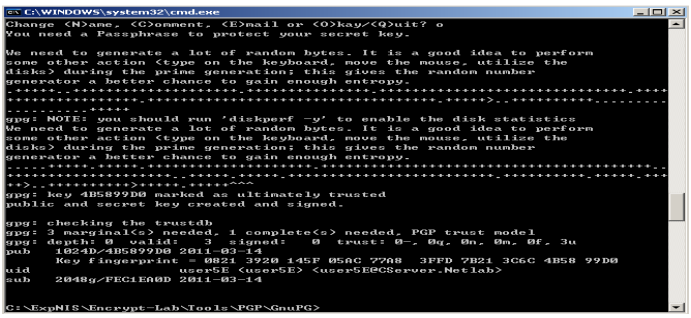


图 8.7 输入密码

9. 接下来 gpg 会根据以上信息生成公私密钥对，并将它们存放在 C:\Documents and Settings\Administrator\Application Data\gnupg 目录下，名字分别为：pubring.gpg 和 secring.gpg。如图 8.8 所示。

「**说明**」默认情况下 Application Data 目录是隐藏的，通过“资源浏览器”|“工具”菜单|“文件夹选项”|“查看”选项卡，选中“显示所有文件和文件夹”项，即可显示隐藏的目录和文件。

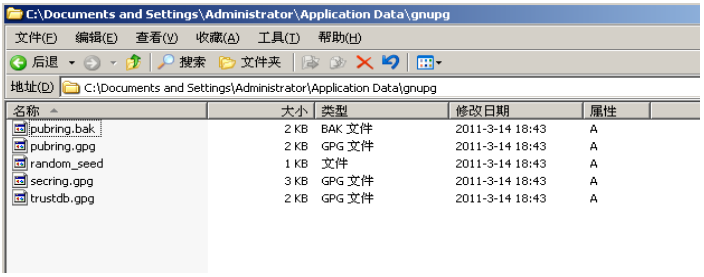


图 8.8 生成公私密钥对

10.导出公钥

(1)在gpg工作目录键入命令：gpg -a -o D:\Work\PGP\userGXpubkey.asc --export userGX (userGX) (userGX@CServer.Netlab)，gpg会将公钥导入到D:\Work\PGP\这个指定目录的userGXpubkey.asc文件中。

(2)在 C:\Documents and Settings\Administrator\Application Data 目录下新建一个文件夹：gnupg1,将 gnupg 中的内容拷贝过来。

(3)用同样的方法在生成另一个公钥，只需要将上面的 user5E 改成 user5F 或其它的即可。

(4)在 D:\Work\PGP 下新建一个文件夹：PGP1，将之前 PGP 中的内容拷贝过来,等其公钥导入 PGP 文件夹后，然后再将 PGP1 中内容拷贝到 PGP 中即可（其实此时的 PGP 文件中已经有两个公钥），如图 8.9 所示。



图 8.9 公钥列表

(5)导入公钥，将公钥导入至本机 gpg 库，其命令如下：gpg --import D:\Work\PGP\userGYpubkey.asc。

11.加密

(1)在“D:\Work\PGP\”目录中新建一文本文件“user5F.txt”,内容是: xinxi

(2)利用用户 user5E 的的公钥进行加密，并对其进行签名

在 gpg 工作目录键入如下命令：gpg -sea -r *user5F*@CServer.Netlab *加密文件绝对路径*，其中 user*5F* @CServer.Netlab 为 USER-ID。加密完成后，gpg 还要对其进行签名表明这个密文文件是“我”发出的，而不是“其它人”，在提示处输入前面设置的用于保护本机私钥的密码即可，输入的密钥是用户 user5E 的。最后在原文件所在目录下，生成一个名为“user5F.txt.asc”的文件，如图 8.10，8.11 所示。

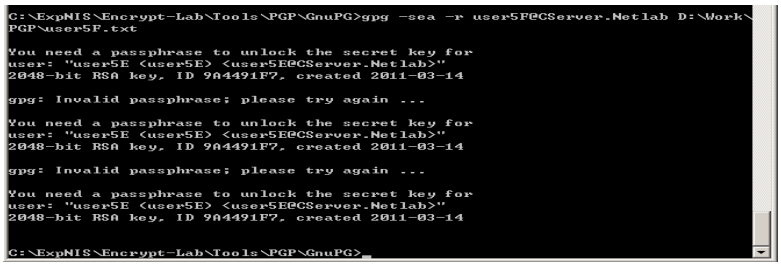


图 8-10 加密文件

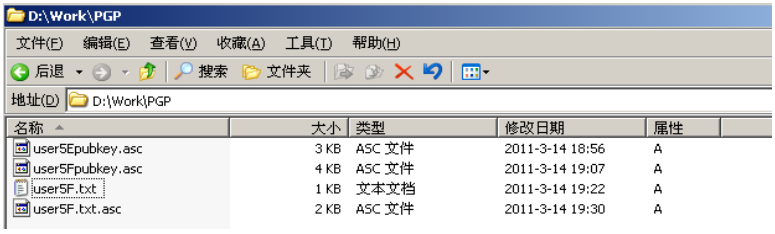


图 8.11 加密结果

12.解密

在 gpg 工作目录下键入命令：gpg -d *加密文件绝对路径* > *解密后文件路径*，此时 gpg 要求输入前面设置的用于保护本机私钥的密码。输入密码，此时输入的密钥为 user5F,解开私钥。在存放加密文件的目录下就生了一个解密后的文件，打开解密文件，浏览正文，与同组主机确定其正确性，如图 8.12 所示。

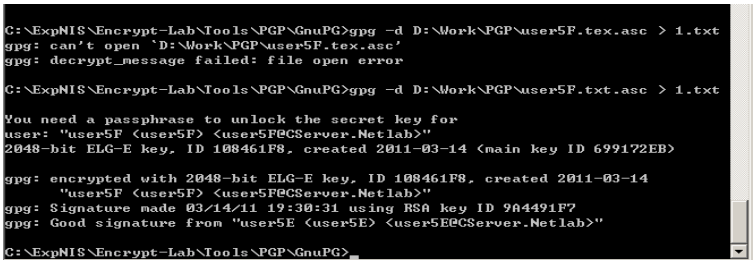


图 8.12 解密命令

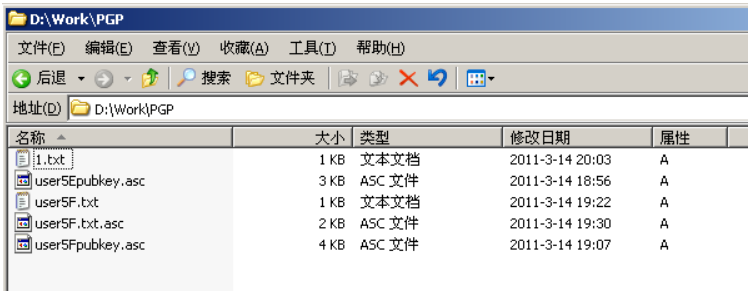


图 8.13 解密后的文件

六、问题思考

1.根据 PGP 的加密原理，说明为什么 PGP 要比 RSA 加密速度要快得多。

实验九 Windows 口令破解

一、实验目的

1.了解 Windows 口令破解原理
2.能够运用工具实现口令破解

二、实验环境

Windows，交换网络结构

三、实验工具

LC5，SuperDic

四、实验原理

1.口令破解方法

口令破解主要有两种方法：字典破解和暴力破解。

字典破解是指通过破解者对管理员的了解，猜测其可能使用某些信息作为密码，例如其姓名、生日、电话号码等，同时结合对密码长度的猜测，利用工具来生成密码破解字典。如果相关信息设置准确，字典破解的成功率很高，并且其速度快，因此字典破解是密码破解的首选。

而暴力破解是指对密码可能使用的字符和长度进行设定后(例如限定为所有英文字母和所有数字，长度不超过 8)，对所有可能的密码组合逐个实验。随着可能字符和可能长度的增加，存在的密码组合数量也会变得非常庞大，因此暴力破解往往需要花费很长的时间，尤其是在密码长度大于 10，并且包含各种字符（英文字母、数字和标点符号）的情况下。

2.口令破解方式

口令破解主要有两种方式：离线破解和在线破解

离线破解攻击者得到目标主机存放密码的文件后，就可以脱离目标主机，在其他计算机上通过口令破解程序穷举各种可能的口令，如果计算出的新密码与密码文件存放的密码相同，则口令已被破解。可以将口令破解程序的工作流程用图 9.1 来表示。

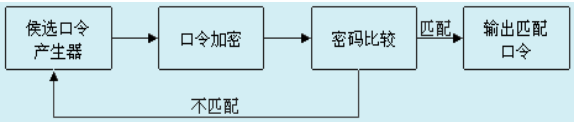


图 9.1 口令破解程序的工作流程

(1)候选口令产生器

候选口令产生器的作用是不断生成可能的口令。有几种方法产生候选口令，一种是用枚举法来构造候选口令(暴力破解)，另一种方法是从一个字典文件里读取候选口令(字典破解)。

(2)口令加密

口令加密过程就是用加密算法对从口令候选器送来的候选口令进行加密运算而得到密码。这要求加密算法要采用和目标主机一致的加密算法。加密算法有很多种，通常与操作系统的类型和版本相关。

(3)口令比较

口令比较就是将从候选口令计算得到的新密码和密码文件中存放的密码相比较。如果一致，那么口令破解成功，可以使用候选口令和对应的账号登录目标主机。如果不一致，则候选口令产生器计算下一个候选口令。

通过在线破解攻击者可以使用一个程序连接到目标主机，不断地尝试各种口令试图登录目标主机。目标主机系统中某些低等级的账号的口令往往容易被尝试成功，然后，攻击者使用其账号进入系统获取密码存放文件(Windows 系统是 SAM 文件，Linux 系统是 passwd 等文件)，再使用离线破解方法破解高权限的口令(管理员口令等)。

五、实验步骤

1.字典破解

(1)在本机创建新用户。为了达到实验效果，用户口令不要设置得过于复杂，可以选择自己的生日，例如 19870308。将你创建的用户名及密码填入表 9.1。

表 9.1 填写表格

用户名	
密码	

(2)进入实验平台，单击工具栏“字典生成器”按钮，启动“字典生成器”。选择“生日”标签页，输入的年份与月份信息应尽量包含步骤(1)中用到的生日日期，在“生成字典”标签页中确定字典文件存放的路径以及新用户口令位数，如图 9.2，9.3 所示。



图 9.2 输入参数



图 9.3 保存并选择密码位数

(3)点击生成字典序，保存直至完成，如图 9.4 所示。

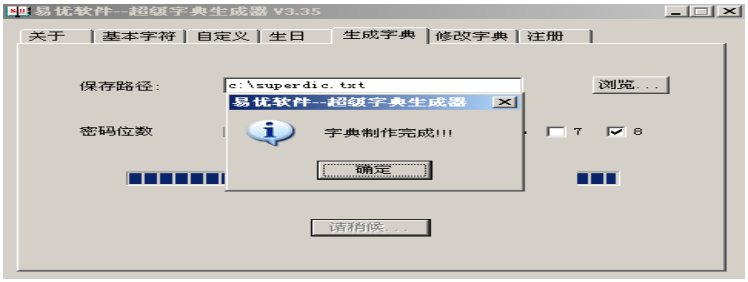


图 9.4 字典制作完成

(4)单击工具栏“LC5”按钮，启动 LC5 口令破解工具。选择“Session”(会话)丨“Session Options…”(会话选项)菜单项，在弹出的“Auditing Options For This Session”对话框中选中“Dictionary Crack”项的“Enabled”，取消其它项的“Enabled”。单击“Dictionary List”(字典列表)按钮，导入步骤(2)中生成的字典文件。

(5)返回 LC5 主界面，选择“Session”丨“Import…”(导入)菜单项，在弹出的“Import”对话框中导入本地用户列表如图 9-5 所示。

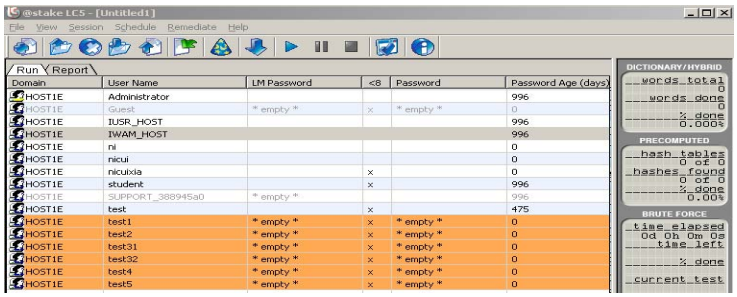


图 9.5 导入用户列表

(6)选择“Session”|“Begin Audit”(开始审计)菜单项，开始字典破解用户口令，如图 9.6 所示。

Domain	User Name	LM Password	<8	Password	Password Age (days)	Locked Out	Disabled
HOST1E	Administrator	??????MIN			996		
HOST1E	Guest	* empty *	x	* empty *	0		x
HOST1E	IUSR_HOST				996		
HOST1E	IWAM_HOST				996		
HOST1E	ni	19870308		19870308	0		
HOST1E	nicui	19870308		19870308	0		
HOST1E	nicuixia	123456	x	123456	0		
HOST1E	student	123456	x	123456	996		
HOST1E	SUPPORT_388945a0	* empty *			996		x
HOST1E	test	1234	x	1234	475		
HOST1E	test1	* empty *	x	* empty *	0		
HOST1E	test2	* empty *	x	* empty *	0		
HOST1E	test31	* empty *	x	* empty *	0		
HOST1E	test32	* empty *	x	* empty *	0		
HOST1E	test4	* empty *	x	* empty *	0		
HOST1E	test5	* empty *	x	* empty *	0		

图 9.6 开始审计

2.暴力破解

(1)创建新用户，建议用户口令仅由英文字母和数字组成，长度不超过 6 位，如 123abc。

(2)选择 LC5 的“File”|“New Session…”(新会话)菜单项，新建会话。重新导入本地用户列表。

(3)在会话选项中仅选中“Brute Force Crack”(暴力破解)|“Enabled”，并在“Character Set”(字符集)中选择“alphabet+numbers”(字母表+数字)，如图 9.7 所示。

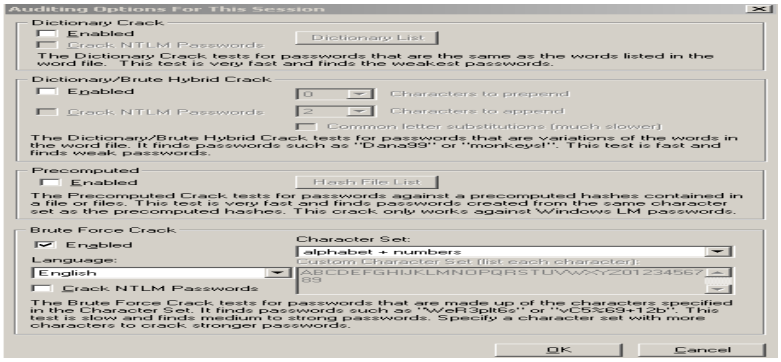


图 9.7 参数设置

(4)开始暴力破解，新建用户口令，结果如图 9.8 所示。

Domain	User Name	LM Password	<8	Password	Passwor
HOST1E	Administrator	??????MIN			996
HOST1E	Guest	* empty *	x	* empty *	0
HOST1E	IUSR_HOST				996
HOST1E	IWAM_HOST				996
HOST1E	ni	???????8			0
HOST1E	nicui	???????8			0
HOST1E	nicuixia		x		0
HOST1E	nini	NI123	x	ni123	0
HOST1E	student		x		996
HOST1E	SUPPORT_388945a0	* empty *			996
HOST1E	test	1234	x	1234	475
HOST1E	test1	* empty *	x	* empty *	0
HOST1E	test2	* empty *	x	* empty *	0
HOST1E	test31	* empty *	x	* empty *	0
HOST1E	test32	* empty *	x	* empty *	0
HOST1E	test4	* empty *	x	* empty *	0
HOST1E	test5	* empty *	x	* empty *	0

图 9.8 破解结果

3.不同密码强度的破解时间比较

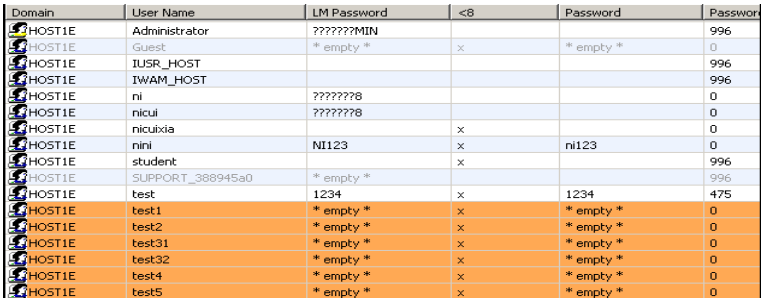
(1)再次新建 4 个用户，使用不同强度的用户口令。默认情况下该 4 个用户名及其口令如表 9.2。

9.2 不同强度的用户口令

用户名	密码
user1	1234
user2	12abc
user3	Abc123
User4	12_ab+

(2)新建 LC5 会话，在会话选项中选中暴力破解选项，字符设置选择“Custom”(自定义)。

(3)开始暴力破解，如图 9.9 所示。



Domain	User Name	LM Password	<8	Password	Passwor
HOST1E	Administrator	???????MIN			996
HOST1E	Guest	* empty *	x	* empty *	0
HOST1E	IUSR_HOST				996
HOST1E	IWAM_HOST				996
HOST1E	ni	???????8			0
HOST1E	nicui	???????8			0
HOST1E	nicuixia		x		0
HOST1E	nini	NI123	x	ni123	0
HOST1E	student		x		996
HOST1E	SUPPORT_388945a0	* empty *			996
HOST1E	test	1234	x	1234	475
HOST1E	test1	* empty *	x	* empty *	0
HOST1E	test2	* empty *	x	* empty *	0
HOST1E	test31	* empty *	x	* empty *	0
HOST1E	test32	* empty *	x	* empty *	0
HOST1E	test4	* empty *	x	* empty *	0
HOST1E	test5	* empty *	x	* empty *	0

图 9.9 新建用户

(4)当破解完成后，查看 LC5 的破解信息，填写表 9.3。

表 9.3 破解用时记录

user1 破解用时	
User2 破解用时	
User3 破解用时	
User4 破解用时	

「注」由于 user4 的密码设置比较复杂，所以破解的时间非常长。若时间不允许，不必等待最后的破解结果。

(5)根据实验结果不难发现长密码比短密码破解要更多的时间，复杂密码比简单密码需要更多的时间，这也就是设置复杂密码能够提高系统安全性。

六、问题思考

1.此实验对你有什么启发？

实验十 IIS 服务器

一、实验目的

1.学会搭建 IIS 服务器
2.学会对 IIS 服务器进行权限设置进而提高服务器的安全
3.学会在 IIS 下进行安全加密通信

二、实验环境

Windows，交换网络结构

三、实验工具

四、实验原理

Internet 信息服务器(即 Internet Information Server，简称 IIS)是用户创建信息服务器的最重要的组件，它是微软公司主推的服务器，其最新的版本是 Windows 2003 中包含的 IIS 6.0。IIS 与 Window NT Server 完全集成在一起，因而用户能够利用 Windows NT Server 和 NTFS(NT File System，NT 的文件系统)内置的安全特性，建立强大、灵活且安全的 Internet 和 Intranet 站点。

IIS 支持 HTTP(Hypertext Transfer Protocol，超文本传输协议)，FTP(File Transfer Protocol，文件传输协议)以及 SMTP 协议，通过使用 CGI 和 ISAPI，IIS 可以得到高度的扩展。通过 IIS，开发人员就可以开发出新一代动态的、富有魅力的 Web 站点。IIS 不需要开发人员学习新的脚本语言或者编译应用程序，它完全支持 VBScript，JScript 开发软件以及 Java，它也支持 CGI 和 WinCGI，以及 ISAPI 扩展和过滤器。

IIS 支持服务器应用的 Microsoft BackOffice 系列，Microsoft BackOffice 系列包括以下内容。

(1)Microsoft Exchange Server 客户/服务器通讯和群组软件；

(2)Microsoft Proxy Server 代理服务器；

(3)用于连接 IBM 企业网络的 Microsoft SNA Server；

(4)用于集中管理分布式系统的 Microsoft Systems Management Server；

(5)Microsoft Commercial Internet System（MCIS）；

(6)IIS 的设计目的是建立一套集成的服务器服务，用以支持 HTTP，FTP 和 SMTP，它能够提供快速的、集成的、可扩展的 Internet 服务器。

IIS 适应性极高，同时系统资源的消耗也是最少，IIS 的安装，管理和配置都相当简单，这是因为 IIS 与 Windows NT Server 网络操作系统紧密的集成在一起，另外，IIS 还使用与 Windows NT Server 相同的 SAM（Security Accounts Manager，安全性账号管理器），对于管理员来说，IIS 使用诸如 Performance Monitor 和 SNMP（Simple Nerwork Management Protocol，简单网络管理协议）之类的 NT 已有管理工具。

IIS 支持 ISAPI，使用 ISAPI 可以扩展服务器功能，而使用 ISAPI 过滤器可以预先处理和事后处理储存在 IIS 上的数据。用于 32 位 Windows 应用程序的 Internet 扩展可以把 FTP，SMTP 和 HTTP 协议置于容易使用且任务集中的界面中，这些界面将 Internet 应用程序的使用大大简化，IIS 也支持 MIME（Multipurpose Internet Mail Extensions，多用于 Internet 邮件扩展），它可以为 Internet 应用程序的访问提供一个简单的注册项。

IIS 的一个重要特性是支持 ASP。IIS 3.0 版本以后引入了 ASP，可以很容易的张贴动态内容和开发基于 Web 的应用程序。对于诸如 VBScript，JScript 开发软件，或者由 Visual Basic，Java，Visual C++开发系统，以及现有的 CGI 和 WinCGI 脚本开发的应用程序，IIS 都提供强大的本地支持。

在 Windows Server 2003 中，IIS 6.0 与系统进行了很好的集成，它提供了许多一级组件，其中一些与相关的服务和工具绑定在一起，管理员可以根据需要的服务来选择所需的组件。IIS 的核心组件包括 Internet 服务管理器(安装基于 HTML 版本的 IIS 管理界面)、FrontPage 服务器扩展(以方便使用 FrontPage 和 Visual InterDev 来创建和管理站点和发布内容)、Internet 信息服务管理单元(可以将 IIS 的管理界面安装到 MMC 中)、Web 服务(可以使 HTTP 协议响应 TCP/IP 网络上的 Web 客户端请求)、文件传输协议服务(为建立用于上传或下载的 FTP 站点提供支持)、NNTP Service(提供简单网络新闻服务)、SMTP Service(提供简单邮件传输功能)和公用文件(提供所需要的 IIS 程序文件)等。另外，IIS 还支持其他一些功能强大的组件，如 XML、ASP、 ISAPI(Internet 服务器应用程序编程接口)、IDC(Internet 数据连接器)、JVM(服务器端的 Java 虚拟机)、JSP、 JavaScript、VBScript 和 CGI(公共网关接口)等，这些组件直接影响到服务器所提供的内容和功能。

IIS 6.0 与 Windows Server 2003 中的其他组件不同，它是一个 Internet 信息服务平台。IIS 6.0 提供的众多服务都是用来完成它的核心功能的，而且这些服务都可以应用到 Internet 上的信息服务中，其中最常用、最重要的服务是 Web 服务和 FTP 服务，它们也是在安装 IIS 6.0 时默认安装的服务。安装了 IIS 6.0 的服务器就成为了 Internet 信息服务器，它对内可以服务本地局域网络，对外可以服务于 Internet。

五、实验步骤

1.创建网站

(1)在主机 A 上点击“开始|程序|管理工具|Internet 信息服务（IIS）管理器”，如图 10.1 所示。

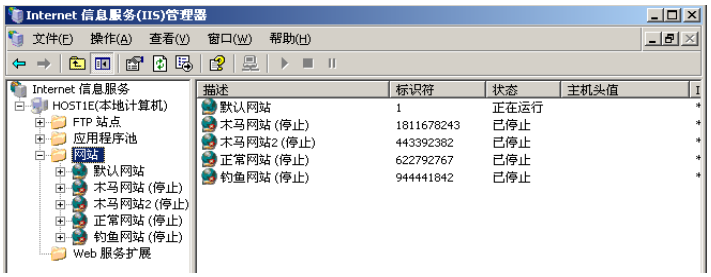


图 10.1 IIS 管理器界面

(2)右键点击“网站”，依次选取“新建|网站（W）”，根据网站创建向导完成网站的创建。其中“网站描述”为“我的网站”；“网站 IP 地址”为本机 IP 地址；(本机 IP 地址的获取方法如下：选择“开始”->”运行”->输入 cmd,回车，在控制台中输入命令 ipconfig /all,寻找到 IP address,就是本机的 IP 地址了)。“网站 TCP 端口”设为“808”(可选择任意未被占用端口)如图 10.2 所示，主目录“路径”为“C:\我的网站”(需自己创建目录)，网站访问权限为默认值。



图 10.2 参数设置

此时网站创建完毕，如图 10.3 所示。

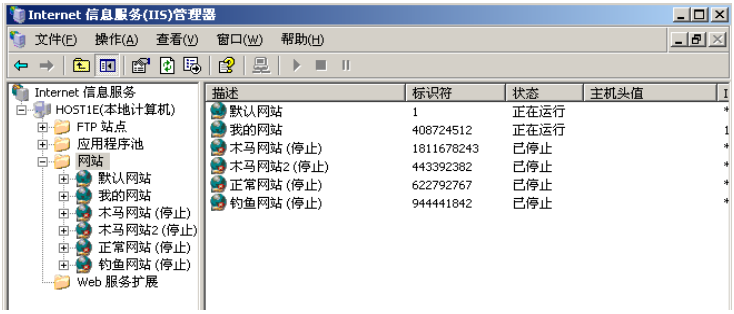


图 10.3 网站创建完毕

2.创建和访问主页

进入“C:\我的网站”目录，参考“D:\Work\IIS\index.html”(查看源码的方法为：打开index.html,鼠标右键—>查看源码)制作自己的主页 index.html，并保存在当前目录下。

打开主机 B 的 IE 浏览器，访问主机 A 上部署好的我的网站，访问方式为：“http://主机 A 的 IP 地址：808/index.html”。 观察访问是否成功，如果弹出如图 10.4 所示的对话框，则需要在主机 A 上的“我的网站”进行以下操作：我的网站—>属性—>目录安全性—>编辑—>启用匿名访问，如图 10.5 所示，尝试再一次访问。

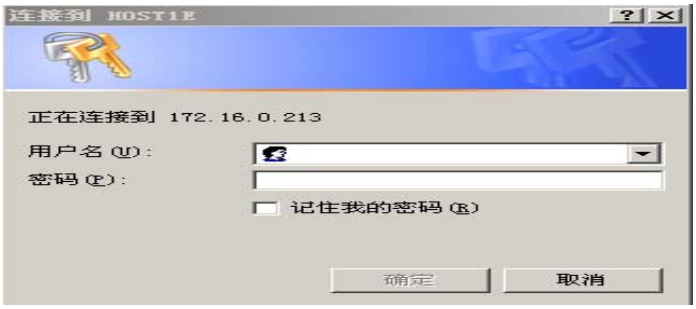


图 10.4 登录名和密码

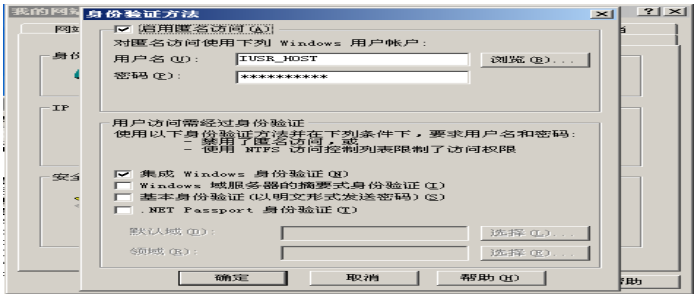


图 10.5 启用匿名访问

再次用主机 B 访问，可以得到如图 10.6 所示的界面。

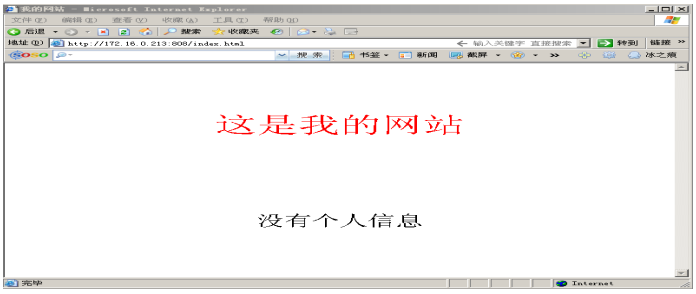


图 10.6 访问成功

3.创建 FTP 站点

(1)同样在主机 A 上，右键点击“FTP 站点|新建|FTP 站点”进入 FTP 站点创建向导。

(2)根据提示完成创建。其中“FTP 站点描述”为“我的 FTP 站点”如图 10.7 所示。



图 10.7 输入 FTP 站点描述

(3)“FTP 站点使用的 IP 地址”为本机 IP 地址，端口设置为 7777(可选择任意未被占用端口)，如图 10.8 所示。

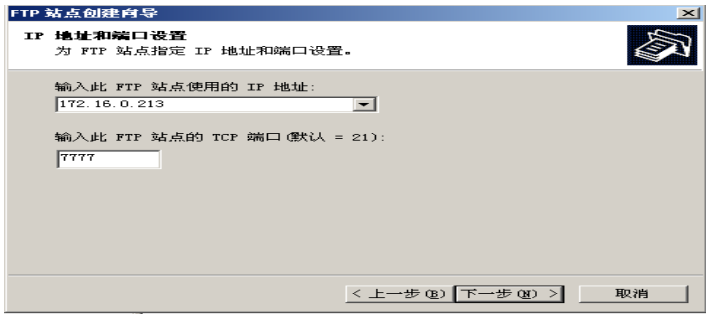


图 10.8 IP 地址和端口设置

(4)“FTP 用户隔离”为默认选择“不隔离用户”如图 10.9 所示。

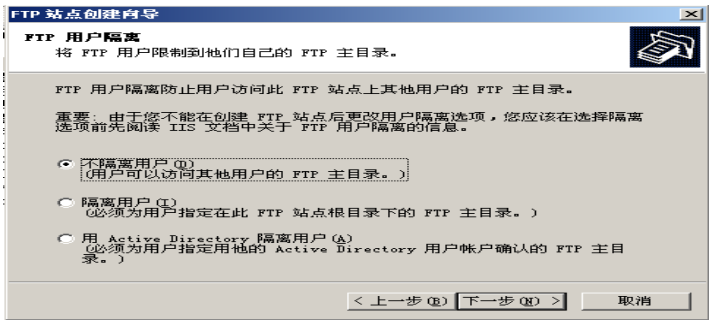


图 10.9 FTP 用户隔离

(5)“FTP 站点主目录”为“C:\我的 FTP 站点”，如图 10.10 所示。



图 10.10 FPT 站点主目录

(6)站点访问权限为默认值，如图 10.11 所示。

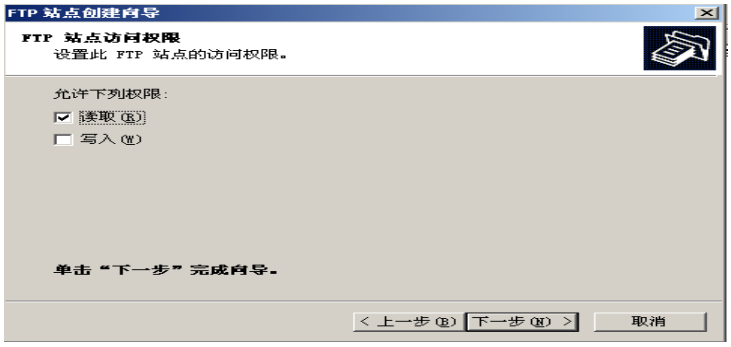


图 10.11　FTP 站点访问权限设置

(7)主机 A 在目录“C:\我的 FTP 站点”中创建文本文件“A 的文本文档.txt”然后在里面输入任意的内容。

(9)主机 B 打开 IE 浏览器，登录主机 A 的 FTP 站点“ftp://主机 A 的 IP 地址:7777”并尝试对“A 的文本文档.txt”进行读取/写入/修改/删除等操作，查看哪种操作成功。结果应该为只能读取。

实验十三 日志审计

一、实验目的

1.学习查看 IIS 日志
2.掌握 IIS 日志的配置

二、实验环境

Windows，交换网络结构

三、实验工具

FTPScan，X-Scan

四、实验原理

1.Windows 日志系统

WindowsNT/2000 的系统日志文件有应用程序日志 AppEvent.Evt、安全日志 SecEvent.Evt、系统日志 SysEvent.Evt，根据系统开通的服务还会产生相应的日志文件。例如，DNS 服务器日志 DNS Serv.evt，FTP 日志、WWW 日志等。日志文件默认存放位置：%systemroot%\system32\config，默认文件大小 512KB。这些日志文件在注册表中的位置为 HKEY_LOCAL_MACHINE\system\CurrentControlSet\Services\Eventlog，可以修改相应键值来改变日志文件的存放路径和大小。

Windows NT/2000 主要有以下三类日志记录系统事件：应用程序日志、系统日志和安全日志。

(1)应用程序日志

记录由应用程序产生的事件。例如，某个数据库程序可能设定为每次成功完成备份后都向应用程序日志发送事件记录信息。应用程序日志中记录的时间类型由应用程序的开发者决定，并提供相应的系统工具帮助用户查看应用程序日志。

(2)系统日志

记录由 WindowsNT/2000 操作系统组件产生的事件，主要包括驱动程序、系统组件和应用软件的崩溃以及数据丢失错误等。系统日志中记录的时间类型由 Windows NT/2000 操作系统预先定义。

(3)安全日志

记录与安全相关的事件，包括成功和不成功的登录或退出、系统资源使用事件(系统文件的创建、删除、更改)等。与系统日志和应用程序日志不同，安全日志只有系统管理员才可以访问。在 WindowsXP 中，事件是在系统或程序中发生的、要求通知用户的任何重要事情，或者是添加到日志中的项。事件日志服务在事件查看器中记录应用程序、安全和系统事件。通过使用事件查看器中的事件日志，用户可以获取有关硬件、软件和系统组件的信息，并可以监视本地或远程计算机上的安全事件。事件日志可帮助您确定和诊断当前系统问题的根源，还可以帮助用户预测潜在的系统问题。WindowsNT/2000 的系统日志由事件记录组成。每个事件记录为三个功能区：记录头区、事件描述区和附加数据区，表 13-1 描述了事件记录的结构。

表 11.1　事件记录结构

记录头	日期	时间	主体标识	计算机名
	事件标号	事件来源	事件等级	事件类别
事件描述	事件描述区的内容取决于具体的事件，可以是事件的名称、详细说明、产生该事件的原因、建议的解决方案等信息。			
附加数据	可选数据区，通常包括可以以16进制方式显示的二进制数据。具体内容由产生事件记录的应用程序决定。			

事件标题包含以下关于事件的信息，如表 11.2 所示。

表 11.2 事件标题包含的事件信息

日期	事件发生的日期
时间	事件发生的时间
用户	用户事件发生时已登录的用户的用户名。
计算机	发生事件的计算机的名称。
事件ID	标识事件类型的事件编号。产品支持代表可以使用事件ID来帮助了解系统中发生的事情。
来源	事件的来源。它可以是程序、系统组件或大型程序的个别组件的名称。
类型	事件的类型。它可以是以下五种类型之一：错误、警告、信息、成功审核或失败审核。
类别	按事件来源对事件进行的分类。它主要用于安全日志。

所记录的每个事件的描述取决于事件类型。日志中的每个事件都可归类为表 11.3 所描述的类型之一。

表 11.3 事件类型

信息	描述任务(如应用程序、驱动程序或服务)成功运行的事件。例如，当网络驱动程序成功加载时将记录“信息”事件。
警告	不一定重要但可能表明将来有可能出现问题的事件。例如，当磁盘空间快用完时将记录“警告”消息。
错误	描述重要问题(如关键任务失败)的事件。“错误”事件可能涉及数据丢失或功能缺失。例如，当启动过程中无法加载服务时将记录“错误”事件。
成功审核（安全日志）	描述成功完成受审核安全事件的事件。例如，当用户登录到计算机时将记录“成功审核”事件。
失败审核（安全日志）	描述未成功完成的受审核安全事件的事件。例如。当用户无法访问网络驱动器时可能记录“失败审核”事件。

Windows2003 的日志系统通常放在下面的位置：

(1)安全日志文件：C:\WINDOWS\system32\config\SecEvent.EVT；

(2)系统日志文件：C:\WINDOWS\system32\config\SysEvent.EVT；

(3)应用程序日志文件：C:\WINDOWS\system32\config\AppEvent.EVT；

(4)FTP 服务日志默认位置：C:\WINDOWS\system32\LogFiles\msftpsvc1\；

(5)WWW 服务日志默认位置：C:\WINDOWS\system32\LogFiles\w3svc1\。

2.IIS 日志系统

IIS（Internet 信息服务）的日志是用于记录关于用户活动的细节并按一定的格式创建的可以查看的文件。

信息存储在 ASCII 文件或与 ODBC 兼容的数据库中。IIS 中的日志记录信息超出了 Microsoft Windows 事件日志或性能监视器功能的范围。日志包括的信息诸如哪些用户访问了您的站点、访问者查看了什么内容，以及最后一次查看该信息的时间。可以使用日志来评估内容受欢迎程度或识别信息瓶颈。

IIS 服务提供了四种日志文件的格式可以供选择，它们分别是：

(1)Microsoft IIS 日志文件格式：一种固定的 ASCII 格式；

(2)NCSA 共用日志文件格式：一种固定的 ASCII 格式；

(3)ODBC 日志记录：一种记录到数据库的固定格式，与该数据库兼容；

(4)W3C 扩展日志文件格式：一种可自定义的 ASCII 格式，默认情况下选择此格式。

下面分别详细介绍这些格式。

(1)IIS 日志文件格式

IIS 格式是固定的(不能自定义的)ASCII 格式。IIS 格式比 NCSA 公用格式记录的信息多。IIS 格式包括一些基本项目，如用户的 IP 地址、用户名、请求日期和时间、服务状态码和接收的字节数。另外，IIS 格式还包括详细的项目，如所用时间、发送的字节数、动作（例如，GET 命令执行的下载）和目标文件。这些项目用逗号分开，使得格式比使用空格作为分隔符的其他 ASCII 格式更易于阅读。时间记录为本地时间。

当在文本编辑器中打开 IIS 格式的文件时，项目与下面的示例相似：

```
192.168.114.201, -, 03/20/01, 7:55:20, W3SVC2, SALES1, 172.21.13.45, 4502, 163, 3223, 200, 0,
GET, /DeptLogo.gif, -,
172.16.255.255, anonymous, 03/20/01, 23:58:11, MSFTPSVC, SALES1, 172.16.255.255, 60, 275, 0,
0, 0, PASS, /Intro.htm, -,
```

上面所示的项目将在下面的表中加以说明。每个表项的行来自第二个站点实例(以 W3SVC2 形式出现在“服务”下面)，底行来自第一个 FTP 站点实例(以 MSFTPSVC1 形式出现在“服务”下面)。由于页宽所限，该示例出现在三个表中。

用户的IP地址	用户名称	日期	时间	服务和实例	计算机名
192.168.114.201		03/20/01	7:55:20	W3SVC2	SALES1
172.16.255.255	匿名	03/20/01	23:58:11	MSFTPSVC1	SALES1

服务器IP地址	所用时间	发送字节	接收字节	服务状态码	状态码
172.21.13.45	4502	163	3223	200	0
172.16.255.255	60	275	0	0	0

请求类型	操作目标	参数
GET	/DeptLogo.gif	
[376] PASS	/Intro.htm	

在上面的示例中，第一个项目表明：2001 年 3 月 20 日上午 7:55，IP 地址为 192.168.114.201 的匿名用户发出一条 HTTP GET 命令，从 IP 地址为 172.21.13.45、名为 SALES1 的服务器请求图像文件/DeptLogo.gif。163 字节的 HTTP 请求有 4502 毫秒（4.5 秒）的处理时间来完成，并将 3223 个字节的数据毫无错误地返回给匿名用户。

(2)NCSA 公用日志文件格式

美国国家超级计算技术应用中心（NCSA）公用格式是一种固定的（不能自定义的）ASCII 格式，可用于网站但不能用于 FTP 站点。NCSA 公用格式记录了关于用户请求的基本信息，如远程主机名、用户名、日期、时间、请求类型、HTTP 状态码和服务器发送的字节数。项目之间用空格分开，时间记录为本地时间。

当在文本编辑器中打开 NCSA 公用格式文件时，项目与下面的示例相似：

```
172.21.13.45 - Microsoft\fred [08/Apr/2001:17:39:04 -0800] "GET /scripts/iisadmin/ism.dll?
http/serv HTTP/1.0" 200 3401
```

「注」在前面的项目中，第二个属性字段(显示用户的远程登录名)是空的，它由 IP 地址 172.21.13.45 后面的连字符表示。

以上示例的项目在下面的表中说明。由于页宽所限，该示例显示在两个表中。

远程主机	远程登录名称	用户名称	日期	时间和GMT时差
172.21.13.45	-	Microsoft\fred	08/Apr/2001	17:39:10 -0800

请求/版本	服务状态码	传送的字节
GET/scripts/iisadmin/ism.dll?http/serv HTTP/1.0	200	3401

上面的项目表明：Microsoft 域中 IP 地址为 172.21.13.45、名为 Fred 的用户在 2001 年 4 月 8 日下午 5:39 分发出一条 HTTP GET 命令(即下载一个文件)。该请求将 3401 个字节的数据正确无误地返回给名为 Fred 的用户。

(3)使用 ODBC 日志记录用适当的属性为日志数据创建包含表的数据库

IIS 中包含有 SQL 模板文件，它可以在 SQL 数据库中运行，以创建从 IIS 接受日志项目的表。该文件名为 Logtemp.sql 且位于 systemroot\System32\Inetsrv(如果您接受了安装默认值)，下列属性是必需的。

属性名称	属性类型
ClientHost	varchar(255)
Username	varchar(255)
LogTime	datetime
Service	varchar(255)
Machine	varchar(255)
ServerIP	varchar(50)
ProcessingTime	Int
BytesRecvd	Int
BytesSent	Int
ServiceStatus	Int
Win32Status	Int
Operation	varchar(255)
Target	varchar(255)
Parameters	varchar(255)

为数据库赋予系统数据源名(DSN)，ODBC 软件用它来查找数据库。向 IIS 提供数据库和表的名称。如果访问数据库时需要用户名和密码，也必须在 IIS 中指定。

五、实验步骤

1.访问正常的网页

(1)同组主机互访对方 Web 主页（访问主机即为客户端，被访问主机即为服务器），在 IE 地址栏中输入“http:///*同组主机 IP*”，确保登录成功。在这里我们让主机 A 登陆主机 B，结果如图 11.1 所示：

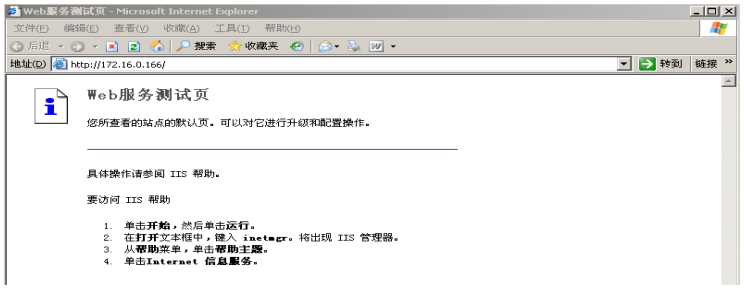


图 11.1　访问结果

(2)在确认 B 的 Web 服务被访问过后，进入 C:\WINDOWS\system32\LogFiles\W3SVC1 目录(稍等片刻)，打开扩展名为“ex 当前日期.log”的文件，观察默认日志格式的文件内容，你将看到类似图 11.2 的日志内容。

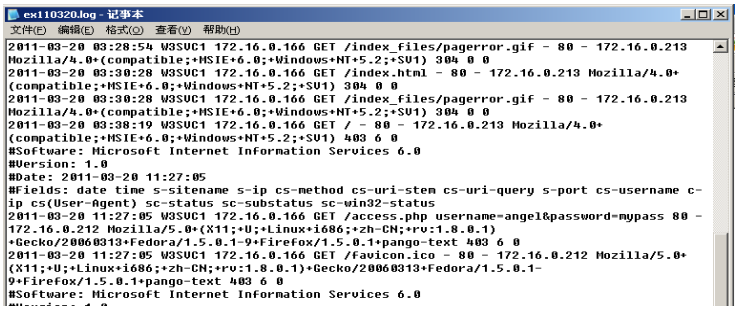


图 11.2　日志内容

「注」系统默认的当前时间为格林威治国际标准时间，转化为北京时间要在该时间的基础上加 8,若超过 24 则日期加 1,时间再减去 24。

2.访问无权限和不存在的网页

(1)在“Internet 信息服务(IIS)管理器”中，右键单击“默认网站”，选择“属性”。在弹出的“默认网站 属性”对话框中单击“目录安全性”标签页，单击“IP 地址和域名限制”组框中的“编辑”按钮。在弹出的对话框中选择“授权访问”，单击“添加”按钮，将同组主机的 IP 地址添加到拒绝访问列表中，单击“确定”按钮，直到完成。

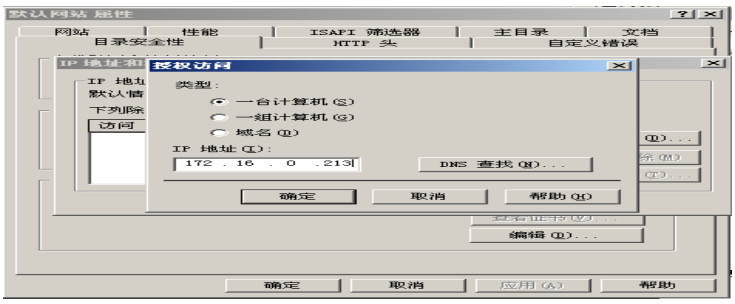


图 11.3 确定授权访问

(2)同组主机再次访问本机 Web 主页（同组主机应重新启动 IE 浏览器），网页提示信息：您未被授权查看该页，HTTP 错误代码：403.6。

(3)本机再次打开 Web 日志文件，查看无权限访问的情况下日志的内容。

(4)本机关闭日志文件，设置“默认网站”属性，去掉对同组主机 IP 地址的禁止。请同组主机访问本机(Web 服务)不存在的页面，如“http://同组主机 IP/1.htm”，网页提示信息：无法找到该页，HTTP 错误代码：404，如图 11.4 所示。

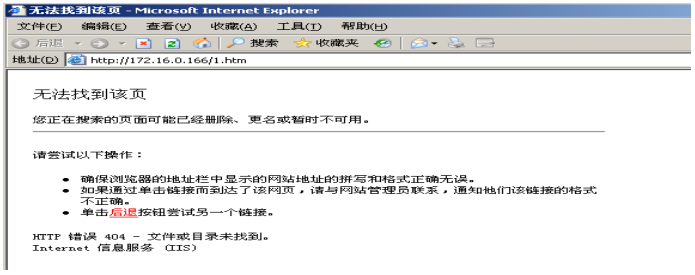


图 11.4 访问结果

(5)打开 IIS 日志文件，查看无法找到网页情况下的日志内容，如图 11.5 所示。

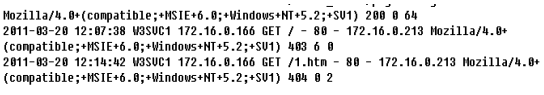


图 11.5 日志内容

3.分别自定义日志格式

(1)在“默认网站 属性”中，把网站“活动日志格式”确定为“W3C 扩展日志文件格式”，在“属性丨高级”中选择“扩展日志选项”自定义日志格式，如图 11.6 所示。

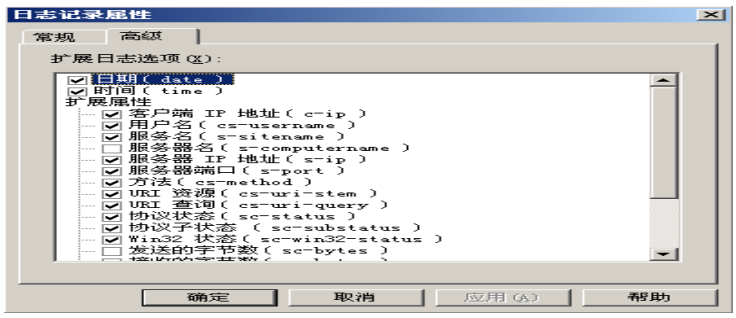


图 11.6 打开自定义日志格式界面

(2)在这里可以设置 W3C 日志的格式，下面我们只选中日期，时间，客户端 IP 地址以及用户名四项做试验，如图 11.7 所示，设置好后单击“确定”按钮使设置生效。请同组主机访问本机 Web 主页，本机片刻后查看日志文件，举例说明日志格式:2008-01-03 06:14:14 172.16

.0.50。

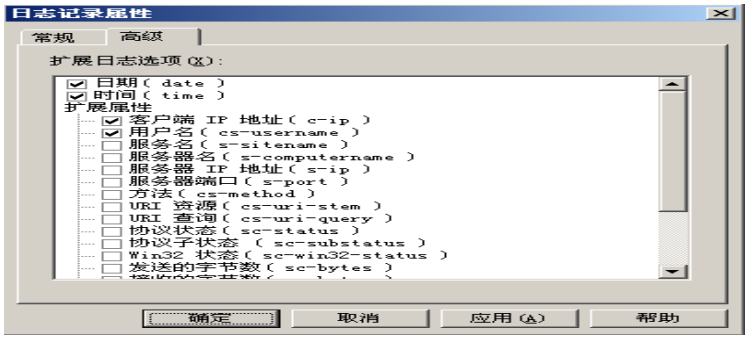


图 11.7 自定义日志格式

(3)自定义其它日志格式，同组主机访问 Web 主页，查看日志内容，如图 11.8 所示。

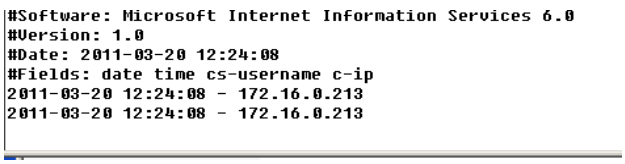


图 11.8 日志内容

4.扫描 Web 服务器漏洞查看 Web 日志内容

(1)重新设置 W3C 日志的格式，选中全部扩展日志选项。

(2)同组主机使用 X-Scan 工具对本机进行扫描。具体操作：同组主机进入实验平台，单击工具栏“X-Scan”按钮，启动 X-Scan 工具，单击菜单栏“设置”|“扫描参数”。在弹出的“扫描参数”对话框中，指定检测范围(在“指定 IP 范围”处填写被扫描主机 IP 地址)，并展开左侧“全局设置”项，点击“扫描模块”项，选中扫描项“WWW 弱口令”，开始扫描。

(3)扫描完成后，本机查看 Web 日志内容，可以大致判断本机被扫描页面的类型以及扫描者的意图，如被探测漏洞脚本文件是否存在等。

5.匿名登录 FTP 服务器

(1)本机在目录“C:\Inetpub\ftproot”新建文本文件“新建文本文档.txt”。

(2)请同组主机访问本机 FTP 服务（在 IE 地址栏中输入“FTP://同组主机 IP”），成功登录后，分别对“新建文本文档.txt”进行打开、重命名、复制和删除操作，能否成功？

(3)在确认同组主机完成上述操作后，本机进入 C:\WINDOWS\system32\LogFiles\MSFTPSVC1 目录(稍等片刻)，打开扩展名为“ex 当前日期.log”的文件，观察默认日志格式的文件内容，你将看到类似图 11.9 的日志内容。

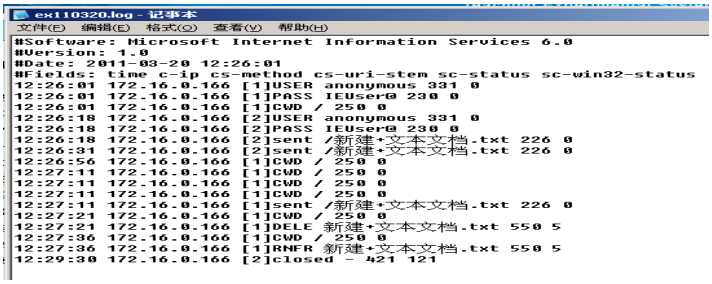


图 11.9 日志内容

(4)查看 FTP 日志文件，分析同组主机对 FTP 服务器所做操作及操作执行结果。

(5)本机在桌面新建名为 upload.txt 的文本文件，登录同组主机 FTP 服务器，并将本地文件 upload.txt 上传至 FTP 服务器，操作是否成功？（失败）。请同组主机查看 FTP 日志，分析刚才 FTP 客户所做的操作，日志内容如图 11.10 所示。

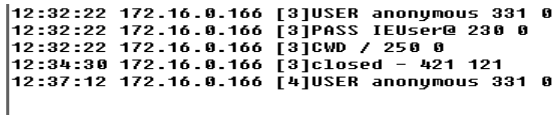


图 11.10 日志内容

(6)设置本地 FTP 站点上传功能，具体操作：本机在“Internet 信息服务(IIS)管理器”中，右键单击“默认 FTP 站点”，选择“属性”，进入“默认 FTP 站点属性”|“主目录”。选择“FTP 站点目录”|“写入”属性。点击“确定”，保存设置。

(7)确定同组主机已完成步骤(6)操作后，本机再次将文件 upload.txt 上传至同组主机 FTP 服务器，是否成功？(成功)本机查看 FTP 日志新增内容，如图 11.11 所示分析刚才 FTP 客户所做的操作。

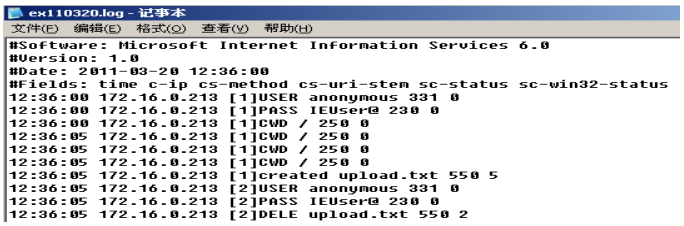


图 11.11 日志内容

6.用户登录 FTP 服务器

(1)本机在“Internet 信息服务(IIS)管理器”中，右键单击“默认 FTP 站点”，选择“属性”。在弹出的“默认 FTP 站点 属性”对话框中单击“安全帐号”标签页，将“允许匿名连接”前的对号去掉，设置 FTP 服务器为不允许匿名连接，点击“确定”，如图 11.12 所示，保存设置。

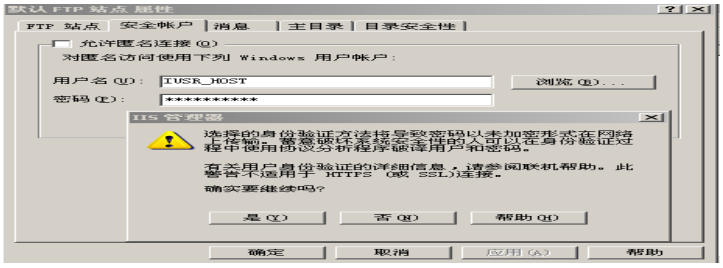


图 11.12 访问权限设置

(2)请同组主机再次访问本机 FTP 服务器(同组主机应重新启动 IE 浏览器)，则会弹出“登录身份”界面，界面提示需要用户名和密码，如图 11.13 所示，在“用户名”和“密码”中依次使用“jlcss/jlcssok”(失败)、“Administrator/jlcssok”(失败)、“Administrator/jlcssadmin”(成功)登录 FTP 服务器。登录都能否成功？

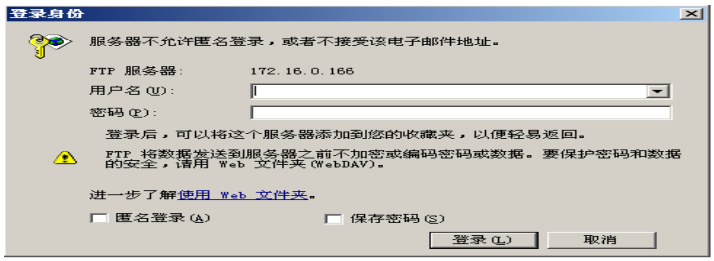


图 11.13 登陆身份界面

(3)本机再次打开 FTP 日志文件，查看 FTP 服务器对三次登录的记录内容，如图 11.14 所示。

```
12:36:05 172.16.0.213 [2]USER anonymous 331 0
12:36:05 172.16.0.213 [2]PASS IEUser@ 230 0
12:36:05 172.16.0.213 [2]DELE upload.txt 550 2|
12:38:55 172.16.0.213 [1]closed - 421 121
13:08:34 172.16.0.213 [3]USER anonymous 331 0
13:08:34 172.16.0.213 [3]PASS IEUser@ 530 1326
13:08:34 172.16.0.213 [4]USER anonymous 331 0
13:08:34 172.16.0.213 [4]PASS IEUser@ 530 1326
13:10:08 172.16.0.213 [5]USER jlcss 331 0
13:10:08 172.16.0.213 [5]PASS - 530 1326
13:10:37 172.16.0.213 [6]USER Administrator 331 0
13:10:37 172.16.0.213 [6]PASS - 530 1326
13:10:47 172.16.0.213 [7]USER Administrator 331 0
13:10:47 172.16.0.213 [7]PASS - 230 0
13:10:47 172.16.0.213 [8]USER Administrator 331 0
13:10:47 172.16.0.213 [8]PASS - 230 0
13:12:58 172.16.0.213 [7]closed - 421 121
13:12:58 172.16.0.213 [8]closed - 421 121
```

图 11.4 日志内容

7.自定义日志格式

参照自定义 Web 日志格式方法，自定义 FTP 日志格式，并进行验证。

8.扫描 FTP 服务器漏洞查看 FTP 日志内容

(1)单击工具栏“FTPScan”按钮，进入 FTPScan 工作目录，输入命令：ftpscan.exe 同组主机 IP，扫描同组主机 FTP 服务器漏洞，扫描结果如图 11.15 所示。

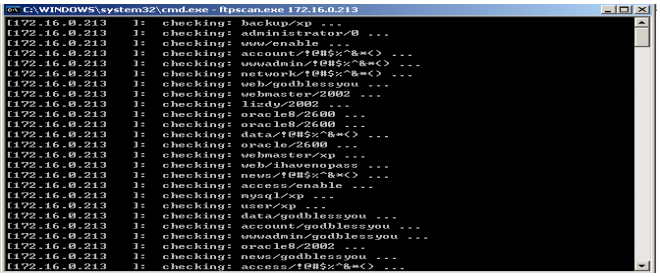


图 11.15 扫描结果

(2)扫描完成后查看日志内容，如图 11.16 所示，分析 FTPScan 的扫描过程，

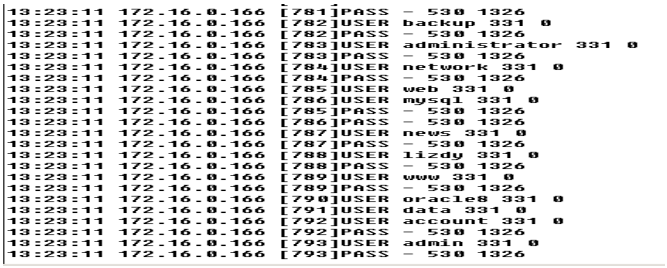


图 11.16 日志内容

六、问题思考

1.什么是日志文件，它有何作用？

实验十二 防范 SQL 注入

一、实验目的

1.了解防范 SQL 注入的方法
2.学会利用合法性校验防范 SQL 注入
3.学会利用 prepared statement 执行 SQL 查询

二、实验环境

Linux，交换网络结构

三、实验工具

MySQL 数据库，PHP 脚本语言，JavaScript 脚本语言

四、实验原理

1.防范 SQL 注入

Web 开发人员认为 SQL 查询请求是可以信赖的操作，但事实却是恰恰相反的，他们没有考虑到用户可以控制这些查询请求的参数，并且可以在其中输入符合语法的 SQL 命令。

解决 SQL 注入问题的方法再次归于对特殊字符的过滤，包括 URL、表格域以及用户可以控制的任何输入数据。与 SQL 语法相关的特殊字符以及保留字应当在查询请求提交到数据库之前进行过滤或者被去除（例如跟在反斜号后面的单引号）。过滤操作最好在服务器端进行。将过滤操作的代码插入到客户机端执行的 HTML 中，实在是不明智的，因为攻击者可以修改验证程序。防止破坏的唯一途径就是在服务器端执行过滤操作。避免这种攻击更加可靠的方式就是使用存储过程。具体可以通过以下若干方法来防范 SQL 注入攻击。

(1)对前台传入参数按的数据类型，进行严格匹配(如查看描述数据类型的变量字符串中，是否存在字母)。

(2)对于单一变量(如上面的 K，N)如果有必要，过滤或替换掉输入数据中的空格。

(3)将一个单引号（“'”），替换成两个连续的单引号（“''”）。

(4)限制输入数据的有效字符种类，排除对数据库操作有特殊意义的字符（如“--”）。

(5)限制表单或查询字符串输入的长度。

(6)用存储过程来执行所有的查询。

(7)检查提取数据的查询所返回的记录数量。如果程序只要求返回一个记录，但实际返回的记录却超过一行，那就当作出错处理。

(8)将用户登录名称、密码等数据加密保存。加密用户输入的数据，然后再将它与数据库中保存的数据比较，这相当于对用户输入的数据进行了“消毒”处理，用户输入的数据不再对数据库有任何特殊的意义，从而也就防止了攻击者注入 SQL 命令。

总而言之，就是要尽可能地限制用户可以存取的数据总数。另外，对用户要按“最小特权”安全原则分配权限，即使发生了 SQL 注入攻击，结果也被限制在那些可以被正常访问到的数据中。

2.合法性校验

(1)客户端进行合法性校验

在制作网站的时候，尤其是各种电子商务网站，首先都会让用户填写一些表格来获取注册用户的各种信息，因为用户有可能输入各式各样的信息，而有些不符合要求的数据会给服务器后台处理程序带来不必要的麻烦，甚至导致网站出现一些安全问题。因此我们在将这些信息保存到网站的数据库之前，要对这些用户所输入的信息进行数据合法性校验，以便服务器后台程序可以安全顺利地执行。

通过运行在客户端的的 JavaScript 或其它脚本可以检验用户的输入数据。在 JavaScript 中，利用 form.textfield.value 得到 form 表单的 textfield 文本框中输入的数据，然后通过 RegExp 对象（保存有关正则表达式模式匹配信息的固有全局对象）的 test 方法进行正则表达式模式匹配，通过匹配结果决定用户的后续操作。

(2)服务器进行合法性校验

在客户端对用户输入数据进行合法性校验是方便、高效的，将数据的校验工作放在客户端进行，这样既减少了服务器受攻击的风险，也减少了维护人员的维护工作，但同时它也存在着一定的风险和不足。

1)风险

对于采用如下方式进行用户名和密码验证方式的网站来说，仅通过客户端对用户输入数据进行校验是完全不够的。

用户登录 login.htm 页面，在文本框中输入了用户名和密码，login.htm 页面通过 GET 或 POST 方法将用户名和密码数据提交给了服务器端脚本，服务器端脚本通过查询数据库信息确定登录用户是否为合法用户。

当用户通过 login.htm 页面进行用户名和密码提交时，客户端数据检验是有效的。但当用户绕过 login.htm 页面，尝试通过 URL 进行登录时，客户端数据检验则不会起任何作用。用户依然可以通过构造输入数据来进行 SQL 注入攻击。

```
http://Web服务器/access.php?username=angel' or '1=1
```

2)不足

对 JavaScript 或其它脚本的运行，最终还是要取决于客户端所使用的 Web 浏览器，当编写的 JavaScript 不一定可以完全正常的运行在某一款浏览器上时，很有可能在客户端的 JavaScript 不会精确的检验用户输入的各种数据。而服务器脚本（如 JSP、PHP、Perl）程序，只是与服务器环境有关，无论客户端是什么浏览器，对于服务器脚本程序来说是没有分别的，所以选择使用服务器端的脚本程序来进行数据合法性的校验是一个好的选择。

3)PHP 脚本校验

通过 PHP 脚本函数 preg_match（进行正则表达式匹配）或 preg_match_all（进行全局正则表达式匹配）可对用户输入数据进行合法性校验。

```
int preg_match(<string pattern>, <string subject> [, array matches [, int flags]]);
```

●在 subject 字符串中搜索与 pattern 给出的正则表达式相匹配的内容。

●函数返回 pattern 所匹配的次数。要么是 0 次（没有匹配）或 1 次，因为 preg_match 在第一次匹配之后将停止搜索。preg_match_all 则相反，会一直搜索到 subject 的结尾处。如果出错 preg_match()返回 FALSE。

「注」如果只想查看一个字符串是否包含在另一个字符串中，不要用 preg_match。可以用 strpos 或 strstr 替代，要快得多。

以下范例 PHP 脚本，在文本中搜索“PHP”：

```
<?php
// 正则表达式分隔符后面的"i"表示不区分大小写字母的搜索
if (preg_match("/php/i", "PHP is the web scripting language of choice."))
{
    print "A match was found.";
}else
{
    print "A match was not found.";
}
?>
```

3.预编译 SQL 查询

(1)prepared statement

prepared statement 可以在执行具体的 SQL 查询前进行 SQL 预编译，这样在以后执行相同的 SQL 查询时，只需传入不同的参数，便可重复执行，而不用每次执行相同的 SQL 查询时都让服务器耗费时间进行编译。

下面是一个 prepared statement 的范例。

```
select * from new where id=?
```

其中符号“？”叫做占位符（placeholder），执行 SQL 时，必须传入参数，取代占位符，才能真正执行 SQL 查询。

在 SQL 查询中使用 prepared statement 可以增进安全性及效率。

1)prepared statement 把 SQL 的逻辑语句与传入的参数相分离，可以增加安全性，这样的做法，可以避免 SQL 注入攻击。如果使用一般的 SQL 查询，没有分离 SQL 逻辑与传入参数，就必须非常小心处理用户输入的数据，通常会使用一些特定的函数，限制单引号、双引号、斜杠等特征字符。但是当使用 prepared statement 时，根本不用使用特殊的函数来避免 SQL 注入的攻击，你可以直接使用 prepared statement，而不会造成任何 SQL 注入漏洞。

2)效率的提升来自 prepared statement 的一些特殊之处，首先 prepared statement 中的 SQL 查询只要预编译一次，之后执行的 SQL 查询就不用再做这些编译动作，如果要执行相同的 SQL 查询很多次，就可以增加执行的速度。另外，prepared statement 使用了 binary protocol，传统的 mysql 会将传入参数转换成字符串，再进行传入，但使用 binary protocol 后，不会进行参数的转换，而是直接将参数以原有的 binary 形式进行传入，降低了 cpu 的负荷，也减少了网络的占用率（转换成字符串，参数量会变大）。

(2)MySQL statement API

MySQL 在 4.1 及以上版本中提供了 prepared statement 功能，通过调用 statement API 接口函数可以实现 prepared statement。MySQL 由 mysql.stmt.Statement 对象提供 prepared statement 功能。

(3)PHP5 支持 prepared statement

PHP5 的 mysqli 扩展（Improved MySQL Extension）支持 prepared statement。它能够访问基于 MySQL4.1 及以下版本提供的特性。

五、实验步骤

1.客户端进行合法性校验

进行实验之前首先启动 MySQL 服务，命令如图 12.1 所示。

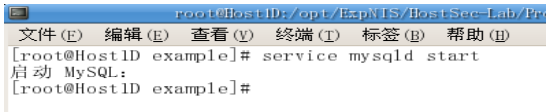


图 12.1 启动 MySQL 服务

(1)单击工具栏“控制台”按钮，进入实验目录。login 是存在 SQL 注入漏洞的 Web 应用程序。复制 login.htm 和 login.php 文件到/var/www/html/目录(Web 服务文档主目录)，如图 12.2 所示。



图 12.2 拷贝文件

(2)使用 Web 浏览器浏览 login.htm，在 URL 地址栏中输入：http://本机 IP 地址/login.htm，结果如图 12.3 所示。

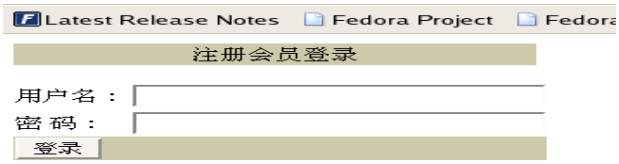


图 12.3 登陆后的界面

进入“注册会员登录”页面，用户名：hello，密码：hellopass，如图 12.4 所示，确定登录成功，如图 12.5 所示。

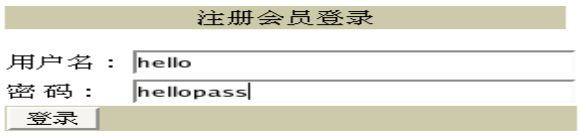


图 12.4 输入用户名和密码



图 12.5 登陆成功界面

(3)注入攻击

返回 login.htm 登录界面，输入用户名：hello' or '1=1，密码任意，如图 12.6 所示，尝试登录。

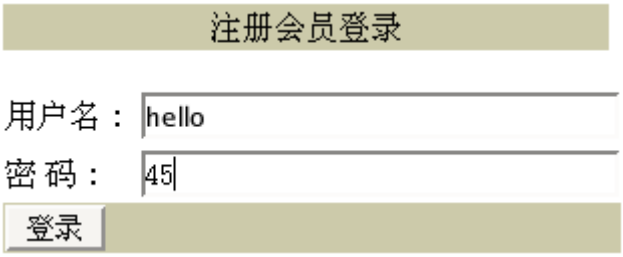


图 12.6 输入用户名和密码

由于 login.htm 没有对“用户名”、“密码”输入数据的合法性进行验证，从而导致了 SQL 被注入。

(4)编辑/var/www/html/login.htm 文件，利用 JavaScript 对用户输入数据进行合法性验证，限制用户输入“'”（单引号）、、“"”（双引号）、“-”、“=”、“;”、“>”、“<”、“/”、“%”特殊字符及 SQL 关键字。

(5)加入合法性校验后，尝试基于 login.htm 进行 SQL 注入攻击。

(6)加入合法性校验后，尝试基于 URL 进行 SQL 注入攻击。

2.服务器进行合法性校验

(1)重命名复制实验目录 login.htm 和 login.php 文件至/var/www/html/login2.htm 和 login2.php。

(2)编辑/var/www/html/login2.php 文件，利用 PHP 脚本对用户输入数据进行合法性验证，限制用户输入“'”（单引号）、“"”（双引号）、“-”、“=”、“;”、“>”、“<”、“/”、“%”特殊字符及 SQL 关键字。

(3)加入合法性校验后，尝试基于 login.htm 进行 SQL 注入攻击。

(4)加入合法性校验后，尝试基于 URL 进行 SQL 注入攻击。

3.预处理执行 SQL 查询

(1)重命名复制实验文件 login.htm 和 login.php 至/var/www/html/login3.htm 和 login3.php。

(2)编辑/var/www/html/login3.php 文件，重写 PHP 访问 MySQL 数据库部分，利用 prepared statement 实现 SQL 查询。

「说明」 关于 PHP5 mysql 扩展(Improved MySQL Extension)参见应用服务器 PHP 手册(http://应用服务器 IP/php/mysqli/index.html)。需要实验人员从手册中挖掘信息，理解 API 使用方法，编写代码。

(3)尝试进行各种 SQL 注入攻击。

实验十三 IPSec 安全协议

一、实验目的

1.了解 IPSec 主要协议
2.理解 IPSec 工作原理
3.Windows 环境下能够利用 IPSec 在两台主机间建立安全隧道

二、实验环境

Windows，交换网络结构

三、实验工具

网络协议分析器

四、实验原理

1.VPN 和 IPSec 概述

VPN 是英文 Virtual Private Network 的缩写，可译为虚拟专用网。它是采用隧道技术、加密和身份认证等方法，在公共网络上构建企业网络的技术。VPN 通过采用“隧道”技术，在 Internet 或国际互联网工程工作组（IETF）制定的统一标准下，在公众网形成企业的安全、机密、顺畅的专用链路。

在目前的虚拟专用网络解决方案中，最为值得关注的就是 IPSec(IP Security Protocol，IP 安全协议)。IPSec 是 IETF(www.ietf.org)以 RFC 形式公布的一组安全 IP 协议集，是在 IP 级为 IP 业务提供保护的安全协议标准，其基本的目的就是把安全机制引入 IP 协议，通过使用现代密码学方法支持机密性和认证服务，使用户能有选择的使用，并得到所期望的安全服务。

IPSec 作为一套标准的集合，包括加密技术、Hash 算法 Internet 密钥交换、AH（Authentication Header，认证报头）、ESP(Encapsulation Security Payload，封装安全载荷)等协议，在需要时还可以互相组合。

IPSec 是基于 OSI 第三层网络层的隧道协议，使用包作为数据交换单位，将 IP 包封装在附加的 IP 包头中，通过 IP 网络发送。

IPSec 提供了一种标准的、健壮的以及包容广泛的机制，可用为 IP 协议及上层协议提供

以下几种安全服务：数据源验证，确保收到的数据的发送者为实际的发送者；数据完整性，确保数据在传输过程中未被非法篡改；抗重播保护，防止数据被假冒者复制存储并重复发送；信息机密性，确保数据在传输过程中不被偷看。IPSec 定义了一套默认的、强制实施的算法，以确保不同的实施方案可以共通。

IPSec 也存在一些缺点：IPSec 需要已知或固定范围的 IP 地址，所以在动态分配地址时不适合 IPSec；除了 TCP/IP 协议以外，IPSec 不支持其它协议；除了包过滤处，它没有指定其它访问控制方法，对于采用 NAT 方式访问公共网络的情况难以处理。

IPSec 规范包含很多文档，最重要的文档是在 1998 年 11 月发布的 RFC2401、2402、2406 和 2408。

2.IPSec 服务

IPsec 通过让系统选择所需的安全协议，决定服务中使用的算法和为请求服务提供任何加密密钥来实现 IP 级的安全服务。有两种协议可以用来提供安全性：一个是使用 AH 协议报头指定的认证协议；另一个是由用于该协议的包格式指定的加密/认证联合协议 ESP。

表 13.1 描述了 AH 和 ESP 提供的各种服务。对于 ESP 而言，有两种情况：带认证选项和不带认证选项。AH 和 ESP 都是访问控制的工具，它们都基于密钥分发以及与这些安全协议相关的流管理。

表 13.1 IPSec 传输方式比较

	AH（认证报头）	ESP（仅加密）	ESP（加密和认证）
访问控制	√	√	√
无连接完整性	√		√
数据源认证	√		√
拒绝重放包	√	√	√
保密性		√	√
受限制的流量保密性		√	√

3.安全关联

在 IP 保密和认证的机制中的一个关键概念是安全关联（security association，SA）。关联是发送方和接收方之间的单向关系，该关联为其上的流提供安全服务。如果一个双向安全交换需要一个对等的关系，那么就要建立两个安全关联。安全服务由 AH 或者 ESP 来提供给 SA，但是它们不能同时提供。

安全参数索引（security parameters index，SPI）：赋给此 SA 的一个仅在本地有意义的字节串，此 SPI 由 AH 和 ESP 报头携带，使得接收系统能选择合适的 SA(接收到的数据包将在此 SA 下处理)。

IP 目的地址(IP destination address)：目前仅允许使用单播地址，这是 SA 的目的端点地址，可以是终端用户系统或者防火墙、路由器这样的网络系统。

安全协议标识（security protocol identifier）：它标识关联是一个 AH 安全关联还是一个 ESP 安全关联。

因此，在任何 IP 包中，安全关联由 IP 报头的目的地址唯一标识，而 SPI 被标识在封装扩展报头中（AH 或者 ESP）。

4.传输模式和隧道模式

AH 和 ESP 都支持两种工作模式：传输模式和隧道模式。

(1)传输模式

传输模式主要为上层协议提供保护。也就是说，传输模式增强了对 IP 包上层负载的保护，如对 TCP 段、UDP 段和 ICMP 包的保护(这些均直接运行在 IP 网络层之上)。一般地，传输模式用于在两个主机(如客户端和服务器、两个工作站)之间进行端对端的通信。当主机在 IPv4 上运行 AH 或 ESP 时，其上层负载通常是接在 IP 报头后面的数据。传输模式下的 ESP 加密和认证(认证可选)IP 载荷，则不包括 IP 报头。

AH、ESP 协议的传输工作模式(基于 IPv4)如图 13.1 所示。



图 13.1 传输模式网络封包

(2)隧道模式

隧道模式对整个 IP 包提供保护。为了达到这个目的，在把 AH 或者 ESP 域添加到 IP 包中后，整个包加上安全域被作为带有新外部 IP 报头的新“外部”IP 包的载荷。整个原始的或者说是内部的包在“隧道”上从 IP 网络中的一个节点传输到另一个节点，沿途的路由器不能检查内部的 IP 报头。因为原始的包被封装，新的更大的包有完全不同的源地址和目的地址，因此增加了安全性。隧道模式被使用在当 SA 的一端或者两端为安全网关时，比如使用 IPSec 的防火墙和路由器。

AH、ESP 协议的隧道工作模式（基于 IPv4）如图 13.2 所示。

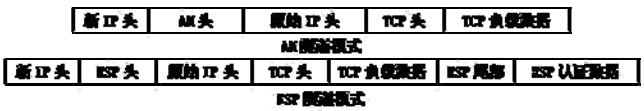


图 13.2 隧道模式网络封包

5.IPSec 工作原理

IPSec 包含 4 类组件：

(1)IPSec 进程本身：验证头协议(AH)或封装安全载荷协议(ESP)；

(2)Internet 密钥交换协议(IKE，Internet Key Exchange)：进行安全参数协商；

(3)SADB(SA Database)：用于存储安全关联(SA，Security Association)等安全相关参数；

(4)SPD(Security Policy Database，安全策略数据库)：用于存储安全策略。

IPSec 的工作原理类似于包过滤防火墙。IPSec 是通过查询安全策略数据库 SPD 来决定接收到的 IP 包的处理，但不同于包过滤防火墙的是，IPSec 对 IP 数据包的处理方法除了丢弃、直接转发(绕过 IPSec)外，还有进行 IPSec 的处理。进行 IPSec 处理意味着对 IP 数据包进行加密和认证，保证了在外部网络传输的数据包的机密性、真实性、完整性，使通过 Internet 进行安全的通信成为可能。

在 IETF 的标准化下，IPSec 的处理流程受到了规范。

(1)IPSec 流出处理

如图 13.3，在流出处理过程中，传输层的数据包流进 IP 层，然后按如下步骤执行。

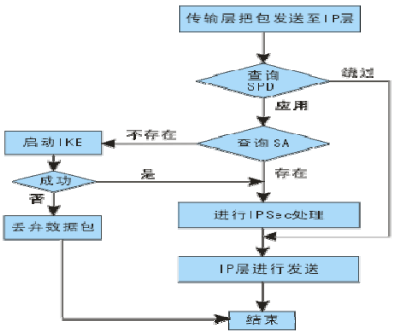


图 13.3 IPSec 流出处理流程

1)查找合适的安全策略。从 IP 包中提取出“选择符”来检索 SPD，找到该 IP 包所对应的流出策略，之后用此策略决定对该 IP 包如何处理：绕过安全服务以普通方式传输此包或应用安全服务。

2)查找合适的 SA。根据策略提供的信息，在安全关联数据库中查找为该 IP 包所应该应用的安全关联 SA。如果此 SA 尚未建立，则会调用 IKE，将这个 SA 建立起来。此 SA 决定了使用何种基本协议(AH 或 ESP)，采用哪种模式(隧道模式或传输模式)，以及确定了加密算法，验证算法，密钥等处理参数。

3)根据 SA 进行具体处理。根据 SA 的内容，对 IP 包的处理将会有几种情况：使用隧道模式下的 ESP 或 AH 协议，或者使用传输模式下的 ESP 或 AH 协议。

(2)IPSec 流入处理

如图 13.4，在流入处理过程中，数据包的处理按如下步骤执行。

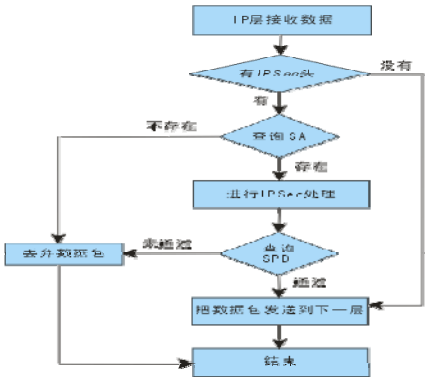


图 13.4 IPSec 流入处理流程

1)IP 包类型判断：如果 IP 包中不包含 IPSec 头，将该包传递给下一层；如果 IP 包中包含 IPSec 头，会进入下面的处理。

2)查找合适的 SA：从 IPSec 头中摘出 SPI，从外部 IP 头中摘出目的地址和 IPSec 协议，然后利用<SPI，目的地址，协议>在 SAD 中搜索 SPI。如果 SA 搜索失败就丢弃该包。如果找到对应 SA，则转入以下处理。

3)具体的 IPSec 处理：根据找到的 SA 对数据包执行验证或解密进行具体的 IPSec 处理。

4)策略查询：根据选择符查询 SPD，根据此策略检验 IPSec 处理的应用是否正确。最后，将 IPSec 头剥离下来，并将包传递到下一层，根据采用的模式的不同，下一层或者是传输层，或者是网络层。

五、实验步骤

1.IPsec 虚拟专用网络的设置

(1)进入 IPsec 配置界面

1)主机 A、B 通过“开始”|“程序”|“管理工具”|“本地安全策略”打开 IPSec 相关配置界面。

2)在默认情况下 IPsec 的安全策略处于没有启动状态，必须进行指定，IPsec 才能发挥作用。IPsec 包含以下 3 个默认策略，如图 13.5 所示。

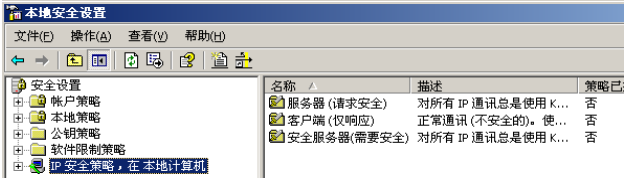


图 13.5 本地安全设置

安全服务器：对所有 IP 通讯总是使用 Kerberos 信任请求安全。不允许与不被信任的

客户端的不安全通讯。这个策略用于必须采用安全通道进行通信的计算机。

客户端：正常通信，默认情况下不使用 IPSec。如果通信对方请求 IPSec 安全通信，则可以建立 IPSec 虚拟专用隧道。只有与服务器的请求协议和端口通信是安全的。

服务器：默认情况下，对所有 IP 通信总是使用 Kerberos 信任请求安全。允许与不响应请求的客户端的不安全通信。

3)以上策略可以在单台计算机上进行指派，也可以在组策略上批量指派，为了达到通过协商后双方可以通信的目的，通信双方都需要设置同样的策略并加以指派。

(2)定制 IPSec 安全策略

1)双击“安全服务器(需要安全)”项，进入“安全服务器属性”页，如图 13.6 所示，可以看到在“规则”页签中已经存在 3 个“IP 安全规则”，单击“添加”按钮，进入向导添加新安全规则。

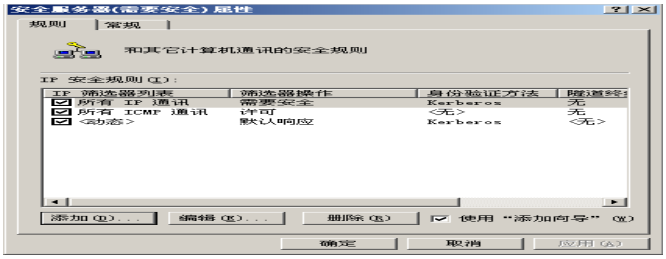


图 13.6 安全服务器属性

2)在本练习中，实现的是两台主机之间的 IPSec 安全隧道，而不是两个网络之间的安全通信，因此，选择“此规则不指定隧道”，即选用传输模式 IPSec，如图 13.7 所示，选中后单击“下一步”按钮。

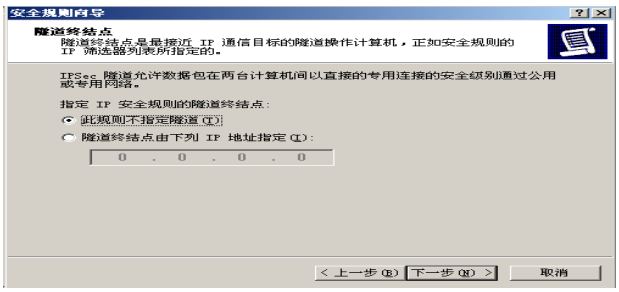


图 13.7 安全规则向导设置

3)在选择网络类型的界面。安全规则可以应用到 3 种网络类型：所有网络连接、局域网(LAN)和远程访问。本练习中，我们选择“所有网络连接”，如图 13.8 所示，单击“下一步”按钮。

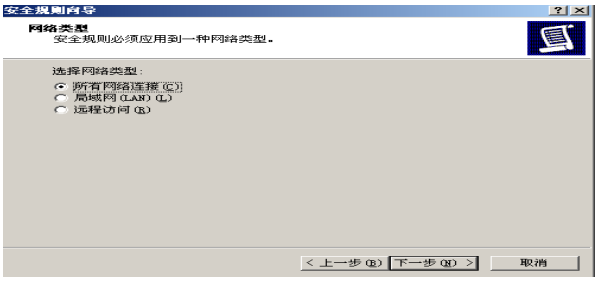


图 13.8 网络类型设置

4)在 IP 筛选器列表界面。我们定制自己的筛选操作，单击“添加”按钮，进入“IP 筛选器列表”界面，如图 13.9 所示。

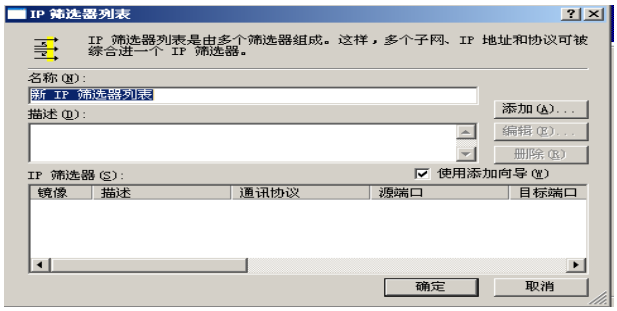


图 13.9 IP 筛选器列表

5)定制自己的 IP 筛选器。点击“添加”按钮进入“IP 筛选器向导”，单击“下一步”按钮。

6)在“IP 筛选器描述和镜像属性”的“描述”中，可自由添加对新增筛选器的解释信息，在这里输入“与同组主机进行安全的 icmp 通信”，如图 13.10 所示，单击“下一步”按钮。

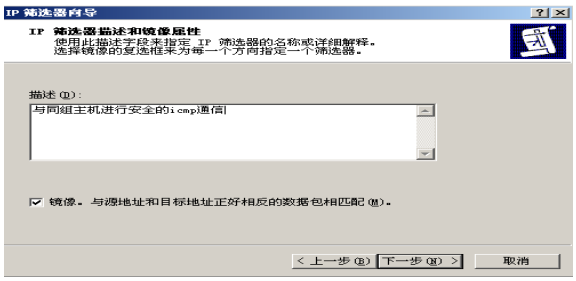


图 13.10 筛选器描述

7)IP 通信源选择“我的 IP 地址”，单击“下一步”按钮。

8)IP 通信目标选择“一个特定的 IP 地址”，IP 地址填写：同组主机 IP，如图 13.11 所示，单击“下一步”按钮。

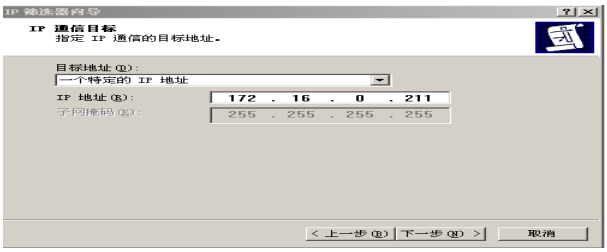


图 13.11 设定特定 IP

9)选择“ICMP”协议类型，如图 13.12 所示，单击“下一步”按钮。单击“完成”按钮，完成定制 IP 筛选器。

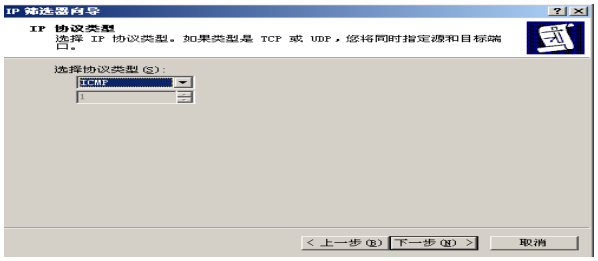


图 13.12 IP 协议类型

10)单击“确定”按钮，退出“IP 筛选器列表”对话框。

操作界面返回到“安全规则向导”，设置新的 IP 筛选器：

1)在“IP 筛选器列表”中选中“新 IP 筛选器列表”，单击“下一步”按钮。

2)在“筛选器操作”界面单击“添加”按钮新建筛选器操作，在弹出的“筛选器操作向导”界面中，单击“下一步”按钮，进入安全服务规则向导，如图 13.13 所示。

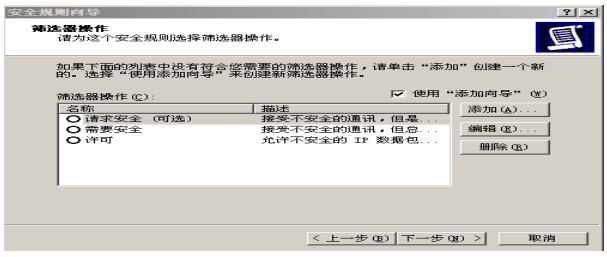


图 13.13 筛选器规则设置

3)新的筛选器操作名称为“安全的 ICMP 通信”，描述自定义，如图 13.14 所示，单击“下一步”按钮。

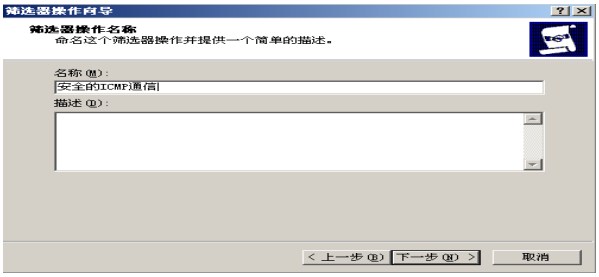


图 13.14 确定筛选器操作名称

4)在“筛选器操作常规选项”中选中“协商安全”，如图 13.15 所示，单击“下一步”

按钮。

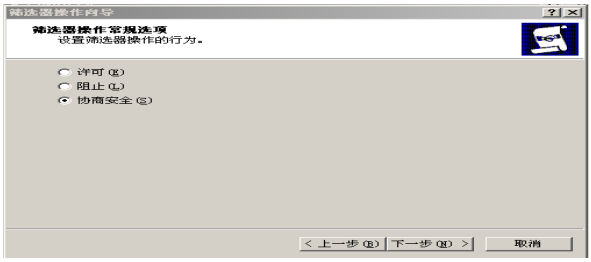


图 13.15 设置筛选器操作

5)选中“不与不支持 IPSec 的计算机通信”，如图 13.16 所示，单击“下一步”按钮。

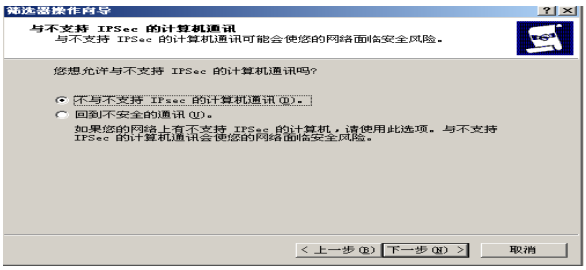


图 13.16 IPSec 通信设置

6)在“IP 通信安全措施”中，选择“完整性和加密”，如图 13.17 所示，单击“下一步”按钮，直至最后完成筛选器操作设置。

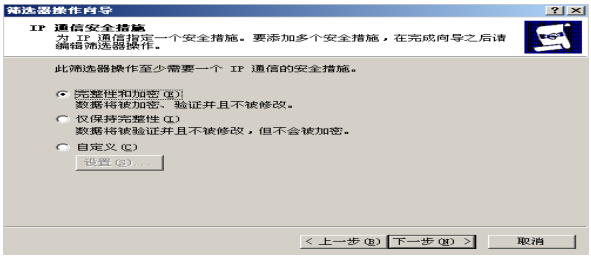


图 13.17 IP 通讯安全措施设置

7)返回到“安全规则向导”，在“筛选器操作”列表中选中“安全的 ICMP 通信”，如图 13.18 所示，单击“下一步”按钮。

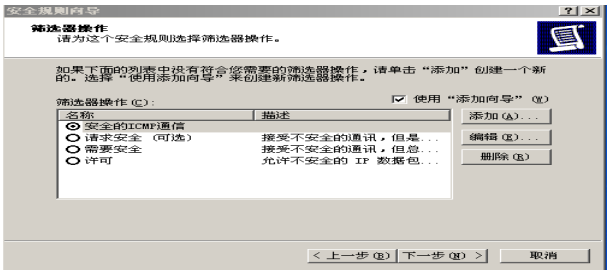


图 13.18 选择筛选器操作

8)在“身份验证方法”界面。选中“使用此字符串保护密钥交换(预共享密钥)”，填写共享密钥“jlcss”(主机 A、主机 B 的共享密钥必须一致)，如图 13.19 所示，单击“下一步”按钮，直至最终完成。

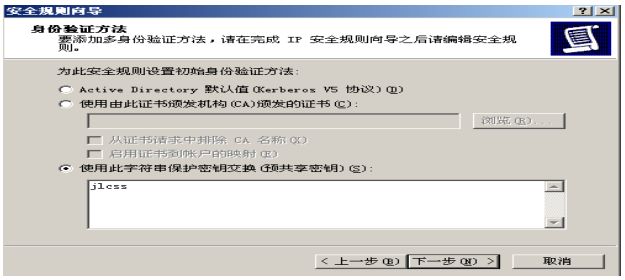


图 13.19 身份验证方法

2.IPsec 虚拟专用网络的检测

「注」 应用策略之前必须指派策略，否则策略不会自动生效。右键点击“安全服务器”，选择“指派”使策略生效。

(1)主机 A 不指派策略，主机 B 不指派策略。

主机 A 在控制台中，输入如下命令：ping 主机 B 的 IP，填写 ping 操作反馈信息。

(2)主机 A 指派策略，主机 B 不指派策略。

主机 A 在控制台中，输入如下命令：ping 主机 B 的 IP，填写 ping 操作反馈信息。

(3)主机 A 不指派策略，主机 B 指派策略。

主机 A 在控制台中，输入如下命令：ping 主机 B 的 IP，填写 ping 操作反馈信息。

(4)主机 A 指派策略，主机 B 指派策略。

主机 A 在控制台中，输入如下命令：ping 主机 B 的 IP，填写 ping 操作反馈信息。

3.协议分析 ESP

首先确保主机 A、主机 B 均已指派策略。

(1)主机 A、B 进入实验平台，单击工具栏“协议分析器”按钮，启动协议分析器。定义过滤器，设置“网络地址”过滤为“主机 A 的 IP<—>主机 B 的 IP”；单击“新建捕获窗口”按钮，点击“选择过滤器”按钮，确定过滤信息。在新建捕获窗口工具栏中点击“开始捕获数据包”按钮，开始捕获数据包。

(2)主机 A 在控制台中对主机 B 进行 ping 操作。

(3)待主机 A ping 操作完成后，主机 A、B 协议分析器停止数据包捕获。切换至“协议解析”视图，观察分析源地址为主机 A 的 IP、目的地址为主机 B 的 IP 的数据包信息，如图 13.20 所示。

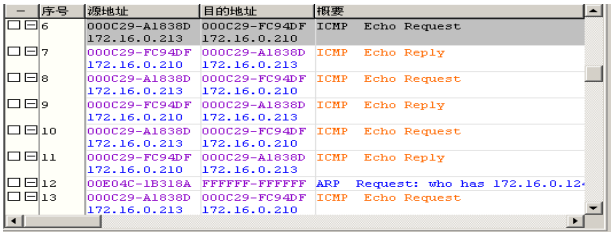


图 13.20 概要解析

(4)分析右侧协议树显示区中详细解析及下侧十六进制显示区中的数据，参照图 13.21，按照链路层报头（默认 14 字节）→网络层报头（本实验中为 20 字节）→ESP 报头的顺序解析数据，回答下列问题：

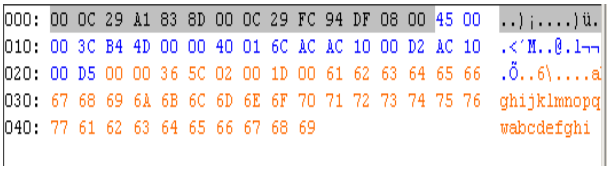


图 13.21 ESP 十六进制数据

ESP 协议类型值（十进制）：_____

安全参数索引(SPI)值是：_____

序列号是：_____

ICMP 负载是否被加密封装：_____

4.协议分析 AH

(1)主机 A、B 同时进行如下操作，修改“ICMP 安全通信策略”，利用 AH 协议对数据源进行身份验证，而不对传输数据进行加密处理。

(2)在“本地安全设置”界面中，双击“安全服务器(需要安全)”。

(3)在“属性”对话框中，双击“新 IP 筛选器列表”。

(4)在“编辑规则 属性”对话框中，选择“筛选器操作”页签，双击“安全的 ICMP 通信”。

(5)在“属性”对话框中，选择“安全措施”页签，在“安全措施首选顺序”中，双击唯一的一条规则。

(6)在“编辑安全措施”对话框中，选中“自定义”，单击“设置”按钮，具体操作如图 13.22 所示。



图 13.22 自定义安全措施设置

单击“确定”按钮，直至最后。

(7)主机 A、B 再次启动协议分析器，过滤规则不变，开始捕获数据包。

(8)主机 A 对主机 B 进行 ping 操作，待操作完成，如图 13.23 所示，协议分析器停止捕获数据包。切换至“协议解析视图”，观察十六过制显示区数据，参照图 13.24，按照链路层报头（默认 14 字节）→网络层报头（本实验中为 20 字节）→AH 报头的顺序解析数据，回答下列问题。

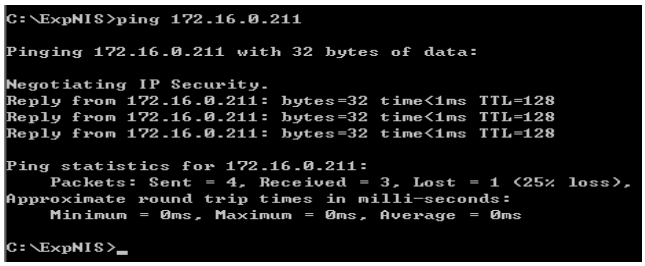


图 13.23 ping 操作

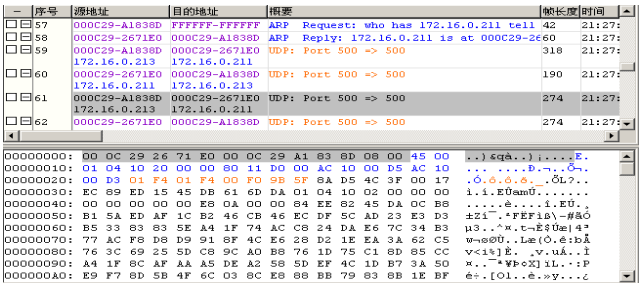


图 13.24 AH 十六进制数据

AH 协议类型值（十进制）：

下一个报头所标识的协议类型是：

载荷长度值是：

由该值计算出 AH 报头总长度是：

具体计算方法：

安全参数索引值是：

ICMP 负载是否被加密封装：

实验十四 信息搜集

一、实验目的

1.了解信息搜集的一般步骤
2.学会熟练使用 ping 命令
3.学会利用 nmap 等工具进行信息搜集

二、实验环境

Windows，Linux，企业网络结构

三、实验工具

Nmap，网络协议分析器

四、实验原理

1.信息搜集步骤

攻击者搜集目标信息一般采用七个基本的步骤：
(1)找到初始信息，比如一个 IP 地址或者一个域名；
(2)找到网络地址范围，或者子网掩码；
(3)找到活动机器；
(4)找到开放端口和入口点；
(5)弄清操作系统；
(6)弄清每个端口运行的是哪种服务；
(7)画出网络结构图。

2.ping 命令概述

使用 ping 可以测试目标主机名称和 IP 地址，验证与远程主机的连通性，通过将 ICMP 回显请求数据包发送到目标主机，并监听来自目标主机的回显应答数据包来验证与一台或多台远程主机的连通性，该命令只有在安装了 TCP/IP 协议后才可以使用。

ping 命令格式：ping [选项] 目标主机。

生存时间（TTL）：指定数据报被路由器丢弃之前允许通过的网段数量。TTL 是由发送主机设置的，以防止数据包在网络中循环路由。转发 IP 数据包时，要求路由器至少将 TTL 减小 1。

3.nmap 概述

nmap 是一个网络探测和安全扫描程序，系统管理者和个人可以使用这个软件扫描大型的网络，获取哪台主机正在运行以及提供什么服务等信息。nmap 支持很多扫描技术，例如：UDP、TCP connect()、TCP SYN(半开扫描)、ftp 代理(bounce 攻击)、反向标志、ICMP、FIN、ACK 扫描、圣诞树(Xmas Tree)、SYN 扫描和 null 扫描。nmap 还提供了一些高级的特征，例如：通过 TCP/IP 协议栈特征探测操作系统类型，秘密扫描，动态延时和重传计算，并行扫描，通过并行 ping 扫描探测关闭的主机，诱饵扫描，避开端口过滤检测，直接 RPC 扫描(无须端口映射)，碎片扫描，以及灵活的目标和端口设定。

nmap 运行通常会得到被扫描主机端口的列表。nmap 总会给出 well known 端口的服务名(如果可能)、端口号、状态和协议等信息。每个端口的状态有：open、filtered、unfiltered。open 状态意味着目标主机能够在这个端口使用 accept()系统调用接受连接。filtered 状态表示：防火墙、包过滤和其它的网络安全软件掩盖了这个端口，禁止 nmap 探测其是否打开。unfiltered 表示：这个端口关闭，并且没有防火墙/包过滤软件来隔离 nmap 的探测企图。通常情况下，端口的状态基本都是 unfiltered 状态，只有在大多数被扫描的端口处于 filtered 状态下，才会显示处于 unfiltered 状态的端口。

根据使用的功能选项，nmap 也可以报告远程主机的下列特征：使用的操作系统、TCP 序列、运行绑定到每个端口上的应用程序的用户名、DNS 名、主机地址是否是欺骗地址、以及其它一些东西。有关 namp 的命令可参考命令帮助。

五、实验步骤

下面以 Windows 环境为例进行说明，此实验主机 A 可与 B 同时相互搜集对方信息，下面的步骤以主机 A 为例讲解。

(1) ping 探测

主机 A 开启命令行，对主机 B 进行 ping 探测，如图 14.1 所示，根据主机 B 的回复，可以确定主机 A 和主机 B 之间的连通情况，还可以根据回复数据包的 TTL 值对操作系统进行猜测。

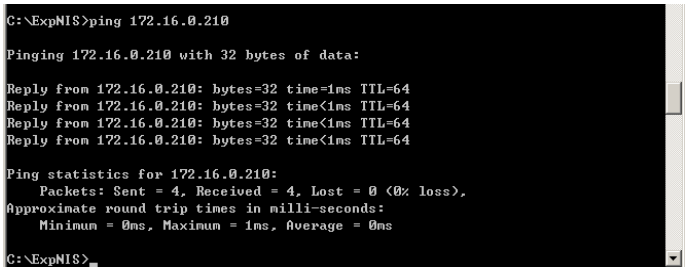


图 14.1 ping 操作的结果

回复数据包的 TTL 值：

主机 B 操作系统可能为：

(2)Nmap 扫描

1)对活动主机进行端口扫描

主机 A 使用 Nmap 工具对主机 B 进行 TCP 端口同步扫描(范围 1-150)，如图 14.2 所示。

nmap 命令：nmap –pT 1-150 172.16.0.210

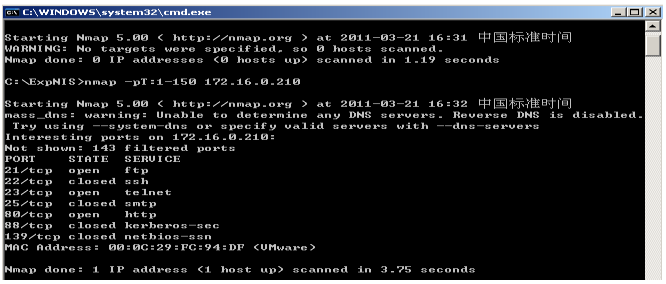


图 14.2 TCP 端口同步扫描

主机 B 开放的 TCP 端口：

对主机 B 进行 UDP 端口扫描（范围是 110-140）：

Nmap 命令；

主机 B 开放的 UDP 端口：

2)对活动主机操作系统进行探测

主机 A 对主机 B 进行 TCP/IP 指纹特征扫描，如图 14.3 所示。

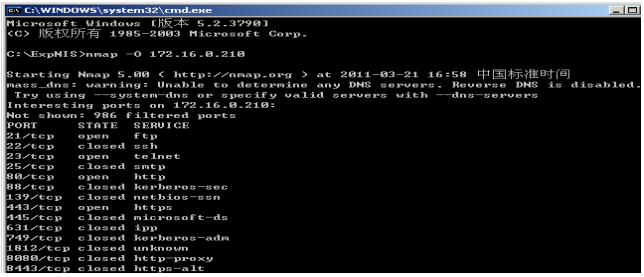


图 14.3 指纹特征扫描

3)对活动主机运行服务进行探测

主机 A 单击平台工具栏“协议分析器”按钮，启动协议分析器进行数据包捕获。打开

IE 在地址栏中输入 http://主机 B 的 IP，访问主机 B 的 web 服务，停止协议分析器，查看捕获结果。图 14.4 可做为参考。

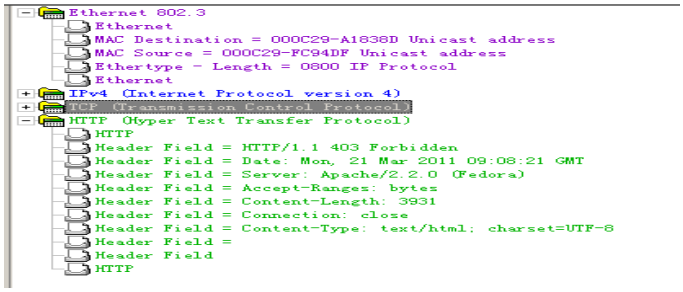


图 14.4 捕获结果

4)对活动主机 IP 协议进行探测

主机 A 使用 nmap 命令对主机 B 进行 IP 协议探测，如图 14.5 所示。

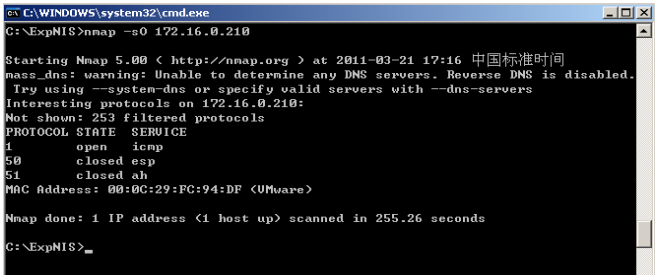


图 14.5 IP 协议探测

(3)探测总结

根据上述实验所得结果，填写下表。

目标主机 IP	目标主机 MAC	目标主机开放端口	目标主机操作系统
目标主机开放服务	目标主机服务软件	服务软件版本	主机支持的 IP 协议

六、问题思考

1. 137/UDP 端口提供的是什么服务？Linux 系统是否提供此服务?

实验十五 综合扫描与安全评估

一、实验目的

1.熟悉 X-Scan 工具的使用方法
2.利用 Windows Sockets 编写网络应用程序

二、实验环境

Windows，交换网络结构

三、实验工具

FTPScan，X-Scan，网络协议分析器

四、实验原理

1.漏洞扫描概述

漏洞扫描是一种网络安全扫描技术，它基于局域网或 Internet 远程检测目标网络或主机安全性。通过漏洞扫描，系统管理员能够发现所维护的 Web 服务器的各种 TCP/IP 端口的分配、开放的服务、Web 服务软件版本和这些服务及软件呈现在 Internet 上的安全漏洞。漏洞扫描技术采用积极的、非破坏性的办法来检验系统是否含有安全漏洞。网络安全扫描技术与防火墙、安全监控系统互相配合使用，能够为网络提供很高的安全性。

漏洞扫描分为利用漏洞库的漏洞扫描和利用模拟攻击的漏洞扫描。

利用漏洞库的漏洞扫描包括：CGI 漏洞扫描、POP3 漏洞扫描、FTP 漏洞扫描、SSH 漏洞扫描和 HTTP 漏洞扫描等。

利用模拟攻击的漏洞扫描包括：Unicode 遍历目录漏洞探测、FTP 弱口令探测、OPENRelay 邮件转发漏洞探测等。

2.漏洞扫描方法

1)漏洞库匹配法

基于漏洞库的漏洞扫描，通过采用漏洞规则匹配技术完成扫描。漏洞库是通过以下途径获取的：安全专家对网络系统的测试、黑客攻击案例的分析以及系统管理员对网络系统安全配置的实际经验。漏洞库信息的完整性和有效性决定了漏洞扫描系统的功能，漏洞库应定期修订和更新。

2)插件技术(功能模块技术)

插件是由脚本语言编写的子程序，扫描程序可以通过调用它来执行漏洞扫描，检测系统中存在的漏洞。插件编写规范化后，用户可以自定义新插件来扩充漏洞扫描软件的功能。这种技术使漏洞扫描软件的升级维护变得相对简单。

3.弱口令

通常帐户包含用户名及对应的口令。当口令使用简单的数字和字母组合时，非常容易被破解，称这种口令为弱口令。X-Scan 工具中涵盖了很多种弱口令扫描方法，包括 FTP、SMTP、SSH、POP3、IMAP、TELNET、WWW 等。

为消除弱口令产生的安全隐患，需要设置复杂的密码，并养成定期更换密码的良好习惯。复杂的密码包含数字，字母（大写或小写），特殊字符等。例如：123$%^jlcss2008 或 123$%^JLCSS2008。

4.Microsoft-ds 漏洞

Windows 系统存在一个拒绝服务漏洞，因为 Windows 默认开启的 microsoft-ds 端口(TCP 445)允许远程用户连接。当远程用户发送一个非法的数据包到 microsoft-ds 端口(TCP 445)时，核心资源被 LAN、MAN 服务占用，导致拒绝服务攻击，造成蓝屏。如一个攻击者发送一个连续的 10k 大小的 NULL 字串数据流给 TCP 端口 445 时，引起的最常见的症状是 LAN、MAN 服务将占用大量的核心内存，计算机发出的“嘀嘀嘀…”的告警声将被声卡驱动无法装载的错误状态所替代，IIS 不能为 asp 的页面服务，作为管理员去重启服务器时，系统将会显示你没有权限关闭或重启计算机。严重的话，以后计算机只要一打开，就会自动消耗 100%的 CPU 资源，根本无法进行正常的工作，而且很难恢复过来。

五、实验步骤

1.开放服务扫描

1)设置扫描范围

本机进入实验平台，单击工具栏“X-Scan”按钮，启动 X-Scan。依次选择菜单栏“设置”|“扫描参数”菜单项，打开扫描参数对话框。在“检测范围”参数中指定扫描 IP 的范围，在“指定 IP 范围”输入要检测同组主机域名或 IP，也可以对多个 IP 进行检测，例如“202.0.0.68-202.0.0.160”，这样就对这个网段的主机进行检测。这里对单一的 IP 进行扫描，输入同组主机 IP，如图 15.1 所示。

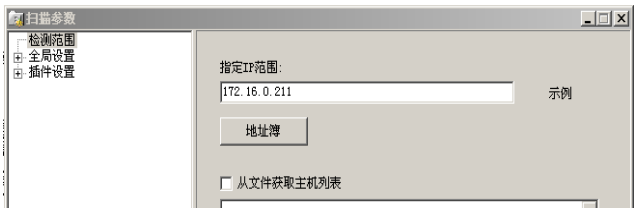


图 15.1　输入 IP 范围

2)全局设置

本机在“全局设置”的“扫描模块”选项里，可以看到待扫描的各种选项，先只对开放服务进行扫描，选择“开放服务”选项，如图 15.2 所示。

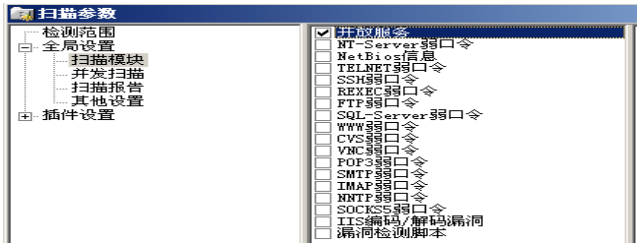


图 15.2 扫描模块设置

“并发扫描”选项中可设置线程和并发主机数量，这里选择默认设置，如图 15.3 所示。

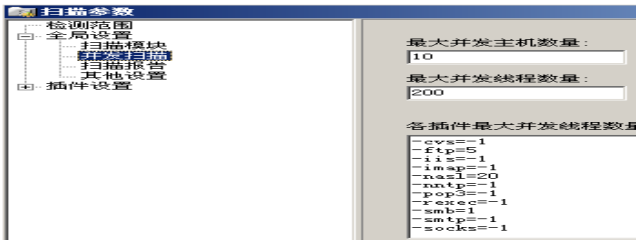


图 15.3 主机数量和线程数量设置

“其他设置”选项中，如果对单一主机进行扫描时，通常选择“无条件扫描”选项，如图 15.4 所示。

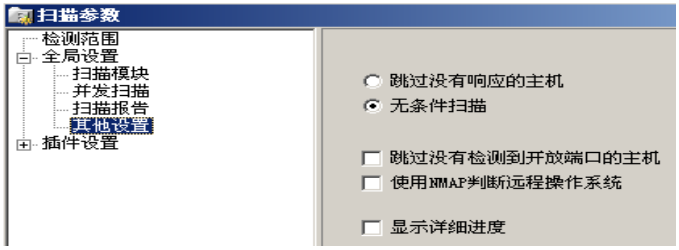


图 15.4 其他设置

选择此选项时 X-Scan 会对目标进行详细检测，这样结果会比较详细也会更加准确，但扫描时间会延长。

当对方禁止 ICMP 回显请求时，如果设置了“跳过没有响应的主机”选项，X-Scan 会自动跳过该主机，自动检测下一台主机。

3)插件设置

在“端口相关设置”选项中可以自定义一些需要检测的端口。检测方式有“TCP”、“SYN”两种，TCP 方式容易被对方发现，准确性要高一些；SYN 则相反。在这里选用 TCP 方式，如图 15.5 所示。

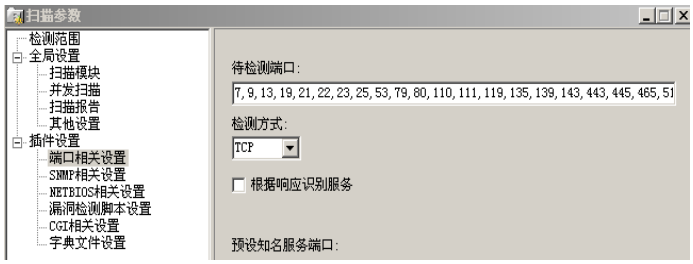


图 15.5 端口设置

4)开始扫描

扫描前请同组主机打开协议分析器，进入“设置”|“定义过滤器”|“选择协议过滤”，设置过滤协议为“HTTP”、“FTP”(如图 15.6)，单击“新建捕获窗口”按钮，点击“选择过滤器”按钮，确定过滤信息。在新建捕获窗口工具栏中点击“开始捕获数据包”按钮，开始捕获数据包。

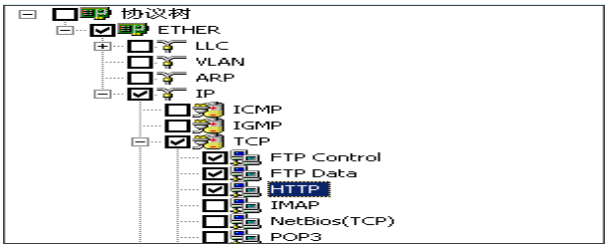
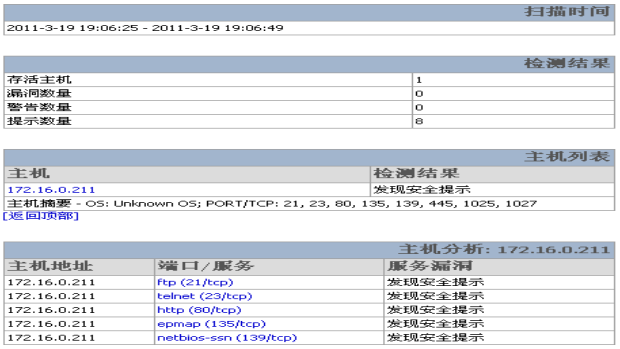


图 15.6 设置过滤协议

本机设置好 X-Scan 的相关参数，单击“确定”按钮，然后单击“开始扫描”。X-Scan 会对同组主机进行详细检测，扫描过程中如果出现错误会在“错误信息”中看到。

5)结束扫描

本机在进行扫描过程中如果检测到漏洞的话，可在“漏洞信息”中查看。扫描结束以后自动弹出检测报告，包括漏洞的信息，如图 15.7 所示。



扫描时间
2011-3-19 19:06:25 - 2011-3-19 19:06:49

检测结果	
存活主机	1
漏洞数量	0
警告数量	0
提示数量	8

主机列表	
主机	检测结果
172.16.0.211	发现安全提示
主机摘要 - OS: Unknown OS; PORT/TCP: 21, 23, 80, 135, 139, 445, 1025, 1027	

[返回顶部]

主机分析: 172.16.0.211		
主机地址	端口/服务	服务漏洞
172.16.0.211	ftp (21/tcp)	发现安全提示
172.16.0.211	telnet (23/tcp)	发现安全提示
172.16.0.211	http (80/tcp)	发现安全提示
172.16.0.211	epmap (135/tcp)	发现安全提示
172.16.0.211	netbios-ssn (139/tcp)	发现安全提示

图 15.7 检测报告

还有安全漏洞及解决方案，如图 15.8 所示，以便对同组主机进行详细的分析。



安全漏洞及解决方案: 172.16.0.211		
类型	端口/服务	安全漏洞及解决方案
提示	ftp (21/tcp)	**TCP port** ftp
提示	telnet (23/tcp)	**TCP port** telnet
提示	http (80/tcp)	**TCP port** http
提示	epmap (135/tcp)	**TCP port** epmap
提示	netbios-ssn (139/tcp)	**TCP port** netbios-ssn
提示	microsoft-ds (445/tcp)	**TCP port** microsoft-ds
提示	network blackjack (1025/tcp)	**TCP port** network blackjack
提示	unknown (1027/tcp)	**TCP port** unknown

图 15.8 安全漏洞及解决方案

报告保存在 X-Scan 文件夹下的 log 目录中（C:\ExpNIS\NetAD-Lab\Tools\XScan\log）。报告中可以查看同组主机中开放的端口以及提供的服务。

6)分析扫描结果

本机分析扫描器生成的扫描结果，对存在的漏洞进行风险评估。

请同组主机停止协议分析器，观察协议分析器中本机与同组主机的会话情况。

「注」由于开放服务扫描携带的信息具有随机性和不可见性，因此在协议分析器解析 FTP 命令时在会话交互图上会出现命令乱码现象，属于正常。”

2.漏洞检测脚本扫描

1)本机对扫描器进行设置

在“全局设置”|“扫描模块”中只选择“漏洞检测脚本”，如图 15.9 所示，其它设置与任务一相同。

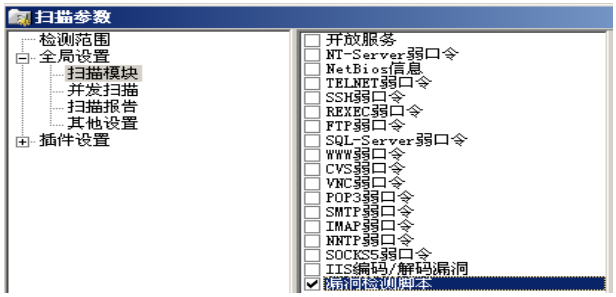


图 15.9 扫描模块设置

2)开始扫描

同组主机关闭协议分析器“捕获窗口”，设置协议分析器的捕获缓冲区大小为 8M，具体操作方法如下：单击菜单栏“设置”，选择“捕获缓冲区大小”，选择“8M”，如图 15.10 所示。



图 15.10 缓冲区大小设置

定义过滤器 | 协议过滤，选择协议“FTP Control”和“FTP Data”，如图 15.11 所示。



图 15.11 过滤协议设置

新建“捕获窗口”，选择此前设置的过滤器，开始捕获。

本机对同组主机进行扫描。

3)结束扫描

本机对扫描器生成的扫描结果进行分析，并根据扫描结果判断 X-Scan 对同组主机进行了哪些类别的 FTP 扫描行为。

扫描的部分结果如图 15.12，15.13 所示。

检测结果

存活主机	1
漏洞数量	6
警告数量	15
提示数量	30

主机列表

主机	检测结果
127.0.0.1	发现安全漏洞

主机摘要 - OS: Windows 2003; PORT/TCP: 21, 23, 80, 135, 445, 1025, 1027, 6000

[返回顶部]

主机分析: 127.0.0.1

主机地址	端口/服务	服务漏洞
127.0.0.1	www (80/tcp)	发现安全提示
127.0.0.1	microsoft-ds (445/tcp)	发现安全漏洞
127.0.0.1	ftp (21/tcp)	发现安全漏洞
127.0.0.1	telnet (23/tcp)	发现安全提示
127.0.0.1	epmap (135/tcp)	发现安全提示
127.0.0.1	unknown (1027/tcp)	发现安全提示
127.0.0.1	network blackjack (1025/tcp)	发现安全提示
127.0.0.1	x11 X Window System (6000/tcp)	发现安全提示
127.0.0.1	netbios-ssn (139/tcp)	发现安全漏洞
127.0.0.1	DCE/12345778-1234-abcd-ef00-0123456789ac (1025/tcp)	发现安全提示
127.0.0.1	DCE/82a94280-036b-11cf-972c-00aa006887b0 (1027/tcp)	发现安全提示
127.0.0.1	DCE/12345678-1234-abcd-ef00-0123456789ab (1025/tcp)	发现安全提示

图 15.12 扫描结果

类型	端口/服务	安全漏洞及解决方案
提示	www (80/tcp)	**开放服务** "WEB"服务运行于该端口 BANNER信息： HTTP/1.1 200 OK Content-Length: 2254 Content-Type: text/html Content-Location: http://127.0.0.1/index.html Last-Modified: Wed, 02 Jul 2008 02:49:16 GMT Accept-Ranges: bytes ETag: "5ce4d437eedbc81:e57" Server: Microsoft-IIS/6.0 Date: Sat, 19 Mar 2011 10:41:16 GMT Connection: close <html><head> <meta http-equiv="Content-Type" content="text/html charset=gb2312"><title id="titletext">Web服务测试页 </title></head><body bgcolor="white"> <table> <tbody><tr> NESSUS_ID : 10330
提示	www (80/tcp)	**目录扫描器** 该插件试图确认远程主机上存在的各普通目录 The following directories were discovered: /image While this is not, in and of itself, a bug, you should manually inspect these directories to ensure that they are in compliance with company security standards

图 15.13 安全漏洞及解决方案

同组主机停止协议分析器并观察两机会话状况。

实验十六 洪泛攻击

一、实验目的

1.理解带宽攻击原理
2.理解资源消耗攻击原理
3.掌握洪泛攻击网络行为特征

二、实验环境

Windows，交换网络结构

三、实验工具

nmap，洪泛工具，网络协议分析器

四、实验原理

1.SYN Flood 攻击

Dos（Denial of Service）拒绝服务攻击是指在特定攻击发生后，被攻击的对象不能及时提供应有的服务。从广义上说，任何导致服务器不能正常提供服务的攻击都是拒绝服务攻击。

SYN Flood 是当前最流行的拒绝服务攻击之一，这是一种利用 TCP 协议缺陷，发送大量的伪造的 TCP 连接请求，从而使得被攻击方资源耗尽（CPU 满负荷或内存不足）的攻击方式。

TCP 协议是基于连接的，也就是说，为了在服务端和客户端之间传送 TCP 数据，必须先建立一个虚拟电路，也就是 TCP 连接。

建立 TCP 连接的标准过程如下：

第一步，请求端（客户端）发送一个包含 SYN 标志的 TCP 报文，SYN 即同步（Synchronize），同步报文会指明客户端使用的端口以及 TCP 连接的初始序号；

第二步，服务器在收到客户端的 SYN 报文后，将返回一个 SYN+ACK 的报文，表示客户端的请求被接受，同时 TCP 序号被加 1，ACK 即确认(Acknowledgement)；

第三步，客户端也返回一个确认报文 ACK 给服务器端，同样 TCP 序列号被加 1，到此一个 TCP 连接完成。

以上的连接过程在 TCP 协议中被称为三次握手。

问题就出在 TCP 连接的三次握手中，假设一个用户向服务器发送了 SYN 报文后突然死机或掉线，那么服务器在发出 SYN+ACK 应答报文后是无法收到客户端的 ACK 报文的(第三次握手无法完成)，这种情况下服务器端一般会重试(再次发送 SYN+ACK 给客户端)并等待一段时间后丢弃这个未完成的连接，这段时间的长度我们称为 SYN 超时，一般来说这个时间是分钟的数量级(大约为 30 秒-2 分钟)；一个用户出现异常导致服务器的一个线程等待 1 分钟并不是什么很大的问题，但如果有一个恶意的攻击者大量模拟这种情况，服务器端将为了维护一个非常大的半连接列表而消耗非常多的资源。实际上如果服务器的 TCP/IP 栈不够强大，最后的结果往往是堆栈溢出崩溃——即使服务器端的系统足够强大，服务器端也将忙于处理攻击者伪造的 TCP 连接请求而无暇理睬客户的正常请求(毕竟客户端的正常请求比率非常之小)，此时从正常客户的角度看来，服务器失去响应，这种情况我们称作：服务器端受到了 SYN Flood 攻击(SYN 洪水攻击)。

2.ICMP Flood 攻击

正常情况下，为了对网络进行诊断，一些诊断程序，比如 Ping 等，会发出 ICMP 请求报文(ICMP Request)，计算机接收到 ICMP 请求后，会回应一个 ICMP 应答报文。而这个过程是需要 CPU 处理的，有的情况下还可能消耗掉大量的资源，比如处理分片的时候。这样如果攻击者向目标计算机发送大量的 ICMP Request 报文（产生 ICMP 洪水），则目标计算机会忙于处理这些请求报文，而无法继续处理其它的网络数据报文，这也是一种拒绝服务。

对于诸如此类洪泛攻击，可以利用设置防火墙和关闭不必要的端口来加以防范。设置防火墙可以直接拒绝接受非法的或不可信任的用户的连接，而关闭不必要的端口可以减少半连接的可能性，从而有效的抑制洪泛攻击所带来的危害。下面给出一些具体实施办法：

●监控计算资源的使用。例如建立资源分配模型图，统计敏感的计算资源使用情况；

●修补漏洞。例如给操作系统或应用软件包升级；

●关掉不必要的 TCP/IP 服务。关掉系统中不需要的服务，以防止攻击者利用；

●过滤网络异常包。例如通过防火墙配置阻断来自 Internet 的恶意请求。

五、实验步骤

1.捕获洪水数据

1)攻击者单击实验平台工具栏中的“协议分析器”按钮，启动协议分析器。单击工具栏“定义过滤器”按钮，在弹出的“定义过滤器”窗口中设置如下过滤条件：

在“网络地址”属性页中输入“any<->同组主机 IP 地址”，如图 16.1 所示。



图 16.1 网络地址设置

在“协议过滤”属性页中选中“协议树”|“ETHER”|“IP”|“TCP”结点项，如图 16.2 所示。



图 16.2 过滤协议设置

单击“确定“按钮使过滤条件生效。

单击“新建捕获窗口”按钮，点击“选择过滤器”按钮，确定过滤信息。在新建捕获窗口工具栏中点击“开始捕获数据包”按钮，开始捕获数据包。

2)性能分析

靶机启动系统“性能监视器”，监视在遭受到洪水攻击时本机 CPU、内存消耗情况，具体操作如下：依次单击“开始”|“程序”|“管理工具”|“性能”。在监视视图区点击鼠标右键，选择“属性”打开“系统监视器属性”窗口，如图 16.3 所示，在“数据”属性页中将“计数器”列表框中的条目删除。

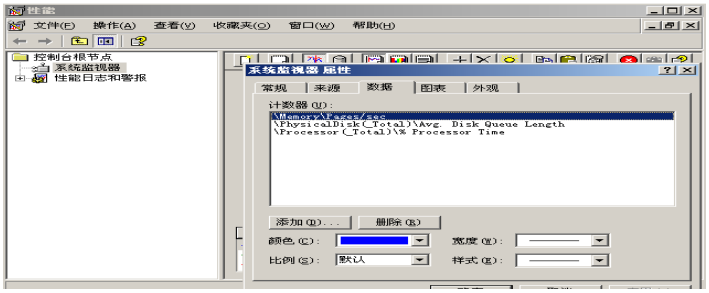


图 16.3 数据计数器

单击“添加”按钮，打开“添加计数器”对话框，在“性能对象”中选择“TCPv4”，在“从列表选择计数器”中选中“Segments Received/sec”,如图 16.4 所示，单击“添加”按

钮，然后“关闭”添加计数器对话框；单击“系统监视器属性”对话框中的“确定”按钮，使策略生效。

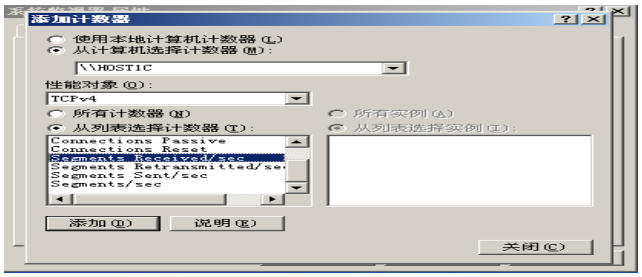


图 16.4 计数器设置

靶机打开“任务管理器”，单击“性能”选项卡，如图 16.5 所示，记录内存的使用状况。

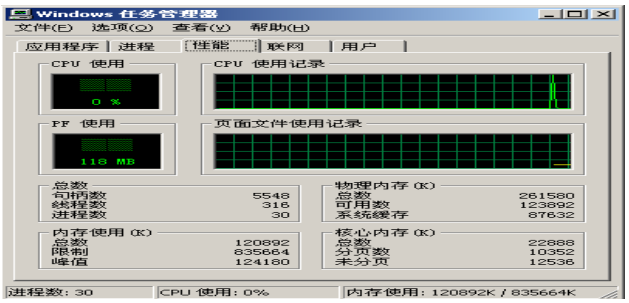


图 16.5 内存使用情况

2.洪水攻击

(1)攻击者单击实验平台工具栏中的“nmap”按钮，进入 nmap 工作目录。在控制台中输入命令：nmap -v －sS -T5 “靶机 IP 地址”，对靶机进行端口扫描，如图 16.6 所示，根据 nmap 对靶机的扫描结果选择一个开放的 TCP 端口作为洪水攻击的端口。

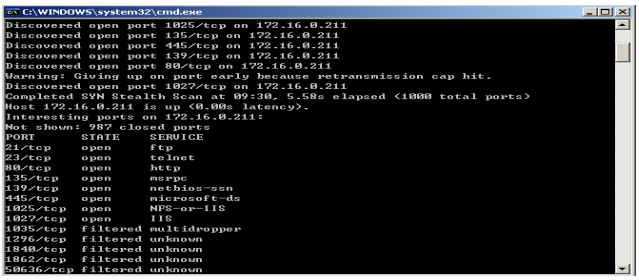


图 16.6 扫描结果

(2)单击工具栏“洪泛工具”按钮，启动洪泛工具，在视图中需要输入以下信息：

目的 IP:靶机 IP 地址；

目标端口:在步骤 1 中扫描所得的靶机开放端口（建议 80/tcp 端口）；

伪源 IP：任意。

单击“发洪水”按钮，对靶机进行 SYN 洪水攻击。

(3)攻击者对靶机实施洪水攻击后，靶机观察“性能”监控程序中图形变化，如图 16.7 并通过“任务管理器”性能页签观察内存的使用状况，如图 16.8 所示，比较攻击前后系统性能变化情况。

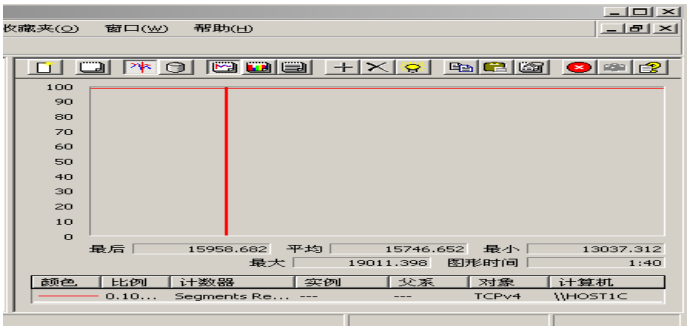


图 16.7 图形变化

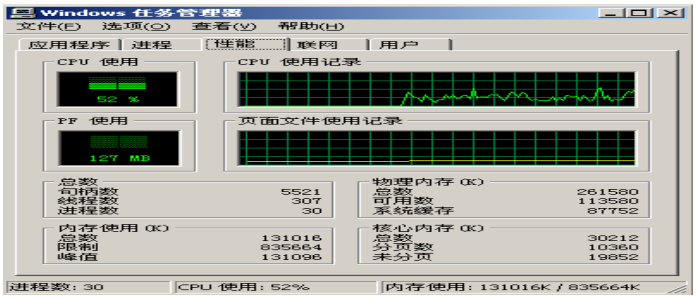


图 16.8 性能查看

(4)攻击者停止洪水发送，并停止协议分析器捕获，如图 16.9 所示，分析攻击者与靶机间的 TCP 会话数据。

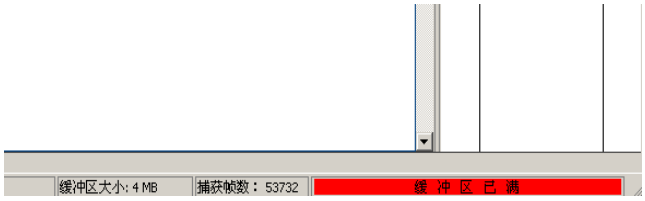


图 16.9 捕获结果

(5)通过对协议分析器所捕获到的数据包进行分析，说明在攻击者对靶机开放的 TCP 端口进行洪泛攻击时，靶机为什么会消耗大量的系统资源。

3.ICMP 洪水攻击

(1)攻击者启动协议分析器，监听任意源与靶机间的 ICMP 会话数据，协议分析器设置方法参看步骤一。

(2)靶机启动“性能监视器”，监视在遭受到洪水攻击时本机 CPU、内存消耗情况。如图 16.11，16.12 所示，具体操作参看步骤一。需要说明的是监视的性能对象应为 ICMP，并且计数单位应为“Messages Received/sec”，如图 16.10 所示。

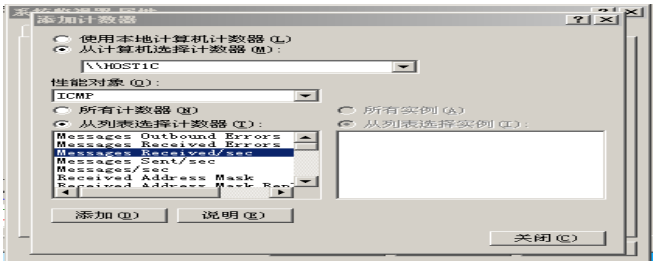


图 16.10　添加计数器

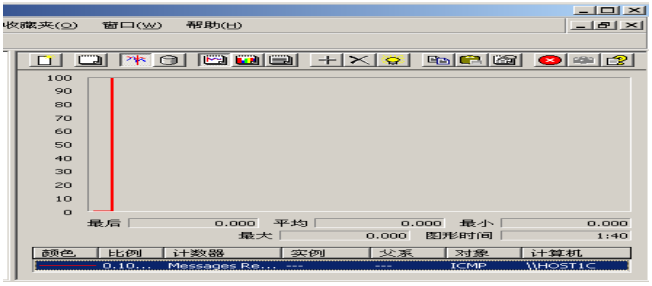


图 16.11 初始图形

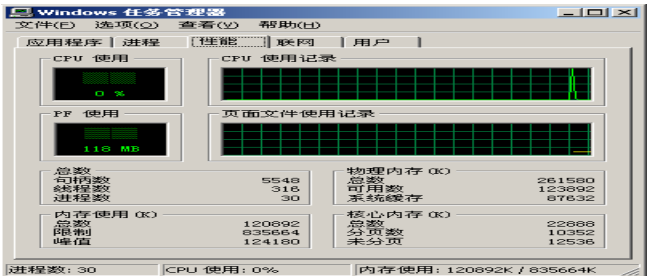


图 16.12 初始性能

(3)攻击者对靶机进行洪水攻击，进入洪泛工具“ICMP 洪水攻击”视图，填写相关信息，并发 ICMP 洪水。

(4)靶机观察“性能”监控程序中图形变化，如图 16.13 所示，比较洪水攻击前后系统性能变化情况，如图 16.14 所示。

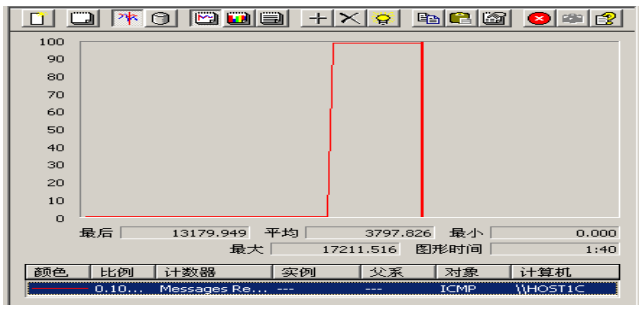


图 16.13 图形变化

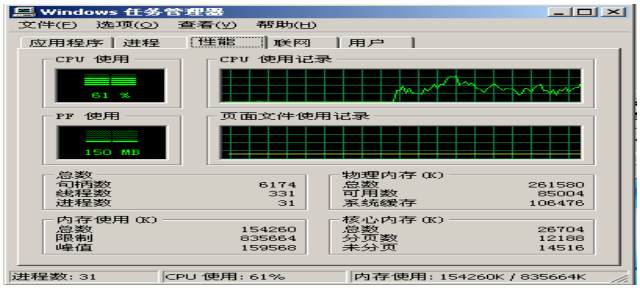


图 16.14 性能变化

(5)攻击者停止洪水发送，并停止协议分析器捕获，观察并分析 ICMP 会话过程。

实验十七 ARP 欺骗

一、实验目的

1.理解 ARP 欺骗攻击原理
2.掌握 ARP 欺骗攻击全过程
3.学会如何防范 ARP 欺骗

二、实验环境

Windows，Linux，交换网络结构

三、实验工具

ARPattack，UdpTools，协议分析器

四、实验原理

假设这样一个网络，一个 Hub 连接有 3 台 PC 机：PC1、PC2 和 PC3。

PC1 的 IP 地址为 172.16.0.1，MAC 地址为 11-11-11-11-11-11

PC2 的 IP 地址为 172.16.0.2，MAC 地址为 22-22-22-22-22-22

PC3 的 IP 地址为 172.16.0.3，MAC 地址为 33-33-33-33-33-33

正常情况下，PC1 的 ARP 缓存表内容如下：

表 27-1 PC1 的 ARP 缓存表内容

Internet Address	Physical Address	Type
172.16.0.3	33-33-33-33-33-33	dynamic

下面 PC2 要对 PC1 进行 ARP 欺骗攻击，目标是更改 PC1 的 ARP 缓存表，将与 IP 地址 172.16.0.3 映射的 MAC 更新为 PC2 的 MAC 地址，即 22-22-22-22-22-22。

PC2 向 PC1 发送一个自己伪造的 ARP 应答，而这个应答数据中发送方 IP 地址是 172.16.0.3(PC3 的 IP 地址)，MAC 地址是 22-22-22-22-22-22(PC3 的 MAC 地址本来应该是 33-33-33-33-33-33,这里被伪造了)。当 PC1 收到 PC2 伪造的 ARP 应答，就会更新本地的 ARP 缓存(PC1 不知道 MAC 被伪造了)，而且 PC1 不知道这个 ARP 应答数据是从 PC2 发送过来的。这样 PC1 发送给 PC3 的数据包都变成发送给 PC2 了。PC1 对所发生的变化一点儿都没

有意识到，但是接下来的事情就让 PC1 产生了怀疑，因为它连接不到 PC3 了，PC2 只是接收 PC1 发给 PC3 的数据，并没有转发给 PC3。

PC2 做“man in the middle”（中间人），进行 ARP 重定向。打开自己的 IP 转发功能，将 PC1 发送过来的数据包转发给 PC3，就好比一个路由器一样，而 PC3 接收到的数据包完全认为是从 PC1 发送来的。不过，PC3 发送的数据包又直接传递给 PC1，倘若再次进行对 PC3 的 ARP 欺骗，那么 PC2 就完全成为 PC1 与 PC3 的中间桥梁，对于 PC1 与 PC3 的通讯就可以了如指掌了。

ARP 是一个重要的 TCP/IP 协议，并且用于确定对应 IP 地址的网卡物理地址。使用 arp 命令，能够查看本地计算机或另一台计算机的 ARP 缓冲表中的当前内容。此外，使用 arp 命令，也可以用人工方式输入静态的 IP/MAC 地址对。

缺省状态下，ARP 缓存表中的项目是动态的，每当发送一个指定地点的数据帧且缓存表不存在当前项目时，ARP 便会自动添加该项目。一旦缓存表的项目被添加，它们就已经开始走向失效状态。例如，在 Windows 2003 网络中，如果添加的缓存项目没有被进一步使用，该项目就会在 2 至 10 分钟内失效。因此，如果 ARP 缓存表中项目很少或根本没有时，请不要奇怪，通过另一台计算机或路由器的 ping 命令即可添加。常见的 ARP 命令请参见命令帮助。

五、实验步骤

1.正常通信

正常通信如图 17.1 所示。

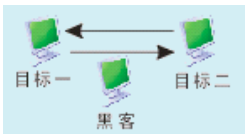


图 17.1 正常通信

(1)目标主机二单击工具栏“UDP 工具”按钮，启动 UDP 连接工具，创建 2513/udp 服务端，如图 17.2 所示。

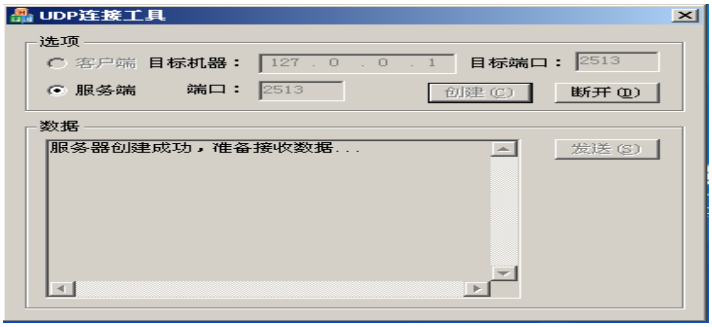


图 17.2 创建 2513/udp 服务器

(2)目标主机一启动 UDP 连接工具，将“目标机器”IP 地址指定为目标主机二的地址，目标端口与服务器一致。在“数据”文本框中输入任意内容，如图 17.3 所示，单击“发送”按钮，向服务端发送数据。服务端确定接收到数据，如图 17.4 所示。

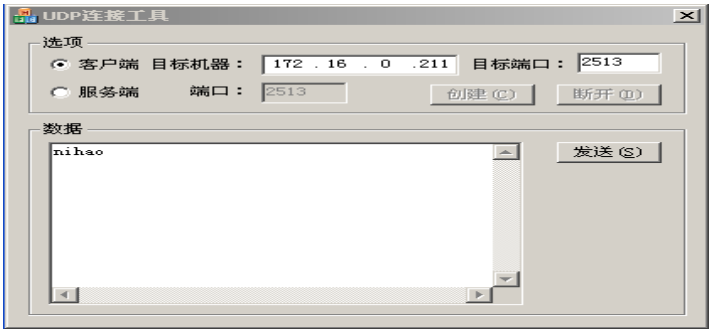


图 17.3 客户端数据

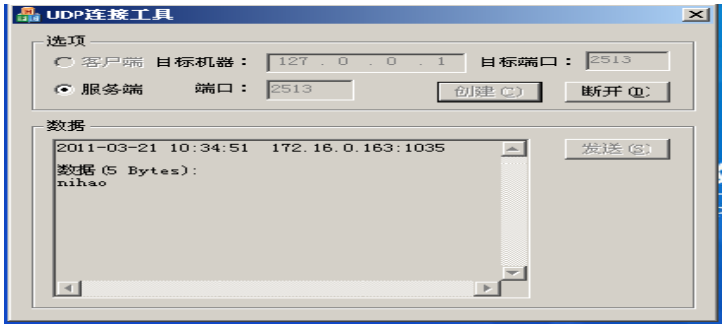


图 17.4 服务器端接收数据

(3)黑客主机单击工具栏“控制台”按钮，切换至/opt/ExpNIS/NetAD-Lab/Tools/ids/目录(Snort 目录)，如图 17.5 所示，执行如下命令。

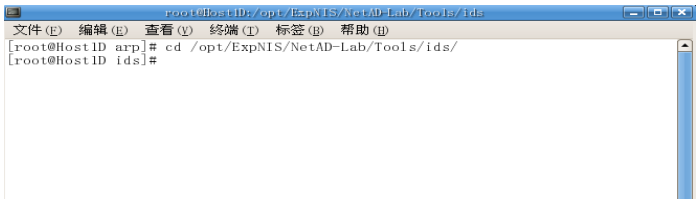


图 17.5 切换目录

(4)运行 snort –dev src 目标主机 IP and udp，如图 17.6 所示。

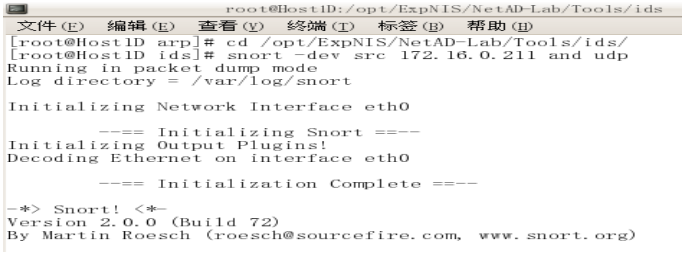


图 17.6　运行结果

目标主机一再次向目标主机二发送消息，黑客主机停止 snort 监听(Ctrl+C)，观察 snort 监听结果，是否监听到目标主机间的通信数据(结果如图 17.7 所示)，为什么？

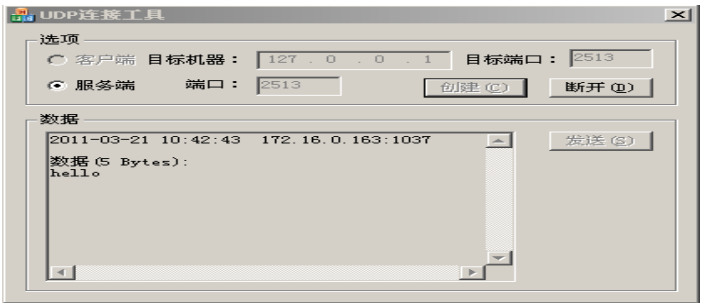


图 17.7 服务器端接收数据

(5)目标主机一查看 ARP 缓存表，确定与目标主机二的 IP 相映射的 MAC 地址是否正常，如图 17.8 所示。

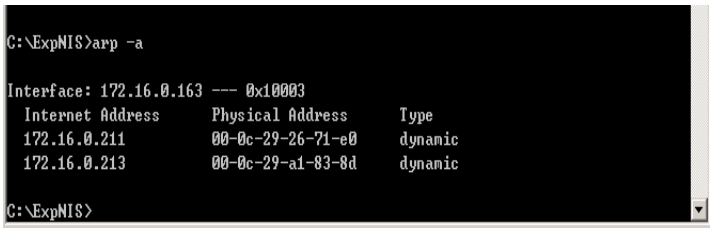


图 17.8 地址映射情况

2.ARP 攻击

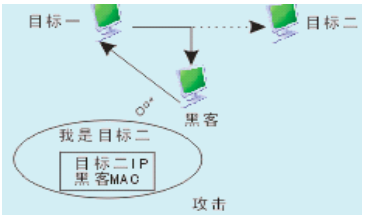


图 17.9　ARP 攻击示意图

(1)黑客主机单击平台工具栏“控制台”按钮，进入实验目录，运行 ARPattack 程序攻击目标主机一，将其 ARP 缓存表中与目标主机二相映射的 MAC 地址更改为黑客主机的 MAC 地址，命令如图 17.10 所示。

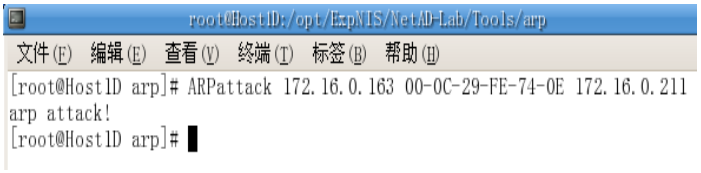


图 17.10 运行 ARPattack

其中第一个参数为被攻击主机 IP 地址，第二个参数为被攻击主机 MAC 地址，第三个参数为与被攻击主机进行正常通信的主机 IP 地址。

通过上述命令在目标主机一的 ARP 缓存表中，与目标主机二 IP 相绑定的 MAC 被更改为黑客主机 MAC。

(2)黑客主机启动 snort，如图 17.11 所示，同样监听源 IP 地址为目标主机一、传输协议类型为 UDP 的网络数据。

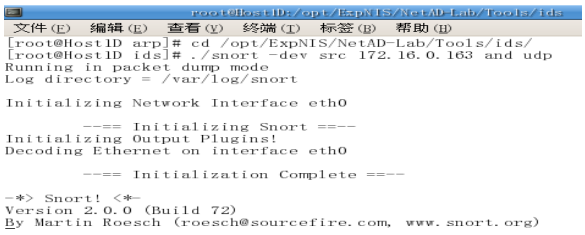


图 17.11 黑客主机启动 snort

(3)目标主机一继续向目标主机二发送数据，目标主机二是否接收到数据(不能)？目标主机间的通信是否正常？黑客主机停止 snort 监听，观察 snort 监听结果，如图 17.12 所示，是否监听到目标主机间的通信数据，为什么？

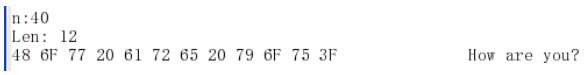


图 17.12 snort 监听结果

(4)目标主机一查看 ARP 缓存表，确定与目标主机二的 IP 相映射的 MAC 地址是否正常如图 17.13 所示。

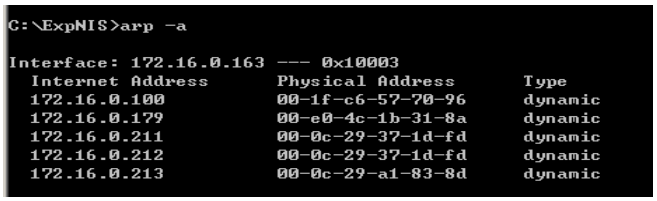


图 17.13 IP 地址映射

3.单向欺骗

正如步骤 2 中所示的实验现象，在黑客实施了简单的 ARP 攻击后，目标主机二会接收不到目标主机一的消息，在接下来的时间里目标主机一、二很容易会对网络状况产生怀疑。它们会去查看并修改 ARP 缓存表。所以，应尽量减少目标主机由于受到 ARP 攻击而表现出的异常，将黑客主机做为“中间人”，将目标主机一发送的数据转发给目标主机二，是一种很可行的方法。

(1)黑客主机开启路由功能，具体操作如下：

在控制台中输入命令：echo 1 >/proc/sys/net/ipv4/ip_forward

(2)黑客主机捕获来自目标主机一的数据包，并将其转发给目标主机二，具体操作如下(添加 iptables 防火墙转发规则)：

```
[root@Host1D arp]# iptables -I FORWARD -i eth0 -o eth0 -s 172.16.0.163 -d 172.16
.0.211 -j ACCEPT
[root@Host1D arp]# iptables -I FORWARD -m state --state ESTABLISHED,RELATED -j A
CCEPT
```

上述第一条规则允许将来自网络接口 eth0、源 IP 为目标主机一 IP、目的 IP 为目标主机二 IP 的数据包进行转发，目的网络接口为 eth0；第二条规则允许接收针对第一条规则的应答数据包

(3)黑客主机启动 snort，监听源地址为目标主机一 IP、协议类型为 UDP 的数据包。

(4)目标主机一再次向目标主机二发送 UDP 数据，目标主机二是否接收到数据(结果如图 17.14 所示)？为什么？

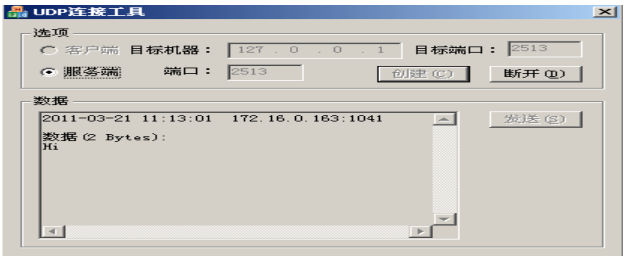


图 17.14 服务器端接收数据

(5)黑客主机停止 snort 监听，会观察到类似如图 17.15 所示信息。

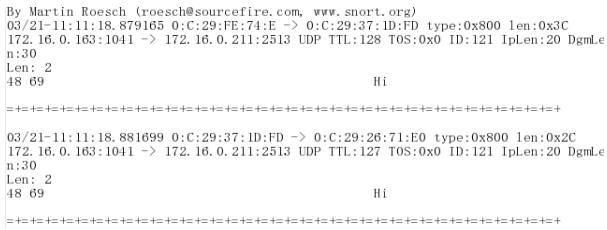


图 17.15 snort 监听结果

(6)黑客主机查看 ARP 缓存表，确定与目标主机一的 IP 相映射的 MAC 地址；确定与目标主机二的 IP 相映射的 MAC 地址。

(7)目标主机二查看 ARP 缓存表，确定与目标主机一的 IP 相映射的 MAC 地址。

下面来测试目标主机二对一的数据通信情况。

(8)黑客主机启动 snort，仅监听协议类型为 ICMP 的网络数据包。

(9)目标主机一对目标主机二进行 ping 操作，是否能够 ping 通？请描述数据包的在网络中的传输路径。

(10)黑客主机停止 snort 监听，观察结果，是否监听到主机一给主机二发出的 ICMP 回显请求数据包？是否监听到主机二给主机一发出的 ICMP 回显应答数据包？为什么会出现此种现象？

3.ARP 监听

由于 ARP 欺骗是通过伪装其它 IP 地址向目标主机发送 ARP 应答报文实现的，所以通过 ARP 监听可以监视网络中的目标为本机的 ARP 应答数据包的流向。

设置监听程序对目标地址为本机地址或子网广播地址或受限广播地址的 ARP 数据包进行监听。

假设本机 IP 地址为 172.16.0.152，子网掩码为 255.255.255.0 为例，使用 snort 监听满足上述条件的数据包，命令如下：

/.snort –dev arp and “dst 172.16.0.50 or dst 172.16.0.255 or dst 255.255.255.255”

六、问题思考

1.通过 ARP 欺骗方法，如何监听局域网络（交换网络）与 Internet 之间的通信？

2.黑客如何才能够做到监听目标主机一、二间的全部通信数据呢？

实验十八 shell 后门

一、实验目的

1.理解后门的定义与分类
2.掌握后门的操作与原理

二、实验环境

Windows，交换网络结构

三、实验工具

JlcssShell

四、实验原理

1.后门的定义

最早的后门是由系统开发人员为自己留下入口而安装的，而今天，并非开发人员将后门装入自己设计的程序中，而是大多数攻击者将后门装入他人开发和维护的系统中。通过使用这样的后门，攻击者可以很轻松地获得系统的访问权，进而获得系统的控制权。为了更加明确，我们给出后门的以下定义：

后门是一个允许攻击者绕过系统中常规安全控制机制的程序，它按照攻击者自己的意愿提供通道。

有许多不同类型的后门，但每种都可以绕过系统的常规性安全检测，使得攻击者获得进入系统的入口。例如：一个普通的用户可能不得不输入一个口令，这个口令每 90 天会变换一次。而有了后门，攻击者可以用一个固定的口令而无需变换。

有了植入系统的后门，攻击者可能根本不需要提供任何口令就可以登录到计算机。普通用户可能被迫使用某个特别的加密协议访问计算机，而攻击者可以利用后门访问那些使用完全不同协议的计算机。一旦安装了后门，攻击者如何访问该逻辑单元完全取决于攻击者自己。

许多人用特洛伊木马或者简单地用特洛伊来形容每个后门，这种将术语“后门”和特洛伊木马混淆的做法是非常错误的，应该尽量避免。后门只是简单地提供通道，而特洛伊木马将自己伪装成某个有用的程序，或者干脆将自己隐藏起来，不要将这些概念混为一谈。如果一

个程序仅提供后门通道，那么它只是一个后门；如果可以伪装成一个有用的程序，那么它便是特洛伊木马。当然，有的工具可以同时是后门和特洛伊木马。但是，只有当攻击者企图将后门伪装成某个有用程序时，它才可以称为“特洛伊木马”。我们用特洛伊木马后门这一不太明确的概念定义这种工具，因为它们伪装成某个友善的程序同时还提供访问通道，利用这一完全定义将有助于人们理解后门与木马的区别。

2.不同类型的后门通道

正如我们在前面定义中看到的一样，后门的作用在于为攻击者进入目标计算机提供通道。这个通道可能表现为不同形式，它取决于攻击者的目的和所使用的特定后门类型。后门能够为攻击者提供许多种不同类型的访问，包括以下几种：

本地权限的提升：这类后门使得对系统有访问权的攻击者突然变换其权限等级成为管理员，有了这些超级用户权限，攻击者可以重新设置系统或访问任何存储在系统中的文件。

单个命令的远程执行：利用这种类型的后门，攻击者可以向目标计算机发送消息。每次执行一个单独的命令，后门执行攻击者的命令并将其输出返回给攻击者。

远程命令行解释器访问：正如我们所知的远程 shell 命令，这种类型的后门允许攻击者通过网络快递直接地键入受害计算机的命令提示。攻击者可以利用命令行解释器的所有特征，包括执行一个命令集合的能力编写脚本，选择一些文件进行操作。远程 shell 比简单的单命令远程执行要强大得多，因为它们可以模拟攻击者对目标计算机的键盘有直接访问权的情形。

远程控制 GUI（Remote Control of the GUI）：比将命令行解释器弄混乱更甚，有些后门可以让攻击者看到目标计算机的 GUI，控制鼠标的移动，输入对键盘的操作，这些都是通过网络实现的。有了对 GUI 的远程控制，攻击者可以看到受害者对计算机的所有操作，甚至远程控制 GUI。

无论后门提供何种类型的访问，我们都会发现这些方法的重点在于控制。后门使得攻击者控制计算机，这一切通常是通过网络远程实现的。有了装入目标计算机的后门，攻击者可以利用这种控制搜索计算机中的易感染文件，改变存储在系统中的任何数据，改装计算机，甚至使系统瘫痪。利用后门，攻击者可以像受害者计算机本身的管理员一样对其进行同样的控制。更有甚者，攻击者可以通过 Internet 在世界的任何地方实现该控制。

3.后门的安装

攻击者可以自己植入后门，通过某种普通的开发技术拥有系统的初始入口，例如缓冲区溢出或者典型的系统错误配置。一旦攻击者闯入一个目标计算机，通常要做的第一件事就是装入后门，从容地返回到受害系统。

另外，攻击者也可以利用一个自动化的程序安装后门，例如病毒、蠕虫和恶意移动代码。通过它们攻击者可以探查到通向目标计算机系统的通道并打开一个后门，为攻击者提供对系统的完全控制。

安装后门的最后一种方法是欺骗受害者自己安装，攻击者可能会通过 E-mail 向受害者发一个程序或者利用远程文件共享能力将这样的程序写入受害者的硬盘。如果攻击者可以利用某个看似不错的程序骗得用户的信任，他们可能上当将后门装入自己的计算机。这些用户很少会意识到安装了攻击者的恶意代码，他们已经为攻击者提供了对其计算机的完全控制。

后门是在安装了后门程序的用户或攻击者允许的前提下运行的，注意到这一点非常重要。如果一个攻击者在目标系统中获得超级用户权限，攻击者安装的后门将以这些强有力的权限运行。类似地，如果攻击者只能欺骗具有有限权限的低级用户安装后门，攻击者对于该目标计算机而言，也就只有这个用户所拥有的有限权限。因此，后门为攻击者提供的对该系统的控制取决于安装该后门用户的权限等级。

五、实验步骤

1.系统自带远程控制工具(3389 远程控制)

(1)设置远程登录用户

主机 B 依次单击“我的电脑”|“属性”|“远程”|“远程桌面”，选中“启用这台计算机上的远程桌面”，如图 18.1 所示。

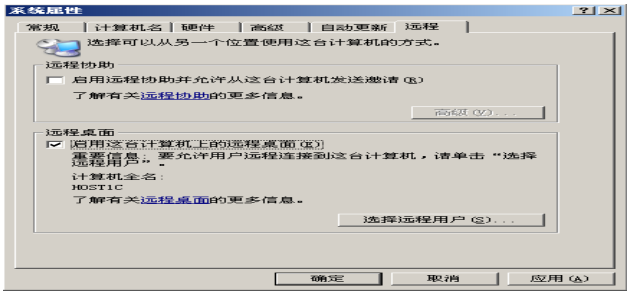


图 18.1 启用远程桌面

单击“选择远程用户”按钮，进入远程桌面用户，单击“添加”按钮，添加远程用户帐户，在选择用户对话框中点选“高级”|“立即查找”，在查找结果中选择一个已存在的用户，按确定，完成用户添加工作，如图 18.2 所示。

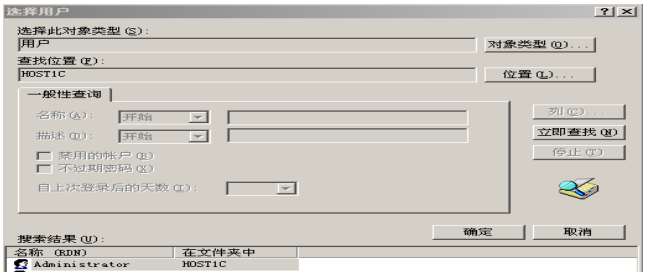


图 18.2 选择用户

(2)将用户名，密码告知同组主机 A，并由其对本机进行远程登录

主机 A 依次单击“开始”|“程序”|“附件”|“通讯”|“远程桌面连接”，启动远程桌面连接工具，在计算机一栏填写同组主机 B 的 IP 地址，如图 18.3 所示，单击“连接”按钮进行连接。

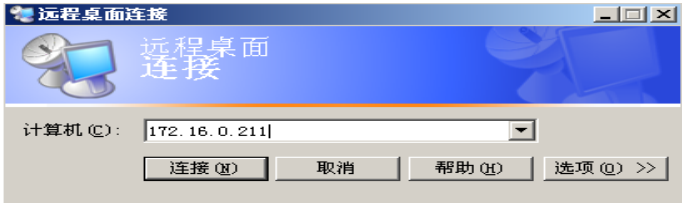


图 18.3 远程桌面连接

在出现的登录界面中填入同组主机 B 提供的用户名和密码，如图 18.4 所示。



图 18.4 输入用户名和密码

以图形界面登录到同组主机，如图 18.5 所示。



图 18.5 登陆到同组主机

利用远程连接，在同组主机上进行文件操作，注意不要随便删除连接主机上的文件。

2.远程控制工具(JlcssShell)

(1)主机 B 首先在控制台中执行 netstat -an，查看本机开启的端口情况，如图 18.6 所示。

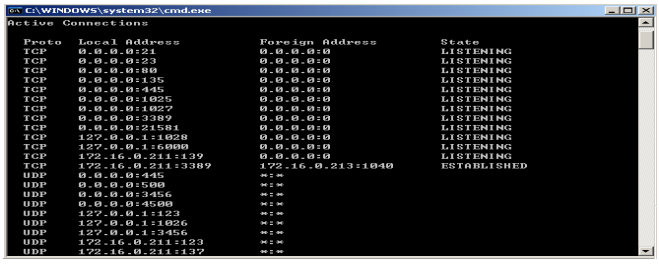


图 18.6 查看开启的端口情况

单击实验平台工具栏中“JlcssShell”按钮，进入 JlcssShell 工作目录，运行 JlcssShell.exe，再次查看本机开启端口的情况，如图 18.7 所示，端口 21581 是否开启_____。

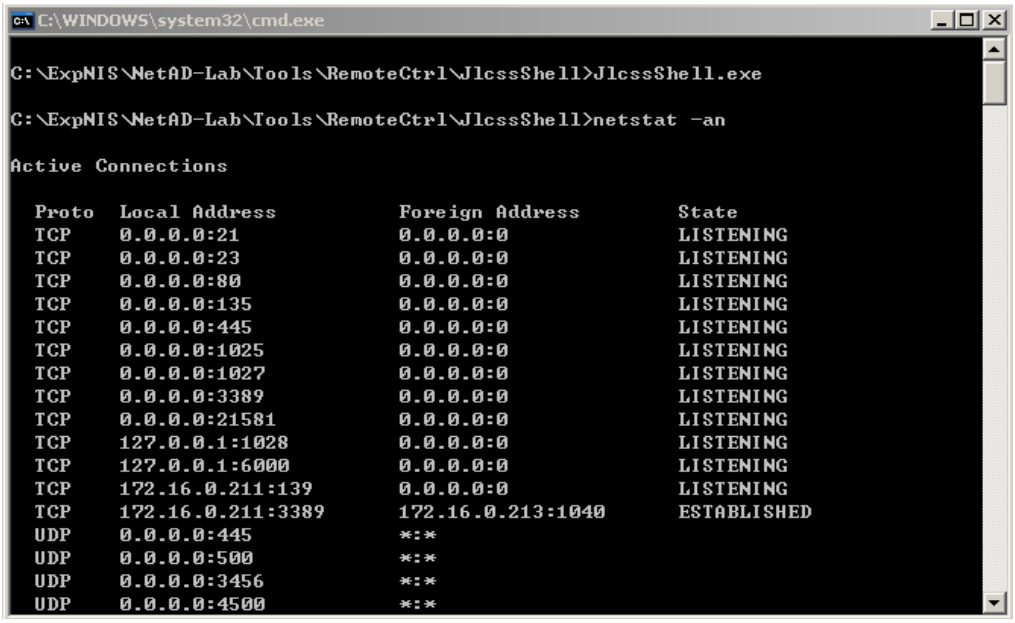


图 18.7 开启端口情况

(2)主机 A 确认 JlcssShell 后门植入主机 B 后，用“telnet”命令对主机 B 连接并实现部分功能的控制。主机 A 打开命令行操作界面，输入“telnet *主机 B 的 IP 地址* 21581”,其中“21581”为 JlcssShell 后门程序的执行端口。然后输入“连接密码”：jlcssok。 确认后即可进入远程控制界面。输入“？”键入“回车”，获取帮助菜单如图 18.8 所示。

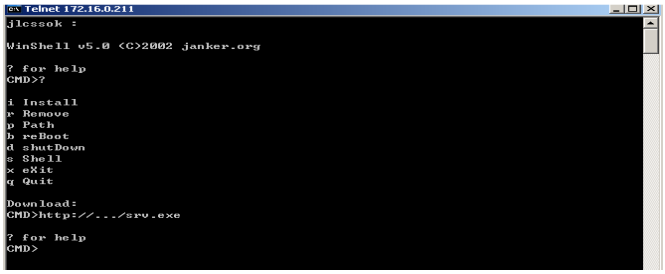


图 18.8 帮助菜单

「注」帮助菜单中 q 操作不但能够退出当前远程连接操作，而且可以卸载远程 shell 后门。因此在执行了 q 操作后，需要重新运行程序，启动后门。

（3）主机 A 对主机 B 进行简单的磁盘操作，如创建文件，写文件等，看是否能够成功。

六、问题思考

1．简述后门和木马的区别。

实验十九 Windows2003 防火墙实践

一、实验目的

1.了解防火墙的含义与作用
2.学习防火墙的基本配置方法

二、实验环境

Windows，交换网络结构

三、实验工具

UdpTools，Windows Server 2003 系统防火墙

四、实验原理

1.防火墙

在古代，人们已经想到在寓所之间砌起一道砖墙，一旦火灾发生，它能够防止火势蔓延到别的寓所，于是有了“防火墙”的概念。

进入信息时代后，防火墙又被赋予了一个类似但又全新的含义。防火墙是指设置在不同网络(如可信任的企业内部网和不可信的公共网)或网络安全域之间的一系列部件的组合。它是不同网络或网络安全域之间信息的唯一出入口，能根据企业的安全政策控制(允许、拒绝、监测)出入网络的信息流，且本身具有较强的抗攻击能力。它是提供信息安全服务，实现网络和信息安全的基础设施。在逻辑上，防火墙是一个分离器、一个限制器、也是一个分析器，有效地监控了内部网络和 Internet 之间的任何活动，保证了内部网络的安全。

2.防火墙功能

(1)防火墙是网络安全的屏障

一个防火墙(作为阻塞点、控制点)能极大地提高一个内部网络的安全性，并通过过滤不安全的服务而降低风险。由于只有经过精心选择的应用协议才能通过防火墙，所以网络环境

变得更安全。如防火墙可以禁止诸如众所周知的不安全的 NFS 协议进出受保护的网络，这样外部的攻击者就不可能利用这些脆弱的协议来攻击内部网络。防火墙同时可以保护网络免受基于路由的攻击，如 IP 选项中的源路由攻击和 ICMP 重定向中的重定向攻击。防火墙应该可以拒绝所有以上类型攻击的报文并通知防火墙管理员。

(2)防火墙可以强化网络安全策略

通过以防火墙为中心的安全方案配置，能将所有安全软件(如口令、加密、身份认证、审计等)配置在防火墙上。与将网络安全问题分散到各个主机上相比，防火墙的集中安全管理更经济。例如在网络访问时，一次一密口令系统和其它的身份认证系统完全可以不必分散在各个主机上，而集中在防火墙一身上。

(3)对网络存取和访问进行监控审计

如果所有的访问都经过防火墙，那么，防火墙就能记录下这些访问并作出日志记录，同时也能提供网络使用情况的统计数据。当发生可疑动作时，防火墙能进行适当的报警，并提供网络是否受到监测和攻击的详细信息。另外，收集一个网络的使用和误用情况也是非常重要的。这样可以清楚防火墙是否能够抵挡攻击者的探测和攻击，并且清楚防火墙的控制是否充足。而网络使用统计对网络需求分析和威胁分析等而言也是非常重要的。

(4)防止内部信息的外泄

通过利用防火墙对内部网络的划分，可实现内部网重点网段的隔离，从而限制了局部重点或敏感网络安全问题对全局网络造成的影响。再者，隐私是内部网络非常关心的问题，一个内部网络中不引人注意的细节可能包含了有关安全的线索而引起外部攻击者的兴趣，甚至因此而暴露了内部网络的某些安全漏洞。使用防火墙就可以隐蔽那些透漏内部细节的服务如 Finger，DNS 等。Finger 显示了主机的所有用户的注册名、真名，最后登录时间和使用 shell 类型等。Finger 显示的信息非常容易被攻击者所获悉。攻击者可以知道一个系统使用的频繁程度，这个系统是否有用户正在连线上网，这个系统是否在被攻击时引起注意等等。防火墙可以同样阻塞有关内部网络中的 DNS 信息，这样一台主机的域名和 IP 地址就不会被外界所了解。

除了安全作用，防火墙还支持具有 Internet 服务特性的企业内部网络技术体系 VPN。通过 VPN，将企事业单位在地域上分布在全世界各地的 LAN 或专用子网，有机地联成一个整体。不仅省去了专用通信线路，而且为信息共享提供了技术保障。

3.NAT

NAT 英文全称是“Network Address Translation”，中文意思是“网络地址转换”，它是一个 IETF(Internet Engineering Task Force, Internet 工程任务组)标准，允许一个整体机构以一个公共 IP 地址出现在 Internet 上。顾名思义，它是一种把内部私有 IP 地址翻译成公共 IP 地址的技术。

简单的说，NAT 就是在局域网内部网络中使用内部地址，而当内部节点要与外部网络进行通讯时，就在网关处，将内部地址替换成公用地址，从而在外部公网（Internet）上正常使用，NAT 可以使多台计算机共享 Internet 连接，这一功能很好地解决了公共 IP 地址紧

缺的问题。通过这种方法，您可以只申请一个公共 IP 地址，就把整个局域网中的计算机接入 Internet 中。这时，NAT 屏蔽了内部网络，所有内部网络计算机对于公共网络来说是不可见的，而内部网计算机用户通常不会意识到 NAT 的存在。这里提到的内部地址，是指在内部网络中分配给节点的私有 IP 地址，这个地址只能在内部网络中使用，不能被路由。虽然内部地址可以随机挑选，但是通常使用的是下面的地址：10.0.0.0～10.255.255.255，172.16.0.0～172.16.255.255，192.168.0.0～192.168.255.255。NAT 将这些无法在互联网上使用的保留 IP 地址翻译成可以在互联网上使用的合法 IP 地址。而全局地址，是指合法的 IP 地址，它是由 NIC（网络信息中心）或者 ISP(网络服务提供商)分配的地址，对外代表一个或多个内部局部地址，是全球统一的可寻址的地址。

NAT 功能通常被集成到路由器、防火墙、ISDN 路由器或者单独的 NAT 设备中。比如 Cisco 路由器中已经加入这一功能，网络管理员只需在路由器的 IOS 中设置 NAT 功能，就可以实现对内部网络的屏蔽。再比如防火墙将 Web Server 的内部地址 192.168.1.1 映射为外部地址 202.96.23.11，外部访问 202.96.23.11 地址实际上就是访问访问 192.168.1.1。另外对资金有限的小型企业来说，现在通过软件也可以实现这一功能。Windows 98 SE、Windows 2000 都包含了这一功能。

NAT 有三种类型：静态 NAT(Static NAT)、动态地址 NAT(Pooled NAT)、网络地址端口转换 NAPT（Port－Level NAT）。

其中静态 NAT 设置起来是最为简单和最容易实现的一种，内部网络中的每个主机都被永久映射成外部网络中的某个合法的地址。而动态地址 NAT 则是在外部网络中定义了一系列的合法地址，采用动态分配的方法映射到内部网络。NAPT 则是把内部地址映射到外部网络的一个 IP 地址的不同端口上。根据不同的需要，三种 NAT 方案各有利弊。

动态地址 NAT 只是转换 IP 地址，它为每一个内部的 IP 地址分配一个临时的外部 IP 地址，主要应用于拨号，对于频繁的远程联接也可以采用动态 NAT。当远程用户联接上之后，动态地址 NAT 就会分配给他一个 IP 地址，用户断开时，这个 IP 地址就会被释放而留待以后使用。

网络地址端口转换 NAPT（Network Address Port Translation）是人们比较熟悉的一种转换方式。NAPT 普遍应用于接入设备中，它可以将中小型的网络隐藏在一个合法的 IP 地址后面。NAPT 与动态地址 NAT 不同，它将内部连接映射到外部网络中的一个单独的 IP 地址上，同时在该地址上加上一个由 NAT 设备选定的 TCP 端口号。

在 Internet 中使用 NAPT 时，所有不同的信息流看起来好像来源于同一个 IP 地址。这个优点在小型办公室内非常实用，通过从 ISP 处申请的一个 IP 地址，将多个连接通过 NAPT 接入 Internet。实际上，许多 SOHO 远程访问设备支持基于 PPP 的动态 IP 地址。这样，ISP 甚至不需要支持 NAPT，就可以做到多个内部 IP 地址共用一个外部 IP 地址访问 Internet，虽

然这样会导致信道的一定拥塞，但考虑到节省的 ISP 上网费用和易管理的特点，用 NAPT 还是很值得的。

4.Windows 2003 防火墙

Windows 2003 提供的防火墙称为 Internet 连接防火墙，通过允许安全的网络通信通过防火墙进入网络，同时拒绝不安全的通信进入，使网络免受外来威胁。Internet 连接防火墙只包含在 Windows Server 2003 Standard Edition 和 32 位版本的 Windows Server 2003 Enterprise Edition 中。

在 Windows2003 服务器上，对直接连接到 Internet 的计算机启用防火墙功能，支持网络适配器、DSL 适配器或者拨号调制解调器连接到 Internet。它可以有效地拦截对 Windows 2003 服务器的非法入侵，防止非法远程主机对服务器的扫描，从而提高 Windows 2003 服务器的安全性。同时，它也可以有效拦截利用操作系统漏洞进行端口攻击的病毒，如冲击波等蠕虫病毒。如果在用 Windows 2003 构造的虚拟路由器上启用此防火墙功能，能够对整个内部网络起到很好的保护作用。

(1)启用/关闭防火墙

1)打开“网络连接”，右击要保护的连接，单击“属性”，出现“本地连接属性”对话框。

2)选择“高级”选项卡，单击“设置”按钮，出现启动/停止防火墙界面。如果要启用 Internet 连接防火墙，请单击“启用(O)”按钮；如果要禁用 Internet 连接防火墙，请单击“关闭(F)”按钮。

(2)防火墙服务设置

Windows 2003 Internet 连接防火墙能够管理服务端口，例如 HTTP 的 80 端口、FTP 的 21 端口等，只要系统提供了这些服务，Internet 连接防火墙就可以监视并管理这些端口。

1)解除阻止设置

在“例外”选项卡中，可以通过设定让防火墙禁止和允许本机中某些应用程序访问网络，加上“√”表示允许，不加“√”表示禁止。如果允许本机中某项应用程序访问网络，则在对话框中间列表中所列出该项服务前加“√”（如果不存在则可单击“添加程序”按钮进行添加）；如果禁止本机中某项应用程序访问网络，则将该项服务前的“√”清除（如果不存在同样可以添加）。在“Windows 防火墙阻止程序时通知我”选项前打“√”则在主机出现列表框中不存在的应用程序欲访问网络时，防火墙会弹出提示框询问用户是否允许该项网络连接。

2)高级设置

在“高级”选项卡中，可以指定需要防火墙保护的网络连接，双击网络连接或单击“设置”按钮设置允许其他用户访问运行于本主机的特定网络服务。选择“服务”选项卡，其中列举出了网络标准服务，加上“√”表示允许，不加“√”表示禁止。如果允许外部网络用

户访问网络的某一项服务，则在对话框中间列表中所列出该项服务前加“√”（如果不存在则可单击“添加程序”按钮进行添加）；如果禁止外部网络用户访问内部网络的某一项服务，则将该项服务前的“√”清除（如果不存在同样可以添加）。选择“ICMP”选项卡，允许或禁止某些类型的 ICMP 响应，建议禁止所有的 ICMP 响应。

(3)防火墙安全日志设置

Windows2003 防火墙可以记录所有允许和拒绝进入的数据包，以便进行进一步的分析。在“高级”选项卡的“安全日志记录”框中单击“设置”按钮，进入“日志设置”界面。

如果要记录被丢弃的包，则选中“记录被丢弃的数据包”复选按钮；如果要记录成功的连接，则选中“记录成功的连接”复选按钮。

日志文件默认路径为 C:\WINDOWS\pfirewall.log，用记事本可以打开，所生成的安全日志使用的格式为 W3C 扩展日志文件格式，可以用常用的日志分析工具进行查看分析，也可以重新指定日志文件，而且还可以通过“大小限制”限定文件的最大使用空间。

「说明」建立安全日志是非常必要的，在服务器安全受到威胁时，日志可以提供可靠的证据。

五、实验步骤

1.防火墙日志设置

在“Windows 防火墙”的“高级”选项卡中，点击“安全日志记录”中的“设置”按钮，在“日志设置”对话框中指定日志文件名称、大小及记录选项。

2.防火墙基础操作

操作概述：启用 Windows Server 2003 系统防火墙，具体做法为：右击“网上邻居”——>“属性”——>右击“本地连接”——>”属性”——>”高级”，如图 19.1 所示，然后再进行相关的设置，设置规则阻断 ICMP 回显请求数据包。

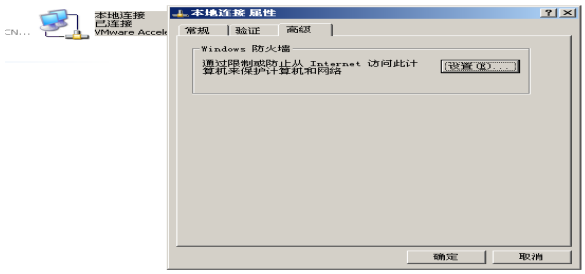


图 19.1 寻找防火墙

(1)在启用防火墙之前，同组主机通过 ping 指令互相测试网络连通性，确保互相是连通的，如图 19.2 所示，若测试未通过请排除故障。

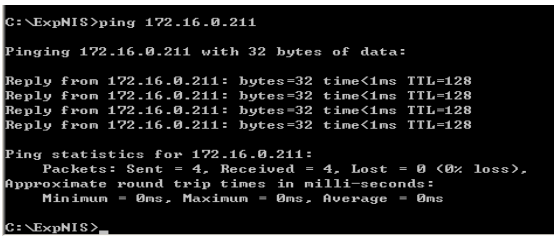


图 19.2　Ping 测试

(2)本机启用防火墙，并设置防火墙仅对“本地连接”进行保护，如图 19.3 所示。

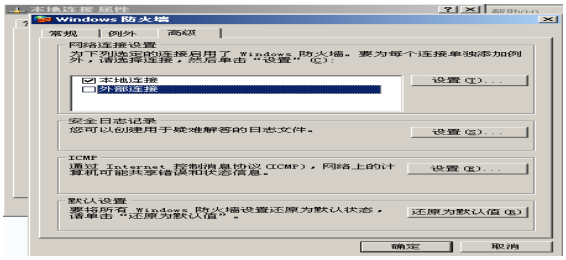


图 19.3　启用防火墙

(3)同组主机再次通过 ping 指令互相测试网络连通性，确认是否相互连通，如图 19.4 所示。

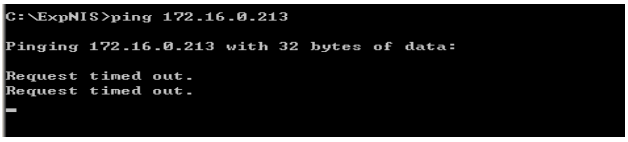


图 19.4　Ping 测试

(4)设置本机防火墙允许其传入 ICMP 回显请求，如图 19.5 所示。

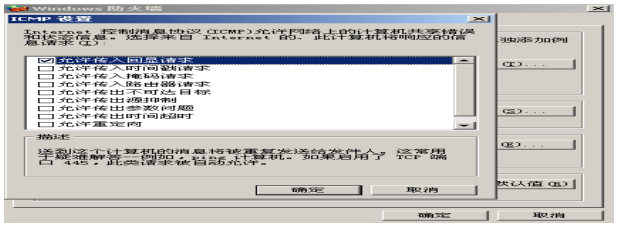


图 19.5　ICMP 回显请求设置

(5)同组主机第三次测试网络连通性，确认是否相互连通，如图 19.6 所示。

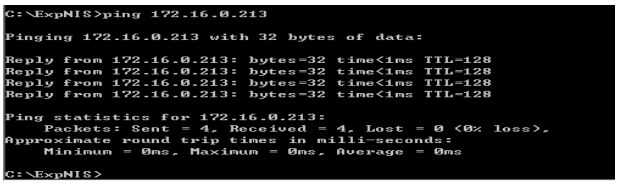


图 19.6　Ping 测试

(6)查看防火墙日志，判断已发生的网络行为。

3.防火墙例外操作

操作概述：启用 Windows Server 2003 系统防火墙，在“例外”选项卡中添加程序“UdpTools”(路径为：C:\ExpNIS\NetAD-Lab\Tools\Analyzer\tools\UdpTools.exe)，允许 UdpTools 间通信，并弹出网络连接提示信息。

(1)关闭防火墙，同组主机间利用 UdpTools 进行数据通信，确保通信成功。

「**说明**」UdpTools 通信双方分别为客户端和服务端，其默认通过 2513/UDP 端口进行通信，可以自定义通信端口，运行如图 19.7 所示，进行通信，如图 19.8 所示。

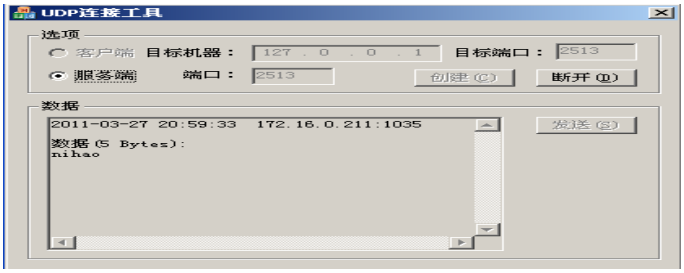


图 19.7 服务器端设置

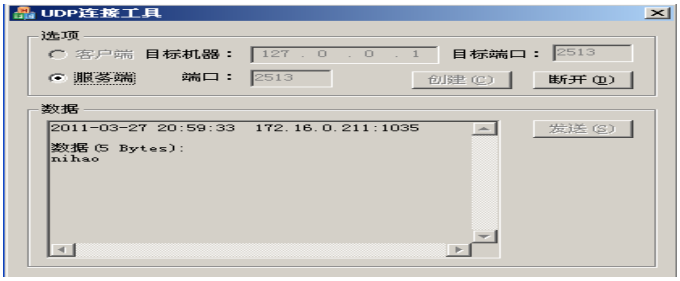


图 19.8 正常通信

(2)本机启用防火墙(仅对本地连接)，将本机作为 UdpTools 服务器端，同组主机以 UdpTools 客户端身份进行通信，确定客户端通信请求是否被防火墙阻塞。

(3)断开 UdpTools 通信，单击“例外”选项卡，在“程序和服务”列表框添加程序“UdpTools.exe”（C:\ExpNIS\NetAD-Lab\Tools\Analyser\tools\ UdpTools.exe）并将其选中。再次启动 UdpTools 并以服务器身份运行，同组主机仍以客户端身份与其通信，确定客户端通信请求是否被防火墙阻塞。

(4)实验完成，关闭系统防火墙。

4.NAT 操作

实验角色说明如表 19.1 所示。

表 19.1 角色说明

实验主机	实验角色
主机A、B	内网主机
主机C、D	NAT
主机E、F	外网主机

操作概述：Windows Server 2003“路由和远程访问”服务包括 NAT 路由协议。如果将 NAT 路由协议安装和配置在运行“路由和远程访问”的服务器上，则使用专用 IP 地址的内部网络客户端可以通过 NAT 服务器的外部接口访问 Internet。



图 19.9 网络拓扑

参看图 19.9，当内部网络主机 PC1 发送要连接 Internet 主机 PC2 的请求时，NAT 协议驱动程序会截取该请求，并将其转发到目标 Internet 主机。所有请求看上去都像是来自 NAT 服务器的外部连接 IP 地址，这样就隐藏了内部网络主机。

在这里我们将 Windows Server 2003 主机配置成为“路由和远程访问”NAT 服务器，并模拟搭建 Internet 网络环境对 NAT 服务器进行测试。

(1)实验网络拓扑规划。

按图 19.9 所示，本实验需 3 台主机共同完成，设定主机 A 为内网主机 PC1，将其内部网络接口(默认为“本地连接”)的默认网关指向主机 C 的内部网络接口(默认为“本地连接”)，如图 19.10 所示。

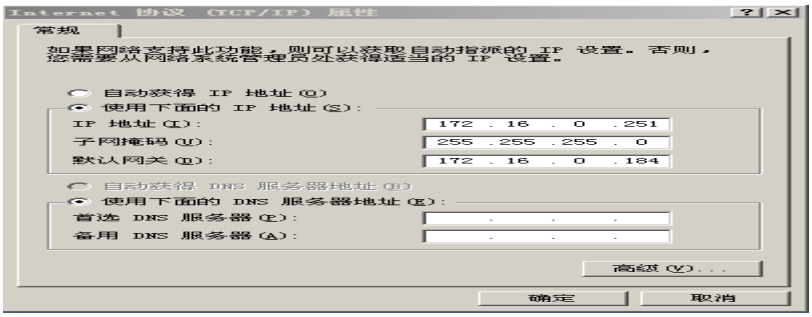


图 19.10 主机 A 的设置

设定主机 C 为 NAT 服务器，通过网上邻居，将 19.11 所示的网络连接标识作为服务器。



图 19.11 服务器端网络情况

设定主机 E 为外网主机 PC2，其网络邻居的网络连接情况为如图 19.12 所示。



图 19.12 外网网络情况

而 A 的主机的本地连接是连通的，而本地连接 2 是没有连通的，若 A 与 E 的网络连接情况相同，则另外再选一台满足条件的内网主机。若所选主机是图 19.13 所示的情况，只需要禁用掉一个即可，如图 19.14 所示。



图 19.13 所选主机网络情况



图 19.14 禁用一个连接

默认外部网络地址 202.98.0.0 / 24；内部网络地址 172.16.0.0 / 24，也可根据实际情况指定内网与外网地址。

默认主机 C“本地连接”为内部网络接口；“外部连接“为外部网络接口，也可指定“本地连接”为外部网络接口。

(2)按步骤(1)中规划,配置主机 C“本地连接”、“外部连接”的 IP 地址。

(3)主机 C 配置 NAT 路由服务。依次单击“开始”|“程序”|“管理工具”|“路由和远程访问”，在“路由和远程访问”，选择要安装 NAT 路由协议的本地服务器，右键单击在弹出菜单中选择“配置并启用路由和远程访问”。

「注」操作期间若弹出“为主机名启用了 Windows 防火墙/Internet 连接共享服务”警告信息，请先禁用“Windows 防火墙/Internet 连接共享”服务，后重试操作。具体做法：“开始”|“程序”| “管理工具”|“计算机管理”|“服务和应用程序”|“服务”，在右侧服务列表中选择“Windows Firewall/Internet Connection Sharing(ICS)”服务，先将其停止，然后在启动类型中将其禁用。

(4)在“路由和远程访问服务器安装向导”中选择“网络地址转换(NAT)”服务，如图 19.15 所示。

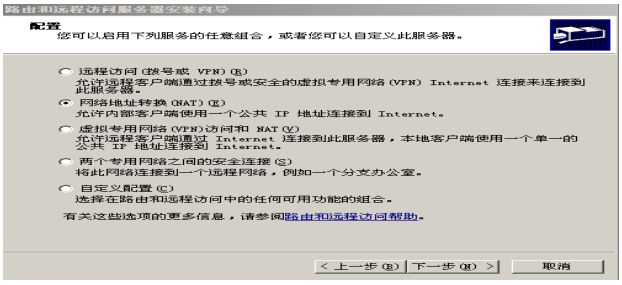


图 19.15 配置设置

(5)在“NAT Internet 连接”界面中指定连接到 Internet 的网络接口，该网络接口对于 Internet 来说是可见的。若在步骤(1)中已将“外部连接”指定为公共接口，则此处应选择“外部连接”，如图 19.16 所示。

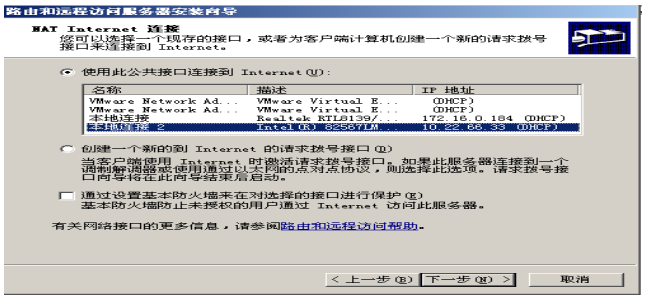


图 19.16 NAT Internet 连接

(6)在“名称和地址转换服务”界面中选择“我将稍后设置名称和地址服务”（若“本地连接”为自动获取 IP 地址，安装向导会自动检测到网络上的 DHCP 服务器，因此“名称和地址转换服务”界面将不会出现）。至最后完成路由和远程访问配置。

(7)连通性测试

内网主机 A 通过 ping 指令对外网主机 E 做连通性测试，如图 19.17 所示。



图 19.17 Ping 测试

关掉路由和远程访问配置，再次用 A ping E 进行测试，如图 19.18 所示。

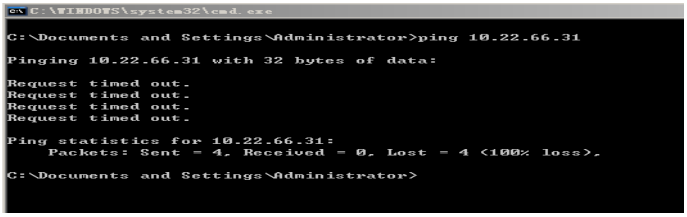


图 19.18　Ping 测试

实验二十 Windows2003 用户权限管理

一、实验目的

1.了解 SID
2.掌握权限基本原则及设置方法
3.掌握磁盘配额设置方法

二、实验环境

Windows，交换网络结构

三、实验原理

1.什么是权限

如果提到用户权限，我们可以将其分成两类：登录权限和操作权限。所谓的“登录权限”指的是在帐户通过身份验证前所具备的权限，而“操作权限”指的是在帐户通过身份验证之后所具备的权限。我们讨论的“权限”是后者。

Windows 系统提供了非常细致的权限控制项，能够精确定制用户对资源的访问控制能力，大多数的权限从其名称上就可以基本了解其所能实现的内容。

“权限”(Permission)是针对资源而言的。也就是说，设置权限只能是以资源为对象，即“设置某个文件夹有哪些用户可以拥有相应的权限”，而不能是以用户为主，即“设置某个用户可以对哪些资源拥有权限”。这就意味着“权限”必须针对“资源”而言，脱离了资源去谈权限毫无意义——在提到权限的具体实施时，“某个资源”是必须存在的。

利用权限可以控制资源被访问的方式，如 User 组的成员对某个资源拥有“读取”操作权限、Administrators 组成员拥有“读取+写入+删除”操作权限等。

2.安全标识符

在 Windows 系统中，系统是通过安全标识符（Security Identifier，SID）对用户进行识别的，而不是很多用户认为的“用户名称”。SID 可以应用于系统内的所有用户、组、服务或计算机，因为 SID 是一个具有惟一性、绝对不会重复产生的数值，所以，在删除了一个账户（如名为“A”的账户）后，再次创建这个“A”账户时，前一个 A 与后一个 A 账户的

SID 是不相同的。这种设计使得账户的权限得到了最基础的保护，盗用权限的情况也就彻底杜绝了。

3.权限的四项基本原则

针对权限的管理有四项基本原则，即：拒绝优于允许原则、权限最小化原则、累加原则和权限继承性原则。这四项基本原则对于权限的设置来说，将会起到非常重要的作用，下面就来了解一下：

(1)拒绝优于允许原则

“拒绝优于允许”原则是一条非常重要且基础性的原则，它可以非常完美地处理好因用户在用户组的归属方面引起的权限“纠纷”。

(2)权限最小化原则

Windows 系统将“保持用户最小的权限”作为一个基本原则进行执行，这一点是非常有必要的。这条原则可以确保资源得到最大的安全保障。这条原则可以尽量让用户不能访问或不必要访问的资源得到有效的权限赋予限制。

(3)权限继承性原则

权限继承性原则可以让资源的权限设置变得更加简单。

(4)权限累加原则

这个原则比较好理解，就是单纯的累加，好比“1+1=2”一样。

显然，“拒绝优于允许”原则是用于解决权限设置上的冲突问题的；“权限最小化”原则是用于保障资源安全的；“权限继承性”原则是用于“自动化”执行权限设置的；而“累加原则”则是让权限的设置更加灵活多变。

注意：在 Windows 系统中，Administrators 组的全部成员都拥有“取得所有者身份”（Take Ownership）的权力，也就是管理员组的成员可以从其他用户手中“夺取”其身份的权力。

4.磁盘配额

磁盘配额可以跟踪以及控制磁盘空间的使用，简单的来说，就是在多用户时，作为计算机管理员可设置不同用户拥有不同的磁盘配额。该用户只能在这个限额下使用磁盘。比如管理员将某用户在 E 盘的磁盘配额设为 100MB，那么这个用户在使用时就最多只能使用 E 盘的 100MB 空间。

启动磁盘配额时，可以设置两个值：磁盘配额限制和磁盘配额警告级别。当用户超过了指定的磁盘空间限制（也就是允许用户使用的磁盘空间量）时，系统将阻止进一步使用磁盘空间并记录该事件。当用户超过了指定的磁盘空间警告级别（也就是用户接近其配额限制的点）时，则只记录事件。

启用卷的磁盘配额时，系统从那个值起自动跟踪新用户卷使用。只要用 NTFS 文件系统将卷格式化，就可以在本地卷、网络卷以及可移动驱动器上启动配额。另外，网络卷必须从卷的根目录中得到共享，可移动驱动器也必须是共享的。Windows 安装将自动升级使用 Windows NT 中的 NTFS 版本格式化的卷。

由于按未压缩时的大小来跟踪压缩文件，因此不能使用文件压缩来防止用户超过其配额限制。

四、实验步骤

1.SID 查看

(1)进入控制台，在平台左下脚点“开始“---》”运行“，输入 cmd,然后回车.

(2）控制台中输入命令行：whoami/user, 将会得到类似图 20.1 所示信息.

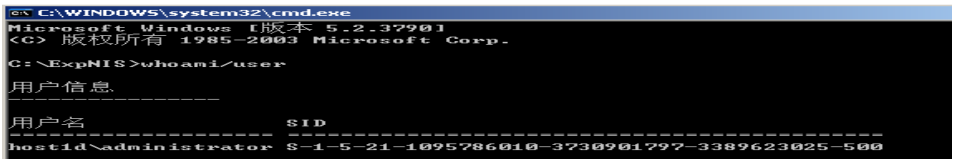


图 20.1 用户信息

2.权限的四项基本原则演示

(1)拒绝优先原则

右键点击我的电脑，选择管理，然后选择系统工具|本地用户和组|用户，右键选择“新用户”，如图 20.2 所示。

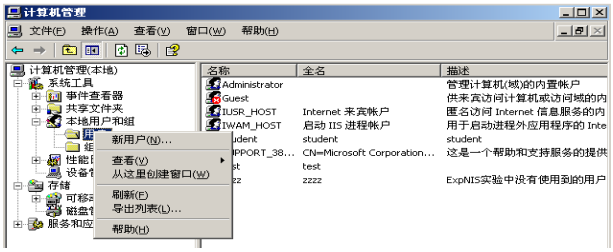


图 20.2 选择新建用户

在弹出的新用户对话框中，填写用户名 test1，如果用户存在，就换一个用户名，并设置“密码永不过期”，如图 20.3 所示。单击“创建”按钮创建用户。

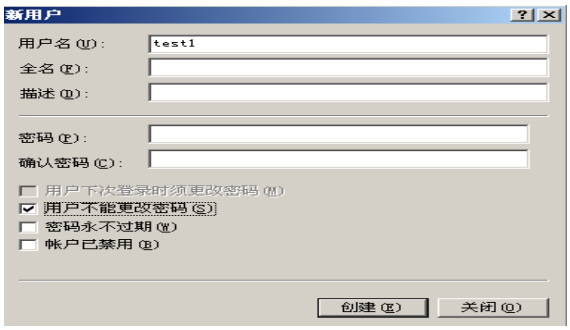


图 20.3 创建用户

右键单击本地用户和组丨组，选择“新建组”。在弹出的对话框中新建组 A、B，并将刚刚新建的 test1 用户添加到组中，如图 20.4 所示。

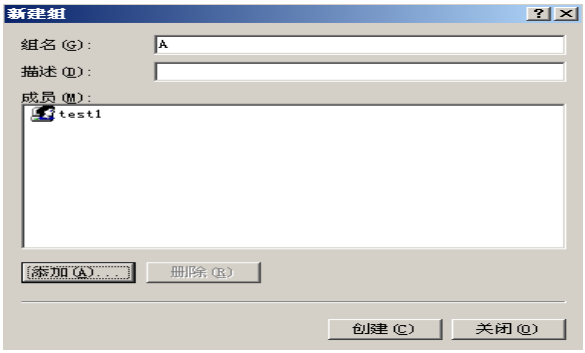


图 20.4 新建组并添加用户

在本地磁盘 C 中新建名为 test 的文件夹，在里面新建文本文件 test.txt，内容任意。

「说明」本地磁盘 D 为 FAT32 文件系统，此种文件系统不支持文件或目录权限设置，也不支持磁盘配额设置。

右键单击 test.txt 文件，选择“属性”，在“安全”选项卡中，单击“添加”按钮，将包含 test 用户的组 A、B 添加进来，将组 A 的权限设置成“允许完全控制”，如图 20.5 所示，组 B 的权限设置成“拒绝读取”，如图 20.6 所示。

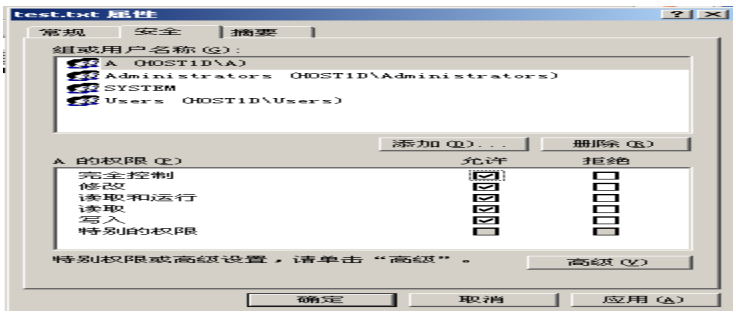


图 20.5 设置 A 的操作权限

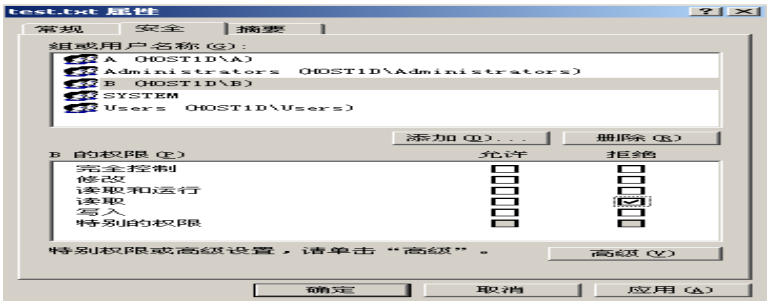


图 20.6 设置 B 的操作权限

(2)权限最小原则

1)注销当前用户，使用 administrator 用户登录系统，新建用户 test2，默认情况下用户 test2 隶属组为：

2)注销当前用户，使用 test2 用户登录系统，进入 C:\WINDOWS 系统目录，尝试修改其中的文件，操作结果：

(3)权限继承原则

1)注销当前用户，使用 administrator 用户登录系统，新建用户 test31、test32.

在本地磁盘 C 中新建名为 test3 的文件夹，将其权限设置成对 test31 用户完全控制，test32 用户只可以读取。

2)在 test3 目录中新建名为 subtest3 的文件夹。

3)分别使用 test31、test32 用户登录系统，访问目录 C:\test3\subtest3，访问结果：

4)权限累加原则

1)注销当前用户，使用 administrator 用户登录系统，新建用户 test4，默认隶属 Users 组。

2)在本地磁盘 C 中新建名为 test4 的文件夹，然后在 test4 文件夹中再新建文件夹 subtest4。

3)设置文件夹 subtest4 权限，对 test4 只有写权限。

4)设置文件夹 test4 权限，对 test4 只有读取和执行的权限。

5)注销当前用户，使用 test4 用户登录系统，访问目录 C:\test4\subtest4，证实 test4 用户对此目录拥有的权限？

3.NTFS 分区上分配磁盘配额

(1)注销当前用户，使用 administrator 用户登录系统，新建用户 test5，默认隶属 Users 组。

(2)在本地磁盘 C 中点击鼠标右键，选择“属性”，打开磁盘属性菜单，选择磁盘属性对话框中的“配额”选项卡。勾选“启用配额管理”和“拒绝将磁盘空间给超过配额限制的用户”，点击“配额项”按钮，进入配额项管理。选择“配额”菜单中的“新建配额项”，进入选择用户界面添加 test5 用户，在“添加新配额项”界面中勾选“将磁盘空间限制为”，调整配额值为 5M，“将警告登记”设为 1KB，单击“确定”按钮，完成配额添加。

(3)注销当前用户，使用 test5 用户登录系统，在磁盘 C 中新建一个文件夹 test5，向 test5 文件夹中添加文件，记录文件大小超过 5M 时的情况。

「注」向文件夹 test5 中添加文件时，可以新建一个 bmp 画图文件，用画图工具编辑该图片，只要增加图片大小即可使文件存储空间变大。

实验二十一 Windows2003 审核策略设置

一、实验目的

1.了解计算机审核的重要性
2.掌握使用 Windows 自带审核策略的使用方法
3.掌握 Windows 事件查看器的使用方法

二、系统环境

Windows,交换网络结构

三、实验工具

监控器工具

四、实验原理

1.审核策略

安全审核对于任何企业系统来说都极其重要，因为只能使用审核日志来说明是否发生了违反安全的事件。如果通过其他某种方式检测到入侵，正确的审核设置所生成的审核日志将包含有关此次入侵的重要信息。每当用户执行了指定的某些操作，审核日志就会记录一个审核项。例如，修改文件或策略可以触发一个审核项。审核项显示了所执行的操作、相关的用户帐户以及该操作的日期和时间。您可以审核操作中的成功尝试和失败尝试。

计算机上的操作系统和应用程序的状态是动态变化的。例如，有时可能需要临时更改安全级别，以便立即解决管理问题或网络问题。这些更改经常会被忘记，并且永远不会撤销。这说明计算机可能不再满足企业安全的要求。

作为企业风险管理项目的一部分，定期分析可以使管理员跟踪并确保每个计算机有足够的安全级别。分析的重点是专门指定的、与安全有关的所有系统方面的信息。这使管理员可以调整安全级别，而且最重要的是，可以检测到系统中随着时间的推移而有可能产生的所有安全缺陷。安全审核对于任何企业系统来说都极其重要，因为只能使用审核日志来说明是否发生了违反安全的事件。如果通过其他某种方式检测到入侵，正确的审核设置所生成的审核日志将包含有关此次入侵的重要信息。通常，失败日志比成功日志更有意义，因为失败通常

说明有错误发生。例如，如果用户成功登录到系统，一般认为这是正常的。然而，如果用户多次尝试都未能成功登录到系统，则可能说明有人正试图使用他人的用户 ID 侵入系统。事件日志记录了系统上发生的事件。安全日志记录了审核事件。组策略的“事件日志”容器用于定义与应用程序、安全性和系统事件日志相关的属性，例如日志大小的最大值、每个日志的访问权限以及保留设置和方法。

2.文件审核

(1)Windows2003 文件审核

Windows 下系统提供了几个预定义的审核策略会帮助用户完成一些重要事件的审计跟踪工作，但需要手工的设置，才能使这些功能生效。下面介绍一下 Windows 下提供的一些审计策略。

Windows 2000 系统以后的 Windows 系统中都预定义了一些系统审核策略，这些审核策略在只有 NTFS 分区下有效。新审核策略的引入，在检测计算机系统安全方面起着极其重要的作用。所有审核策略的审核项信息都被系统记录到本机“安全性”日志中，可以通过事件查看器的“安全性”分支查看这些审核信息。这些预定义审核策略的设置位置在“本地安全策略管理器”中的如下分支：安全设置\本地策略\审核策略。可以通过“控制面板”|“管理工具”|“本地安全策略”来启动本地安全策略管理工具，也可以通过组策略编辑器定位到如下分支对预定义策略进行设置：“本地计算机”丨“策略”|“计算机配置”|“windows 设置”|“本地策略”|“审核策略”。

因为审核项的信息都被记录到了磁盘文件当中，如果过多的设置审核项目就会造成系统性能的下降，因此一般只对一些非常重要系统操作内容进行审计跟踪。

(2)对象访问事件 ID

对象访问事件 ID 解释如表 21.1 所示。

表 21.1 对象访问事件解释

对象访问事件	
560	允许访问一个已存在的对象。
562	已关闭对象句柄。
563	尝试打开准备删除的对象。注意：当在Createfile()中指定FILE_DELETE_ON_CLOSE标记时，文件系统将使用它。
564	已删除受保护的对象。
565	允许访问一个已存在的对象类型。
567	已使用与句柄相关的权限。
568	尝试创建正在被审核的文件的硬链接。
569	“授权管理器”中的资源管理器尝试创建一个客户端上下文
570	客户端尝试访问一个对象。注意：将为在对象上尝试的每个操作生成一个事件。
571	客户端上下文已被“授权管理器”应用程序删除。
572	管理员管理器初始化该应用程序。

五、实验步骤

1.设置并验证“审核对象访问”策略

(1)设置“审核对象访问”策略

依次进入“开始”|“程序”|“管理工具”|“本地安全策略”，启动本地安全策略管理器。进入管理器定位到如下分支：“安全设置”|“本地策略”|“审核策略”，选择“审核对象访问”项，双击该项（或单击右键菜单中的属性）进入属性页。选中“审核这些操作”中的“成功”、“失败”复选框。然后单击“确定”按钮完成设置策略操作。同样方法，将其它审核策略设置为“无审核”，如图 21.1 所示。

策略	安全设置
审核策略更改	无审核
审核登录事件	无审核
审核对象访问	成功, 失败
审核过程跟踪	无审核
审核目录服务访问	无审核
审核特权使用	无审核
审核系统事件	无审核
审核帐户登录事件	无审核
审核帐户管理	无审核

图 21.1　本地审核策略

(2)．audit 目录文件审核

1)C 盘下新建 audit 文件夹。

2)audit 目录下新建文本文件 general.txt（在启动审核前创建文件）。

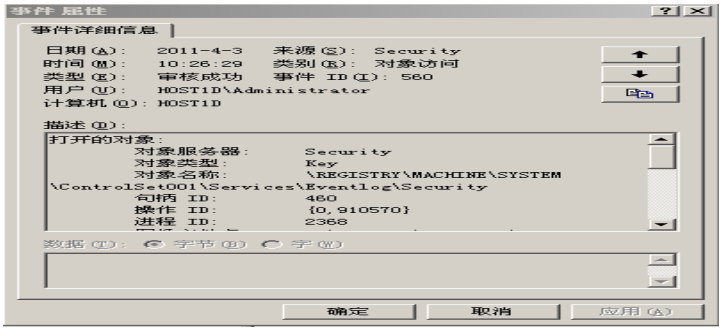
3)设置 audit 文件夹属性，在属性对话框中依次点选“安全”|“高级”|“审核”|“添加”，在“选择用户或组”对话框的“输入要选择的对象名称”文本框中输入“everyone”，单击“确定”按钮。在弹出的“audit 的审核项目”对话框中，选中“创建文件/写入数据”对应的“成功”与“失败”复选按钮，单击“确定”按钮，直至完成。

4)为了能够清晰分析后续审核事件，建议先将系统已有审核条目清除。具体做法如下：通过系统“管理工具”打开“事件查看器”，点选左侧“安全性”分支，右键单击该项，选择“清除所有事件”。

5)对 general.txt 文件进行写入操作，并保存。刷新“事件查看器”|“安全性”分支，查看右侧事件列表“分类”项为“对象访问”的事件，结合实验原理“常用审核事件 ID”部分如图 21.2,21.3 所示，回答下列问题：

审核成功	2011-4-3	10:26:29	Security	对象访问	560	Administrator
审核成功	2011-4-3	10:26:15	Security	对象访问	562	Administrator
审核成功	2011-4-3	10:26:15	Security	对象访问	567	Administrator
审核成功	2011-4-3	10:26:15	Security	对象访问	560	Administrator
审核成功	2011-4-3	10:25:42	Security	系统事件	517	SYSTEM

图 21.2 审核结果



20.3 事件详细信息

针对写入数据操作，系统的审核事件序列是：

解释序列事件：

6)调换步骤：(2)(3)(4)步的顺序改为(4)(3)(2)(在启动审核后创建文件)，重新进行此部分实验，回答下列问题：

针对创建文件操作，系统的审核事件序列是：

解释序列事件：

针对写入数据操作，系统的审核事件序列是：

解释序列事件：

7)重新设置 audit 文件夹审核策略，仅对“读取数据”事件进行审核，回答下列问题：
仅针对读取数据操作，系统的审核事件序列是：
解释序列事件：

8)可尝试对其它事件进行审核，如删除、更改权限等。

2.文件事件审计

(1)单击工具栏“监控器”按钮，打开监控器工具。在左侧向导栏中选择“文件监控”，进入文件监控视图。

(2)单击菜单栏“选项”|“设置”，在“设置”对话框中可以设置文件监控所要监控的目录、监控进程和操作类型（新建文件、删除文件、文件写操作，修改文件属性）。单击“确定”按钮应用设置。

(3)单击监控器工具栏开始按钮，开始文件监控，在指定目录或使用指定应用程序进行新建文件等操作，观察监控视图的审计信息。

实验二十二 Windows2003 注册表安全设置

一、实验目的

1.了解注册表的作用
2.掌握注册表的安全设置及修改方法

二、实验环境

Windows,交换网络结构

三、实验原理

1.注册表概述

注册表是存储计算机的配置信息的数据容器。Microsoft Windows 9x、Windows CE、Windows NT 和 Windows 2000 中使用的中央分层数据库，用于存储为一个或多个用户、应用程序和硬件设备配置系统所必需的信息。

注册表包含 Windows 在运行期间不断引用的信息，例如，每个用户的配置文件、计算机上安装的应用程序以及每个应用程序可以创建的文档类型、文件夹和应用程序图标的属性表设置、系统上存在哪些硬件以及正在使用哪些端口。

注册表取代了 Windows 3.x 和 MS-DOS 配置文件（例如，Autoexec.bat 和 Config.sys）中使用的绝大多数基于文本的.ini 文件。虽然几个 Windows 操作系统都有注册表，但这些操作系统的注册表有一些区别。

注册表数据存储在二进制文件中。而且因为它复杂的结构和没有任何联系的 CLSID 键使得它可能看上去很神秘。不幸的是，微软并没有完全公开讲述关于注册表正确设置的支持信息，这样使得注册表看上去更不可琢磨。处理和编辑注册表如同“黑色艺术”一样，它在系统中的设置让用户感觉像在黑暗中摸索一样找不到感觉。这样，因为用户对这方面的缺乏了解使得注册表更多的出现故障。

注册表是一套控制操作系统外表和如何响应外来事件工作的文件。这些“事件”的范围从直接存取一个硬件设备到接口如何响应特定用户到应用程序如何运行等等。注册表因为它的

目的和性质变的很复杂，它被设计为专门为 32 位应用程序工作，文件的大小被限制在大约 40MB。

2.注册表的作用

在系统中注册表是一个记录 32 位驱动的设置和位置的数据库。当操作系统需要存取硬件设备，它使用驱动程序，甚至设备是一个 BIOS 支持的设备。无 BIOS 支持设备安装时必须需要驱动，这个驱动是独立于操作系统的，但是操作系统需要知道从哪里找到它们，文件名、版本号、其他设置和信息，没有注册表对设备的记录，它们就不能被使用。

当一个用户准备运行一个应用程序，注册表提供应用程序信息给操作系统，这样应用程序可以被找到，正确数据文件的位置被规定，其他设置也都可以被使用。注册表保存关于缺省数据和辅助文件的位置信息、菜单、按钮条、窗口状态和其他可选项。它同样也保存了安装信息（比如说日期），安装软件的用户，软件版本号和日期，序列号等。根据安装软件的不同，它包括的信息也不同。然而，一般来说，注册表控制所有 32 位应用程序和驱动，控制的方法是基于用户和计算机的，而不依赖于应用程序或驱动，每个注册表的参数项控制了一个用户的功能或者计算机功能。用户功能可能包括了桌面外观和用户目录。所以计算机功能和安装的硬件和软件有关，对用户来说这些参数项都是公用的。有些程序功能对用户有影响，有些是作用于计算机而不是为个人设置的，同样的，驱动可能是用户指定的，但在很多时候，它们在计算机中是通用的。

在系统中注册表控制所有 32 位应用程序和它们的功能及多个应用程序的交互，比如复制和粘贴，它也控制所有的硬件和驱动程序。虽然多数可以通过控制面板来安装和设置，理解注册表仍是做 Winnt 和 Win95 系统管理基本常识。

3.注册表的特点

(1)注册表允许对硬件、系统参数、应用程序和设备驱动程序进行跟踪配置，这使得修改某些设置后不用重新启动成为可能。

(2)注册表中登录的硬件部分数据可以支持高版本 Windows 的即插即用特性。当 Windows 检测到机器上的新设备时，就把有关数据保存到注册表中，另外，还可以避免新设备与原有设备之间的资源冲突。

(3)管理人员和用户通过注册表可以在网络上检查系统的配置和设置，使得远程管理得以实现。

4.注册表主键说明

常见注册表主键如下：

HKEY_CLASSES_ROOT

包含注册的所有 OLE 信息和文档类型，是从 HKEY_LOCAL_MACHINE\SOFTWARE\CLASSES 复制的。

HKEY_CURRENT_USER

包含登录的用户配置信息，是从 HKEY_USERS\当前用户子树复制的。

HKEY_LOCAL_MACHINE

包含本机的配置信息。其中 CONFIG 子树是显示器打印机信息； ENUM 子树是即插即用设备信息；SYSTEM 子树是设备驱动程序和服务参数的控制集合；SOFTWARE 子树是应用程序专用设置。

HKEY_USERS

所有登录用户信息。

HKEY_CURRENT_CONFIG

包含常被用户改变的部分硬件软件配置，如字体设置、显示器类型、打印机设置等。是从 HKEY_LOCAL_MACHINE\CONFIG 复制的。

四、实验步骤

1.注册表安全设置

(1)清空远程可访问的注册表路径

Windows2003 操作系统提供了注册表的远程访问功能，只有将可远程访问的注册表路径设置为空，才能有效地防止黑客利用扫描器通过远程注册表读取计算机的系统信息及其它信息。

打开系统“管理工具”，选择“本地安全策略”，将“本地策略”|“安全选项”中的“网络访问：可远程访问的注册表路径、可远程访问的注册表路径和子路径”两项策略清空，如图 22.1，22.2 所示，结果如图 22.3 所示。

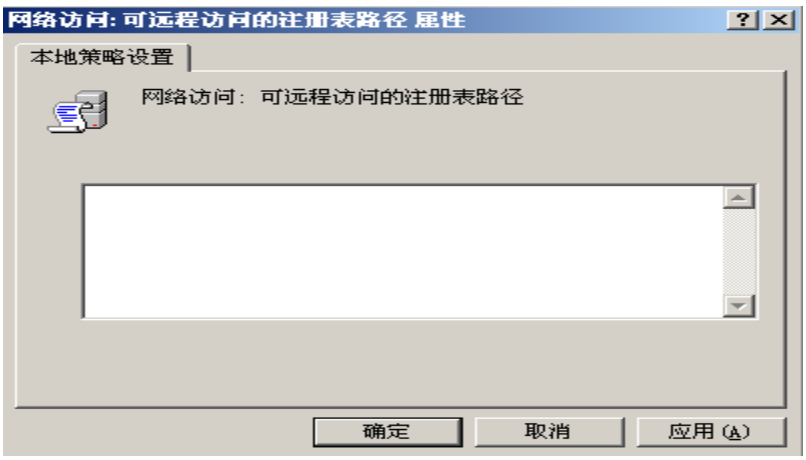


图 22.1 设置可远程访问的注册表路径

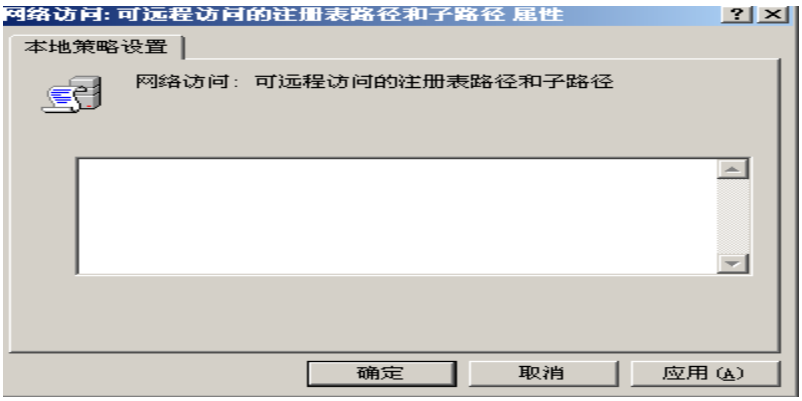


图 22.2 设置可远程访问的注册表路径和子路径

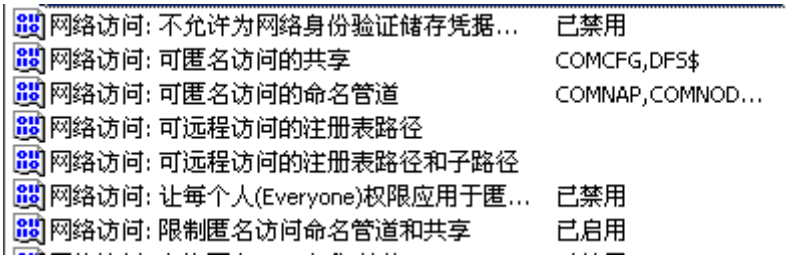


图 22.3 设置结果

(2)关闭自动保存隐患

Windows2003 操作系统在调用应用程序出错时，系统会自动将一些重要的调试信息保存起来，以便日后维护系统时查看，不过这些信息很有可能被黑客利用，一旦获取的话，各种重要的调试信息就会暴露无疑。

1)双击 C:\WINDOWS\regedit.exe 文件或直接在“开始丨运行”（Win+R）中输入 regedit，打开“注册表编辑器”，如图 22.4 所示。

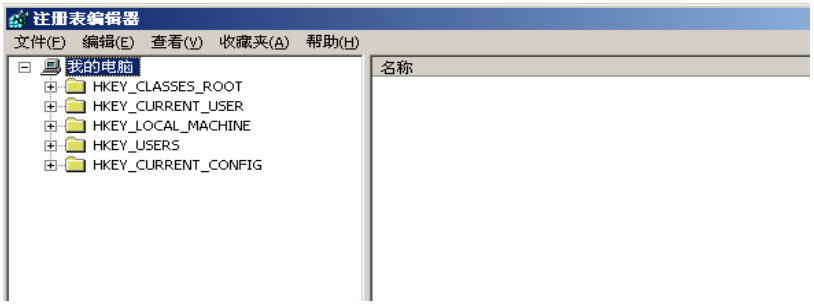


图 22.4　注册表编辑器

2)依次展开 HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\AeDebug 分支，设置“Auto”项的键值为 0,如图 22.5 所示：

名称	类型	数据
(默认)	REG_SZ	(数值未设置)
Auto	REG_SZ	0
Debugger	REG_SZ	"C:\Program Files\Microsoft Visual Studio\Common\MSD...
UserDebuggerHotKey	REG_DWORD	0x00000000 (0)

图 22.5 设置 Auto

(3)关闭资源共享隐患

为了给局域网用户相互之间传输信息带来方便，Windows2003 系统提供了文件和打印共享功能，不过我们在享受该功能带来便利的同时，共享功能也给黑客入侵提供了方便。

通过网上邻居设置“本地连接”，在“本地连接 属性”的“常规”选项卡中，取消勾选“Microsoft 网络的文件和打印机共享”,如图 22.6 所示.

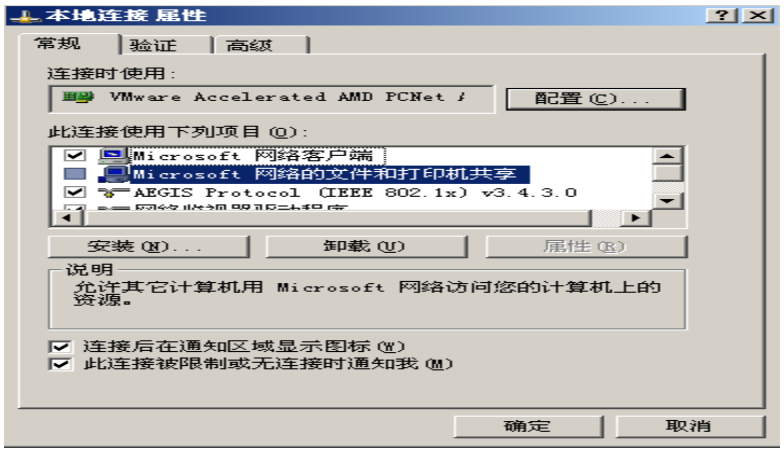


图 22.6 设置 Microsoft 网络的文件和打印机共享

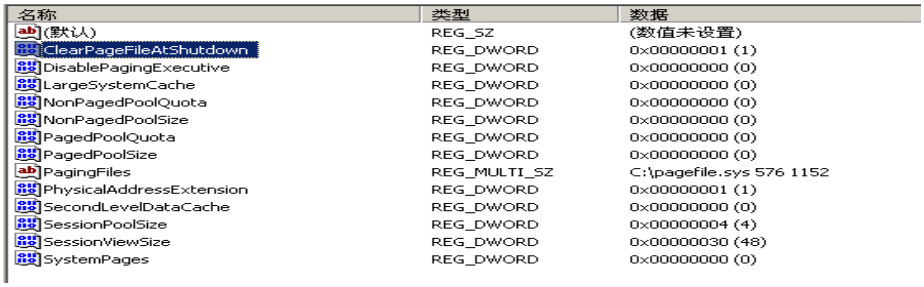
(4)关闭页面交换隐患

Windows 2003 操作系统中的页面交换文件中，其实隐藏很多重要隐私信息，这些信息都是在动态中产生的，要是不及时将它们清除，就很有可能成为黑客的入侵突破口。

打开注册表编辑器，定位到

HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\

SessionManager\MemoryManagement 分支，设置 ClearPageFileAtShutdown 项的键值为 1。如图 22.7 所示。



名称	类型	数据
(默认)	REG_SZ	(数值未设置)
ClearPageFileAtShutdown	REG_DWORD	0x00000001 (1)
DisablePagingExecutive	REG_DWORD	0x00000000 (0)
LargeSystemCache	REG_DWORD	0x00000000 (0)
NonPagedPoolQuota	REG_DWORD	0x00000000 (0)
NonPagedPoolSize	REG_DWORD	0x00000000 (0)
PagedPoolQuota	REG_DWORD	0x00000000 (0)
PagedPoolSize	REG_DWORD	0x00000000 (0)
PagingFiles	REG_MULTI_SZ	C:\pagefile.sys 576 1152
PhysicalAddressExtension	REG_DWORD	0x00000001 (1)
SecondLevelDataCache	REG_DWORD	0x00000000 (0)
SessionPoolSize	REG_DWORD	0x00000004 (4)
SessionViewSize	REG_DWORD	0x00000030 (48)
SystemPages	REG_DWORD	0x00000000 (0)

图 22.7 设置 ClearPageFileAtShutdown 项

(5)防火墙 TTL 主机类型探测

(1)打开系统控制台输入命令：ping 127.0.0.1,如图 22.8 所示.

```
C:\ExpNIS>ping 127.0.0.1

Pinging 127.0.0.1 with 32 bytes of data:

Reply from 127.0.0.1: bytes=32 time<1ms TTL=128
Reply from 127.0.0.1: bytes=32 time<1ms TTL=128
Reply from 127.0.0.1: bytes=32 time<1ms TTL=128
Reply from 127.0.0.1: bytes=32 time<1ms TTL=128

Ping statistics for 127.0.0.1:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
Approximate round trip times in milli-seconds:
    Minimum = 0ms, Maximum = 0ms, Average = 0ms

C:\ExpNIS>
```

图 22.8 Ping 结果

查看返回 TTL 值:

(2)打开注册表编辑器，定位到 HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\Tcpip\Parameters，修改 DefaultTTL 值为十进制 110。重启系统，使用 ping 命令查看本机 TTL 值。